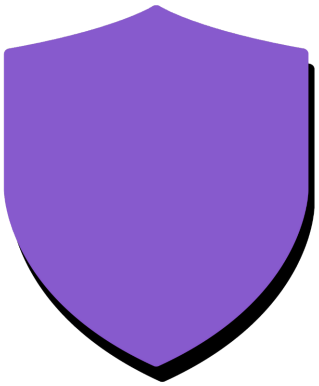
كتاب
الأمن السيبراني



تعلم الأمن السيبراني من الصفر حتى الإحتراف
تعلم أساسيات الأمن السيبراني للمبتدئين باللغة العربية
الإصدار الأول

إعداد فهد قطينة

أكاديمية الأمن السيبراني
CYBERCOURSE.COM

جدول المحتويات

الفصل الأول: مقدمة عن الأمن السيبراني 3

الفصل الثاني: المصطلحات الأساسية في الأمن السيبراني 13

الفصل الثالث: أنواع الهاكرز وخطوات الاختراق .....

الفصل الرابع: المخاطر والهجمات السيبرانية .....

الفصل الخامس: أبرز أنواع الهجمات السيبرانية .....

الفصل السادس: الهندسة الإجتماعية .....

الفصل السابع: البرمجيات الخبيثة

الفصل الثامن: الجدران النارية

الفصل التاسع: المصائد السيبرانية HoneyPots

الفصل العاشر: التحقيق الجنائي الرقمي .....

الفصل الحادي عشر: أهم وأشهر أدوات الأمن السيبراني .....

الفصل الثاني عشر: خارطة تعلّم الأمن السيبراني (من الصفر إلى الاحتراف) .....

الفصل الثالث عشر: المسارات المهنية في الأمن السيبراني .....

الفصل الرابع عشر: مصادر تعلم الأمن السيبراني .....

الفصل الخامس عشر: المعايير العالمية في الأمن السيبراني .....

الفصل السادي عشر: شهادات الأمن السيبراني .....

الفصل السابع عشر: إختبارات الأمن السيبراني .....

الفصل الأول: مقدمة عن الأمن السيبراني



الأمن السيبراني هو ممارسة حماية الأنظمة الحاسوبية والشبكات والبرمجيات والمعلومات من الهجمات الرقمية أو الوصول غير المصرح به أو الأضرار. يشمل ذلك مجموعة من التقنيات والإجراءات والضوابط المصممة للحفاظ على سرية وسلامة وتوفر المعلومات، وكذلك حماية البنية التحتية الرقمية من الاختراقات والتهديدات السيبرانية. بعبارة أخرى، يهدف الأمن السيبراني إلى تأمين الفضاء الرقمي بكل مكوناته ضد المخاطر المتزايدة في العصر الحديث.

أهمية الأمن السيبراني

تبرز أهمية الأمن السيبراني نظرًا للاعتماد المتزايد على التكنولوجيا في جميع مجالات الحياة. يمكن أن تؤدي الهجمات السيبرانية إلى خسائر مالية جسيمة للشركات والمؤسسات، وإلى انتهاك خصوصية الأفراد عبر تسريب البيانات الحساسة أو سرقة الهوية. إضافة إلى ذلك، قد تشكل التهديدات السيبرانية خطرًا على الأمن الوطني حين تستهدف الهجمات البنية التحتية الحيوية أو الخدمات الحكومية. لذلك أصبح الاستثمار في الأمن السيبراني أمرًا ضروريًا لحماية الأصول الرقمية وضمان استمرارية الأعمال، فضلًا عن الحفاظ على ثقة الجمهور في الخدمات والتقنيات الرقمية.

الأمن السيبراني في الشرق الأوسط

في الشرق الأوسط، شهد مجال الأمن السيبراني اهتمامًا متزايدًا في السنوات الأخيرة نتيجة تصاعد التهديدات الرقمية في المنطقة. فقد أصبحت البنية التحتية الحيوية - مثل قطاع الطاقة والنفط والاتصالات والخدمات المالية - هدفًا لهجمات سيبرانية متطورة على خلفية التوترات الجيوسياسية الإقليمية. كما أن التحول الرقمي السريع في دول الشرق الأوسط وزيادة الخدمات الحكومية والإلكترونية جعل الحاجة ملحة لتعزيز التدابير الأمنية لحماية البيانات والأنظمة. استجابةً لذلك، تبنّت العديد من دول المنطقة استراتيجيات وطنية للأمن السيبراني، وأنشأت فرقًا متخصصة للاستجابة لحوادث الأمن السيبراني (فرق/CERT وطنية)، مع التركيز على تدريب الكوادر وبناء الوعي الأمني لدى الجمهور. هذه الجهود تأتي لضمان حماية المصالح الحيوية والبنية التحتية الرقمية للدول في وجه تهديدات سيبرانية متنامية على المستوى العالمي والإقليمي.

أنواع الأمن السيبراني الرئيسية

هناك عدة مجالات رئيسية يشملها الأمن السيبراني، من أبرزها ما يلي:

1. **الأمن الشبكي (Network Security):** يهدف هذا المجال إلى حماية شبكات الحاسوب ومواردها من المتسللين والبرمجيات الخبيثة والمستخدمين غير

المصرح لهم. يتم تحقيق ذلك من خلال استخدام أدوات وضوابط متعددة مثل الجدران النارية (Firewalls) التي تتحكم في حركة المرور الشبكية، ونظم كشف التسلل (IDS) ونظم منع التسلل (IPS) لرصد أي نشاط مشبوه أو إيقافه، بالإضافة إلى الشبكات الافتراضية الخاصة (VPN) التي تؤمن الاتصالات عبر الإنترنت، وتقسيم الشبكة إلى أجزاء معزولة (Network Segmentation) للحد من انتشار الهجمات. الهدف الأساسي للأمن الشبكي هو ضمان اتصالات آمنة بين الأجهزة على الشبكة ومنع حدوث خروقات للبيانات أو تسلل غير مشروع إلى موارد الشبكة.

2. **أمن المعلومات (Information Security أو InfoSec):** يركز أمن المعلومات على حماية البيانات، سواء أثناء تخزينها أو خلال نقلها، من الوصول غير المصرح به أو التعديل والتلاعب. يشمل ذلك تطبيق تقنيات مثل **التشفير** لضمان سرية البيانات بحيث لا يمكن قراءتها إلا من قبل المخولين، واستخدام أنظمة **النسخ الاحتياطي** المنتظمة للحفاظ على نسخ احتياطية من المعلومات المهمة واستعادتها عند الحاجة، إضافة إلى فرض **ضوابط التحكم بالوصول** التي تحدد من يملك صلاحية قراءة أو تعديل بيانات معينة. الهدف الأساسي هو الحفاظ على سرية المعلومات وسلامتها وتوفرها (المعروف بثالوث CIA للأمن المعلوماتي)، بحيث تبقى البيانات سرية، صحيحة وغير معدلة، ومتاحة للاستخدام عند الحاجة.

3. **أمن التطبيقات (Application Security):** يهتم هذا المجال بضمان أن البرمجيات والتطبيقات تكون آمنة من الثغرات منذ مرحلة التطوير وطوال دورة حياتها التشغيلية. لتحقيق ذلك، يتبع المطورون ممارسات **البرمجة الآمنة** لتفادي الأخطاء الأمنية أثناء كتابة الشفرة المصدرية، كما يتم إجراء **تحديثات وتصحيحات دورية** (Patches) للتطبيقات لمعالجة أي ثغرة أمنية مكتشفة بسرعة. بالإضافة إلى ذلك، تُنفَّذ اختبارات **اختراق للتطبيقات** لمحاكاة هجمات

حقيقية والكشف عن نقاط الضعف قبل أن يستغلها المهاجمون، ويتم استخدام جدران حماية لتطبيقات الويب (WAF) لحماية التطبيقات الإلكترونية من الهجمات الشائعة على الويب. الهدف هو منع استغلال ثغرات التطبيقات المختلفة، مثل هجمات حقن قواعد البيانات *(SQL Injection)* أو هجمات البرمجة عبر المواقع *(XSS)* وغيرها من الهجمات التي قد تستهدف برمجيات المؤسسة.

4. **أمن السحابة (Cloud Security):** مع ازدياد الاعتماد على الخدمات السحابية (مثل خدمات AWS أو Azure أو Google Cloud)، يركّز أمن السحابة على حماية الأنظمة والبيانات الموجودة في البيئة السحابية. يتضمن ذلك ضمان **تشفير البيانات** المخزنة أو المتنقلة ضمن خوادم السحابة بحيث لا يطلع عليها إلا المصرح لهم، وإدارة **إعدادات التكوين الآمن** لموارد السحابة للتأكد من عدم وجود إعدادات افتراضية ضعيفة أو منافذ مفتوحة بشكل غير ضروري. كما يشمل أمن السحابة تطبيق ضوابط **الهوية والوصول** بصرامة في البيئات السحابية، بحيث يتم التحقق من هوية المستخدم وتحديد صلاحياته بدقة قبل السماح له بالوصول إلى الموارد. أيضًا يتم **مراقبة نشاط السحابة** بشكل مستمر لاكتشاف أي سلوك غير طبيعي أو تهديد محتمل. الهدف هو ضمان خصوصية البيانات وسلامتها ضمن البيئات الافتراضية المشتركة، بحيث يمكن الاستفادة من مزايا الحوسبة السحابية دون التضحية بأمن المعلومات.

5. **أمن الأجهزة الطرفية (Endpoint Security):** يركز أمن الأجهزة الطرفية على حماية أجهزة المستخدم النهائية التي تشكل نقاط الاتصال مع الشبكة، مثل الحواسيب الشخصية والمحمولة، والهواتف الذكية، والأجهزة اللوحية، بالإضافة إلى أجهزة إنترنت الأشياء المتصلة بالشبكة. تستخدم عدة وسائل لتحقيق ذلك، من بينها برامج **مكافحة الفيروسات والبرمجيات الخبيثة** التي تكشف عن التهديدات وتحذفها من الجهاز، وأنظمة **الكشف والاستجابة للأجهزة الطرفية (EDR)** التي تراقب سلوك الجهاز بشكل مستمر وتتفاعل بسرعة مع

أي نشاط مشبوه أو غير مألوف، فضلًا عن حلول **إدارة الأجهزة المحمولة (MDM)** التي تضمن تأمين إعدادات الهواتف الذكية والأجهزة اللوحية والتحكم بالميزات الأمنية عليها عن بُعد. الهدف هو حماية هذه الأجهزة باعتبارها بوابات الدخول للشبكة، مما يمنع المهاجمين من استغلالها كنقاط ضعف تمكنهم من التسلل إلى أنظمة المؤسسة الأكبر.

6. **إدارة الهوية والوصول (Identity and Access Management - IAM):** يهتم هذا المجال بالتحكم في هويات المستخدمين وتفاصيل دخولهم وصلاحياتهم ضمن الشبكة أو النظام. يشمل ذلك آليات متعددة لضمان أن الشخص الذي يحاول الوصول هو مخول بالفعل ويملك الصلاحيات المناسبة. من أبرز هذه الآليات **المصادقة متعددة العوامل (MFA)** التي تطلب من المستخدم إثبات هويته عبر أكثر من طريقة (مثل كلمة المرور بالإضافة إلى رمز يُرسل للهاتف أو البصمة)، و**التحكم بالوصول المعتمد على الأدوار (RBAC)** حيث تُمنح كل مستخدم صلاحيات محددة بناءً على دوره الوظيفي فلا يمكنه تجاوزها، وكذلك نظام **تسجيل الدخول الأحادي (SSO)** الذي يسمح للمستخدم بالولوج إلى عدة أنظمة مرتبطة ببعضها عبر عملية مصادقة واحدة آمنة. الهدف هو ضمان أن الوصول إلى الموارد الحساسة يتم من قبل الأشخاص المصرح لهم فقط، وتقليل خطر الوصولات غير المشروعة سواء أكانت عن طريق اختراق حسابات أو إساءة استخدام الصلاحيات الداخلية.

7. **الأمن التشغيلي (Operational Security - OpSec):** يركز الأمن التشغيلي على حماية العمليات والإجراءات الداخلية للمؤسسة من أي تسريب للمعلومات أو استغلال للثغرات العملية. يتعلق هذا المجال بوضع سياسات وإجراءات تقلل فرص الخطأ البشري أو إساءة الاستخدام. من الأمثلة على ذلك **تقييد وسائل نقل البيانات** المسموح بها (على سبيل المثال، قد تُمنع الأجهزة الخارجية مثل محركات الأقراص المحمولة من الاستخدام دون إذن لتفادي تسريب البيانات)،

ووضع ضوابط على **مشاركة المعلومات الحساسة** داخل المؤسسة بحيث لا يطَّلع عليها إلا المعنيون. بالإضافة إلى ذلك، يتم تنفيذ **برامج توعية وتدريب للموظفين** بصورة منتظمة لزيادة وعيهم حول أساليب الهندسة الاجتماعية والتهديدات الداخلية وكيفية التعامل الآمن مع المعلومات. كما تُطبَّق آليات **مراقبة مستمرة للسلوكيات الداخلية** للكشف عن أي نشاط غير اعتيادي من قبل الموظفين قد يشير إلى تهديد داخلي. الهدف هو تقليل المخاطر الناجمة عن الأخطاء البشرية أو نقاط الضعف داخل العمليات الداخلية، وبالتالي حماية المؤسسة من التسريب أو الاختراق الذي قد يأتي من الداخل.

8. **التعافي من الكوارث واستمرارية الأعمال (Disaster Recovery & Business Continuity):** يختص هذا المجال بضمان قدرة المؤسسة على مواصلة عملياتها واستعادة أنظمتها وبياناتها سريعًا بعد التعرض لحادث أمني كبير أو عطل تقني كارثي. في إطار ذلك، يتم إعداد **خطط نسخ احتياطي واستعادة** تشمل أخذ نسخ احتياطية دورية من البيانات وقواعد المعلومات الهامة والاحتفاظ بها بشكل آمن، ووضع استراتيجيات **استعادة الأنظمة** لإعادة تشغيل الخدمات والأنظمة الحيوية بسرعة بعد توقفها. إضافة إلى ذلك، يتم تطوير **خطط الاستجابة للحوادث** التي توضح الخطوات الواجب اتباعها فور وقوع حادث سيبراني أو انقطاع في الخدمة، بما في ذلك فرق الطوارئ ومسؤوليات كل منها. يتم أيضًا إنشاء **أنظمة بديلة وتكرار للبنية التحتية الحرجة** (مثل وجود خوادم احتياطية أو مراكز بيانات بديلة) لضمان استمرار تشغيل الخدمات الأساسية حتى في حال تعطل المكونات الرئيسية. الهدف هو الإبقاء على العمليات الحيوية للمؤسسة قيد العمل أو إعادتها للعمل في أقصر وقت ممكن خلال وبعد الأزمات، مما يقلل من آثار الحوادث ويضمن استمرارية الخدمات للعملاء والمستفيدين.

9. **أمن الأجهزة المحمولة (Mobile Security):** يركّز أمن الأجهزة المحمولة على حماية الهواتف الذكية والأجهزة اللوحية وما تحويه من بيانات وتطبيقات من المخاطر المتنوعة مثل البرمجيات الخبيثة أو السرقة أو الاختراق. نظرًا لكون هذه الأجهزة أصبحت جزءًا أساسيًا من بيئة العمل والحياة الشخصية، فإن تأمينها يمثل تحديًا مهمًا. من التدابير المستخدمة في هذا السياق **إدارة أذونات التطبيقات** بحيث لا يُسمح للتطبيقات بالوصول إلى بيانات أو ميزات حساسة إلا ضمن حدود الحاجة وبموافقة المستخدم، واستخدام **متصفحات آمنة** أو تطبيقات أمنية للتصفح لتقليل مخاطر التصيد الإلكتروني أو استغلال الثغرات عبر الإنترنت، بالإضافة إلى **تفعيل تشفير الجهاز** بحيث تبقى البيانات المخزنة عليه محمية حتى لو وقع الجهاز في الأيدي الخطأ. كما تشمل الجهود الحرص على **تحديث أنظمة تشغيل الأجهزة المحمولة والتطبيقات** باستمرار لسد الثغرات الأمنية المعروفة. الهدف هو منع المخترقين من استغلال الهواتف أو الأجهزة المحمولة كنقطة دخول إلى شبكات أكبر أو كوسيلة لسرقة معلومات شخصية أو تجارية حساسة، خاصة أن هذه الأجهزة كثيرًا ما تكون الحلقة الأضعف إذا لم يتم تأمينها بالشكل الملائم.

10. **أمن إنترنت الأشياء (IoT Security):** مع الانتشار الهائل لأجهزة **إنترنت الأشياء** في المنازل والمؤسسات - مثل الكاميرات الذكية والمستشعرات والأجهزة القابلة للارتداء - برزت حاجة ملحّة لتأمين هذه الأجهزة المتصلة. يتميز هذا المجال بتحديات خاصة، أبرزها أن العديد من أجهزة إنترنت الأشياء تُطرح في الأسواق بإعدادات أمان ضعيفة أو كلمات مرور افتراضية معروفة، مما يجعلها عرضة للاستغلال. لذلك يشمل أمن الـIoT إجراءات مثل **تغيير الإعدادات الافتراضية** وتعزيز كلمات المرور على هذه الأجهزة، ووضعها في **شبكات معزولة** عن الشبكة الرئيسية كلما أمكن لتقليل الضرر في حال اختراق أحدها، بالإضافة إلى **تحديث البرمجيات الثابتة (Firmware)** لتلك الأجهزة بانتظام لضمان معالجة أية ثغرات أمنية فور اكتشافها. أيضًا تتم مراقبة حركة المرور

من وإلى أجهزة إنترنت الأشياء لكشف أي نشاط غير طبيعي قد يدل على اختراق. الهدف هو منع الهجمات المبنية على استغلال أجهزة إنترنت الأشياء ضعيفة التأمين، مثل الهجمات التي تقوم بها شبكات البوت نت *(Botnets)* (ومن أشهرها هجوم "ميراي" الذي استغل آلاف الأجهزة غير المؤمنة في تنفيذ هجمات واسعة النطاق على الإنترنت).

11. **أمن البنية التحتية الحيوية (Critical Infrastructure Security):** يركز هذا النوع من الأمن على حماية الأنظمة والمرافق التي يعد عملها ضروريًا لاستمرار الحياة المدنية واستقرار المجتمع. يشمل ذلك قطاعات حيوية مثل شبكات **الطاقة الكهربائية**، أنظمة **المواصلات والنقل**، **منشآت المياه**، **القطاع الصحي**، وغيرها من المرافق التي يؤدي تعطلها إلى تأثيرات خطيرة على الأمن والاقتصاد. في هذا السياق، تُتخذ إجراءات خاصة لتأمين أنظمة التحكم الصناعي وأنظمة الإشراف وجمع البيانات **(SCADA)** المستخدمة في إدارة هذه المرافق، وذلك من خلال فصلها قدر الإمكان عن الإنترنت العام وتطبيق بروتوكولات أمان صارمة لتسجيل ومراقبة أي نشاط. بالإضافة إلى ذلك، يتم **مراقبة محاولات الهجمات السيبرانية الفيزيائية** التي قد تستهدف هذه المنشآت، حيث يمكن للهجمات الإلكترونية الحديثة أن تُحدث تأثيرات فيزيائية (مثل إيقاف محطة توليد كهرباء أو تعطيل شبكة نقل). الهدف هو منع أو تقليل فرص نجاح أي هجوم سيبراني قد يؤدي إلى تعطيل الخدمات الأساسية أو إلحاق الضرر بالبنية التحتية التي يعتمد عليها المجتمع، وبالتالي حماية الأرواح والممتلكات والاقتصاد من تبعات تلك الهجمات.

12. **الدفاع ضد الهندسة الاجتماعية (Social Engineering Defense):** على الرغم من كل التقنيات المتقدمة في مجال الحماية، يبقى **العامل البشري** أحد أضعف الحلقات في الأمن السيبراني. لذا فإن الدفاع ضد **هجمات الهندسة الاجتماعية** يركز على تعزيز الوعي والتدريب البشري لمواجهة الأساليب التي

تستهدف خداع الأشخاص بدلًا من اختراق الأنظمة التقنية مباشرة. تشمل هذه الأساليب الخبيثة **التصيد الإلكتروني (Phishing)** عبر رسائل بريد مزيفة أو مواقع احتيالية لخداع الضحايا للكشف عن معلومات سرية، و**التصيد الصوتي (Vishing)** عبر مكالمات هاتفية تنتحل صفات رسمية للحصول على بيانات حساسة، وعمليات **الخداع المباشر أو انتحال الهوية** حيث يتظاهر المهاجم بأنه شخص موثوق به للوصول إلى معلومات أو مواقع محظورة. لمواجهة هذه التهديدات، يتم تنفيذ **برامج تدريب وتوعية دورية للموظفين** لتمكينهم من التعرف على محاولات الاحتيال هذه والتصرف الصحيح حيالها، مثل التحقق من هوية المتصل أو مرسل البريد قبل الاستجابة، وعدم مشاركة المعلومات السرية عبر قنوات غير رسمية. الهدف هو تحويل الموظفين والمستخدمين عمومًا إلى **خط دفاع أول** بدلاً من أن يكونوا نقطة ضعف، وذلك عبر رفع مستوى الوعي والثقافة الأمنية لديهم بحيث يصعب خداعهم أو استدراجهم من قبل المهاجمين.

مجالات متخصصة في الأمن السيبراني

بالإضافة إلى المجالات الرئيسية المذكورة أعلاه، هناك أيضًا مجالات متخصصة ظهرت لتغطية جوانب محددة في الأمن السيبراني، من بينها:

- **اختبار الاختراق/القرصنة الأخلاقية:** يختص هذا المجال بمحاولة اختراق أنظمة المؤسسة بشكل آمن وقانوني بهدف اكتشاف الثغرات الأمنية قبل أن يستغلها المهاجمون الفعليون. يقوم **المخترقون الأخلاقيون** بفحص الشبكات والتطبيقات والمحاكاة الواقعية للهجمات لتحديد نقاط الضعف، ثم يقدمون توصيات لمعالجتها وتعزيز حماية النظام.

- **التحقيق الجنائي الرقمي:** يركز على جمع وتحليل الأدلة الرقمية عند وقوع حوادث سيبرانية. يعمل المتخصصون في التحقيق الجنائي الرقمي على **استخراج البيانات والأدلة من الأجهزة الإلكترونية** (كالحواسيب والهواتف والخوادم) بطريقة تحفظ سلامة الدليل، وذلك لفهم كيفية وقوع الاختراق أو الجريمة السيبرانية وتحديد الجناة أو الثغرات التي تم استغلالها. هذا المجال ضروري لتتبع المهاجمين قانونيًا ولمعرفة مواطن الضعف لتصحيحها ومنع تكرار الحوادث.

- **الحوكمة والمخاطر والامتثال (GRC):** يهتم هذا التخصص بالجوانب الإدارية والتنظيمية للأمن السيبراني. **الحوكمة** تعنى بوضع سياسات وإجراءات الأمن السيبراني وضمان اتباعها عبر هيكلة واضحة للمسؤوليات. **إدارة المخاطر** تتضمن تحديد وتقييم المخاطر الأمنية التي تواجه المؤسسة ووضع خطط لمعالجتها أو التخفيف من حدتها. أما **الامتثال** فيركز على التأكد من أن نظم وإجراءات المؤسسة متوافقة مع المعايير والقوانين المحلية والدولية الخاصة بأمن المعلومات. يساعد مجال GRC المؤسسات على بناء برنامج أمني متين ومترابط يوازن بين المتطلبات التقنية والإدارية والقانونية.

- **أمن الذكاء الاصطناعي وتعلم الآلة:** مع تنامي استخدام تقنيات **الذكاء الاصطناعي (AI)** و**تعلم الآلة (ML)** في مختلف القطاعات، برزت الحاجة لحماية هذه التقنيات نفسها من الهجمات، وكذلك استغلالها في تعزيز الأمن السيبراني. يهتم هذا المجال بتطوير خوارزميات ذكاء اصطناعي قادرة على **كشف التهديدات السيبرانية والتنبؤ بها** بشكل أسرع وأكثر دقة من الطرق التقليدية، مثل أنظمة اكتشاف الاختراق المعززة بالذكاء الاصطناعي التي تتعرف على الأنماط الشاذة في حركة البيانات. وفي الوقت ذاته، يتعامل المجال مع **تأمين أنظمة الذكاء الاصطناعي** وحمايتها من العبث أو الخداع (مثل هجمات تزوير بيانات التدريب التي قد تؤثر على دقة نموذج التعلم الآلي). يعد هذا

التخصص حديثًا نسبيًا ومهمًا لضمان أن التقنيات الذكية تعمل لصالح تعزيز الأمن دون أن تصبح هي نفسها نقطة ضعف جديدة.

ختامًا، يتضح أن الأمن السيبراني مجال واسع ومتعدد الأوجه، حيث يتكامل كل تخصص من التخصصات أعلاه مع غيره لتحقيق الهدف الأسمى وهو حماية البيانات والأنظمة التقنية وضمان استمرارية الخدمات في عالمنا الرقمي. ومع استمرار التطور التكنولوجي، تزداد الحاجة إلى فهم أعمق لمجالات الأمن السيبراني المختلفة والعمل على تطويرها باستمرار لمواجهة التهديدات الناشئة وتأمين مستقبل أكثر أمانًا للجميع.

المصطلحات الأساسية في الأمن السيبراني

الأمن السيبراني مجال مليء بالمصطلحات التقنية التي تصف التهديدات الإلكترونية وأساليب الحماية منها. إن فهم هذه المصطلحات الأساسية يساعد على تكوين صورة واضحة حول كيفية حدوث الهجمات الإلكترونية وكيفية الوقاية منها. في هذا الفصل نقدم قائمة بأهم المصطلحات المستخدمة في مجال الأمن السيبراني، مع شرح مبسّط وواضح لكل مصطلح. هذه المصطلحات ستساعد المبتدئين على بناء أساس قوي لفهم أمن المعلومات والتعامل مع مخاطره.

1. الأمن السيبراني (Cybersecurity)

حماية الأنظمة الحاسوبية والشبكات والبيانات من الهجمات الإلكترونية. يشمل الأمن السيبراني مجموعة من التقنيات والممارسات المصممة لمنع الوصول غير المصرح به، وضمان سرية المعلومات وسلامتها وتوافرها.

2. أمن المعلومات (Information Security)

فرع من الأمن يركز على حماية المعلومات من الوصول أو التعديل أو الإفشاء غير المصرح به. يتضمن أمن المعلومات وضع سياسات وإجراءات تحافظ على سرية البيانات ونزاهتها وتوفرها سواء كانت مخزنة إلكترونيًا أو على ورق.

3. أمن الشبكات (Network Security)

حماية شبكات الحاسوب من الاختراقات والهجمات. يشمل ذلك تأمين أجهزة الشبكة (مثل الموجهات والجدران النارية) ومراقبة حركة البيانات لضمان عدم استغلال نقاط الضعف للتسلل أو سرقة المعلومات.

4. أمن التطبيقات (Application Security)

مجموعة ممارسات لحماية برامج التطبيقات من الثغرات الأمنية والهجمات. يتضمن ذلك كتابة برامج آمنة، واختبار التطبيقات لكشف الثغرات، وتطبيق تحديثات 3

0 v وتصحيحات لسد أي ضعف قد يُستغل من قبل المهاجمين.

5. أمن الطرفيات (Endpoint Security)

حماية الأجهزة النهائية المتصلة بالشبكة (مثل الحواسيب الشخصية والهواتف الذكية) من التهديدات. يشمل ذلك استخدام برامج مضادة للفيروسات وجدران حماية على الجهاز، وتحديث أنظمة التشغيل بانتظام لضمان عدم وجود ثغرات معروفة.

6. التهديد (Threat)

أي حدث محتمل أو جهة قد تُسبب ضررًا للنظام أو البيانات. التهديد قد يكون برنامجًا خبيثًا أو مهاجمًا بشريًا أو حتى كارثة طبيعية؛ وهو يمثل الخطر الذي يحاول أمن المعلومات التصدي له.

7. الثغرة الأمنية (Vulnerability)

نقطة ضعف في نظام أو برنامج يمكن أن يستغلها مهاجم لاختراقه أو إحداث ضرر. قد تكون الثغرة ناتجة عن خطأ برمجي أو إعداد خاطئ أو تصميم غير آمن، ومن المهم تصحيحها أو سدها قبل أن تُستغل.

8. المخاطر الأمنية (Risk)

مقياس لاحتمالية وقوع تهديد معين واستغلاله لثغرة ما، مع حجم الضرر الناتج عنه. إدارة المخاطر تتضمن تحديد المخاطر المحتملة وتقييمها ثم اتخاذ إجراءات لتقليلها إلى مستوى مقبول عبر وسائل حماية مناسبة.

9. السرية (Confidentiality)

مبدأ أساسي في الأمن السيبراني يعني ضمان عدم كشف المعلومات الحساسة إلا للأشخاص المخوّلين. تحقيق السرية يتم عبر تقنيات مثل التشفير والتحكم في صلاحيات الوصول، لمنع المتطفلين من الاطلاع على البيانات.

10. سلامة المعلومات (Integrity)

يقصد بها الحفاظ على صحة ودقة المعلومات وعدم تعديلها أو العبث بها بشكل غير مصرّح. سلامة المعلومات تضمن أن البيانات تظل موثوقة ولم تتعرض لتلاعب أو تحريف أثناء التخزين أو النقل.

11. التوافر (Availability)

التأكد من بقاء الأنظمة والمعلومات متاحة للاستخدام عند الحاجة. يعني ذلك أن تعمل الخدمات الحاسوبية بصورة مستمرة، مع وجود خطط واستراتيجيات لمنع انقطاع الخدمة أو استعادتها بسرعة في حال حدوث مشكلة.

12. الحادث الأمني (Security Incident)

حدث أمني غير اعتيادي قد يدل على محاولة اختراق أو تعرّض للمعلومات. أمثلة على الحوادث الأمنية تشمل دخول غير مصرّح، أو انتشار برمجيات خبيثة في الشبكة. عند وقوع حادث أمني، يجب اتباع إجراءات الاستجابة المناسبة.

13. الخرق الأمني (Security Breach)

نجاح مهاجم في تجاوز الدفاعات الأمنية والوصول إلى نظام أو بيانات بشكل غير مصرّح. قد ينتج عن الخرق الأمني سرقة بيانات حساسة أو تعطيل خدمات، ويتطلب عادة إبلاغ الأطراف المتأثرة واتخاذ إجراءات لمعالجة الثغرات ومنع تكراره.

14. سطح الهجوم (Attack Surface)

جميع النقاط المحتملة التي يمكن أن يستغلها المهاجم للدخول إلى نظام أو شبكة. كلما زاد عدد الخدمات والبرامج المفتوحة على الإنترنت أو عدد المستخدمين والصلاحيات، زاد سطح الهجوم. تقليل سطح الهجوم يتم عبر تعطيل الخدمات غير الضرورية وتطبيق مبدأ الأقل امتياز.

15. مسار الهجوم (Attack Vector)

الطريق أو الوسيلة التي يستخدمها المهاجم للوصول إلى الهدف أو استغلال الثغرة. يشمل ذلك الأساليب التقنية (مثل استغلال ثغرة برمجية عبر الإنترنت) أو الطرق الاجتماعية (كالتصيد الاحتيالي لخداع المستخدم). معرفة مسارات الهجوم تساعد في وضع وسائل دفاع مناسبة.

16. جهة التهديد (Threat Actor)

الشخص أو الجهة المسؤولة عن تنفيذ التهديد أو الهجوم. قد تكون جهة التهديد مخترقًا فرديًا أو مجموعة منظمة (مثل مجموعات القرصنة) أو حتى دولة تقوم بهجمات سيبرانية. فهم دوافع وإمكانيات جهة التهديد يساعد على تقييم خطورة الهجوم.

17. المخترق (Hacker)

شخص ماهر في مجال الحاسوب والشبكات، يمكن أن يستخدم مهاراته بشكل شرعي أو ضار. يرتبط مصطلح "المخترق" شعبيًا بمن يخترق الأنظمة بشكل غير قانوني، لكن هناك أيضًا مخترقين أخلاقيين يستخدمون مهاراتهم لتحسين الأمن بالعثور على الثغرات وإصلاحها.

18. قرصان القبعة البيضاء (White Hat Hacker)

خبير أمن سيبراني يستخدم مهارات الاختراق لأغراض مشروعة وأخلاقية. يعمل "القبعة البيضاء" عادة لصالح الشركات أو بشكل مستقل لاختبار أنظمة الحماية، والكشف عن الثغرات الأمنية قبل أن يستغلها المهاجمون وإبلاغ الجهات المسؤولة لإصلاحها.

19. قرصان القبعة السوداء (Black Hat Hacker)

مخترق غير أخلاقي يقوم بأنشطة اختراق لأهداف ضارة أو للكسب غير المشروع. "القبعة السوداء" يتسلل إلى الشبكات والأنظمة دون إذن، لسرقة المعلومات أو تخريب الأنظمة أو ابتزاز الضحايا ماليًا من خلال الهجمات الإلكترونية.

20. قرصان القبعة الرمادية (Grey Hat Hacker)

مخترق يقع بين القبعة البيضاء والسوداء؛ قد يخترق الأنظمة دون تصريح لكنه لا يستخدم المعلومات بشكل خبيث بالضرورة. في بعض الحالات يبلغ "القبعة الرمادية" عن الثغرات بعد اختراق النظام، لكنه يظل يقوم بذلك دون إذن مسبق مما يثير جدلاً حول قانونية أفعاله.

21. الهندسة الاجتماعية (Social Engineering)

أسلوب خداع يستخدمه المهاجم للتلاعب بالبشر بدلًا من الأنظمة التقنية. يقوم على استغلال الثقة أو نقاط الضعف البشرية للحصول على معلومات سرية أو الوصول غير المصرح. أمثلة على الهندسة الاجتماعية تشمل انتحال صفة دعم فني لإقناع المستخدم بالإفشاء عن كلمة مروره.

22. التصيد الاحتيالي (Phishing)

هجوم إلكتروني يخدع الضحية للكشف عن معلومات حساسة (مثل كلمات المرور أو التفاصيل البنكية). غالبًا يتم عبر إرسال بريد إلكتروني أو رسالة تبدو وكأنها من جهة موثوقة، تحتوي على رابط مزيف يدفع المستخدم إلى موقع خداعي يشبه الموقع الحقيقي لسرقة بياناته.

23. التصيد الموجه (Spear Phishing)

نوع متقدم من التصيد يستهدف شخصًا أو منظمة معينة بشكل محدد. يتم تخصيص الرسالة الخداعية لتبدو ذات صلة بالمستهدف (مثل استخدام اسمه أو منصبه) مما يزيد من احتمالية نجاحها. الهدف هو اختراق أهداف عالية القيمة عبر رسائل تبدو شخصية وموثوقة.

24. تصيد الحيتان (Whaling)

شكل من أشكال التصيد الاحتيالي يستهدف الشخصيات المهمة أو كبار المسؤولين (الحيتان) في الشركات أو المؤسسات. تكون الرسائل مصممة بعناية لاستهداف مديرين تنفيذيين أو شخصيات رفيعة المستوى بغرض الحصول على وصول لمعلومات حساسة أو موارد مالية.

25. التصيّد الصوتي (Vishing)

اختصار لـ "Voice Phishing"، وهو هجوم تصيد عبر الاتصالات الصوتية. يقوم المهاجم بالاتصال هاتفيًا بالضحية منتحلًا صفة جهة موثوقة (مثل بنك أو شركة) ويستخدم الهندسة الاجتماعية لإقناع الضحية بمشاركة معلومات سرية أو القيام بإجراء ما يخدم المهاجم.

26. التصيّد عبر الرسائل (Smishing)

تصيد احتيالي عبر الرسائل النصية (SMS). يرسل المهاجم رسالة نصية تبدو وكأنها من مصدر موثوق (كالبنك أو شركة معروفة) تحتوي على رابط ضار أو تطلب معلومات خاصة. بمجرد ضغط الضحية على الرابط أو الرد بالمعلومات، يمكن أن يتم سرقة بياناته أو إصابة جهازه.

27. الانتحال (Spoofing)

عملية تزييف الهوية في الاتصالات الرقمية لخداع الطرف المستهدف. قد يكون ذلك عبر انتحال عنوان IP أو بريد إلكتروني أو حتى موقع ويب. الهدف هو إقناع الضحية بأن الرسالة أو الموقع حقيقي وموثوق بينما هو في الواقع مزيف أرسله المهاجم.

28. التنصت (Sniffing)

اعتراض ومراقبة حركة البيانات في الشبكة بشكل غير مصرّح. يقوم المهاجم الذي يمارس التنصت باستخدام أدوات برمجية أو أجهزة لالتقاط حزم البيانات أثناء انتقالها عبر الشبكة، مما يمكنه من رؤية معلومات حساسة (مثل كلمات المرور) إذا كانت غير مشفرة.

29. البرمجيات الخبيثة (Malware)

مصطلح شامل يصف أي برنامج أو شفرة برمجية مصممة لإلحاق الضرر بالأنظمة أو سرقة المعلومات. تشمل البرمجيات الخبيثة الفيروسات والديدان وأحصنة طروادة وبرامج الفدية وبرامج التجسس وغيرها. يقوم المهاجمون بنشر البرمجيات الخبيثة بطرق مختلفة لاختراق الأجهزة والأنظمة.

30. الفيروس (Virus)

نوع من البرمجيات الخبيثة يربط نفسه ببرنامج شرعي أو ملف، وينتشر بنسخ نفسه عند تشغيل البرنامج المصاب. يمكن للفيروسات أن تُلحق أضرارًا بالأجهزة عبر حذف ملفات أو إبطاء النظام، وعادةً ما تحتاج إلى تدخل المستخدم (كتشغيل ملف مصاب) لبدء نشاطها.

31. الدودة (Worm)

برمجية خبيثة ذاتية الانتشار لا تحتاج إلى إرفاق نفسها ببرنامج آخر. تستغل الديدان موارد الشبكة للانتقال من جهاز إلى آخر بشكل تلقائي، ويمكنها التكاثر بسرعة كبيرة. غالبًا ما تسبب الديدان استهلاكًا كبيرًا لعرض النطاق وإبطاء الشبكات أو تعطيلها.

32. حصان طروادة (Trojan Horse)

برنامج خبيث يتظاهر بأنه برنامج سليم أو مفيد لخداع المستخدم لتشغيله. بمجرد تشغيل "حصان طروادة"، يقوم بتنفيذ إجراءات ضارة في الخفاء، مثل فتح باب خلفي للمهاجم أو سرقة بيانات، بينما يظن المستخدم أنه مجرد تطبيق عادي (كالألعاب أو الأدوات المجانية).

33. برامج الفدية (Ransomware)

أحد أخطر أنواع البرمجيات الخبيثة؛ يقوم بتشفير ملفات الضحية بشكل يمنع الوصول إليها. يطالب المهاجم لاحقًا بفدية مالية (عادةً بالعملة الرقمية) مقابل توفير مفتاح فك التشفير. برامج الفدية تستهدف الشركات والأفراد، ويمكن أن تشل الأعمال حتى يتم الدفع أو استعادة البيانات من النسخ الاحتياطية.

34. برامج التجسس (Spyware)

برمجيات خبيثة تتسلل إلى النظام وتعمل على جمع معلومات عن المستخدم دون علمه. يمكن لبرامج التجسس تسجيل نشاط المستخدم على الإنترنت، وجمع كلمات المرور أو أرقام البطاقات، وحتى مراقبة ضغطات المفاتيح (مثل برامج keylogger). غالبًا تُباع هذه المعلومات أو تُستخدم لأغراض احتيالية.

35. البرامج الإعلانية (Adware)

برامج غير مرغوب فيها تعرض إعلانات بصورة مستمرة ومزعجة على جهاز المستخدم. بعض البرامج الإعلانية تكون مجرد إزعاج، لكنها قد تجمع أيضًا بيانات عن عادات تصفح المستخدم وترسلها إلى جهات خارجية دون إذن. في بعض الحالات يمكن أن تفتح البرامج الإعلانية الباب أمام برمجيات أكثر ضررًا.

36. الجذور الخفية (Rootkit)

برنامج خبيث يخفي وجوده ونشاطاته داخل النظام عبر تعديل النظام نفسه. يمنح "الجذر الخفي" المهاجم صلاحيات عالية (جذر النظام) تمكنه من السيطرة الكاملة، مع إخفاء عمليات التجسس أو التخريب عن برامج الحماية. إزالة الجذور الخفية صعب للغاية لأنها تتغلغل عميقًا في النظام.

37. مسجل المفاتيح (Keylogger)

برنامج تجسس خفي يسجل كل ما يكتبه المستخدم على لوحة المفاتيح. يهدف مسجل المفاتيح إلى جمع معلومات حساسة مثل كلمات المرور وكتابات المحادثات والنصوص المهمة. قد يكون جزءًا من برمجيات خبيثة أو جهاز مادي يُثبت بشكل سري، ويتم إرسال البيانات المجمعة إلى المهاجم.

38. الباب الخلفي (Backdoor)

وسيلة خفية تسمح بتجاوز أنظمة الحماية والدخول إلى النظام مباشرة. قد يترك المهاجم بابًا خلفيًا بعد اختراقه الأول لضمان إمكانية العودة لاحقًا بسهولة. أحيانًا تكون الأبواب الخلفية أكواد برمجية يضعها مطور أو مهاجم عمداً في البرنامج للسماح بالدخول دون مرور بإجراءات المصادقة المعتادة.

39. شبكة الروبوتات (Botnet)

مجموعة كبيرة من الأجهزة الحاسوبية المخترَقة والمُسيطر عليها عن بعد من قبل المهاجم. يُصاب كل جهاز في الشبكة ببرمجية خبيثة (روبوت Bot) تتيح للمهاجم التحكم فيه عبر خادم قيادة وتحكم. تُستخدم شبكات الروبوتات في شن هجمات واسعة النطاق مثل هجمات حجب الخدمة أو إرسال البريد المزعج بشكل جماعي.

40. حصان طروادة للوصول عن بعد (Remote Access Trojan - RAT)

نوع خاص من أحصنة طروادة يمنح المهاجم سيطرة كاملة عن بعد على جهاز الضحية. بمجرد إصابة الجهاز بهذا البرنامج الخبيث، يستطيع المهاجم مشاهدة شاشة الضحية، والتحكم في الملفات، وتشغيل الأوامر كما لو كان جالسًا أمام الحاسوب المستهدف.

41. التهديد المستمر المتقدم (APT)

هجوم سيبراني معقد ومستمر تقوم به عادة جهات محترفة (مثل مجموعات مدعومة من دول). يتسلل المهاجم في APT إلى الشبكة المستهدفة بهدوء ويبقى لأطول فترة ممكنة دون كشف، جامعًا المعلومات أو منتظرًا الوقت المناسب لإحداث ضرر كبير. يمتاز هذا النوع من الهجمات بالتخطيط الدقيق وتجنب إثارة الانتباه.

42. ثغرة اليوم الصفري (Zero-Day Vulnerability)

ثغرة أمنية غير معروفة للباحثين أو الشركات المصنعة وقت اكتشافها من قبل المهاجم. سُمّيت "يوم صفري" لأنه لا يكون هناك أي يوم سابق توفر فيه تصحيح لهذه الثغرة. يستغل المهاجمون هذه الثغرات بسرعة قبل إصدار تحديث أو Patch لإصلاحها, مما يجعلها خطيرة للغاية نظرًا لعدم وجود دفاع محدد ضدها عند الهجوم.

43. هجوم حجب الخدمة (DoS Attack)

هجوم يهدف إلى تعطيل خدمة أو موقع على الإنترنت عبر إغراقه بطلبات أو بيانات زائدة عن طاقته. يؤدي هجوم حجب الخدمة (Denial of Service) إلى بطء شديد في الخدمة أو توقفها تمامًا، مما يمنع المستخدمين الشرعيين من الوصول إليها. غالبًا ما يُنفَّذ الهجوم من جهاز واحد أو مصدر وحيد.

44. هجوم حجب الخدمة الموزع (DDoS Attack)

مشابه لهجوم حجب الخدمة ولكنه ينفذ من عدة أجهزة أو مصادر متعددة في وقت واحد. يستخدم المهاجمون عادةً شبكات الروبوتات لإرسال كميات هائلة من حركة البيانات نحو الهدف بشكل متزامن. يصعب صد هجمات DDoS لكثافة تدفق البيانات من أماكن مختلفة، وقد تحتاج إلى حلول خاصة لتخفيفها.

45. هجوم الرجل في المنتصف (Man-in-the-Middle Attack)

هجوم يتسلل فيه المهاجم بين طرفين متواصلين (مثلاً بين مستخدم وموقع ويب) دون علمهما. يقوم "الرجل في المنتصف" باعتراض الرسائل المرسلة، وقد يعدّلها أو يسرق معلومات حساسة قبل إعادة إرسالها للطرف المستهدف. يستخدم المهاجم تقنيات لانتحال هوية أحد الطرفين بحيث يظن الطرف الآخر أنه يتواصل بشكل آمن.

46. هجوم القوة الغاشمة (Brute Force Attack)

طريقة تخمين لكلمات المرور أو المفاتيح من خلال تجربة جميع الاحتمالات الممكنة بشكل منهجي حتى العثور على الصحيح. قد تكون الهجمات بالقوة الغاشمة بطيئة لكنها فعالة إذا كانت كلمة المرور ضعيفة. يمكن إحباطها عبر استخدام كلمات مرور قوية وتحديد عدد محاولات تسجيل الدخول قبل فرض تأخير زمني أو حظر.

47. هجوم القاموس (Dictionary Attack)

نوع من هجمات التخمين يستعين بقائمة كلمات شائعة أو قاموس لغوي لتجربة كلمات المرور المحتملة بدلاً من كافة التركيبات. يفترض المهاجم أن العديد من المستخدمين يستعملون كلمات مرور معروفة أو شائعة. تسهل الحماية من هذا الهجوم عبر تجنب استخدام كلمات المرور الشائعة واستخدام تراكيب معقدة فريدة.

48. هجوم جدول قوس قزح (Rainbow Table Attack)

أسلوب لكسر كلمات المرور المشفرة من خلال جداول مسبقة الحساب. جدول قوس قزح هو قاعدة بيانات تحوي كلمات شائعة مع التمثيل المشفر المقابل لها (مثل التجزئة). إذا تمكن المهاجم من الحصول على قيمة مجزأة (هاش) لكلمة مرور ما، يمكنه البحث في جدول قوس قزح عن المطابقة واستنتاج الكلمة الأصلية دون الحاجة لتجريب كل احتمال.

49. تجاوز سعة المخزن المؤقت (Buffer Overflow)

ثغرة برمجية تنتج عند كتابة بيانات بشكل يتجاوز حجم الذاكرة المخصصة (المخزن المؤقت). يؤدي ذلك إلى فيضان البيانات إلى أجزاء أخرى من الذاكرة، مما قد يسمح للمهاجم بحقن تعليمات خبيثة أو تعطيل البرنامج. استغلال تجاوز السعة واحد من أقدم التقنيات الهجومية، ويُمكّن المهاجم من تنفيذ تعليمات برمجية ضارة على النظام المستهدف.

50. الحقن (SQL Injection)

هجوم يستهدف قواعد البيانات الخاصة بالتطبيقات عبر إدخال تعليمات SQL خبيثة في حقول الإدخال (مثل نماذج الويب). إذا لم يتم تعامل التطبيق بشكل صحيح مع تلك المدخلات، يقوم خادم قاعدة البيانات بتنفيذ أوامر المهاجم. يمكن لهجوم حقن SQL أن يكشف بيانات حساسة أو يعدّلها أو حتى يتحكم في الخادم تمامًا.

51. البرمجة عبر المواقع (XSS)

اختصار لـ Cross-Site Scripting، وهي ثغرة في تطبيقات الويب تسمح للمهاجم بحقن سكريبتات خبيثة في صفحات موقع موثوق. يحدث ذلك عادة عبر حقل إدخال للمستخدم غير مؤمَّن بشكل صحيح. إذا نجح الهجوم، يتم تنفيذ السكريبت في متصفح المستخدمين الآخرين، ما قد يؤدي إلى سرقة بيانات حساسة مثل ملفات تعريف الارتباط (Cookies) أو تشويه محتوى الموقع.

52. تزوير طلبات المواقع (CSRF)

اختصار لـ Cross-Site Request Forgery، وهو هجوم يدفع المستخدم المصادق (الذي سجّل دخوله) إلى تنفيذ إجراءات غير مرغوبة دون علمه. يقوم المهاجم بإعداد رابط أو رمز خبيث، وعند نقر المستخدم عليه، يُرسل طلب إلى موقع موثوق نيابة عنه وكأنه

إجراء صحيح. يمكن بهذا خداع المستخدم لتغيير إعدادات أو إجراء معاملات دون قصد.

53. اختطاف الجلسة (Session Hijacking)

هجوم يستولي فيه المهاجم على جلسة مستخدم نشطة على نظام أو موقع ويب. بعد أن يسجل المستخدم دخوله ويستلم معرّف جلسة (كملف تعريف ارتباط)، يحاول المهاجم سرقة هذا المعرف واستخدامه لانتحال هوية المستخدم والوصول إلى حسابه دون الحاجة لتسجيل الدخول. لهذا تُستخدم بروتوكولات التشفير (مثل HTTPS) لحماية معرّفات الجلسات أثناء انتقالها عبر الشبكة.

54. اختطاف النقر (Clickjacking)

تقنية خداع تجعل المستخدم ينقر على شيء يختلف عما يظنه. يقوم المهاجم بوضع طبقة شفافة مخادعة فوق صفحة ويب شرعية أو زر، بحيث يظن المستخدم أنه ينقر على الزر الظاهر لكنه في الواقع ينقر على عنصر مخفي يقوم بإجراء ضار (مثلاً، إعطاء صلاحيات أو تغيير إعدادات). من طرق الوقاية استخدام إعدادات أمان المتصفح التي تمنع تضمين الموقع داخل إطارات خارجية.

55. اجتياز الدليل (Directory Traversal)

ثغرة تمكّن المهاجم من الوصول إلى ملفات أو أدلة (مجلدات) على الخادم ليست مصرحًا له برؤيتها. يتم ذلك عبر إدخال مسارات خاصة في طلبات الويب (مثل `../` للرجوع إلى دليل أعلى) بهدف الوصول إلى ملفات نظام حساسة. في حال عدم معالجة التطبيق للمسارات بشكل صحيح، قد ينجح المهاجم في عرض ملفات تكوين أو كلمات مرور مخزنة على الخادم.

56. تنفيذ التعليمات البرمجية عن بعد (Remote Code Execution)

ثغرة خطيرة تسمح للمهاجم بتنفيذ أوامر أو برامج على جهاز الضحية عن بعد. إذا وجد المهاجم مدخلًا لهذه الثغرة في تطبيق أو نظام, يمكنه تشغيل تعليماته الخبيثة بحرية كما لو كان لديه وصول مباشر. تؤدي ثغرات RCE عادة إلى سيطرة كاملة على النظام المستهدف، مما يجعلها من أخطر أنواع الثغرات.

57. تسميم نظام أسماء النطاقات (DNS Poisoning)

هجوم يستهدف نظام أسماء النطاقات (DNS) لتوجيه المستخدمين إلى مواقع مزيفة. يقوم المهاجم بإدخال بيانات خاطئة في ذاكرة تخزين DNS المؤقتة (Cache) لاسم نطاق معين، مما يتسبب في إرجاع عنوان IP خاطئ. على سبيل المثال، قد يزور المستخدم موقعًا يبدو صحيحًا لكن DNS المحوَّر يوجهه إلى خادم المهاجم الذي يقلّد الموقع الأصلي لسرقة البيانات.

58. هجوم سلسلة التوريد (Supply Chain Attack)

هجوم يستهدف نقاط الضعف في مكونات سلسلة التوريد التقنية للهدف. بدل مهاجمة الهدف مباشرة، يخترق المهاجم أحد الموردين أو البرمجيات الطرفية التي يعتمد عليها الهدف. عند تحديث البرنامج أو استخدام المكوّن المسموم، ينتقل الاختراق إلى داخل شبكة الهدف. أصبحت هذه الهجمات شائعة مع تعقّد سلاسل التوريد البرمجية وكثرة الاعتماد على برمجيات خارجية.

59. جدار الحماية (Firewall)

نظام أمني يراقب حركة البيانات الشبكية الواردة والصادرة ويقرر السماح بها أو منعها وفقًا لقواعد محددة. يعمل جدار الحماية كحاجز بين الشبكة الداخلية الموثوقة والعالم الخارجي غير الموثوق، فيمنع المرور غير المصرح ويحمي الأجهزة من العديد من الهجمات الخارجية عبر تصفية الاتصالات.

60. مضاد الفيروسات (Antivirus)

برنامج يكتشف البرمجيات الخبيثة (كالفيروسات والدودة وأحصنة طروادة) ويعمل على إزالتها أو عزلها. يستخدم مضاد الفيروسات قواعد بيانات تحتوي تعريفات لأنواع معروفة من البرمجيات الضارة، كما يستطيع أحيانًا كشف سلوك مريب للتعرف على تهديدات جديدة. من المهم تحديث برنامج مضاد الفيروسات بانتظام ليتمكن من التعرف على أحدث التهديدات.

61. نظام كشف التسلل (IDS)

اختصار لـ Intrusion Detection System، وهو نظام أو برنامج يراقب حركة الشبكة ونشاط الأنظمة بحثًا عن أنماط مشبوهة أو معروفة كدلالة على حدوث هجوم. في حال اكتشاف نشاط غير اعتيادي (مثل محاولات اختراق)، يصدر IDS تنبيهًا للمسؤولين. مهمة IDS تنحصر في الكشف والتنبيه، ولا يتخذ إجراء لمنع الهجوم بشكل تلقائي.

62. نظام منع التسلل (IPS)

اختصار لـ Intrusion Prevention System، وهو مشابه لنظام كشف التسلل (IDS) لكنه يتخذ خطوة إضافية بمنع الهجوم بشكل تلقائي. عند رصد نشاط مريب أو هجوم معروف، يقوم IPS بعرقلة حركة البيانات المشبوهة أو منع المهاجم من الوصول، وبالتالي يحمي النظام في الوقت الفعلي بدلًا من الاكتفاء بإطلاق تحذير.

63. جدار حماية تطبيقات الويب (WAF)

اختصار لـ Web Application Firewall، وهو جهاز أو برنامج يحمي تطبيقات الويب خصوصًا من الهجمات الشائعة عليها. يعمل WAF كطبقة أمان بين المستخدم وتطبيق الويب، فيراقب الطلبات الواردة ويرشحها. يمكنه منع هجمات مثل حقن SQL أو XSS عبر اكتشاف الأنماط الخبيثة في حركة البيانات المتجهة إلى التطبيق.

64. شبكة خاصة افتراضية (VPN)

اختصار لـ Virtual Private Network، وهي تقنية تتيح إنشاء اتصال مشفّر وآمن عبر شبكة عامة مثل الإنترنت. عند استخدام VPN، يتم توجيه حركة البيانات خلال نفق مشفر بين الجهاز والشبكة الخاصة الوجهة، مما يحمي البيانات من التجسس ويخفي عنوان IP الحقيقي للمستخدم، مما يعزز الخصوصية والأمان عند الاتصال عن بعد.

65. بروتوكول SSL/TLS

بروتوكولات تشفير تؤمّن نقل البيانات عبر الإنترنت. SSL (طبقة المقابس الآمنة) وTLS (أمن طبقة النقل) يعملان على تشفير البيانات بين العميل والخادم، خاصة في تصفح الويب (HTTPS). يضمن SSL/TLS أن المعلومات المرسلة (مثل كلمات المرور أو بيانات الدفع) تنتقل بشكل آمن ولا يمكن لمتعقب اعتراضها بشكل مقروء.

66. بروتوكول HTTPS

امتداد آمن لبروتوكول HTTP القياسي المستخدم لتصفح الويب. يشير حرف "S" إلى "Secure" أي آمن، ويعني أن الاتصال بين المتصفح والموقع مشفر باستخدام SSL/TLS. عند رؤية "https://" في بداية عنوان الموقع، فهذا يدل على أن البيانات (مثل بيانات النماذج وكلمات المرور) تنتقل مشفرة، مما يوفر حماية من التنصت أو السرقة أثناء النقل.

67. بروتوكول SSH

اختصار لـ Secure Shell، وهو بروتوكول يوفر قناة اتصال مشفرة بين حاسوبين عبر الإنترنت. يُستخدم SSH بشكل شائع للوصول الآمن إلى الخوادم وإدارة الأنظمة عن بعد عبر سطر الأوامر. يضمن SSH أن بيانات الجلسة عن بعد (مثل كلمات المرور والأوامر) تنتقل بأمان ولا يمكن لمهاجم اعتراضها بسهولة.

68. بروتوكول IPsec

مجموعة من البروتوكولات تؤمن الاتصالات على مستوى شبكة الإنترنت (طبقة IP). يستخدم IPsec لتشفير والتحقق من صحة حزم البيانات المرسلة بين طرفين، مما يوفر اتصالاً آمنًا عبر شبكات غير موثوقة. يُستخدم كثيرًا في إنشاء شبكات VPN وفي حماية الاتصالات بين الشبكات المختلفة لضمان عدم تعديل البيانات أو قراءتها أثناء الانتقال.

69. المصادقة (Authentication)

عملية التحقق من هوية المستخدم أو الجهاز قبل منحه حق الوصول. يمكن أن تتم المصادقة عبر عدة طرق مثل: كلمة المرور، أو رمز يُرسل للهاتف (OTP)، أو البصمة البيومترية. الهدف هو التأكد من أن الشخص أو الجهة هي فعلاً ما تدعيه قبل السماح لها باستخدام النظام أو البيانات.

70. التفويض (Authorization)

عملية تحديد صلاحيات كيان مصادق (اجتاز المصادقة) وتحديد ما يحق له فعله أو الوصول إليه. بعد تسجيل الدخول (المصادقة)، يحدد النظام ما إن كان للمستخدم المخول إذن بالوصول إلى مورد معين أو إجراء عملية معينة. مثال: قد يتم تفويض مدير للوصول إلى بيانات حساسة، بينما يُمنع موظف عادي من ذلك.

71. المصادقة متعددة العوامل (MFA)

أسلوب مصادقة يتطلب تقديم أكثر من دليل لإثبات هوية المستخدم. بدل الاعتماد على كلمة مرور فقط (عامل واحد)، تستخدم MFA عوامل إضافية مثل رمز مؤقت يُرسل إلى الهاتف، أو بصمة الإصبع، أو بطاقة ذكية. الهدف هو زيادة صعوبة اختراق

الحسابات، حيث أن المهاجم سيحتاج لاختراق عدة عوامل مستقلة للحصول على الوصول.

72. التشفير (Encryption)

عملية تحويل المعلومات من صورتها المقروءة (نص عادي) إلى صيغة مشفرة غير مفهومة دون امتلاك مفتاح التشفير المناسب. يستخدم التشفير لضمان سرية البيانات، بحيث لو وقعت في يد غير مخول فلن يستطيع فهم محتواها. تعتمد قوة التشفير على طول المفتاح والخوارزمية المستخدمة.

73. فك التشفير (Decryption)

العملية العكسية للتشفير، حيث يتم إعادة تحويل المعلومات من صيغة مشفرة غير مفهومة إلى صيغة مقروءة أو مفهومة باستخدام المفتاح الصحيح. فقط الأطراف المصرح لها التي تملك مفاتيح فك التشفير تستطيع استعادة البيانات الأصلية. إذا كان التشفير قويًا ولم يتوفر المفتاح، يصبح فك التشفير شبه مستحيل.

74. التشفير المتماثل (Symmetric Encryption)

نوع من خوارزميات التشفير يستخدم مفتاحًا واحدًا للتشفير وفك التشفير معًا. هذا يعني أن كلاً من المرسل والمستقبل يستخدمان نفس المفتاح السري. يتميز التشفير المتماثل بسرعته، لكن التحدي الرئيسي هو مشاركة المفتاح بشكل آمن بين الأطراف دون أن يعرفه طرف ثالث.

75. التشفير غير المتماثل (Asymmetric Encryption)

خوارزمية تشفير تستخدم مفتاحين مختلفين: مفتاح عام ومفتاح خاص. المفتاح العام يُنشر للعلن ويمكن لأي شخص استخدامه لتشفير رسالة, لكن لا يمكن فكها إلا

باستخدام المفتاح الخاص المقابل الذي يحتفظ به صاحبه بسرية. هذا الأسلوب يحل مشكلة توزيع المفاتيح في التشفير المتماثل، لكنه أبطأ نسبيًا ويستهلك موارد أكثر.

76. المفتاح العام (Public Key)

جزء من زوج مفاتيح في أنظمة التشفير غير المتماثل. المفتاح العام هو المفتاح الذي يتم نشره علنًا ويمكن للجميع استخدامه. على سبيل المثال، يمكنك استخدام مفتاحي العام لتشفير رسالة وإرسالها إلي, ولا يستطيع فكها وقراءتها إلا من يملك المفتاح الخاص المقابل (وهو أنا).

77. المفتاح الخاص (Private Key)

المفتاح السري في نظام التشفير غير المتماثل، يحتفظ به صاحبه ولا يشاركه مع أحد. يُستخدم المفتاح الخاص لفك تشفير الرسائل التي شُفّرت بالمفتاح العام المقابل، كما يُستخدم أيضًا لتوليد التواقيع الرقمية. الحفاظ على سرية المفتاح الخاص أمر جوهري، فأي شخص يحصل عليه سيتمكن من فك تشفير البيانات أو انتحال هوية صاحبه.

78. التوقيع الرقمي (Digital Signature)

بصمة رقمية فريدة تُلحق بالمستندات أو الرسائل الرقمية لإثبات صحة المصدر وسلامة المحتوى. ينشأ التوقيع الرقمي عبر تشفير ملخص الرسالة (هاش) باستخدام المفتاح الخاص للمرسل. يمكن لأي مستقبل استخدام المفتاح العام للمرسل للتحقق من التوقيع وضمان أن المحتوى لم يتم تعديله وأنه صادر ممن يدّعي إرساله.

79. الشهادة الرقمية (Digital Certificate)

وثيقة إلكترونية تصدرها سلطة موثوقة (سلطة شهادات) لتربط هوية كيان (شخص، موقع، خادم) بمفتاحه العام. تحتوي الشهادة الرقمية على معلومات الهوية والمفتاح العام وتوقيع السلطة المصدرة. تستخدم الشهادات الرقمية في بروتوكول HTTPS لضمان اتصال آمن والتحقق من هوية المواقع والخوادم.

80. البنية التحتية للمفاتيح العامة (PKI)

منظومة متكاملة لإدارة المفاتيح العامة والخاصة والتواقيع الرقمية. تشمل PKI هيئات الإصدار (سلطات الشهادات) التي تصدر الشهادات الرقمية، وهيئات التسجيل التي تحقق من هوية طالب الشهادة، إضافة إلى آليات إبطال الشهادات المنتهية أو المخترَقة. تساهم PKI في إنشاء بيئة ثقة للتعاملات الإلكترونية والتواصل الآمن.

81. دالة التجزئة (Hash Function)

خوارزمية تأخذ بيانات بأي حجم وتُنتج منها بصمة رقمية ثابتة الطول تُعرف بال "هاش". تمتاز دوال التجزئة بأنها حتمية (نفس المدخل تعطي نفس المخرج) وبصعوبة استنتاج المدخل من المخرج (أحادي الاتجاه). تُستخدم التجزئة لتخزين كلمات المرور بشكل آمن (بدون الاحتفاظ بالنص الأصلي) وكجزء من التوقيعات الرقمية للتحقق من سلامة البيانات.

82. مركز عمليات الأمن (SOC)

اختصار لـ Security Operations Center، وهو فريق أو قسم ضمن المؤسسة مكرّس للمراقبة المستمرة للأمن السيبراني. يقوم محللو مركز العمليات الأمنية بمراقبة الشبكات والأنظمة لرصد أي نشاط مريب أو حوادث أمنية، ويستجيبون بسرعة لاحتوائها. يُعتبر الـ SOC عنصرًا حيويًا لتحسين سرعة وكفاءة اكتشاف التهديدات ومعالجتها.

83. إدارة الأحداث والمعلومات الأمنية (SIEM)

اختصار لـ Security Information and Event Management، وهي حلول تجمع بين إدارة معلومات الأمن وإدارة الأحداث الأمنية. تعمل أنظمة SIEM على جمع وتحليل سجلات الأنظمة والشبكات والتطبيقات بشكل مركزي، لاكتشاف الأنماط المحتملة لهجمات أو مخالفات. كما تولد تنبيهات عند تحقق شروط معينة، مما يساعد الفرق الأمنية على فهم الحوادث بسرعة أكبر.

84. الاستجابة للحوادث (Incident Response)

مجموعة الإجراءات المتبعة للتعامل مع حادث أمني بعد اكتشافه بهدف تقليل الضرر واستعادة الوضع الطبيعي. تتضمن الاستجابة للحوادث خطوات مثل: تحديد نطاق الحادث، واحتوائه لمنع انتشاره، والقضاء على التهديد (كإزالة البرمجيات الخبيثة)، ثم استعادة الأنظمة للعمل الطبيعي، وأخيرًا التحقيق والتعلم من الحادث لتحسين الدفاعات المستقبلية.

85. التحليل الجنائي الرقمي (Digital Forensics)

فرع من علوم التحقيق يستخدم لتحليل الأجهزة والأنظمة الرقمية بعد وقوع حوادث أمنية. يهدف التحليل الجنائي الرقمي إلى جمع الأدلة الإلكترونية (مثل سجلات النظام، الملفات المحذوفة، اتصالات الشبكة) بطريقة تحفظ سلامتها القانونية، بهدف فهم كيفية وقوع الاختراق أو الجريمة الإلكترونية وتقديم أدلة قد تُستخدم في الملاحقات القانونية.

86. اختبار الاختراق (Penetration Testing)

محاكاة منهجية لهجوم إلكتروني على نظام أو شبكة بهدف تقييم مستوى الأمن والكشف عن الثغرات. يقوم مختصون (أو فرق أمنية) مرخص لهم بمحاولة اختراق

الأنظمة باستخدام أدوات وأساليب مشابهة لتلك التي يستعملها المهاجمون الحقيقيون. نتائج اختبار الاختراق تساعد على إصلاح نقاط الضعف وتعزيز الإجراءات الأمنية قبل أن يستغلها مهاجم فعلي.

87. تقييم الثغرات (Vulnerability Assessment)

عملية فحص وتحليل الأنظمة والشبكات بحثًا عن الثغرات الأمنية المعروفة. يتم استخدام أدوات آلية وأحيانًا مراجعات يدوية لتحديد نقاط الضعف بدون استغلالها (بعكس اختبار الاختراق الذي يحاول الاستغلال). يخرج تقييم الثغرات بتقرير يوثق الثغرات المكتشفة وأولويات معالجتها، ليساعد المسؤولين على تعزيز دفاعاتهم قبل حدوث أي اختراق.

88. استخبارات التهديدات (Threat Intelligence)

جمع وتحليل المعلومات حول التهديدات السيبرانية الحالية والمحتملة. تشمل استخبارات التهديدات بيانات عن أساليب الهجوم الجديدة، وبرمجيات خبيثة منتشرة، ومجموعات القرصنة النشطة. تستفيد المؤسسات من هذه المعلومات لتحديث استراتيجيات الأمن بشكل استباقي، ومعرفة ما ينبغي التركيز عليه من حماية وفقًا لأحدث التهديدات.

89. صيد التهديدات (Threat Hunting)

عملية بحث استباقي في الشبكات والأنظمة عن أي نشاط خفي أو اختراق غير مكتشف. يقوم محللو صيد التهديدات بتحليل السجلات ونشاط الأجهزة للعثور على علامات تدل على وجود مهاجم متخفٍّ، بدل الانتظار لظهور تنبيهات أو آثار واضحة. هذه الممارسة تساعد في اكتشاف التهديدات المتقدمة التي قد تفلت من أدوات الكشف التقليدية.

90. إدارة الهوية والصلاحيات (IAM)

اختصار لـ Identity and Access Management، وهي مجموعة عمليات وتقنيات لإدارة هويات المستخدمين وصلاحيات وصولهم في المؤسسة. تشمل IAM إنشاء حسابات المستخدمين، وضبط مستويات الوصول بناءً على الأدوار، وإدارة كلمات المرور، وتفعيل المصادقة متعددة العوامل. الهدف هو ضمان أن الأشخاص المناسبين لديهم الوصول المناسب إلى الموارد المناسبة في الوقت المناسب.

91. إدارة التصحيحات (Patch Management)

عملية إدارة وتطبيق تحديثات البرامج والتصحيحات الأمنية بمجرد توفرها. يشمل ذلك التعرف على التحديثات الصادرة من موردي البرمجيات وتقييمها وجدولة تثبيتها على الأنظمة. تهدف إدارة التصحيحات إلى سد الثغرات المكتشفة حديثًا قبل أن يستغلها المهاجمون، وبالتالي الحفاظ على الأنظمة محدثة وآمنة.

92. منع فقدان البيانات (DLP)

اختصار لـ Data Loss Prevention، وهي استراتيجيات وأدوات مصممة لمنع تسرب البيانات الحساسة إلى خارج المؤسسة بدون إذن. تشمل تقنيات DLP مراقبة حركة البيانات (عبر البريد الإلكتروني أو تخزين سحابي مثلاً) واكتشاف المعلومات الحساسة (كالأرقام المالية أو البيانات الشخصية) ومنع إرسالها أو نسخها إن لم يكن الشخص مخوّلًا بذلك.

93. الدفاع في العمق (Defense in Depth)

مبدأ أمني يقوم على بناء طبقات متعددة من الدفاعات لحماية النظام. بدلاً من الاعتماد على وسيلة واحدة (كجدار حماية فقط)، يتم استخدام عدة طبقات مثل جدران الحماية، وأنظمة كشف التسلل، والتشفير، والتحكم في الوصول. الفكرة هي أنه حتى

لو تجاوز المهاجم طبقة دفاعية واحدة، فإن طبقات أخرى ستتصدى له، مما يزيد صعوبة نجاح الهجوم.

94. التهديد الداخلي (Insider Threat)

خطر نابع من أشخاص من داخل المؤسسة لديهم صلاحيات وصول شرعية، لكنهم قد يسؤون استخدامها. قد يكون التهديد الداخلي موظفًا ساخطًا، أو شخصًا تم اختراق حسابه دون علمه. يمكن أن يتسبب التهديد الداخلي في تسريب معلومات حساسة أو تخريب أنظمة الشركة، لذا تضع المؤسسات سياسات ورقابة لرصد التصرفات الشاذة للموظفين.

95. برنامج مكافآت الثغرات (Bug Bounty)

برنامج تعتمده بعض الشركات والمنظمات لدعوة الباحثين الأمنيين والمخترقين الأخلاقيين لاكتشاف الثغرات في أنظمتها وتطبيقاتها. يقدم البرنامج مكافآت مالية أو تقديرية لمن يبلغ عن ثغرة بطريقة مسؤولة. تساعد برامج مكافآت الثغرات على تعزيز الأمن بالاستفادة من مجتمع الباحثين لاكتشاف المشاكل قبل استغلالها من جهات خبيثة.

96. الفجوة الهوائية (Air Gap)

إستراتيجية أمنية لحماية نظام أو شبكة حساسة عبر فصلها تمامًا عن أي شبكات أخرى (خاصة الإنترنت). يكون الجهاز أو الشبكة ذات الفجوة الهوائية غير متصل إلكترونياً بالشبكات الخارجية، مما يصعب جداً الوصول إليها عن بعد. تُستخدم هذه الطريقة في البيئات عالية الحساسية مثل الشبكات العسكرية أو أنظمة التحكم الصناعي لتقليل مخاطر الاختراق.

97. الإنترنت المظلم (Dark Web)

جزء مخفي من الإنترنت لا يمكن الوصول إليه عبر المتصفحات التقليدية أو محركات البحث، ويتطلب برامج خاصة مثل Tor. يشتهر الإنترنت المظلم بأنه سوق للنشاطات غير القانونية (كبيع البيانات المسروقة أو البرمجيات الخبيثة), لذا يهتم خبراء الأمن السيبراني بمراقبة تلك الأوساط للحصول على معلومات عن التهديدات والتعاملات المشبوهة.

98. صندوق الرمل (Sandbox)

بيئة اختبار افتراضية معزولة تُستخدم لتشغيل البرامج غير الموثوقة أو فحص البرمجيات الخبيثة بأمان. في صندوق الرمل، يتم تشغيل الكود في مساحة محصورة لا يمكنها التأثير على باقي النظام أو الشبكة. إذا كان البرنامج خبيثًا أو به خلل، فإن تأثيره سيظل محدودًا داخل هذه البيئة دون التسبب بأضرار حقيقية.

99. المصادقة البيومترية (Biometric Authentication)

طريقة تحقق من الهوية تعتمد على صفات بيولوجية فريدة للفرد. تتضمن أمثلة المصادقة البيومترية: بصمة الإصبع، وبصمة العين (القزحية أو الشبكية), وبصمة الوجه، وحتى بصمة الصوت. تُعد هذه الطريقة قوية لأن هذه السمات يصعب تقليدها أو مشاركتها، وتضيف طبقة أمنية إضافية تتجاوز كلمات المرور التقليدية.

100. اختبار CAPTCHA

اختبار آلي يُستخدم للتفريق بين المستخدم البشري والبرمجيات الآلية (الروبوتات) على الإنترنت. CAPTCHA تعني "اختبار تورنغ العام المؤتمت للتمييز بين الحاسوب والإنسان". غالبًا ما يظهر على شكل صورة أو أحجية بسيطة على المستخدم حلها (مثل كتابة أحرف مشوهة أو اختيار صور معينة) قبل تقديم الطلب. يساعد هذا الاختبار في منع الأنظمة الآلية الضارة من إساءة استخدام الخدمات الإلكترونية.

101. الاستغلال (Exploit)

كود أو برنامج يستغل ثغرة أمنية في نظام أو تطبيق لتحقيق اختراق أو سلوك غير مرغوب. عندما يتم اكتشاف ثغرة، غالبًا ما يطوّر المهاجمون استغلالًا لها لتمكين التنفيذ الفعلي للهجوم. يمكن أن يكون الاستغلال بسيطًا كسطر أوامر أو معقدًا كبرمجية كاملة، ويعد وجود استغلال متاح خطرًا فوريًا يستوجب التصحيح السريع للثغرة.

102. إحضار جهازك الخاص (BYOD)

اختصار لـ Bring Your Own Device، وهي سياسة تسمح للموظفين باستخدام أجهزتهم الشخصية (حاسوب محمول، هاتف ذكي، جهاز لوحي) للوصول إلى موارد الشركة. بالرغم من فوائد BYOD في المرونة وزيادة الإنتاجية، إلا أنها تشكل تحديات أمنية؛ حيث يجب على المؤسسة ضمان تأمين بياناتها على أجهزة ربما لا تسيطر عليها بالكامل، عبر تطبيق سياسات وإجراءات أمن ملائمة.

103. DevSecOps (دمج الأمن في التطوير والعمليات)

منهجية تدمج ممارسات الأمن السيبراني ضمن دورة حياة تطوير البرمجيات وعمليات تقنية المعلومات (Development + Security + Operations). تهدف DevSecOps إلى جعل الأمن جزءًا أصيلًا من عملية البناء والنشر، بحيث يتم الكشف عن الثغرات مبكرًا وإصلاحها بسرعة. بذلك، يتعاون مطورو البرمجيات وفريق العمليات والفرق الأمنية لضمان إصدار تطبيقات آمنة دون تأخير كبير في عملية التطوير.

104. أمن السحابة (Cloud Security)

مجموعة سياسات وتقنيات لحماية البيئات السحابية وخدمات الحوسبة السحابية. نظرًا لتخزين البيانات وتشغيل التطبيقات على خوادم خارجية (في السحابة)، يركز أمن

السحابة على ضمان سرية البيانات المخزنة، وحماية نقلها بين المستخدم والسحابة، وتأمين واجهات البرامج (APIs) المستخدمة للوصول إلى الخدمات. كما يشمل إدارة صلاحيات المستخدمين والتشفير والامتثال للمعايير في البيئات السحابية.

105. تحليل البرمجيات الخبيثة (Malware Analysis)

عملية فحص ودراسة برمجية خبيثة بهدف فهم عملها وأضرارها وطريقة نشوئها. قد يكون التحليل ثابتًا (قراءة الشفرة دون تشغيلها) أو ديناميكيًا (تشغيل البرمجية في صندوق رمل ومراقبة سلوكها). يساعد تحليل البرمجيات الخبيثة فرق الأمن على ابتكار أدوات إزالة وبرامج مضادة أكثر فعالية، وفهم اتجاهات الهجمات للتصدي لها مستقبلًا.

106. البرمجيات المخادعة (Scareware)

نوع من البرمجيات الخبيثة يُظهر رسائل تخويف كاذبة للمستخدم. غالبًا تأخذ شكل نوافذ منبثقة تدعي اكتشاف فيروسات أو مشاكل خطيرة بالجهاز وتحث المستخدم على تحميل برنامج معين أو دفع مبلغ لحل المشكلة. الهدف هو خداع المستخدم وإقناعه بتنزيل برامج ضارة إضافية أو ابتزازه ماليًا مقابل خدمات وهمية.

107. القنبلة المنطقية (Logic Bomb)

شفرة برمجية خبيثة توضع عمدًا داخل برنامج أو نظام وتظل خاملة حتى يتم تفعيلها بواسطة حدث معين أو في وقت محدد. عند التفعيل، "تنفجر" القنبلة المنطقية لتنفذ مهمة ضارة مثل حذف ملفات أو تعطيل نظام. يُمكن أن يزرعها موظف ناقم داخل نظام الشركة لضربه لاحقًا، أو تأتي ضمن برمجيات خبيثة أخرى تنتظر شروطًا معينة للعمل.

108. الحركة الجانبية (Lateral Movement)

أسلوب يستخدمه المهاجم بعد اختراقه الأولي لنظام للانتقال داخل شبكة الضحية. بدلاً من الاكتفاء بالجهاز أو الحساب الأول الذي سيطر عليه، يبدأ بالبحث عن معلومات وصلاحيات تخوله الوصول لأجهزة أو خوادم أخرى (كالقفز من حاسوب موظف إلى خادم قاعدة بيانات). الهدف توسيع نطاق الاختراق والوصول إلى أصول أكثر أهمية. يمكن كشف الحركة الجانبية عبر مراقبة دخول المستخدمين إلى موارد غير معتادة لهم.

109. البريد العشوائي (Spam)

رسائل إلكترونية غير مرغوب فيها تُرسل إلى عدد كبير من المستخدمين بغرض الإعلان المزعج أو الاحتيال. يحمل البريد العشوائي أحيانًا روابط خبيثة أو مرفقات ضارة قد تصيب الجهاز عند فتحها. تستخدم الفلاتر الخاصة في خدمات البريد الإلكتروني لكشف وتصنيف الرسائل المزعجة ومنعها من الوصول إلى صندوق الوارد للمستخدم.

110. الفريق الأحمر (Red Team)

مجموعة من المختصين بأمن المعلومات تُكلَّف بمحاكاة هجمات حقيقية على مؤسسة بهدف تقييم فعالية دفاعاتها. يعمل الفريق الأحمر بشكل مستقل ويحاول التفكير كالمهاجمين لاختراق الأنظمة واختبار جاهزية الفريق الأزرق (المدافع). النتائج تقدم نظرة عملية على نقاط الضعف الأمنية لتصحيحها وتعزيز قدرة الشركة على التصدي للهجمات.

111. الفريق الأزرق (Blue Team)

الجانب المدافع في سيناريوهات الأمن السيبراني. يتألف من خبراء أمن مسؤولين عن حماية أنظمة المؤسسة، ومراقبة الشبكات، والاستجابة للحوادث. عند قيام الفريق الأحمر بهجمات تجريبية أو عند حدوث هجوم حقيقي، يكون الفريق الأزرق هو الجهة

التي تكتشفه وتحتويه. التعاون بين الفريق الأزرق والأحمر بعد التمارين يساعد على تحسين الوضع الأمني العام.

112. الفريق الأرجواني (Purple Team)

فريق ينشأ من تعاون وتنسيق بين الفريق الأحمر (المهاجم) والفريق الأزرق (المدافع). الهدف منه تبادل المعرفة بشكل مستمر: يتعلم الفريق الأزرق من تقنيات واختراقات الأحمر، بينما يتعلم الأحمر من تحديات واكتشافات الأزرق. وجود فريق أرجواني يساهم في تطوير استراتيجيات أمنية أكثر فعالية عبر سد الفجوة بين المهاجمين والمدافعين داخل المؤسسة.

113. التحكم بالوصول (Access Control)

آليات تنظم من يمكنه الوصول إلى الموارد أو الأنظمة ومتى. يتضمن التحكم بالوصول إنشاء قواعد وسياسات تحدد صلاحيات كل مستخدم أو دور؛ على سبيل المثال، قد يُسمح لموظف بقراءة ملف معين ولكن ليس تعديله. أدوات التحكم بالوصول تشمل كلمات المرور، والقوائم (مثل ACL)، وتُستخدم لضمان أن الموارد الحساسة لا يطالعها أو يغيرها إلا المصرح لهم فقط.

114. قائمة التحكم بالوصول (ACL)

اختصار لـ Access Control List، وهي قائمة مرتبطة بملف أو مورد تحدد بالضبط أيُّ المستخدمين أو المجموعات لديهم أي نوع من الوصول إليه. على سبيل المثال، ملف في نظام قد يحتوي ACL تسمح لمستخدم بالقراءة فقط ولآخر بالقراءة والكتابة. تعتبر ACL شكلًا شائعًا لتطبيق التحكم بالوصول الدقيق على الموارد.

115. التحكم بالوصول المعتمد على الدور (RBAC)

اختصار لـ Role-Based Access Control، وهو نموذج لإدارة الصلاحيات يمنح أو يمنع الوصول بناءً على أدوار المستخدمين في المؤسسة. بدلاً من إعطاء صلاحيات لكل مستخدم على حدة، يتم تعريف أدوار (مثل "مدير"، "موظف"، "مسؤول قاعدة بيانات") وكل دور يمتلك مجموعة من الصلاحيات المخصصة. ثم يتم تعيين المستخدمين إلى هذه الأدوار. بهذه الطريقة، يتم تبسيط إدارة الصلاحيات وضمان اتساقها بناءً على موقع المستخدم.

116. الملح (Salt)

بيانات عشوائية تُضاف إلى كلمة المرور قبل تجزئتها لتعزيز أمنها. عند قيام النظام بتخزين كلمات المرور، يقوم بإضافة "ملح" مختلف لكل كلمة مرور ثم يحتفظ بالقيمة المُجزأة فقط. وجود الملح يجعل من الصعب جدًا على المهاجمين استخدام جداول قوس قزح أو هجمات التخمين السريعة لكسر كلمات المرور، لأن نفس كلمة المرور ستنتج تجزئات مختلفة مع أملاح مختلفة.

117. النص العادي (Plaintext)

المعلومات أو البيانات بصيغتها الأصلية المقروءة قبل أن يتم تشفيرها. النص العادي هو ما نفهمه كبشر ويمكن للأجهزة معالجته مباشرة. عند تطبيق التشفير على النص العادي، نحصل على نص مشفر. يجب الحفاظ على النص العادي سريًا وعدم نقله عبر الشبكات العامة دون حماية لأنه عرضة للاعتراض والقراءة.

118. النص المشفر (Ciphertext)

الناتج غير المقروء الذي ينتج عن عملية التشفير. يظهر النص المشفر كسلسلة غير مفهومة من الرموز أو الأحرف، ولا يمكن تفسير محتواه بدون مفتاح فك التشفير المناسب. يهدف تحويل النص العادي إلى نص مشفر إلى حماية محتوى الرسالة أثناء

الانتقال أو التخزين، بحيث حتى لو تم الحصول عليها من قبل جهة غير مصرح لها، لا تفيدها بشيء.

119. التلصص البصري (Shoulder Surfing)

طريقة تجسس مادي تتم بمراقبة الضحية مباشرة أثناء إدخالها معلومات حساسة. قد يقف المهاجم خلف الشخص أو بجانبه لتسجيل ما يكتبه على لوحة المفاتيح أو ما يُدخله على شاشة الهاتف (مثل رمز PIN أو كلمة المرور). للتقليل من هذه المخاطر، يُنصح بتغطية لوحة المفاتيح عند إدخال كلمات المرور في الأماكن العامة والانتباه للمحيط.

120. التسلل الفيزيائي (Tailgating)

اختراق أمني فيزيائي يحدث عند دخول شخص غير مصرح له إلى منطقة آمنة عن طريق ملاحقة شخص مصرح له. على سبيل المثال، قد يقتحم دخيل مبنى شركة من خلال الإمساك بالباب قبل إغلاقه بعد مرور موظف حامل لبطاقة دخول. للوقاية، تُستخدم بوابات أمنية فردية وتوعية الموظفين بعدم السماح لآخرين بالدخول بصحبتهم دون تحقق.

121. نبش القمامة (Dumpster Diving)

أسلوب يعتمد على البحث في مهملات المؤسسة بحثًا عن معلومات مفيدة يمكن استغلالها. قد يجد المهاجم في سلة المهملات مستندات تحتوي كلمات مرور مكتوبة أو تصاميم شبكة أو وسائط تخزين قابلة للإزالة. لذا تتبنى المؤسسات سياسات لإتلاف المستندات الحساسة (كتمزيق الورق أو استخدام آليات حذف آمن للوسائط) لمنع استخراج المعلومات منها.

122. الطعم (Baiting)

حيلة في الهندسة الاجتماعية تعتمد على استدراج الضحية عن طريق عنصر مغرٍ أو مثير للفضول. قد يترك المهاجم وسيط تخزين USB مصابًا ببرمجيات خبيثة في مكان مرئي (كغرفة الاستراحة) على أمل أن يقوم شخص ما بالتقاطه واستخدامه في حاسوبه. أو يرسل رسالة بوعدٍ جذاب يحث المستخدم على النقر على رابط ضار. يعتمد نجاح الطعم على فضول أو طمع الضحية.

123. التحايل بالذريعة (Pretexting)

شكل من أشكال الهندسة الاجتماعية يبني فيه المهاجم قصة مزيفة (ذريعة) لكسب ثقة الضحية وحمله على إفشاء معلومات سرية. قد ينتحل المهاجم شخصية موظف دعم فني ويتصل بالضحية مدعيًا وجود مشكلة تحتاج تفاصيل حسابه لحلها. يتطلب التحايل بالذريعة تحضيرًا مُسبقًا لجعل القصة مقنعة، وهو أحد الأساليب الشائعة للحصول على بيانات حساسة كالمعلومات البنكية أو بيانات الاعتماد.

124. أداة Nmap

برنامج مفتوح المصدر شهير يستخدم لفحص الشبكات وتعداد الأجهزة والخدمات. يقوم Nmap (Network Mapper) بإرسال حزم معينة إلى منافذ الشبكة على أهداف محددة لتحليل الاستجابات. يمكنه اكتشاف المنافذ المفتوحة، ونوع أنظمة التشغيل، والخدمات قيد التشغيل على الأجهزة البعيدة. يعد Nmap أداة أساسية لمسؤولي الشبكات ولمختبري الاختراق لتقييم الوضع الأمني للشبكة.

125. أداة Wireshark

أداة تحليل بروتوكولات الشبكة تتيح مراقبة حركة البيانات (Packet Sniffing) بالتفصيل. تعمل Wireshark على التقاط حزم البيانات المارة عبر شبكة معينة وعرضها للمستخدم لفحص محتواها. تساعد هذه الأداة مسؤولي الأمن والمطورين

على اكتشاف الأخطاء في الاتصالات، وتحليل محاولات الهجوم، وفهم كيفية انتقال البيانات في الشبكة.

126. منصة Metasploit

إطار عمل شامل لاختبار الاختراق يساعد المخترقين الأخلاقيين على تطوير وتنفيذ الاستغلالات للثغرات الأمنية. تتضمن منصة Metasploit مجموعة واسعة من التعليمات البرمجية الجاهزة التي تمثل استغلالات معروفة، مما يتيح للمختبر اختيار ثغرة واستهداف جهاز بها بسهولة. كما يمكن استخدامها بعد الاختراق للقيام بحركات جانبية أو تثبيت أبواب خلفية. إنها أداة قوية لتقييم مدى تعرض الأنظمة للهجمات.

127. توزيعة كالي لينكس (Kali Linux)

نظام تشغيل (توزيعة لينكس) مبني خصيصًا لأغراض الأمن السيبراني واختبار الاختراق. تحتوي Kali Linux على مجموعة ضخمة من الأدوات الموجهة للاختبار الأمني مثل Nmap و Metasploit و Wireshark وغيرها، جميعها مثبتة ومضبوطة جاهزة للاستخدام. يستخدم المختصون هذه التوزيعة كبيئة عمل متكاملة لتنفيذ اختبارات الأمان والتدريب العملي على تقنيات الاختراق.

128. أداة Burp Suite

حزمة متكاملة لتقييم أمن تطبيقات الويب. توفر Burp Suite أدوات متعددة مثل وكيل اعتراض (Intercepting Proxy) لتحليل وتعديل حركة مرور HTTP/HTTPS بين المتصفح والخادم، ومساح تلقائي لاكتشاف الثغرات الشائعة في تطبيقات الويب، وأدوات هجوم موجهة مثل مكرر الطلبات ومفكك التشفير. تُعد Burp Suite أداة أساسية للمتخصصين في مجال اختبار أمان تطبيقات الويب.

129. برنامج PGP

اختصار لـ Pretty Good Privacy، وهو برنامج تشفير يستخدم لتأمين الاتصالات عبر البريد الإلكتروني والملفات. يوفر PGP التشفير غير المتماثل لحماية محتوى الرسائل، بالإضافة إلى التواقيع الرقمية للتحقق من هوية المرسل وسلامة الرسالة. رغم ظهوره منذ التسعينيات، لا يزال PGP معيارًا مهمًا للتواصل الآمن بين الأفراد والشركات.

130. سلطة الشهادة (Certificate Authority)

جهة موثوقة مسؤولة عن إصدار الشهادات الرقمية للمواقع والخوادم والأفراد. تقوم سلطة الشهادة بالتحقق من هوية الجهة المقدمة للطلب (مثلاً شركة تريد شهادة لموقعها الإلكتروني) ثم تصدر شهادة رقمية موقعة منها تثبت هذه الهوية. يعتمد أمان بروتوكولات مثل HTTPS على ثقة المتصفحات بقائمة سلطات الشهادات المعتبرة؛ فإذا كانت الشهادة صادرة عن سلطة موثوقة، يعتبر الاتصال آمنًا.

131. رمز الأمان (Security Token)

جهاز مادي أو رمز رقمي يستخدم كعامل مصادقة إضافي. قد يكون رمز الأمان جهاز بحجم ميدالية يصدر رموزًا مؤقتة (مثل RSA Token)، أو تطبيق هاتف يولد رموز تحقق ثنائية العامل، أو حتى بطاقة ذكية. يضيف رمز الأمان طبقة أخرى من الحماية تتطلب شيئًا يمتلكه المستخدم بالإضافة إلى شيء يعرفه (كلمة المرور)، مما يصعّب على المهاجمين انتحال هوية المستخدم.

132. البصمة الرقمية (Digital Footprint)

مجموعة الآثار والبيانات التي يخلّفها الأفراد أو المنظمات أثناء استخدامهم للتقنيات الرقمية. يشمل ذلك أنشطة على الإنترنت (منشورات، تعليقات، سجل التصفح)،

ومعلومات قد يتم كشفها عنهم (مواقع تواجد، عادات شراء). يمكن أن تُستغل البصمة الرقمية من قبل المهاجمين لجمع معلومات عن الهدف خلال مرحلة الاستطلاع، لذا من المهم الانتباه لما نشاركه علنًا ووضع إعدادات الخصوصية الملائمة.

133. التنزيل العابر (Drive-by Download)

مصطلح يصف تحميل برمجيات خبيثة تلقائيًا على جهاز الضحية عند زيارة موقع ويب مصاب دون أن يلاحظ ذلك أو يقوم بأي إجراء. قد يستغل الموقع المصاب ثغرات في متصفح المستخدم أو مكوناته الإضافية لتنزيل وتشغيل التعليمات الخبيثة. لتجنب التنزيل العابر، يُنصح بتحديث المتصفح باستمرار واستخدام إضافات مانعة للسكربتات أو المحتوى غير الموثوق.

134. الإعلان الخبيث (Malvertising)

دمج برمجيات أو روابط خبيثة ضمن إعلانات تظهر على مواقع ويب شرعية. قد يستغل المهاجم شبكات الإعلان لعرض إعلانات تحوي شفرات ضارة؛ فعندما يشاهد المستخدم الإعلان أو ينقر عليه، يتم إعادة توجيهه لموقع خبيث أو يتم محاولة استغلال ثغرة في متصفحه. تكمن خطورة الإعلان الخبيث في أنه قد يظهر على مواقع موثوقة دون علم أصحابها، مما يتطلب فحص أمني للإعلانات أو استخدام إضافات حجب الإعلانات للوقاية.

135. تقوية النظام (System Hardening)

مجموعة ممارسات تهدف إلى تعزيز أمن الأنظمة عبر تقليل نقاط الضعف فيها. تشمل هذه الممارسات إزالة أو تعطيل الخدمات والبرامج غير الضرورية، وتطبيق التحديثات الأمنية بانتظام، وضبط إعدادات الأمان بشكل صارم (كسياسات كلمات

المرور وجدار الحماية)، وتقييد منافذ الاتصال المفتوحة. بتقوية النظام، نقلل الفرص المتاحة للمهاجمين لاستغلال الثغرات أو الإعدادات الضعيفة.

136. خادم القيادة والسيطرة (Command and Control Server)

خادم يتحكم عبره المهاجم في الأجهزة المخترَقة ضمن شبكة الروبوتات أو الهجمات المتقدمة. بعد إصابة جهاز الضحية، يقوم البرنامج الخبيث بالاتصال بخادم القيادة والتحكم لانتظار الأوامر أو إرسال بيانات مسروقة. يشكّل هذا الخادم مركز إدارة للهجوم، ويمكن عبره إصدار تعليمات جماعية (مثل بدء هجوم DDoS أو تنزيل حمولة إضافية). مراقبة الاتصالات إلى هذه الخوادم تساعد على كشف وجود إصابات داخل الشبكة.

137. تقنية المعلومات الظلّية (Shadow IT)

مصطلح يصف استخدام الموظفين لتطبيقات أو خدمات تقنية معلومات داخل بيئة العمل دون علم أو موافقة قسم تقنية المعلومات الرسمي. قد تشمل أمثلة Shadow IT استعمال موظفين لخدمات سحابية شخصية لتخزين ملفات العمل أو استخدام تطبيقات ويب غير معتمدة لتبادل المعلومات. بالرغم من أن الهدف قد يكون زيادة الإنتاجية، إلا أن هذه الممارسات تعرض البيانات لمخاطر أمنية بسبب غياب الإشراف الأمني عليها.

138. الحمولة الخبيثة (Malicious Payload)

الجزء الضار من الهجوم أو البرمجية الخبيثة الذي ينفذ الضرر الفعلي. قد تكون الحمولة الخبيثة برمجية تُسرق بيانات أو تشفّر ملفات أو تفتح بابًا خلفيًا. في هجمة قد يستخدم المهاجم عدة مراحل؛ البداية تكون عبر استغلال ثغرة لإسقاط حمولة خبيثة على النظام. لذا، يهدف كثير من حلول الأمن إلى كشف ومنع الحمولة قبل أن تعمل - مثلاً عبر فحص المرفقات في البريد أو تحليل البرامج في صندوق الرمل.

139. اختراق البريد الإلكتروني للأعمال (BEC)

اختصار لـ Business Email Compromise، وهو نوع من الاحتيال الإلكتروني يستهدف الشركات عبر اختراق حسابات البريد أو انتحال عناوين بريد مسؤوليها. يستغل المهاجم ثقة الموظفين في المراسلات الداخلية ليطلب تحويل أموال أو كشف معلومات حساسة، متنكرًا بهوية مدير أو شريك. تسببت هجمات BEC في خسائر مالية فادحة عالميًا، لذا يجب تأكيد أي طلبات حساسة تصل عبر البريد بوسيلة تحقق ثانية.

140. التزييف العميق (Deepfake)

تقنية تعتمد على الذكاء الاصطناعي لإنشاء فيديوهات أو تسجيلات صوتية مزيفة تبدو واقعية جدًا، بحيث يصعب تمييزها عن الأصلية. يمكن استخدامها بشكل ضار لانتحال شخصية أفراد (مثل مسؤولين أو مشاهير) وقول أشياء لم يقولوها أو فعل أمور لم يفعلوها. تشكل التزييفات العميقة تهديدًا أمنيًا ومعلوماتيًا لأنها قد تُستغل في خداع الناس أو تشويه السمعة أو كجزء من حملات التصيد المتقدمة.

141. الأمن من خلال الغموض (Security through Obscurity)

مفهوم يقصد به الاعتماد على إخفاء تفاصيل النظام أو التعقيد لإبقاءه آمنًا، بدلًا من بناء دفاعات قوية فعلية. مثال: اعتقاد شركة أن نظامها آمن فقط لأن خصائصه الداخلية غير معروفة للغير. يُعتبر هذا المبدأ ضعيفًا كتوجه أمني؛ فبمجرد انكشاف تلك التفاصيل، يصبح النظام معرضًا للهجوم. لذلك ينصح الخبراء بعدم جعل "الغموض" هو خط الدفاع الوحيد، بل يجب تعزيز الأمن عبر وسائل فعلية (كتشفير البيانات، وتحصين الأنظمة).

142. تمرير التجزئة (Pass the Hash)

هجوم على أنظمة المصادقة يعتمد على استخدام القيمة المُجتزأة (Hash) لكلمة المرور بدلاً من الحاجة لكلمة المرور نفسها. إذا تمكن المهاجم من الحصول على تجزئة كلمة مرور أحد الحسابات (من ذاكرة النظام أو قاعدة بيانات كلمات المرور)، يمكنه تمرير هذه التجزئة إلى نظام المصادقة لتسجيل الدخول دون فك تشفيرها. يستهدف هذا الهجوم بشكل خاص بروتوكولات المصادقة في الأنظمة، ويمكن من خلاله اكتساب امتيازات عالية في الشبكة إن لم تكن الحماية قوية (مثل استخدام تجزئات معززة بأملاح وجلسات قصيرة الأمد).

143. البرمجيات الخبيثة متعددة الأشكال (Polymorphic Malware)

برمجيات خبيثة قادرة على تغيير شفرتها أو سماتها مع كل إصابة أو انتشار، بهدف تجنب كشفها من قبل برامج الحماية. يقوم هذا النوع من البرمجيات بإعادة تشفير نفسه أو تعديل غيره من التفاصيل دون تغيير وظيفته الخبيثة. نتيجة لذلك، يصعب على أنظمة مكافحة الفيروسات التي تعتمد على بصمات ثابتة كشفها، إذ تبدو كل نسخة مختلفة. لمواجهة هذه التهديدات، تُستخدم تقنيات كشف سلوكية أو تحليلية أكثر تقدمًا.

144. البرمجيات الخبيثة عديمة الملفات (Fileless Malware)

هجوم أو برمجية خبيثة تعمل في ذاكرة الجهاز (RAM) دون أن تترك ملفات واضحة على القرص الصلب. يستغل هذا الأسلوب أدوات نظام موثوقة أو سجلات الذاكرة لتنفيذ المهام الخبيثة، مما يصعّب اكتشافه لأن برامج الحماية التقليدية تركز على فحص الملفات. نظرًا لعدم وجود ملف ثابت، يختفي أثر البرمجية الخبيثة العديمة الملفات بعد إعادة تشغيل الجهاز، لكنها قد تكون حققت هدفها من سرقة معلومات أو فتح باب خلفي قبل ذلك.

145. كبير مسؤولي أمن المعلومات (CISO)

اختصار لـ Chief Information Security Officer، وهو منصب إداري رفيع المستوى مسؤول عن الاستراتيجية الأمنية للمؤسسة. يتولى الـ CISO وضع سياسات الأمن السيبراني وضمان تنفيذها، وإدارة فرق الأمن، والتأكد من امتثال الشركة للمعايير واللوائح ذات الصلة بالأمن. كما يمثل المستشار الرئيسي للإدارة التنفيذية فيما يخص مخاطر الأمن السيبراني وسبل التعامل معها.

146. التعدين الخفي (Cryptojacking)

استغلال قدرات أجهزة الحاسوب الخاصة بالضحايا لتعدين العملات الرقمية بشكل غير مشروع ودون علمهم. تتم الإصابة عادةً عبر برمجيات خبيثة أو سكريبتات في مواقع ويب، حيث يبدأ الجهاز المصاب في حل خوارزميات التعدين لصالح المهاجم. يؤدي التعدين الخفي إلى إبطاء الجهاز المستهدف واستهلاك موارده (كالمعالج والكهرباء)، بينما يجني المهاجم أرباح العملات المُعدَّنة. ينصح باستخدام برامج الحماية وإضافات المتصفح التي تكشف سكريبتات التعدين لمنع هذا النوع من الاستغلال.

147. النسخ الاحتياطي (Backup)

العملية الدورية لإنشاء نسخ من البيانات وحفظها في موقع آمن لاستخدامها في حالة فقدان البيانات الأصلية أو تلفها. يُعد النسخ الاحتياطي من أهم إجراءات التعافي من الكوارث وهجمات الفدية؛ إذ يمكن استعادة الملفات والأنظمة من النسخ الاحتياطية بدلًا من الرضوخ لابتزاز المهاجمين. يجب أن تكون النسخ الاحتياطية منتظمة ومتعددة المواقع (محلية وعلى التخزين السحابي مثلاً)، مع اختبار دوري لعملية الاستعادة لضمان جاهزيتها عند الحاجة.

148. التعافي من الكوارث (Disaster Recovery)

مجموعة خطط وإجراءات مُعدّة مسبقًا لاستعادة العمليات والخدمات التقنية بعد تعرضها لكارثة أو أزمة (سواء كانت سيبرانية كالهجمات، أو طبيعية كالفيضانات). يشمل التعافي من الكوارث تحديد المواقع البديلة لتشغيل الأنظمة، وترتيب أولوية استعادة الخدمات الحيوية, وضمان توفر النسخ الاحتياطية اللازمة. الهدف هو تقليل زمن التوقف والخسائر، وضمان استمرار الأعمال بأسرع وقت ممكن بعد الحادث الكبير.

149. المصيدة الإلكترونية (Honeypot)

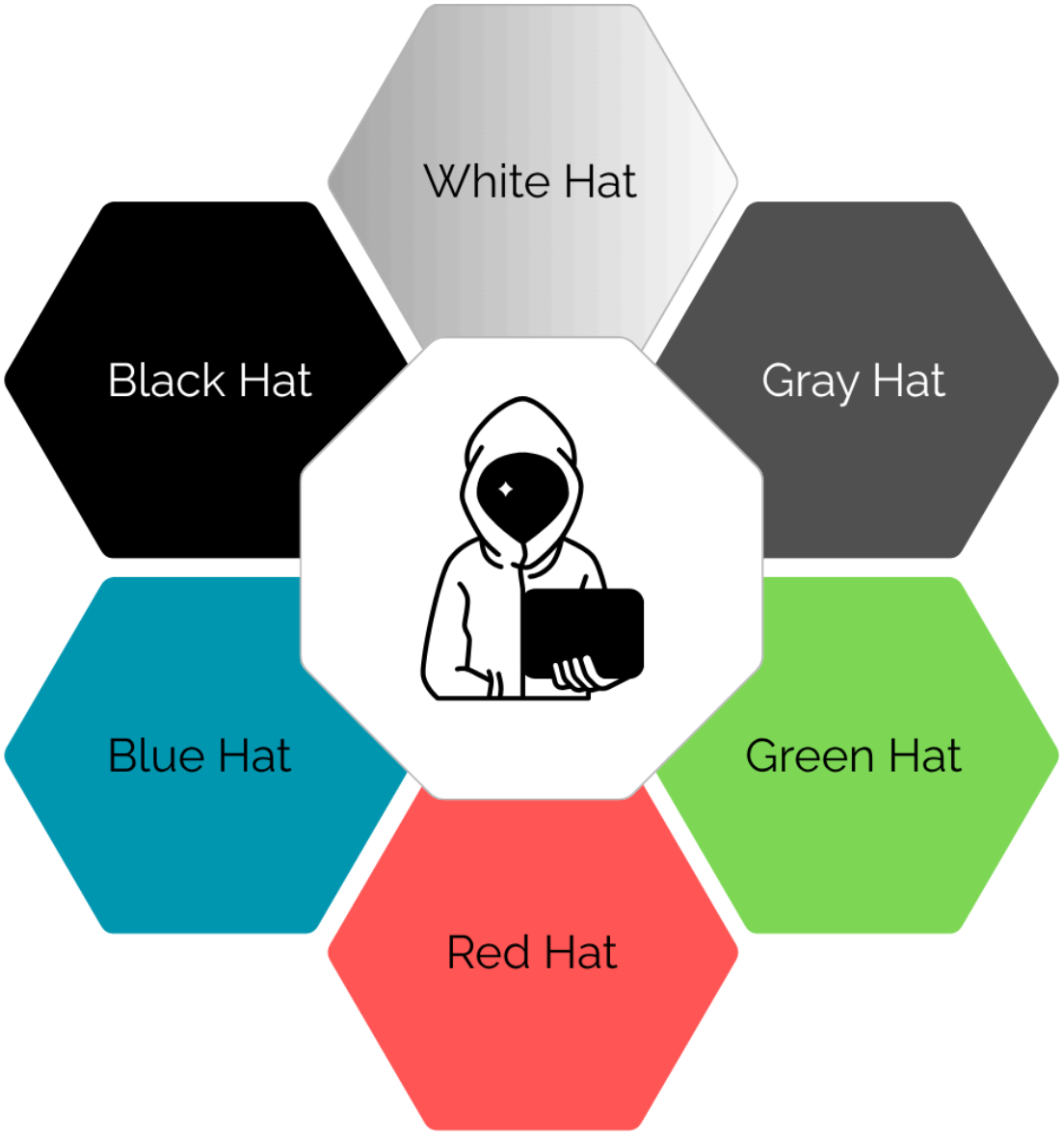
نظام أو خادم وهمي مُصمم لجذب المتسللين ومراقبة أنشطتهم. يتم إعداد المصيدة الإلكترونية لتبدو وكأنها هدف جذاب (مثل خادم يحتوي بيانات مهمة) لكنها في الواقع معزولة وتخضع للمراقبة. عند محاولة المهاجم اختراقها، يتم تسجيل تحركاته وتحليلها لمعرفة أساليبه، مما يساعد فرق الأمن على تعزيز الدفاعات في الأنظمة الحقيقية. كما تساهم honeypots في تشتيت انتباه المهاجم وإضاعة وقته بعيدًا عن الأصول القيمة.

150. هجوم تبديل بطاقة SIM (SIM Swapping)

أسلوب احتيالي يستولي فيه المهاجم على رقم هاتف الضحية بتحويله إلى شريحة SIM جديدة يمتلكها. يتم ذلك عادة عبر خداع موظف شركة الاتصالات بإثباتات مزيفة لإقناعهم بإجراء عملية استبدال الشريحة. بمجرد انتقال الرقم، يستقبل المهاجم الرسائل والمكالمات الموجهة للضحية، بما في ذلك رموز التحقق الثنائية. يتيح ذلك للمهاجم تجاوز حماية الحسابات المصادقة عبر الرسائل النصية والوصول إلى حسابات البريد الإلكتروني أو البنوك المرتبطة برقم الهاتف. للوقاية، توصي شركات

الاتصال بوضع رقم تعريف شخصي (PIN) لحماية عمليات تبديل الشريحة.

أنواع الهاكرز وخطوات الاختراق



عند سماع كلمة **"هاكر"** يتخيل الكثيرون مجرمًا إلكترونيًا يتسلل إلى الأنظمة بقصد سرقة المعلومات أو تخريبها. هذا التصور الشائع **لا يعكس الصورة الكاملة**

لمفهوم القرصنة؛ فالهاكر هو في الأساس شخص ذو **مهارات تقنية عالية** يستطيع استكشاف أنظمة الحاسوب والشبكات بطريقة غير تقليدية. في مجال الأمن السيبراني، يلعب الهاكرز دورًا مزدوجًا: فبعضهم يمثل **تهديدًا خطيرًا** عبر الهجمات الإلكترونية الخبيثة، بينما يساهم البعض الآخر في **تعزيز الحماية** من خلال العثور على الثغرات وإصلاحها. مع تزايد اعتمادنا على التقنيات الرقمية واتساع مساحة العالم الإلكتروني، أصبحت **الهجمات السيبرانية أكثر تكرارًا وتعقيدًا**. لذلك فإن فهم أنواع الهاكرز المختلفة وأساليبهم، بالإضافة إلى إدراك خطوات الاختراق التي يتبعونها، يعد أمرًا بالغ الأهمية **لحماية بياناتنا وأنظمتنا** ولرفع الوعي لدى المبتدئين والمحترفين على حد سواء.

أنواع الهاكرز

شكل توضيحي لأنواع الهاكرز حسب ألوان القبعات المختلفة.
لا يكون جميع الهاكرز بنفس النوايا أو الأساليب؛ لذا قام خبراء الأمن السيبراني بتصنيف القراصنة إلى فئات يُشار إليها عادةً بـ **"قبعات" ملونة** كرمز لنواياهم وأفعالهم. كل **قبعة** تمثل نوعًا معينًا من الهاكرز: القبعة البيضاء للأخلاقيين "الطيبون"، والسوداء للمجرمين "الأشرار"، وبينهما الرمادية. هناك أيضًا قبعات أخرى أقل شهرة كالحمراء والزرقاء والخضراء، تميز أدوارًا خاصة في عالم الاختراق. فيما يلي نظرة تفصيلية على **ستة أنواع من الهاكرز** وفق هذا التصنيف، مع شرح مختصر لكل نوع على حدة:

الهاكر ذو القبعة البيضاء (White Hat)

يُمثل **"القبعة البيضاء"** الهاكر الأخلاقي الذي **يسخر مهاراته لحماية الأنظمة** بدلًا من مهاجمتها. يعمل هؤلاء عادةً كخبراء أمن معلومات أو مختبري اختراق معتمدين، وتستعين بهم الشركات والحكومات بشكل قانوني بهدف **اختبار دفاعاتها الإلكترونية**. يقوم هاكر القبعة البيضاء بمحاولة اختراق أنظمة المؤسسة بشكل آمن

وتحت إذن مسبق، حتى يتمكن من **اكتشاف الثغرات** ومعالجتها قبل أن يستغلها المجرمون. باختصار، أصحاب القبعات البيضاء هم **الأبطال في عالم الأمن السيبراني**؛ إذ يستخدمون معرفتهم التقنية الواسعة **للدفاع** عن الشبكات والبيانات، وهم ملتزمون بالقانون ويمتثلون للمعايير الأخلاقية في كل ما يفعلونه.

الهاكر ذو القبعة الرمادية (Grey Hat)

يقع **"القبعة الرمادية"** في منطقة وسطى بين الأخلاقي وغير الأخلاقي. لا يسعى هاكر القبعة الرمادية عادةً للإضرار بالضحايا أو سرقة الأموال، ولكنه قد يقوم باختراق الأنظمة **دون تصريح** بدافع الفضول أو **تحسين مهاراته التقنية**. مثلًا قد يعثر على ثغرة في موقع أو شبكة دون إذن المالك، ثم يُبلغ عنها لاحقًا أو يعرض إصلاحها مقابل مكافأة. تختلف نوايا وأساليب هؤلاء عن القبعات البيضاء؛ فهم لا يلتزمون تمامًا بالقوانين (بسبب الاختراق غير المصرح به)، ولكن نادرًا ما تكون نواياهم خبيثة كحال القبعات السوداء. **بشكل مبسط:** الهاكر الرمادي قد **يكسر القواعد** دون نية إجرامية صريحة، وغالبًا ما يهدف إلى **لفت الانتباه** إلى الثغرات أو الحصول على التقدير لمهاراته، مما يضعه أخلاقيًا في منطقة رمادية.

الهاكر ذو القبعة السوداء (Black Hat)

تشير **"القبعة السوداء"** إلى الهاكر الإجرامي الذي **يخترق الأنظمة بشكل غير قانوني** لتحقيق أهداف خبيثة. يعتبر هؤلاء القراصنة مصدر التهديد الأساسي في الأمن السيبراني، فهم يستغلون أي ثغرة أمنية أو خطأ تقني من أجل **سرقة المعلومات الحساسة** (مثل البيانات المالية والشخصية)، أو **تعطيل الخدمات** والأنظمة، أو **الابتزاز وطلب الفدية** مقابل فك التشفير عن البيانات (كما يحدث في هجمات برامج الفدية). دوافع قراصنة القبعة السوداء غالبًا ما تكون **الربح المالي** من خلال بيع البيانات أو الاحتيال الإلكتروني، أو بدافع التحدي والتخريب. يستخدمون أدوات وتقنيات متقدمة (كإرسال برمجيات خبيثة، وهجمات التصيّد الاحتيالي، واستغلال الثغرات

التقنية) للوصول غير المصرح به إلى الشبكات. باختصار، القبعة السوداء هم **"الأشرار"** في عالم الهاكرز، ويعمل خبراء الأمن باستمرار على **رصد تحركاتهم وصد هجماتهم** لحماية الأفراد والمؤسسات من شرورهم.

الهاكر ذو القبعة الزرقاء (Blue Hat)

يمكن أن يندرج **"القبعة الزرقاء"** تحت مفهومين مختلفين تمامًا في عالم القرصنة:
الأول: شخص هاكر يفتقر للخبرة العالية ولكنّه يقوم بالاختراق بدافع **الانتقام الشخصي**. هذا النوع من القبعات الزرقاء **لا يهتم بجني المال أو الشهرة** بقدر ما يهمه الردّ على جهة أو شخص أساء إليه. على سبيل المثال قد يكون موظفًا ساخطًا يقوم باختراق نظام شركته السابقة لتصفية حسابات. عادةً تكون هجماته **محدودة الهدف والزمن**؛ أي يهاجم هدفًا محددًا مرة واحدة ثم يتوقف، على عكس القبعة السوداء الذي يستمر في الهجوم لتحقيق مكاسب متواصلة.
الثاني: خبير أمن مستقل **من خارج المنظمة** تستعين به الشركات لاختبار منتجات أو أنظمة جديدة قبل إطلاقها. في هذا السياق، يُدعى الهاكر ذو القبعة الزرقاء إلى **محاكاة الهجمات** على النظام ضمن بيئة مسيطر عليها **دون إلحاق ضرر فعلي**.
العديد من الشركات التقنية الكبيرة تنظم فعاليات خاصة تسمح لهؤلاء المتخصصين بفحص الأنظمة بحثًا عن الثغرات (وتُعرف بعض هذه الفعاليات باسم مؤتمرات Blue Hat). سواء كان القبعة الزرقاء منتقمًا فرديًا أو مختبر اختراق خارجي، فإن **قاسمهم المشترك** هو أنهم **لا يسعون للربح غير المشروع** على المدى الطويل؛ إما يكتفون بهجمة انتقامية عابرة أو يلتزمون بحدود المهمة الموكلة إليهم من قبل جهة رسمية.

الهاكر ذو القبعة الخضراء (Green Hat)

"القبعة الخضراء" هو **الهاكر المبتدئ** في مجتمع القرصنة. يملك هؤلاء الفضول والشغف لتعلم فنون الاختراق، لكنهم **لا يمتلكون بعدُ الخبرة الكافية** أو المعرفة التقنية العميقة. غالبًا ما ينضم المخترق ذو القبعة الخضراء إلى منتديات القرصنة

ويتابع خبراء أكثر تمرسًا سعيًا لاكتساب المهارات. قد يقوم بتجربة أدوات اختراق جاهزة أو تقليد هجمات معروفة على أهداف صغيرة أو ضعيفة، فقط لكي يثبت نفسه ويتعلم من التجربة. النية لدى القبعات الخضراء **ليست دائمًا خبيثة** بحد ذاتها، فهم أشبه بـ"متدربين" يطمحون إلى الوصول لمستوى أعلى في مجتمع الهاكرز. ومع ذلك، يمكن أن يشكلوا **خطرًا محتملًا** نظرًا لقلة معرفتهم؛ فقد يتسببون بأضرار غير مقصودة أثناء تطبيق ما تعلموه. لذا ينظر إليهم كفئة **تشق طريقها نحو الاحتراف**: إن وجدوا التوجيه والأخلاق ربما يصبحون خبراء أمن إيجابيين، أما إن انساقوا وراء الإجرام فقد يتحولون إلى قبعة سوداء جديدة مع الوقت.

الهاكر ذو القبعة الحمراء (Red Hat)

يُمثل **"القبعة الحمراء"** نوعًا فريدًا من الهاكرز يُمكن وصفه بـ **"حارس الإنترنت"** أو المنتقم للأخيار. أصحاب القبعات الحمراء هم **هاكرز vigilantes** أي أنهم يأخذون العدالة السيبرانية بأيديهم ويستهدفون مجرمي الإنترنت (القبعات السوداء) أنفسهم. عندما يحدد هاكر قبعة حمراء مصدر تهديد إلكتروني أو مجرم سيبراني، فإنه لا يكتفي بإبلاغ السلطات أو تأمين النظام المستهدف، بل **يشن هجومًا مضادًا شرسًا** على المهاجم. قد يقوم بتعطيل خوادم الهاكر الأسود، أو تدمير بياناته وأدواته، وحتى سرقة ما سرقه ذلك المجرم وإعادته لأصحابه. يتميز نهج القبعة الحمراء بأنه **هجومي وعدواني للغاية**، وغالبًا ما **يتجاوز الحدود القانونية** في سبيل معاقبة القراصنة الأشرار. ورغم أن دوافعهم نبيلة (حماية المجتمع من المجرمين)، فإنهم ليسوا قراصنة أخلاقيين تقليديين لأنهم **يخرقون القانون** خلال مطاردتهم للمجرمين. باختصار، القبعات الحمراء هم **منتقمون رقميون** يعملون بالخفاء؛ يستخدمون خبرتهم الكبيرة في الاختراق **لمطاردة المخترقين الآخرين** وتحييد خطرهم بشكل جذري، دون التساؤل كثيرًا عن الوسائل المستخدمة في ذلك.

خطوات الاختراق

بعد التعرف على أنواع المهاجمين الإلكترونيين، من المهم فهم **الخطوات والمراحل الأساسية** التي يتبعها المخترقون خلال عملية الاختراق. أي هجوم سيبراني ناجح عادةً ما يمر بسلسلة من المراحل المتتابعة، تمكن المهاجم في النهاية من تحقيق **هدفه الخبيث** إذا لم يوقفه المدافعون في مرحلة ما. أدناه نستعرض **أبرز مراحل الاختراق السبعة** كما يتبعها المخترقون عادةً، مع توضيح **ماهية كل مرحلة** وما الذي تعنيه **للمدافعين عن النظام** وكيف يمكنهم **التصدي لها**:

Reconnaissance (جمع المعلومات)

- **ما هي هذه المرحلة؟** هي مرحلة **استطلاع وتحضير أولية** يقوم فيها المهاجم بجمع أكبر قدر ممكن من المعلومات عن الهدف قبل تنفيذ الهجوم. يستخدم المخترق مصادر مفتوحة ومعلومات متاحة علنًا (مثل مواقع الويب، حسابات التواصل الاجتماعي، سجلات الدومين) وأحيانًا أدوات مسح متخصصة، وذلك بهدف **فهم بنية الهدف ونقاط الضعف المحتملة**. هذه الخطوة أشبه بعملية **تجسس رقمي مسبق** يتعرف فيها المهاجم على تفاصيل الضحية (كالبنية الشبكية، أنظمة التشغيل المستخدمة، الموظفين المهمين، إلخ) لتسهيل المراحل التالية.

- **لماذا تهم المدافعين؟** لأن **معرفة المهاجمين المسبقة** هي ما يسمح لهم بتخطيط هجوم فعال. كلما زادت المعلومات التي يحصل عليها المخترق عن أنظمتك وموظفيك، زادت قدرته على إيجاد مدخل ضعيف. بالنسبة لفرق الأمن السيبراني، تعتبر مرحلة الاستطلاع **جرس إنذار مبكر**؛ حيث إن كشف أي نشاط جمع معلومات غير اعتيادي حول مؤسستك قد يشير إلى محاولة اختراق وشيكة. بالإضافة إلى ذلك، فهم تقنيات الاستطلاع الشائعة يساعد المدافعين على **تحديد المعلومات الحساسة القابلة للعثور** بشكل علني واتخاذ إجراءات لإخفائها أو تأمينها.

- **كيف يمكن الحماية منها؟** أفضل وسيلة هي **تقليل أثر المعلومات المتاحة** عن أنظمتك قدر الإمكان. يجب على المؤسسات **تنظيم معلوماتها العامة**؛ مثل عدم كشف تفاصيل البنية التحتية على الإنترنت، وتوعية الموظفين بعدم مشاركة بيانات الشركة الحساسة على مواقع التواصل. يمكن إجراء **اختبارات OSINT داخلية** لمعرفة ما الذي يمكن للمهاجم جمعه عنك بسهولة ومن ثم تقليل تلك المصادر. أيضًا من المهم **مراقبة حركة الشبكة** واستخدام أنظمة كشف التسلل لرصد أي محاولات مسح أو استطلاع غير معتادة (مثل عدد كبير من الاستعلامات عن خوادم معينة أو محاولات للوصول إلى صفحات غير معلنة). بهذه الخطوات يمكن إحباط مرحلة الاستطلاع أو جعلها أقل فاعلية للمهاجم.

Scanning / Enumeration (الفحص والتعداد)

- **ما هي هذه المرحلة؟** بعد جمع المعلومات النظرية، ينتقل المهاجم إلى **الفحص الفني المباشر** للهدف. في مرحلة الفحص (Scanning) والتعداد (Enumeration) يقوم المخترق بإجراء **مسح للشبكة والأنظمة** بحثًا عن منافذ مفتوحة، خدمات فعّالة، وأنظمة تشغيل أو برامج قديمة تحتوي على ثغرات. يستخدم أدوات آلية مثل ماسحات المنافذ (على غرار Nmap) أو محللات الشبكة لتعداد الأجهزة والخدمات المتصلة بهدف **تحديد نقاط الدخول المحتملة**. قد يحاول أيضًا **استكشاف الحسابات** أو قائمة المستخدمين على النظام ونقاط الضعف المعروفة لكل خدمة. هذه المرحلة عملية أكثر وتتطلب اتصالًا تفاعليًا بالهدف، لذا تُعتبر جسرًا بين الاستطلاع النظري والاختراق العملي.

- **لماذا تهم المدافعين؟** لأن نتائج الفحص تحدد **مسار الاختراق** للمهاجم. إذا تمكن المهاجم من تحديد منفذ مفتوح لخدمة غير مؤمّنة أو اكتشف نظام

تشغيل غير مُحدَّث، فسيركز هجومه على تلك النقطة. بالنسبة للمدافعين، فإن **رصد محاولات المسح المبكرة** يمنح فرصة لإحباط الهجوم قبل وقوعه. كما أن فهم ما يمكن كشفه عبر التعداد يوجه فرق الأمن نحو **تقوية دفاعاتهم**؛ فمثلًا إذا كان بإمكان أي شخص من الإنترنت رؤية قائمة المستخدمين أو معرفة إصدار برنامج الخادم، فهذا ثغرة بحد ذاته يجب سدها. بالإضافة، يعتبر الفحص بمثابة **تنبيه**: حين يرصد فريق الأمن زيادة مفاجئة في **نشاط المسح الشبكي** أو كمية غير طبيعية من طلبات الوصول إلى خدمات معينة، فيجب التعامل معها بجدية كعلامة على أن هناك من يجمع معلومات استعدادًا للاختراق.

- **كيف يمكن الحماية منها؟** عن طريق **تحصين الأنظمة وتقليل فرص الاكتشاف**. أولًا، تطبيق مبدأ **"اقل قدر ممكن من الخدمات"**: أي إغلاق المنافذ والخدمات غير الضرورية بحيث تقل الأشياء التي يمكن للمهاجم فحصها. ثانيًا، استخدام **جدران الحماية** وأنظمة كشف التسلل/منع الاختراق لصد أو مراقبة حزم المسح الشبكي (مثل رفض حركة المرور التي تشبه مسح المنافذ). ثالثًا، **إخفاء لافتات النظام** قدر الإمكان؛ فمثلًا تعطيل الرسائل التي تكشف إصدارات البرمجيات، واستخدام تقنيات مثل **TCP/IP Stack Obfuscation** لجعل نتائج المسح أقل دقة. أخيرًا، القيام بفحوصات دورية **بنفسك** (اختبارات اختراق داخلية) لتعرف ما هي المنافذ أو المعلومات التي يظهرها نظامك للمسح الخارجي، وبالتالي معالجة أي مشكلة قبل أن يجدها المهاجم.

Gaining Access (الوصول المبدئي)

- **ما هي هذه المرحلة؟** هي لحظة **اختراق النظام فعليًا**؛ حيث يستغل المهاجم كل ما جمعه سابقًا لاقتحام الهدف والحصول على **وصول أولي غير مصرح به**.

قد يتم ذلك عبر استغلال ثغرة برمجية (كتنفيذ تعليمات برمجية عن بُعد بسبب خطأ أمني)، أو عبر هجوم **التصيد الاحتيالي** لخداع مستخدم وإدخال برمجية خبيثة، أو باستخدام كلمات مرور تم تسريبها للوصول إلى حسابات مهمة. الهدف في هذه المرحلة هو **فتح ثغرة** في جدار دفاعات الضحية تكفي لدخول المهاجم إلى النظام أو الشبكة المستهدفة. نجاح المهاجم في مرحلة الوصول المبدئي يعني أنه أصبح داخل بيئة الضحية بشكل ما (مثلاً تحكّم بجهاز أو حساب مستخدم).

- **لماذا تهم المدافعين؟** لأنها **المرحلة الحاسمة** التي يبدأ عندها الضرر الحقيقي. منع المهاجم من الوصول المبدئي هو نصف الانتصار في المعركة؛ فإذا تم إيقافه قبل الدخول لن ينجح في بقية المراحل. لذا يركز المدافعون غالبًا معظم جهودهم الوقائية على **منع حدوث الاختراق** من الأصل (سواء عبر تأمين الثغرات التقنية أو توعية المستخدمين ضد الخدع الهندسية الاجتماعية). بالإضافة، عند حصول اختراق أولي فإن سرعة اكتشافه **حرجة للغاية**؛ كلما طالت فترة بقاء المهاجم داخل النظام دون علم المدافعين، ازداد الضرر المحتمل. لهذه المرحلة أيضًا أهمية قانونية وتنظيمية؛ ففي حال حدوث اختراق، يجب على فرق الأمن والإدارة **تفعيل خطط الاستجابة للطوارئ** فور تأكدهم من وصول غير مشروع.

- **كيف يمكن الحماية منها؟** عن طريق **تقوية خط الدفاع الأول** بكل السبل. تقنيًا، يجب **تحديث الأنظمة والبرامج باستمرار** لسد الثغرات المعروفة قبل أن يستغلها المهاجمون، وتطبيق سياسات أمنية صارمة (مثل عدم استخدام كلمات مرور ضعيفة أو مكررة، وتفعيل المصادقة متعددة العوامل لمنع الدخول غير المصرح حتى لو سُرقت كلمة المرور). كما ينبغي نشر حلول **الحماية الطرفية** (كأنظمة الكشف عن الاختراق على الأجهزة والخوادم EDR/IDS) لرصد أي نشاط مشبوه أو برمجيات خبيثة فور حدوثها. من جهة

أخرى، تدريب العاملين على **أساليب التصيّد والهندسة الاجتماعية** سيساهم في منع المهاجم من استغلال **العنصر البشري** كمدخل. وأخيرًا، **وضع خطط استجابة** جاهزة (Incident Response) يُمكّن الفريق الأمني من التحرك السريع والعزل الفوري لأي جهاز يتم اختراقه لمنع المهاجم من التوسع داخل الشبكة.

Privilege Escalation & Internal Recon (تصعيد الصلاحيات واستكشاف داخلي)

- **ما هي هذه المرحلة؟** بعد أن يضع المهاجم قدمه داخل النظام في الوصول المبدئي، يسعى عادةً إلى **تعزيز موطئ قدمه**. يتم ذلك عبر شقين متوازيين: أولًا **تصعيد الصلاحيات** (Privilege Escalation) أي محاولة الحصول على صلاحيات أعلى (مثل التحول من مستخدم عادي إلى مدير نظام "Administrator" أو "Root"). ثانيًا **الاستكشاف الداخلي** للشبكة المخترَقة (Internal Reconnaissance)، حيث يبدأ المهاجم **بجمع معلومات تفصيلية** من داخل بيئة الضحية نفسها. قد يبحث عن حسابات أخرى ذات امتيازات أكبر، أو يفتش عن ملفات إعداد تحتوي على كلمات مرور مخزنة، أو يستكشف الأجهزة الأخرى المتصلة بالشبكة الداخلية لتحضير التحرك التالي. هذه المرحلة تجعل المهاجم ينتقل من مجرد متسلل محدود الإمكانات إلى **متحكم خطير** لديه فهم أعمق لنظام الضحية.

- **لماذا تهم المدافعين؟** لأن تصعيد الصلاحيات يعني **تضاعف خطر المهاجم**. إذا تمكن المخترق من ترقية امتيازاته ليصبح Admin، فسيفتح ذلك أمامه أبوابًا واسعة للوصول إلى كل شيء تقريبًا (ملفات حساسة، إعدادات أمان، حسابات مستخدمين آخرين). بالمثل، الاستكشاف الداخلي يمنحه معرفة **خارطة الشبكة الداخلية** وأين تقع الأصول القيمة، ما يمكنه من توجيه ضرباته بدقة أكبر. بالنسبة لفرق الأمن، هذه المرحلة بالغة الأهمية لرصدها؛ فظهور تصرفات مثل **محاولة مستخدم عادي تنفيذ أوامر إدارية**، أو استخدام أدوات مسح

داخلية من جهاز يفترض أنه مستخدم عادي، هي **مؤشرات اختراق** (Indicators of Compromise) ينبغي ألا تُهمل. بالإضافة، إن استطاع الفريق الأمني منع التصعيد والتحرك الجانبي، يمكن **احتواء الهجوم في نطاق ضيق** حتى لو تمكن المهاجم من الدخول المبدئي.

- **كيف يمكن الحماية منها؟** يكون ذلك عبر **تقليل فرص التصعيد ورصد التحركات الداخلية**. أولًا، يجب الالتزام الصارم بمبدأ **"الأقل صلاحية"** (Least Privilege): أي إعطاء كل مستخدم أو خدمة الحد الأدنى من الصلاحيات التي يحتاجها فقط، بحيث لو اخترق حساب ما فلا يمتلك تلقائيًا مفاتيح السيطرة الكاملة. ثانيًا، **تحديث الأنظمة** ومعالجة أي ثغرات تمكن من تصعيد الامتيازات (فهناك ثغرات معروفة تمكن من التحول إلى مسؤول النظام إذا لم يتم ترقيعها). ثالثًا، استخدام حلول **مراقبة السلوك** و**إدارة سجلات الدخول** لكشف أي نشاط غير اعتيادي داخل الشبكة؛ كأن يقوم حساب موظف بمحاولة الوصول إلى ملفات أو أنظمة لا يفترض به الوصول إليها. يمكن أيضًا الاستعانة بـ**الشبكات المقسمة والفصل بين الصلاحيات**، فمثلًا حساب مسؤول النطاق Domain Admin لا يُستخدم إلا على أجهزة محددة ومحمية. وأخيرًا، **الأدوات التحليلية للتهديدات** (مثل SIEM و UEBA) تساعد على ربط الأحداث وتوليد تنبيهات إذا ما بدأت تظهر أنماط تدل على استكشاف داخلي من قبل جهة مخترقة.

Maintaining Access (الحفاظ على الوصول)

- **ما هي هذه المرحلة؟** بعدما ينجح المهاجم في الاختراق والوصول لعمق النظام، سيحاول غالبًا **البقاء لأطول فترة ممكنة** لتحقيق أهدافه بالكامل. مرحلة الحفاظ على الوصول تعني أن المخترق يسعى لتثبيت **أبواب خلفية** (Backdoors) أو وسائل تحكّم مستمر تمكنه من الدخول ثانيةً حتى إن تم إصلاح

الخلل الذي استغله أول مرة. قد يقوم بإنشاء **مستخدم مخفي** جديد بصلاحيات عالية، أو يثبت برنامجًا خبيثًا مقيمًا كنظام تحكم عن بعد (RAT)، أو يزرع **برمجية خادم خفية** (مثل Web Shell على خادم الويب) تتيح له الرجوع متى شاء. الهدف هو ضمان أن الاختراق **لا يكون مجرد حادثة عابرة**، بل foothold مستمر يستطيع المهاجم استخدامه بدون الحاجة لإعادة الاختراق من الصفر في كل مرة.

- **لماذا تهم المدافعين؟** لأن وجود باب خلفي يعني أن **الخطر يستمر** حتى بعد ظاهر الاختراق الأولي. قد تظن منظمة ما أنها عالجت مشكلة اختراق بإصلاح ثغرة أو تغيير كلمات مرور تم تسريبها، لكن إن كان المهاجم قد ترك منفذًا سريًا له في النظام، فسيعود متى أراد **بلا جهد إضافي** وربما بشكل أكثر خفاءً. الحفاظ على الوصول يمكن المهاجم من **تنفيذ هجمات طويلة الأمد**، مثل التجسس المستمر أو سرقة البيانات على دفعات صغيرة لتفادي الانتباه. كما يصعّب على المحققين عملية القضاء على التهديد، لأن عليهم **البحث عن كل برمجية خبيثة مخفية أو حساب مريب** زرعه المخترق. بالنسبة للمدافعين، هذه المرحلة تعني أنه حتى لو تم صدّ الهجوم الأساسي، قد يظل العدو موجودًا في الداخل إن لم يُكشف الباب الخلفي. وبالتالي، يتوجب على فرق الأمن التعامل بحذر شديد بعد أي حادثة اختراق والتأكد من **تنظيف النظام بالكامل** لمنع المهاجم من العودة.

- **كيف يمكن الحماية منها؟** عبر **كشف وإزالة وسائل البقاء** التي يزرعها المهاجم. يتطلب ذلك إجراء **تحقق أمني معمّق** بعد أي اختراق مشتبه به: فحص الأنظمة بحثًا عن حسابات مستخدمين أو خدمات جديدة **غير معروفة**، مراجعة المهام المجدولة وملفات التشغيل التلقائي للتأكد من عدم إضافة شيء مشبوه، والتدقيق في إعدادات النظام (مثل تفقد سجلات الريجستري في ويندوز أو كرون في لينكس). استخدام برامج **مكافحة البرمجيات الخبيثة**

المتقدمة وحلول EDR يمكن أن يساعد في التعرف على أدوات التحكم عن بعد وأبواب خلفية شائعة وإزالتها. كذلك ينبغي **إعادة تعيين كلمات المرور لجميع الحسابات الحساسة** وربما **إعادة بناء الخوادم المخترَقة** من نقطة الصفر إذا لزم الأمر لضمان نظافتها. بالإضافة إلى ذلك، **المراقبة المستمرة** للشبكة خلال الأسابيع التالية للحادثة ضرورية لرصد أي اتصال غير معتاد قد يشير إلى محاولة المهاجم استخدام وسيلة بقاء لم يتم كشفها. باختصار، التصدي لمرحلة الحفاظ على الوصول يتطلب **يقظة وتحليلًا جنائيًا دقيقًا** للتأكد من أن المهاجم **لم يترك له أثراً نشطًا** داخل البنية التحتية.

Exfiltration / Impact (استخراج البيانات أو التسبب بالضرر)

- **ما هي هذه المرحلة؟** هي مرحلة **تحقيق الهدف النهائي** للمهاجم، وتمثل ذروة عملية الاختراق. بعد التوغل في النظام والتحكم به، سيقوم المهاجم إما بـ **استخراج البيانات الحساسة** (Exfiltration) وإخراجها بهدوء إلى خارج شبكة الضحية، أو سيقوم بتنفيذ **الأثر التخريبي أو الضار** الذي خطط له (Impact) مثل تشفير الملفات وطلب الفدية، أو تعطيل الأنظمة، أو حتى تدمير البيانات. قد يبدأ المهاجم بتحميل قواعد بيانات كاملة، أو نسخ مستندات مهمة إلى خوادمه الخاصة. وإن كان الهدف تخريبًا فقد يشرع في **مسح البيانات** أو زرع برمجيات تمحو المعلومات، وربما إطلاق برمجية **فدية (Ransomware)** تشفر كل ما يمكنها الوصول إليه. هذه المرحلة هي التي تُلحق بالضحية **الخسائر المباشرة** سواء مالية أو معنوية أو تشغيلية.

- **لماذا تهم المدافعين؟** لأنها **لحظة الحقيقة** التي يُختبر فيها نجاح الدفاع أو فشله. إذا وصل المهاجم لهذه المرحلة دون رادع، فهذا يعني أن كل الطبقات الدفاعية السابقة قد أخفقت، والآن المنظمة أمام **خطر ملموس وفوري**: إما

فقدان بيانات سرية (كالبيانات الشخصية للعملاء أو الخطط الاستراتيجية) مما يؤدي إلى أضرار مالية وسمعة سيئة، أو توقف خدمات حيوية قد يشل عمل الشركة. من منظور المدافع، هناك بُعدان مهمان هنا: الأول **الكشف في الوقت المناسب** - حيث لا يزال بالإمكان منع المهاجم من إكمال سرقة البيانات أو إحداث التلف إذا تم رصده عند بدايات هذه المرحلة (مثل ملاحظة حركة بيانات ضخمة خارجة من الشبكة فجأة). الثاني **الاستعداد للأسوأ** - أي وجود خطط طوارئ تحد من الأضرار عند وقوعها (مثل نسخ احتياطية تُستخدم عند هجوم فدية، أو خطة اتصالات لإبلاغ العملاء عن اختراق البيانات). عدم الاستعداد قد يجعل تأثير هذه المرحلة **كارثيًا واستعصاء التعافي منه**.

- **كيف يمكن الحماية منها؟** يتم ذلك عبر **منع المهاجم قدر الإمكان من إخراج أو تدمير ما يريده**، والتخفيف من العواقب إن حدث ذلك. أولًا، يجب تفعيل حلول **منع تسرب البيانات** (DLP) وأنظمة مراقبة حركة الشبكة لكشف أي محاولة غير مصرح بها **لنقل كميات كبيرة من البيانات** إلى خارج نطاق المؤسسة. يمكن أيضًا **تقسيم وتصنيف البيانات** بحيث تكون المعلومات الأكثر حساسية مخزنة في بيئات ذات قيود صارمة ولا يمكن الوصول إليها إلا بإجراءات تحقق إضافية، مما يصعّب على المهاجم سرقتها سريعًا. ثانيًا، **تشفير البيانات الهامة** سواء أثناء التخزين أو أثناء الإرسال يعني أنه حتى لو نجح المهاجم في الحصول على ملفات، ستبقى غير قابلة للقراءة من جانبه إذا لم يملك مفاتيح فك التشفير. ثالثًا، فيما يخص **التسبب بالضرر** مثل هجمات الفدية، فإن وجود **نسخ احتياطية دورية ومؤمّنة** للملفات والأنظمة يعد طوق النجاة؛ حيث تستطيع المؤسسة استعادة بياناتها دون دفع أموال للمبتزين. إلى جانب ذلك، يجب التأكد أن النسخ الاحتياطية نفسها **معزولة** عن الشبكة الرئيسية لمنع وصول المهاجم إليها وتشفيرها هي الأخرى. وأخيرًا، **خطط الاستجابة للأزمات** لابد أن تشمل هذه المرحلة: كأن يكون لدى المؤسسة

فريق متخصص بالتعامل مع حوادث الاختراق يقوم بسرعة باحتواء الأجهزة المتأثرة وفصلها، والتواصل مع الجهات القانونية والتنظيمية إن تطلب الأمر، وإبلاغ العملاء أو المستخدمين بصورة مدروسة للحد من الضرر على السمعة. كلما كانت الاستعدادات أقوى، أمكن **تقليل أثر** اختراق وصل لمرحلته النهائية.

Covering Tracks (إخفاء الآثار)

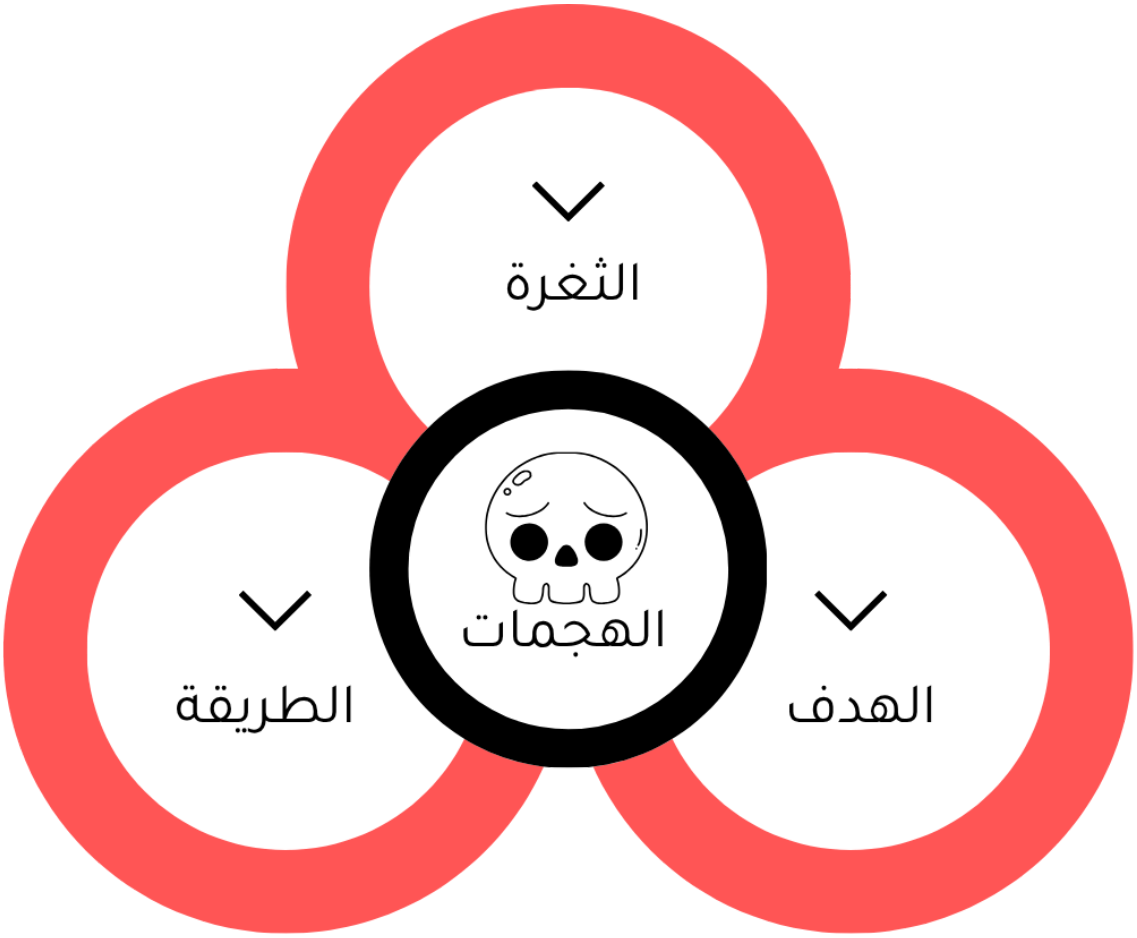
- **ما هي هذه المرحلة؟** هي **المرحلة الختامية** التي يعمل فيها المهاجم على إزالة أي دليل يمكن أن يكشف نشاطه. بعد تنفيذ الهجوم وتحقيق غايته، يحاول المخترق **طمس آثار الاختراق** حتى لا يتم اكتشاف وجوده أو تُتعقب هويته.🪞体 يقوم المهاجم بـ **مسح أو تعديل سجلات الأحداث (Logs)** في الأجهزة والخوادم التي تسلل عبرها، بحيث تختفي الأدلة التي تدين دخوله أو نشاطاته التخريبية. قد يستخدم تقنيات مثل **تزوير الطوابع الزمنية** للملفات (Timestomping) لتبدو كأنها لم تُمس، أو يحذف ملفات مؤقتة وبرامج استخدمها في الاختراق، أو يغير إعدادات النظام لتعطيل تسجيل الأحداث أثناء فترة نشاطه. الهدف من كل ذلك هو جعل عملية التحقيق الجنائي الرقمي **أصعب ما يمكن**، وإطالة أمد بقائه مجهولًا وربما موجودًا في النظام دون انتباه بعد انتهاء الهجوم الرئيسي.

- **لماذا تهم المدافعين؟** لأن إخفاء الآثار يعيق **عملية الاستجابة والتحقيق**. عندما لا يتمكن فريق الأمن من معرفة **كيف** حصل الاختراق أو **متى** ومن أي نقطة بدأ، يصبح من الصعب سد الثغرات ومنع تكرار الهجوم. كذلك إذا نجح المهاجم في إزالة أدلة وجوده، قد **يمكث في الشبكة مدة أطول** دون أن يُلاحظ، أو قد يعود مجددًا عبر أبواب خلفية تركها دون قدرة المحللين على تتبع خطواته. بالنسبة للمدافعين، تعتبر هذه المرحلة **تحديًا مضاعفًا**: عليهم محاولة كشف الاختراق والاستدلال على آثاره رغم محاولة العدو طمسها. كما تستدعي هذه

المرحلة التفكير المسبق في كيفية **تحصين سجلات النظام** ضد العبث. إذا فشل الفريق الأمني في الحصول على أدلة كافية بسبب إخفاء الآثار، فقد يؤدي ذلك إلى **فقدان الثقة** في النظام الأمني كله وصعوبة تقييم نطاق الضرر الحقيقي.

- **كيف يمكن الحماية منها؟** يصعب منع المهاجم من **محاولة** إخفاء آثاره، لكن يمكن جعل مهمته أصعب وزيادة فرص كشفه. من أهم الإجراءات اعتماد **سجلات مركزية محمية**: أي إرسال نسخ من سجلات الأحداث المهمة بشكل لحظي إلى خادم مركزي أو خدمة خارجية محصنة لا يمتلك المهاجم صلاحيات الوصول إليها. بذلك، حتى لو حذف السجلات على الجهاز المخترق، تبقى أدلة النشاط محفوظة خارجيًا. أيضًا ينبغي **تقييد الصلاحيات على ملفات السجل**؛ فالمستخدمون العاديون لا حاجة لهم للوصول إليها، وحتى الحسابات الإدارية يمكن ضبط سياسات تحد من قدرتها على حذف السجلات أو تعديلها. استخدام تقنيات **كشف العبث** (Tamper Detection) مفيد أيضًا، مثل وضع مراقبة على الملفات الحساسة بحيث يتم تنبيه فريق الأمن في حال تم تغيّر أو حذف بعضها. وأخيرًا، في حال وقوع حادثة، يجب تنفيذ **تحقيق جنائي رقمي شامل** بأدوات احترافية يمكنها استعادة أجزاء من السجلات المحذوفة أو الكشف عن نمط التلاعب. كما قد يلجأ المحققون إلى مصادر أدلة غير تقليدية (مثل سجلات أجهزة الشبكة كالجدران النارية أو أنظمة كشف التسلل، أو سجلات الخدمات السحابية) لتعويض أي نقص سببه المهاجم. بهذه الممارسات، يمكن **تقليل فعالية** مرحلة إخفاء الآثار وضمان الاحتفاظ **بصورة واضحة** لما حدث، مما يساعد على تحسين الدفاعات لاحقًا ومحاسبة المسؤولين إذا أمكن.

المخاطر والهجمات السيبرانية



مقدمة حول مفهوم الهجوم السيبراني

في عصرنا الرقمي الحالي، أصبح **الهجوم السيبراني** من أبرز التهديدات التي تواجه الأفراد والمؤسسات. يشير مصطلح الهجوم السيبراني إلى أي محاولة ضارة

تستهدف أنظمة الحاسوب أو الشبكات أو البيانات بقصد إلحاق ضرر أو الحصول على وصول غير مصرح به. يمكن أن تتراوح هذه الهجمات من اختراق بسيط لحساب شخصي إلى عمليات معقدة تهدف إلى تعطيل خدمات حيوية أو سرقة بيانات حساسة. عادة ما ينفذ هذه الهجمات مجرمو الإنترنت أو مجموعات قرصنة أو حتى جهات ترعاها دول، ويسعون من ورائها إلى تحقيق أهداف مختلفة مثل الربح المادي أو التخريب أو التجسس. تتميز الهجمات السيبرانية بتنوع **أساليبها** و**دوافعها**، مما يجعل فهم مكوناتها أساسيًا لبناء دفاعات إلكترونية فعّالة.

معادلة الهجوم السيبراني: الهدف + الطريقة + الثغرة

يمكن تفكيك أي هجوم سيبراني إلى ثلاثة عناصر رئيسية تمثل ما يُعرف بـ **معادلة الهجوم**: **الهجوم = الهدف (الدافع) + الطريقة + الثغرة**. بمعنى آخر، يحدث الهجوم عندما يتوفر لدى المهاجم **هدف أو دافع** واضح، ويستخدم **طريقة أو تقنية** معينة للتنفيذ، مع وجود **ثغرة أو نقطة ضعف** يستغلها للوصول إلى غايته. في الأقسام التالية سنشرح بالتفصيل كل عنصر من هذه العناصر: ما هو، وما أنواعه، وكيف تسهم هذه العناصر مجتمعة في نجاح الهجمات الإلكترونية.

الدوافع (Motivation)

تمثل **الدوافع** السبب أو الهدف الذي يدفع المهاجم لتنفيذ الهجوم السيبراني. يمتلك المهاجم عادة غاية نهائية أو مصلحة يسعى لتحقيقها من خلال الاختراق أو التخريب. فيما يلي أبرز الدوافع الشائعة للهجمات الإلكترونية:

- **دوافع مالية:** يعد الربح المادي من أقوى محركات الهجمات السيبرانية. يسعى المهاجم في هذه الحالة إلى كسب المال بطرق غير قانونية، مثل شن هجمات برامج الفدية لابتزاز الضحايا ماليًا، أو سرقة معلومات بطاقات الائتمان والحسابات البنكية لتحقيق مكاسب نقدية. مثال واقعي هو هجمات **برمجيات**

الفدية (Ransomware) التي تقفل ملفات الضحية وتطالب بفدية مالية لفك التشفير.

- **دوافع سياسية واجتماعية:** تشمل الهجمات ذات الأهداف السياسية أو الأيديولوجية ما يعرف بـ"اختراقات النشطاء (Hacktivism)" أو الهجمات التي ترعاها دول. هنا يكون الهدف التأثير على الرأي العام، أو الاحتجاج على سياسات معينة، أو جمع معلومات استخباراتية. على سبيل المثال، قد تستهدف مجموعة قرصنة ناشطة موقعًا حكوميًا للتعبير عن احتجاج سياسي، أو تقوم دولة ما بهجمات تجسس إلكتروني **(Cyber Espionage)** للحصول على أسرار دولة أخرى.

- **دوافع انتقامية:** قد يكون الدافع أحيانًا شخصيًا بحتًا، كأن يقوم موظف ساخط أو منافس حانق بشن هجوم إلكتروني انتقامًا من شركة أو فرد تسبب في إلحاق ضرر به سابقًا. في هذه الحالة، يكون الهدف إلحاق الأذى بالضحية بدافع الانتقام وليس لتحقيق مكسب مادي. مثال ذلك أن يقوم موظف سابق **بتسريب بيانات حساسة أو حذف ملفات مهمة** انتقامًا من صاحب العمل.

- **دوافع تخريبية (Sabotage):** يقصد بها الرغبة في **التدمير وإلحاق الضرر** بالأنظمة أو البيانات دون هدف مالي أو سياسي محدد، وإنما لمجرد التخريب أو إحداث الفوضى. قد يقوم بعض المخترقين بذلك بدافع التحدي وإثبات المهارة أو لإلحاق ضرر بسمعة الجهة المستهدفة. من الأمثلة الشائعة قيام مخرب إلكتروني **بمسح قاعدة بيانات** موقع ما أو تدمير خوادم شركة منافسة لإيقاف خدماتها وإحداث خسائر تشغيلية.

- **دوافع تجسسية (Espionage):** هنا يكون الهدف **سرقة المعلومات السرية** والحصول على بيانات قيّمة دون إثارة الانتباه. هذا النوع من الدوافع منتشر بين

الدول (للتجسس العسكري أو الاقتصادي) وبين الشركات (للتجسس الصناعي). قد ينفذ المهاجم عملية اختراق طويلة الأمد لسرقة تصاميم تقنية أو معلومات بحثية منافسة أو أسرار تجارية تمنحه أفضلية استراتيجية.

جدير بالذكر أن بعض الهجمات قد تجمع بين أكثر من دافع واحد. على سبيل المثال، قد يتداخل الدافع المالي مع السياسي في حالة تمويل جماعات إجرامية لهجمات تخدم أجندات سياسية. فهم الدوافع يساعد فرق الأمن السيبراني على توقع نوعية الهجمات والأساليب المحتملة، وبالتالي تصميم استراتيجيات دفاعية ملائمة.

الطرق (Methods)

تشير **طرق الهجوم** إلى الأساليب والتقنيات التي يتبعها المهاجمون لتنفيذ هجماتهم الإلكترونية. تتنوع طرق الاختراق بتنوع التقنيات وأهداف المهاجمين، وفيما يلي أهم الطرق المستخدمة في الهجمات السيبرانية مع توضيحها بأمثلة:

- **الهندسة الاجتماعية (Social Engineering):** تعتمد هذه الطريقة على استغلال العنصر البشري بدلًا من الثغرات التقنية. يقوم المهاجم بخداع الضحية للتخلي عن معلومات حساسة أو القيام بإجراءات تخدم المهاجم. من أبرز أمثلة الهندسة الاجتماعية **هجمات التصيّد الإلكتروني (Phishing)**، حيث يُرسل للمستخدم بريد إلكتروني أو رابط مزيف يبدو موثوقًا لخداعه في إدخال بياناته السرية (مثل كلمات المرور أو أرقام البطاقات المصرفية). مثال آخر هو **انتحال الهوية** حيث يتظاهر المهاجم بأنه شخص موثوق (كموظف دعم تقني) لإقناع الضحية بالكشف عن معلومات أو تثبيت برنامج خبيث.

- **البرمجيات الخبيثة (Malware):** وهي برامج أو أكواد برمجية ضارة يُدخلها المهاجم إلى نظام الضحية لتحقيق غرض تخريبي أو تجسسي. تتضمن

البرمجيات الخبيثة أنواعًا عديدة مثل **الفيروسات** التي تتكاثر وتلوث الملفات، و**الدودة (Worm)** التي تنتشر عبر الشبكات، و**أحصنة طروادة (Trojans)** التي تختبئ في برامج تبدو سليمة، وكذلك **برامج الفدية** التي سبق ذكرها. كمثال شائع، يقوم المهاجم بإرسال ملف مرفق عبر البريد الإلكتروني يحتوي على فيروس؛ إذا فتحه الضحية يصيب نظامه ويمنح المهاجم قدرة تحكم أو يسبب تلفًا للملفات.

- **هجمات حجب الخدمة الموزعة (DDoS Attacks):** تهدف هذه الهجمات إلى **تعطيل خدمات أو شبكات** الهدف عبر إغراقها بكم هائل من حركة المرور غير الشرعية تفوق قدرتها على الاستيعاب. يقوم المهاجم عادة باستخدام شبكة واسعة من الأجهزة المخترَقة (بوت نت) لإرسال طلبات وهمية بكميات ضخمة إلى خادم أو موقع الضحية، مما يؤدي إلى بطء شديد أو انهيار الخدمة بالكامل. مثال واقعي هو تعرض مواقع حكومية أو مصرفية لهجوم DDoS يؤدي إلى توقفها عن العمل لساعات، متسببًا في تعطيل الخدمات للمستخدمين الشرعيين.

- **استغلال الثغرات (Exploiting Vulnerabilities):** في هذه الطريقة يستفيد المهاجم من وجود **ثغرة أمنية** أو خلل في برمجيات أو أنظمة الهدف للولوج غير المصرح به أو تنفيذ تعليمات خبيثة. قد تكون الثغرة معروفة (مثل ثغرة لم يتم إصدار تصحيح لها بعد) أو غير معروفة تُسمى **هجوم اليوم الصفر (Zero-Day)** إذا استُغلت قبل اكتشافها وإصلاحها. على سبيل المثال، إذا كان هناك خطأ برمجي في نظام تشغيل أو تطبيق ويب يسمح بتنفيذ أوامر عشوائية، قد يستغل المهاجم هذه الثغرة لتنفيذ **هجوم اختراق قاعدة بيانات** والوصول إلى معلومات حساسة.

تجدر الإشارة إلى أن المهاجمين غالبًا ما يستخدمون مجموعة من الطرق معًا لتحقيق أهدافهم. فقد يبدأ الهجوم بالهندسة الاجتماعية للحصول على مدخل أولي، ثم زرع برمجيات خبيثة، ثم استغلال ثغرة للتعمق أكثر في الشبكة. لذا، فهم **طرق الهجوم** يساعد المدافعين على اتخاذ تدابير وقائية شاملة تغطي النواحي التقنية والبشرية.

الثغرات (Vulnerabilities)

الثغرة الأمنية هي أي **نقطة ضعف أو خلل** في نظام المعلومات يمكن أن يستغلها المهاجم للتسلل أو لتحقيق أغراضه الضارة. قد تظهر الثغرات في البرمجيات أو الأجهزة أو حتى في الإجراءات والبشر (مثل ضعف السياسات أو قلة الوعي الأمني). فيما يلي شرح لمفهوم الثغرات وأنواعها الشائعة مع أمثلة:

- **ضعف التكوين (Misconfiguration):** يحدث عندما يتم إعداد الأنظمة أو الشبكات بشكل غير آمن أو دون مراعاة معايير الحماية. على سبيل المثال، ترك إعدادات المصنع الافتراضية دون تغيير (كأن يبقى اسم المستخدم وكلمة المرور الافتراضية لأجهزة التوجيه)، أو عدم تفعيل بروتوكولات التشفير والحماية بشكل صحيح. هذه الأخطاء في الضبط تفتح بابًا سهلًا للمهاجمين.
  مثال: قد يستغل مهاجم **منفذًا مفتوحًا أو إعدادًا خاطئًا في جدار الحماية** للنفاذ إلى خادم قاعدة بيانات ليس من المفترض أن يكون متاحًا عبر الإنترنت.

- **ثغرات برمجية (Software Bugs/Flaws):** هي أخطاء أو عيوب في كود البرمجيات (أنظمة التشغيل، التطبيقات، قواعد البيانات...إلخ) تؤدي إلى سلوك غير متوقع قد يُستغل. هذه الفئة تشمل نطاقًا واسعًا من الثغرات مثل **ثغرات تجاوز سعة المخزن (Buffer Overflow)**، أو أخطاء منطقية تمكن من تخطي إجراءات التحقق، أو مشاكل في إدارة الذاكرة. **مثال:** اكتشاف ثغرة برمجية في تطبيق ويب تسمح بحقن أوامر **SQL** غير مصرح بها (SQL Injection)

مما يمكّن المهاجم من **عرض أو تعديل بيانات** غير مخصصة له.

- **كلمات مرور ضعيفة (Weak Passwords):** ضعف في **العنصر البشري/الإعدادات** يتمثل في استخدام كلمات مرور سهلة التخمين أو افتراضية. كلمات المرور الضعيفة (مثل "123456" أو "password") تجعل حسابات المستخدمين أو الأنظمة فريسة سهلة لمحاولات الاختراق عبر **هجمات التخمين** أو **الهجوم بالقوة الغاشمة (Brute Force)**. **مثال:** قيام أحد الموظفين باستخدام كلمة مرور شائعة لحسابه على الشبكة الداخلية قد يسمح لمهاجم بتخمينها والوصول إلى موارد الشركة الداخلية بسهولة نسبيًا.

- **عدم تحديث الأنظمة (Outdated Systems):** عدم تطبيق **التحديثات الأمنية** والتصحيحات (Patches) بشكل منتظم يتسبب في بقاء ثغرات معروفة بدون إصلاح. المهاجمون دائمًا ما يستهدفون الأنظمة غير المحدثة لأن الثغرات فيها موثقة وقد تتوفر لها أدوات استغلال جاهزة. **مثال:** هجوم **WannaCry** الشهير في عام 2017 الذي انتشر مستغلًا ثغرة في أنظمة Windows لم يتم ترقيعها لدى العديد من المؤسسات، مما أدى إلى إصابة آلاف الأجهزة ببرمجيات الفدية بسرعة كبيرة.

للوقاية من الثغرات الأمنية، ينبغي اتباع ممارسات مثل: التحديث الدوري للبرمجيات، وتطبيق إعدادات أمان قياسية عند ضبط الأنظمة، واستخدام كلمات مرور قوية وسياسات مصادقة متعددة العوامل، وإجراء فحوصات دورية لاكتشاف نقاط الضعف ومعالجتها قبل أن يستغلها المهاجمون.

المخاطر (Risks)

بعد التعرف على عناصر الهجوم (الدوافع والطرق والثغرات)، يأتي دور فهم **المخاطر السيبرانية** وكيفية إدارتها. في هذا القسم سنناقش تعريف المخاطر، والفرق بينها وبين التهديدات والثغرات، وأنواع التقييم المتعلقة بها، بالإضافة إلى مبادئ **إدارة المخاطر** ومراحلها واستراتيجياتها.

تعريف المخاطر السيبرانية

الخطر (Risk) في السياق السيبراني هو احتمال حدوث **حدث سلبي** ناتج عن استغلال تهديد ما لثغرة ما، ومدى تأثير ذلك الحدث إن وقع. بعبارة أخرى، الخطر يمثل **احتمالية وقوع الهجوم مع حجم الضرر الناتج عنه**. إذا توفر تهديد (كوجود مهاجم أو وسيلة هجومية) ووجدت ثغرة قابلة للاستغلال في النظام، فإن الخطر هو التهديد المحتمل الواقعي الذي يواجه المؤسسة أو الفرد نتيجة اجتماع التهديد مع الثغرة. تتفاوت المخاطر في شدتها؛ بعضها منخفض التأثير أو الاحتمال، وبعضها **عالي الخطورة** إذا كان التهديد محتمل الحدوث وتبعاته شديدة على الأعمال أو الأمن.

الفرق بين المخاطر والتهديدات والثغرات

غالبًا ما يخلط المبتدئون بين مفاهيم **التهديد (Threat)** و**الثغرة (Vulnerability)** و**الخطر (Risk)**، لكن لكل منها معنى خاص:

- **التهديد (Threat):** هو أي **حدث محتمل أو جهة** قادرة على إحداث ضرر. يمكن أن يكون التهديد شخصًا (مثل قرصان إلكتروني أو موظف داخلي ضار) أو برنامجًا خبيثًا أو كارثة طبيعية. التهديد يمثل **الخطر الكامن** أو *النية/الوسيلة* التي قد تستهدف نقطة ضعف. مثال: فيروس جديد ينتشر على الإنترنت، أو مهاجم مجهول يحاول اختراق نظام معين.

- **الثغرة (Vulnerability):** هي **نقطة الضعف** أو الخلل الذي يمكن للتهديد استغلاله لتحقيق الاختراق. الثغرة قد تكون تقنية (خطأ برمجي، إعداد خاطئ) أو

بشرية (سلوك غير آمن، نقص في الوعي). وجود الثغرة يعني أن النظام **غير حصين** تمامًا أمام أنواع معينة من الهجمات. مثال: استخدام برمجية غير محدثة تحتوي على خلل أمني، أو عدم وجود جدار ناري يحمي الشبكة.

- **الخطر (Risk):** ينشأ الخطر عندما يوجد **تهديد** قادر على استغلال **ثغرة**. فهو **احتمال** تحقيق التهديد لأهدافه بنجاح وما ينتج عنه من **أضرار**. تقدير مستوى الخطر يعتمد على عاملين: *احتمالية وقوع الهجوم*، و*مدى تأثيره أو الضرر المترتب عليه*. مثال: إذا كان هناك فيروس (تهديد) يستهدف ثغرة معروفة في نظام غير محدث، فإن احتمال إصابة النظام وتعطله يمثل خطرًا عاليًا.

للتوضيح، يمكن تشبيه العلاقة بينها بمثال من الحياة الواقعية:
· **التهديد:** لص يتجول باحثًا عن منزل ليسرقه - فهو يمثل الخطر المحتمل.
· **الثغرة:** نافذة مفتوحة في المنزل أو باب غير مقفل - يمثل نقطة الضعف التي تتيح للص الدخول.
· **الخطر:** احتمال دخول اللص عبر تلك النافذة المفتوحة وما قد يترتب على ذلك من سرقة أو تخريب - أي **الخسارة المحتملة** نتيجة اجتماع اللص (التهديد) مع النافذة المفتوحة (الثغرة).

إن فهم هذه الفروق جوهري لإدارة الأمن السيبراني: **التهديدات** نحددها ونعرف مصادرها، **الثغرات** نعالجها ونصلحها، **المخاطر** نقيّمها ونتخذ قرارات بشأنها.

أنواع التقييم للمخاطر والتهديدات والثغرات

ضمن إطار إدارة الأمن السيبراني، تُجرى عمليات **تقييم** مختلفة لتحليل الوضع الأمني وتشخيص نقاط الضعف والمخاطر. تنقسم عمليات التقييم عادةً إلى ثلاثة أنواع رئيسية، كل منها يركز على جانب محدد:

- **تقييم المخاطر (Risk Assessment):** هي عملية منهجية ل**تقدير احتمال حدوث خسارة أو ضرر** بسبب تهديد معين، وتقييم **عواقب** ذلك إن حدث. يتضمن تقييم المخاطر تحليلًا للعوامل التي تزيد احتمالية الهجوم (مثل وجود تهديدات نشطة وثغرات معروفة)، وتقدير حجم التأثير أو التكلفة المحتملة على الأصول المهمة في حال وقوع الحادث. يساعد هذا التقييم على تصنيف المخاطر (من منخفضة إلى عالية) وتحديد أولويات معالجتها.

- **تقييم التهديدات (Threat Assessment):** يركّز على **تحديد مصادر التهديدات ودوافعها** ومدى خطورتها. في هذا النوع من التقييم تُجمع معلومات عن الجهات المهدِّدة المحتملة (كمجرمي الإنترنت ذوي التاريخ المعروف، أو مجموعات القرصنة النشطة، أو حتى التهديدات الداخلية مثل الموظفين الساخطين). يتم تحليل قدرة هذه التهديدات ونياتها والأساليب التي قد تستخدمها. الهدف هو فهم *من* قد يهاجم ولماذا وكيف، مما يساعد في الاستعداد للهجمات المتوقعة واتخاذ إجراءات استباقية (مثل تعزيز المراقبة ضد تهديدات معينة أو تحديث سياسات الوصول الداخلي).

- **تقييم الثغرات (Vulnerability Assessment):** هو الفحص المنهجي ل**نقاط الضعف التقنية** في الأنظمة والشبكات والتطبيقات. يقوم الخبراء أو الأدوات الآلية بالبحث عن الثغرات الأمنية في البنية التحتية لتكنولوجيا المعلومات، مثل البرمجيات غير المحدثة، أو الإعدادات الخاطئة، أو الثغرات المكتشفة حديثًا. عادة يتضمن ذلك استخدام ماسحات أمنية وبرامج اختبار اختراق لمعرفة أي الثغرات موجودة وكيف يمكن استغلالها. نواتج تقييم الثغرات هي قائمة بالثغرات الموجودة مرتبة حسب خطورتها، مما يمكّن فرق الأمن من معالجتها قبل أن يستغلها المهاجمون.

هذه التقييمات الثلاثة مترابطة وتعطي معًا صورة شاملة: **تقييم التهديدات** يوضح من أين يمكن أن يأتي الهجوم، **تقييم الثغرات** يكشف أين يمكن أن يضرب الهجوم، و**تقييم المخاطر** يجمع المعطيات ليبين أي السيناريوهات أخطر على الأعمال وما الإجراء المناسب تجاهها.

إدارة المخاطر (Risk Management)

بعد التعرف على المخاطر وتقييمها، تأتي مهمة **إدارة المخاطر**، وهي عملية منهجية لاتخاذ القرارات والإجراءات المناسبة للتعامل مع المخاطر بحيث يتم تقليلها إلى مستوى مقبول. إدارة المخاطر في الأمن السيبراني تعني فهم طبيعة التهديدات والثغرات التي تواجه المنظمة أو الفرد، ثم **تطوير خطة للتعامل مع تلك المخاطر** وفقًا لأولويتها. تتضمن الخطة إما تخفيض احتمالية وقوع الحادث أو تخفيف تأثيره، وأحيانًا نقل المسؤولية أو حتى قبول المخاطر البسيطة. تهدف إدارة المخاطر في النهاية إلى حماية **الأصول القيّمة** (كالبيانات وأنظمة المعلومات) وتحقيق توازن بين مستوى الأمن المطلوب والموارد المتاحة لتحقيقه.

مراحل إدارة المخاطر

تمر عملية إدارة المخاطر بعدة **مراحل أساسية** تضمن التعامل المنظم مع المخاطر الأمنية خطوة بخطوة:

1. **التحديد (Identify):** في هذه المرحلة يتم **حصر وتحديد المخاطر المحتملة** التي قد تهدد الأصول. يشمل ذلك تحديد الأصول المهمة (أجهزة، أنظمة، بيانات) ثم تحديد التهديدات الممكنة لكل منها والثغرات الموجودة أو المحتملة التي قد تستغل. ناتج هذه الخطوة هو قائمة شاملة بالمخاطر الممكنة.

2. **التحليل (Analyse):** بعد تحديد المخاطر، يتم **تحليل كل خطر** من حيث **احتمالية وقوعه** ومدى **تأثيره** على الأعمال أو الأصول فيما لو تحقق. قد يكون

التحليل نوعيًا (تقييم وصفي عالي/متوسط/منخفض) أو كميًا (استخدام معادلات واحتمالات رقمية). الهدف هو فهم خصائص كل خطر وتركيبته (ما التهديد وما الثغرة وما النتيجة المتوقعة).

3. **التقييم (Evaluate):** في هذه المرحلة تُقارن **مستويات المخاطر** الناتجة عن التحليل مع **معايير محددة مسبقًا** لقبول المخاطر. أي يتم تحديد أي المخاطر مقبول (ضمن المستوى المقبول للمؤسسة) وأيها غير مقبول ويتطلب معالجة. هذه المرحلة تساعد في تصنيف المخاطر إلى فئات (مقبولة، تتطلب إجراء، حرجة جدًا إلخ) لاتخاذ قرار بشأنها.

4. **ترتيب الأولويات (Prioritise):** غالبًا ما تُدمج مع مرحلة التقييم أو تليها مباشرة. نظرًا لمحدودية الموارد والوقت، يتم **إعطاء الأولوية** لمعالجة المخاطر الأعلى خطورة أولًا. تُرتب المخاطر حسب درجة خطورتها (ناتج مزيج الاحتمال والتأثير) وكذلك عامل مهلة حدوثها (بعض المخاطر تتطلب معالجة فورية). هذه الخطوة تضمن أن يركز فريق الأمن على ما قد يسبب أكبر ضرر بشكل أسرع.

5. **المعالجة/العلاج (Treat):** يُقصد بها **تنفيذ إجراءات التحكم بالمخاطر** أو معالجتها وفق الاستراتيجية المناسبة. إذا تقرر معالجة خطر معين، توضع خطة للتعامل معه (مثل تصحيح ثغرة برمجية، تعزيز جدران الحماية، تدريب الموظفين، صياغة سياسات جديدة، شراء حلول أمنية... إلخ). قد تشمل المعالجة تخفيف الخطر أو نقله أو غير ذلك من الاستراتيجيات التي سنذكرها لاحقًا. الهدف هنا تقليل احتمال الخطر أو تقليل أثره إلى مستوى مقبول.

6. **المراقبة والمراجعة (Monitor):** بعد تنفيذ المعالجات، تستمر عملية **مراقبة** البيئة الأمنية بشكل دوري لمتابعة حالة المخاطر. البيئة السيبرانية ديناميكية، فقد تظهر تهديدات جديدة أو ثغرات غير معروفة سابقًا. لذا تشمل هذه

المرحلة **مراجعة دورية** لقائمة المخاطر، وإعادة تقييمها عند حدوث تغييرات (مثل إدخال نظام جديد أو تهديد جديد)، والتأكد من فاعلية الضوابط والإجراءات التي تم وضعها. قد يعود المديرون إلى أي مرحلة سابقة إذا لزم الأمر (مثلاً إعادة تحديد مخاطر جديدة، أو تحليل خطر ظهر حديثًا).

استراتيجيات إدارة المخاطر

عند اتخاذ قرار بشأن **كيفية التعامل مع خطر معين**، عادة تختار المنظمات بين عدة استراتيجيات معروفة في إدارة المخاطر. كل استراتيجية تمثل نهجًا مختلفًا في معالجة الخطر بناءً على طبيعته ومستوى قبوله. أبرز **استراتيجيات إدارة المخاطر** تشمل ما يلي:

- **التجنب (Avoidance):** ويعني **إلغاء السبب الجذري للخطر أو تفادي القيام بأي نشاط ينطوي عليه**. إذا كان خطر ما عاليًا ولا يمكن التحكم فيه بسهولة، قد تقرر المنظمة ببساطة تجنبه تمامًا. مثال: إذا كانت هناك خدمة رقمية معرضة لهجمات خطيرة ولا يمكن تأمينها حاليًا، قد يتم إيقاف هذه الخدمة أو عدم توفيرها على الإنترنت إلى أن يتم تأمينها بشكل كافٍ، وبذلك يتم تفادي الخطر كليًا.

- **التحويل (Transfer):** في هذه الاستراتيجية تقوم المنظمة ب**نقل تبعات الخطر إلى طرف آخر** يتحملها جزئيًا أو كليًا. عادة يكون ذلك عبر التأمين أو الاستعانة بطرف خارجي. مثال: شراء وثيقة **تأمين إلكتروني** ضد حوادث الاختراق، بحيث لو وقع الخطر تتحمل شركة التأمين التعويض المالي. مثال آخر: إسناد مهمة معالجة البيانات الحساسة إلى شركة متخصصة ذات إجراءات حماية عالية (التعهيد الآمن)، فهنا انتقلت مسؤولية حماية تلك البيانات جزئيًا إلى الطرف الثالث.

- **القبول (Acceptance):** أحيانًا تكون **تكلفة معالجة الخطر أعلى بكثير من تأثيره المحتمل**، أو يكون احتمال وقوعه ضعيفًا جدًا، لذا قد تقرر الإدارة **قبول الخطر كما هو** دون إجراء خاص. هذا القرار يترافق عادة مع مراقبة دورية لضمان أن الخطر المقبول لا يتفاقم. مثال: قد تقبل شركة ما خطر حدوث عطل في جهاز ثانوي إذا كانت تكلفة شراء جهاز احتياطي أو نظام عالي التوافر تفوق بكثير الضرر الناجم عن تعطل الجهاز لفترة قصيرة.

- **التخفيف (Mitigation):** ويقصد به **اتخاذ إجراءات تخفض من احتمال حدوث الخطر أو تقلل تأثيره** في حال حدوثه. هذه أكثر الاستراتيجيات استخدامًا، وتهدف إلى **تقليل مستوى الخطر إلى الحد المقبول** بدلًا من إزالته بالكامل. مثال: للحد من خطر اختراق الشبكة عبر ثغرات معروفة، يمكن للشركة **تطبيق تحديثات أمنية منتظمة، وتثبيت أنظمة كشف التسلل، وتSegment الشبكة** لعزل الأجزاء الحساسة. هذه الخطوات لا تقضي تمامًا على الخطر ولكن تقلل بشكل كبير فرص نجاح الهجوم أو حجم الضرر لو وقع.

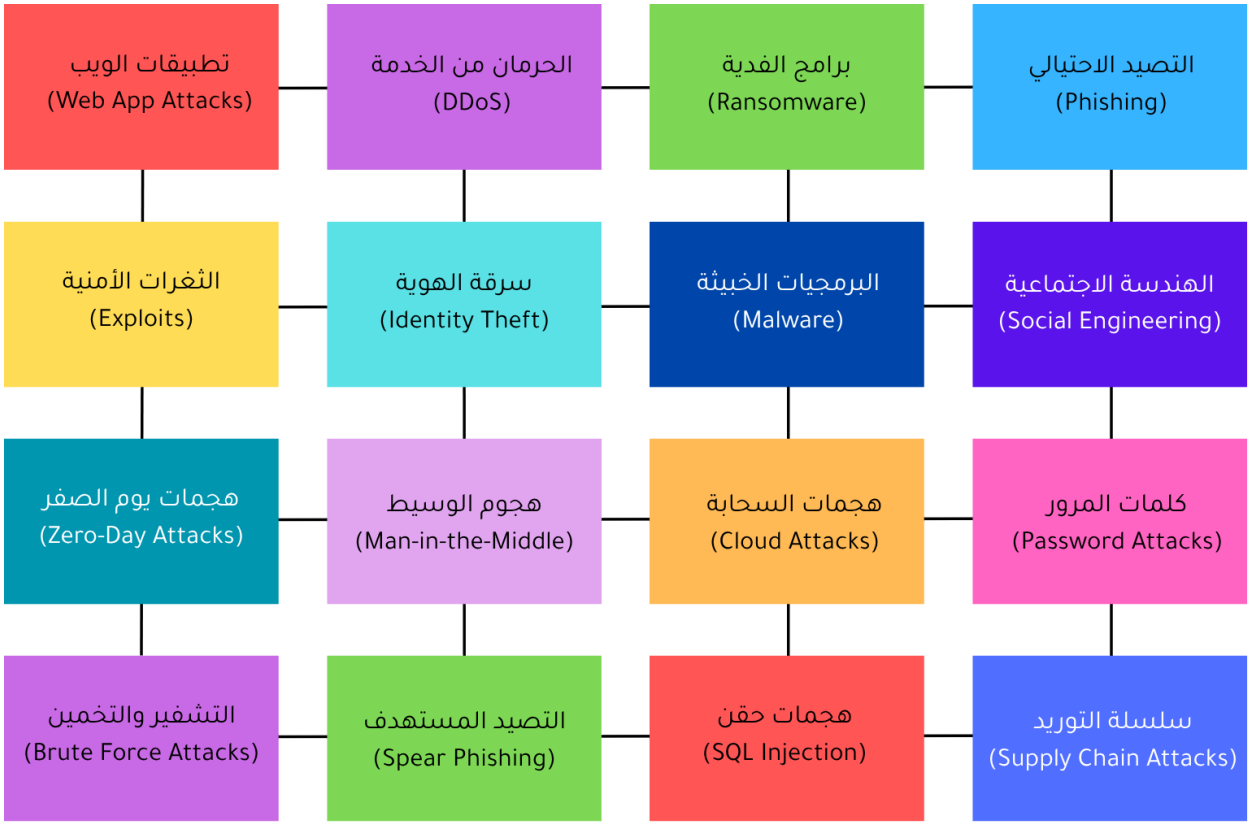
- **الردع (Deterrence):** تعتمد هذه الاستراتيجية على **إجراءات تجعل المهاجمين يحجمون عن استهداف المنظمة** من الأساس. أي بث الخوف أو اليأس في نفس الخصم المحتمل بحيث **لا يقدم على الهجوم**. قد يكون الردع تقنيًا أو قانونيًا أو حتى عبر السمعة. مثال: إعلان الشركة عن امتلاك أنظمة أمن متقدمة ومراقبة مستمرة قد يردع المهاجمين لعلمهم بصعوبة المهمة. كذلك **الملاحقة القانونية** القوية للمهاجمين السابقين ونشر أخبار العقوبات الرادعة يجعل المخترق يفكر مرتين قبل مهاجمة جهة تظهر جدية في العقاب.

كل استراتيجية من الاستراتيجيات أعلاه ليست حصرية، بل يمكن تطبيق مزيج منها بحسب الموقف. قد تتجنب المنظمة بعض المخاطر، وتنقل بعضها، وتخفف البعض

الآخر. الأهم هو أن يتم اتخاذ القرار بشكل منهجي ومدروس، وضمن إطار **سياسة إدارة مخاطر** واضحة تراعي شهية المؤسسة للمخاطر (مدى استعدادها لتحمل أنواع معينة من المخاطر) وتوازن بين الحماية والتكاليف.

خلاصة: فهم **المخاطر والهجمات السيبرانية** بمكوناتها المختلفة (دوافع المهاجمين، طرق الهجوم، الثغرات الأمنية) إلى جانب معرفة كيفية تقييم المخاطر وإدارتها، هو حجر الأساس لبناء برنامج أمن سيبراني فعّال. بأسلوب مبسّط: الهجوم يحدث عندما يلتقي دافع خبيث مع طريقة اختراق فعّالة في وجود ثغرة تسمح بذلك. ومن خلال إدارة المخاطر نتأكد أن هذا المثلث (الدافع-الطريقة-الثغرة) تحت السيطرة قدر الإمكان، عبر تقليل الدوافع لدى الخصم أو منعه من تحقيقها، وسد الطرق والثغرات أمامه، ووضع خطط للتعامل مع الحوادث إن وقعت. بهذا الأسلوب الاستباقي والتعليمي، يصبح المتدربون في مجال الأمن السيبراني أكثر جاهزية للتصدي للتحديات وحماية أنظمتهم ومعلوماتهم في الواقع العملي.

أنواع الهجمات السيبرانية



الهجمات السيبرانية هي محاولات ضارة تستهدف أنظمة الحاسوب والشبكات والأجهزة الرقمية بهدف اختراقها أو تعطيلها أو سرقة البيانات منها. يستخدم المهاجمون تقنيات برمجية وحيلًا مختلفة للوصول غير المصرح به إلى المعلومات الحساسة أو تعطيل الخدمات. وقد أصبحت هذه الهجمات شائعة في العصر الرقمي الحديث، حيث تتنوع أساليبها لتشمل الأفراد والشركات والمؤسسات على حد سواء، مما يجعل الوعي بها وفهم طرق عملها أمرًا ضروريًا للجميع.

تتعدد أنواع الهجمات السيبرانية وفقًا للأساليب والأهداف التي يسعى وراءها المهاجمون. فيما يلي عرض لأبرز أنواع الهجمات الإلكترونية الشائعة، مع شرح مبسّط لكل منها. هذه المعلومات مقدَّمة بأسلوب تعليمي مبسّط، وهي موجّهة للمبتدئين في مجال الأمن السيبراني لفهم طبيعة التهديدات الرقمية الشائعة وكيفية عملها.

التصيد الاحتيالي (Phishing)

التصيد الاحتيالي هو أحد أكثر الهجمات السيبرانية انتشارًا. يعتمد هذا الهجوم على استخدام رسائل أو مواقع إلكترونية مزيفة تبدو وكأنها صادرة عن جهات موثوقة (مثل البنوك أو شركات معروفة). يقوم المهاجم بانتحال صفة مؤسسة أو جهة موثوقة لخداع الضحية وحملها على الكشف عن معلومات حساسة مثل أسماء المستخدم وكلمات المرور أو تفاصيل بطاقات الائتمان.

تنتشر هجمات التصيد الاحتيالي عادةً عبر رسائل البريد الإلكتروني، أو الرسائل النصية القصيرة (SMS)، أو حتى عبر وسائل التواصل الاجتماعي. غالبًا ما تكون هذه الرسائل مصممة بعناية لتبدو شرعية جدًا، حيث تتضمن شعارات وأسماء معروفة، وتتبنى نبرة رسمية مقنعة. قد تحتوي الرسالة على رابط خبيث يدعو المستخدم إلى موقع مزيف أو مرفق ضار. ومن الأساليب الشائعة في التصيد إثارة شعور بالإلحاح أو الخوف لدى الضحية - كادعاء وجود مشكلة خطيرة بحساب الضحية تستوجب التصرف السريع - بهدف دفعه إلى التصرف دون تفكير والكشف عن بياناته السرية.

برامج الفدية (Ransomware)

برامج الفدية هي نوع خطير من البرمجيات الخبيثة التي يقوم بتشفير ملفات الضحية أو نظامها بشكل كامل بحيث يصبح الوصول إلى البيانات مستحيلًا دون مفتاح فك التشفير. عند إصابة جهاز الكمبيوتر أو الشبكة ببرنامج فدية، يجد المستخدم أن ملفاته الهامة قد تم قفلها وتغيير امتداداتها ولا يمكن فتحها بأي طريقة تقليدية. يظهر

للمستخدم عادةً إشعار أو رسالة تفيد بأن ملفاته مشفّرة وأن عليه دفع فدية مالية لقاء استعادتها.

في هجوم برامج الفدية، يطالب المهاجم الضحية بدفع مبلغ من المال مقابل توفير مفتاح فك تشفير الملفات. غالبًا ما يُطلب دفع الفدية بعملة رقمية (مثل **البيتكوين**) لضمان عدم تتبع هوية المهاجم. المشكلة الكبيرة هي أنه حتى عند دفع الفدية، لا يوجد أي ضمان بأن يقوم المهاجم فعليًا بإعادة الملفات إلى حالتها الأصلية. قد يتعرض الأفراد والشركات لخسائر جسيمة بسبب هذه الهجمات، سواء من ناحية فقدان البيانات المهمة أو توقف الأنظمة عن العمل لفترة. لذا تعتبر برامج الفدية من أخطر التهديدات السيبرانية حاليًا، وقد استهدفت مؤسسات حكومية وشركات كبرى ومستخدمين عاديين على حد سواء.

هجمات الحرمان من الخدمة (DDoS)

هجمات الحرمان من الخدمة أو ما يُعرف بالحرمان الموزَّع من الخدمة (Distributed Denial of Service) هي هجمات تهدف إلى تعطيل خدمة أو موقع ويب وجعله غير متاح للمستخدمين الشرعيين. تتم عملية الهجوم عبر إغراق الخادم أو الشبكة المستهدفة بوابل هائل من حركة المرور والطلبات الوهمية في نفس الوقت. يستخدم المهاجمون عادةً شبكة واسعة من الأجهزة المخترَقة مسبقًا - تُسمى **شبكة البوت نت (Botnet)** - لإرسال عدد ضخم جدًا من الطلبات إلى خادم الضحية في وقت واحد.

نتيجة لهذا التدفق الهائل من البيانات، تُستنزَف موارد الخادم (مثل قدرة المعالجة وعرض النطاق الترددي للإنترنت)، فيصبح غير قادر على الاستجابة لطلبات المستخدمين الحقيقيين. بالتالي، يواجه المستخدمون صعوبة في الوصول إلى الموقع أو الخدمة المستهدفة وربما تنقطع الخدمة تمامًا. غالبًا ما تستهدف هجمات DDoS المواقع الإلكترونية الكبيرة أو خوادم الشركات والمؤسسات المالية وحتى البنية التحتية الحيوية. وقد يلجأ المهاجمون إلى هذا الأسلوب لتعطيل منافسين أو ابتزاز

جهات مستهدفة (كالمطالبة بمبالغ مالية لقاء إيقاف الهجوم)، مما يجعل هجمات الحرمان من الخدمة تهديدًا حقيقيًا لاستمرارية الأنشطة على الإنترنت.

الهجمات على تطبيقات الويب (Web Application Attacks)

هذا النوع من الهجمات يستهدف التطبيقات والمواقع الإلكترونية مباشرةً من خلال استغلال الثغرات الأمنية في برمجتها. يعتمد المهاجم على العثور على خلل أو ضعف في الكود البرمجي للموقع لكي ينفّذ من خلاله هجومًا. من الأمثلة الشائعة على هجمات تطبيقات الويب **هجوم حقن SQL** و**هجمات البرمجة عبر المواقع (XSS)**. في حالة حقن SQL يقوم المهاجم بإدخال تعليمات برمجية خبيثة في حقول إدخال البيانات على الموقع (مثل حقول تسجيل الدخول أو البحث) بهدف خداع قاعدة البيانات الخاصة بالموقع. أما في هجمات XSS فيستغل المهاجم ثغرة في صفحات الموقع لحقن أكواد ضارة (غالبًا بلغة جافاسكريبت) بحيث يتم تشغيلها في متصفح المستخدم الذي يزور الموقع.

الهدف الرئيسي من الهجمات على تطبيقات الويب هو الوصول إلى معلومات وبيانات حساسة مخزنة في خوادم الموقع أو التلاعب بمحتوى الموقع نفسه. على سبيل المثال، قد يمكّن استغلال الثغرات المهاجمين من سرقة قواعد بيانات تحتوي على معلومات المستخدمين (كالأسماء وكلمات المرور والبريد الإلكتروني)، أو تعديل محتوى الصفحة وإدراج محتويات خبيثة. وفي بعض الحالات المتقدمة، إذا لم يتم إصلاح الثغرات بسرعة، يمكن أن يصل الضرر إلى سيطرة المهاجم بالكامل على الموقع أو الخادم المستضيف له. ولهذا السبب يعد التأمين البرمجي للمواقع وفحصها بحثًا عن الثغرات أمراً بالغ الأهمية لحماية مستخدميها.

الهندسة الاجتماعية (Social Engineering)

لا تعتمد هجمات الهندسة الاجتماعية على وسائل تقنية معقدة، بل تستغل العنصر البشري كمدخل للاختراق. يقوم المهاجم في هذه الحالة بخداع الأشخاص وإقناعهم

باتخاذ إجراءات تخدم مصلحته أو بالإفصاح عن معلومات سرية، وذلك عن طريق التلاعب النفسي واستغلال الثقة أو جهل الضحية بأساليب الاحتيال. بكلمات أخرى، يستهدف المهاجم **العقل البشري** بدلاً من استهداف الأجهزة أو البرمجيات مباشرة.

يستخدم المهاجم أساليب متنوعة في الهندسة الاجتماعية، مثل انتحال صفة شخص موثوق أو صاحب سلطة. على سبيل المثال، قد يتظاهر بأنه موظف دعم فني يتصل بالمستخدم ويبلغه بوجود مشكلة تستدعي الحصول على كلمة المرور لحلها، أو يدّعي أنه زميل جديد يحتاج إلى إذن دخول معين. من خلال هذه السيناريوهات الكاذبة وغيرها، ينجح المهاجم في كسب ثقة الضحية ودفعها إلى كشف المعلومات التي يريدها أو القيام بتصرف يخدم أهداف الهجوم (مثل النقر على رابط ضار أو تشغيل ملف مرفق). تعتبر هجمات الهندسة الاجتماعية من أخطر الأساليب السيبرانية لأنها تتفادى الكثير من أنظمة الحماية التقنية عبر استهداف **نقطة الضعف الأبرز: الإنسان**. لذا، فإن رفع مستوى الوعي والحذر لدى المستخدمين يُعد خط الدفاع الأول ضد هذا النوع من الهجمات.

البرمجيات الخبيثة (Malware)

البرمجيات الخبيثة هي أي برنامج أو شيفرة برمجية مصممة عمداً لإلحاق الضرر بالأنظمة الحاسوبية أو للقيام بأنشطة غير مشروعة على الجهاز المصاب. يُعتبر مصطلح "البرمجيات الخبيثة" تصنيفًا شاملاً يضم تحت مظلته مجموعة واسعة من التهديدات الرقمية. من أشهر أنواع البرمجيات الخبيثة: **الفيروسات** (التي تصيب الملفات وتتكاثر بالانتشار إلى ملفات أخرى)، **أحصنة طروادة** (برامج تظهر كأنها شرعية ومفيدة لكنها تخفي بداخلها سلوكًا ضارًا)، **الديدان** (برامج خبيثة قادرة على التكاثر الذاتي والانتشار عبر الشبكات)، **برامج التجسس** (Spyware التي تتجسس على نشاط المستخدم لجمع المعلومات)، وغيرها الكثير بما في ذلك برامج الفدية والبرامج الإعلانية الضارة التي تندرج أيضًا ضمن فئة البرمجيات الخبيثة.

تدخل البرمجيات الخبيثة إلى الأجهزة بطرق مختلفة ومتعددة. قد تنتقل عبر مرفقات البريد الإلكتروني الخبيثة، أو من خلال تحميل برامج مجهولة المصدر أو مزيفة من الإنترنت، أو عبر استغلال ثغرات أمنية في النظام عند تصفح مواقع مصابة. بمجرد إصابة الجهاز، تقوم البرمجيات الخبيثة بتنفيذ مهام ضارة تختلف حسب نوعها والغرض الذي صُممت لأجله. بعض البرمجيات الخبيثة تقوم بسرقة البيانات الحساسة مثل كلمات المرور أو ملفات المستخدم الشخصية، وبعضها الآخر قد يسجل ضغطات لوحة المفاتيح للتجسس، أو يفتح بابًا خلفيًا يسمح للمهاجم بالتحكم عن بُعد بالجهاز. هناك أيضًا برمجيات خبيثة مهمتها إلحاق الضرر المباشر كنشر نفسها وتعطيل النظام أو تشويه الملفات. باختصار، تمثل البرمجيات الخبيثة خطرًا رئيسيًا في عالم الأمن السيبراني نظرًا لتعدد أشكالها وأساليبها التخريبية، مما يتطلب من المستخدمين الحيطة والحذر عند التعامل مع الملفات والبرامج غير الموثوقة.

سرقة الهوية (Identity Theft)

سرقة الهوية هي جريمة إلكترونية يقوم فيها المهاجم بالاستيلاء على معلومات شخصية حساسة تخص شخصًا ما ومن ثم استخدامها لانتحال شخصية ذلك الفرد بشكل غير قانوني. تشمل المعلومات التي يسعى المهاجم إلى الحصول عليها أشياء مثل الاسم الكامل، رقم الهوية أو الرقم الوطني، معلومات الحسابات المصرفية، أرقام بطاقات الائتمان، كلمات المرور، وحتى المعلومات الصحية أو الوظيفية إذا كانت تفيده. بعد جمع هذه البيانات الشخصية، يستغل المهاجم الهوية المسروقة لتحقيق مكاسب أو لارتكاب أعمال احتيالية باسم الضحية.

عندما ينجح المهاجم في سرقة هوية شخص ما، يمكنه القيام بالعديد من الأنشطة الضارة مستغلًا اسم الضحية. على سبيل المثال، قد يستخدم بيانات البطاقة الائتمانية لإجراء مشتريات وسحب الأموال، أو يستخدم معلومات تسجيل الدخول لاختراق حسابات الضحية على مواقع التواصل الاجتماعي والبريد الإلكتروني. في حالات

أخرى، قد يتم فتح حسابات جديدة أو قروض بنكية باسم الضحية دون علمه. تكمن خطورة سرقة الهوية في أن الضحية غالبًا لا يكتشف ما حدث إلا بعد فترة من الزمن، ربما حين تصله فواتير أو إشعارات بعمليات لم يقم بها، أو عند تعرّض سمعته الرقمية والشخصية للضرر. استعادة الهوية المسروقة وتصحيح الأضرار المترتبة على ذلك قد تكون عملية طويلة ومعقدة، لذلك يعتبر هذا النوع من الهجمات من التجارب المؤلمة للأفراد. إن حماية المعلومات الشخصية وتوخي الحذر عند مشاركة البيانات الحساسة هما من أفضل وسائل الوقاية ضد سرقة الهوية.

استغلال الثغرات الأمنية (Exploits)

يقصد باستغلال الثغرات الأمنية قيام المهاجمين بالبحث عن نقاط ضعف أو ثغرات في أنظمة البرامج أو الأجهزة ثم استغلالها لاختراق تلك الأنظمة قبل أن يتم إصلاحها أو سدّها. في كل برنامج أو نظام تشغيل تقريبًا يمكن أن تظهر أخطاء برمجية أو ثغرات غير مقصودة تسمح بسلوك غير متوقع. هذه الثغرات قد تمكن المهاجم من تنفيذ أوامر خبيثة أو التخطي عن إجراءات الحماية. عندما يكتشف المهاجم ثغرة معينة، يقوم بكتابة شفرة استغلال **(Exploit)** مصممة خصيصًا للاستفادة من هذه الثغرة وإحداث ضرر أو سيطرة غير مشروعة على النظام المستهدف.

إذا تأخرت الجهة المطورة للبرنامج أو النظام في إصدار تحديثات وتصحيحات أمان لسد الثغرات المكتشفة، فإن الأجهزة أو الخوادم التي تعمل بذلك البرنامج تظل عرضة للهجمات. يستغل المهاجمون هذه الثغرات المفتوحة لتحقيق أهدافهم، مثل سرقة البيانات أو التحكم بالنظام أو تعطيله. على سبيل المثال، قد يتيح استغلال ثغرة في نظام تشغيل أو خادم ويب للمهاجم تنفيذ أوامر بصلاحيات عالية تمكنه من تنصيب برمجيات خبيثة أو إنشاء حسابات مخفية للتجسس. لذلك من المهم جدًا إجراء تحديثات أمنية منتظمة للأنظمة، لأن تصحيح الثغرات المعروفة يغلق الأبواب أمام هذه الهجمات. بشكل عام، يمثل استغلال الثغرات الأمنية سباقًا بين المهاجمين

الذين يسعون للاستفادة من أي خلل بأسرع ما يمكن، والمدافعين الذين يحاولون إصلاح ذلك الخلل قبل وقوع الضرر.

هجمات كلمات المرور (Password Attacks)

تشير هجمات كلمات المرور إلى مختلف الأساليب التي يسعى من خلالها المهاجمون إلى كشف كلمات المرور أو تجاوزها من أجل الوصول غير المصرح به إلى نظام أو حساب محمي. نظرًا لأن كلمة المرور هي المفتاح الشائع لحماية الحسابات والبيانات، فهي هدف رئيسي للقراصنة. تستخدم هذه الهجمات طرقًا عدة لكشف كلمة المرور الصحيحة، سواء عبر التخمين المباشر أو سرقة كلمة المرور بوسائل ملتوية.

أحد الأساليب الشائعة في هجمات كلمات المرور هو **الهجوم بالقوة الغاشمة (Brute Force)**، حيث يحاول المهاجم تجربة عدد كبير جدًا من التركيبات الممكنة لكلمة المرور بشكل منهجي حتى يجد التركيبة الصحيحة. أسلوب آخر هو **هجوم القاموس (Dictionary Attack)**، والذي يعتمد على تجربة قائمة من الكلمات أو العبارات الشائعة وكلمات المرور التي تم تسريبها مسبقًا، على افتراض أن الكثير من المستخدمين يختارون كلمات مرور ضعيفة أو متوقعة. إذا كانت كلمة المرور بسيطة أو شائعة الاستخدام، فإن هذه الهجمات قد تنجح في وقت قصير نسبيًا. بالإضافة إلى ذلك، هناك أساليب أخرى مثل التصيد الاحتيالي لسرقة كلمة المرور مباشرة من المستخدم، أو استخدام **برامج مراقبة لوحة المفاتيح** لالتقاط ما يكتبه المستخدم سرًا. وتجدر الإشارة إلى أن إعادة استخدام نفس كلمة المرور عبر حسابات متعددة تزيد بشكل كبير من خطر الاختراق؛ فإذا تمكن المهاجم من الحصول على كلمة المرور من خلال اختراق أحد المواقع، سيحاول استخدامها للدخول إلى حسابات الضحية الأخرى في مواقع وخدمات مختلفة. لهذا يُنصح دوماً باختيار كلمات مرور قوية وفريدة لكل حساب وتغييرها بشكل دوري لضمان مستوى أعلى من الحماية.

هجمات السحابة (Cloud Attacks)

هجمات السحابة تستهدف البنية التحتية والخدمات السحابية التي أصبحت جزءًا أساسيًا من عمليات الكثير من المؤسسات والأفراد. **الحوسبة السحابية** تعني تخزين البيانات وتشغيل الخدمات عبر خوادم على الإنترنت بدلاً من وجودها على أجهزة محلية خاصة بالمستخدم. هذا التحول إلى السحابة جلب معه فوائد كبيرة، لكنه في المقابل أوجد ساحة جديدة للهجمات إذا لم تكن إعدادات الأمان قوية بما يكفي. في هجمات السحابة، يستغل المهاجمون أي ضعف أو خطأ في تكوين الخدمات السحابية أو أي ثغرة في أنظمة الحماية الخاصة بها للوصول إلى البيانات الحساسة أو لتعطيل تلك الخدمات.

من الأمثلة الشائعة لهجمات السحابة أن يقوم المهاجم بالبحث عن **تهيئات خاطئة أو ضعيفة** في إعدادات الخدمات السحابية. على سبيل المثال، قد تُترك قاعدة بيانات سحابية دون كلمة مرور أو بقيود وصول ضعيفة، فيتمكن المهاجم من استعراض محتوياتها بسهولة. أو ربما يتم تسريب **مفاتيح الوصول (Access Keys)** الخاصة بحساب إحدى الشركات على منصة سحابية ما، وحينها يستطيع المهاجم استخدام تلك المفاتيح للدخول مباشرة إلى موارد الشركة المخزنة في السحابة. نتيجة مثل هذه الاختراقات تكون كارثية في كثير من الأحيان نظرًا لحساسية وضخامة البيانات المخزنة على السحابة، والتي قد تشمل معلومات عملاء أو أسرار تجارية أو أنظمة تشغيلية مهمة. علاوة على ذلك، قد تؤدي هجمات السحابة إلى تعطيل خدمات حيوية تقدمها الشركات لمستخدميها إذا تمكن المهاجم من إيقاف الآلات الافتراضية أو تشويه البيانات. ولذلك، أصبحت أمن السحابة جزءًا لا يتجزأ من أمن المعلومات الشامل، ويتطلب متابعة مستمرة لضمان عدم وجود ثغرات أو أخطاء تكوين قابلة للاستغلال.

هجوم الوسيط (Man-in-the-Middle)

هجوم الرجل في المنتصف أو "الوسيط" هو نوع من الهجمات يقوم فيه المهاجم باعتراض الاتصال بين طرفين بشكل خفي، بحيث ينجح في إدخال نفسه بينهما والتظاهر لكل طرف بأنه الطرف الآخر. بعبارة أخرى، يصبح المهاجم **وسيطًا خبيثًا** في

المحادثة أو تبادل البيانات دون علم الطرفين الشرعيين. نتيجة لذلك، يستطيع قراءة وتخزين وربما تعديل كل البيانات التي تمر بين الطرفين.

تحدث هجمات الوسيط غالبًا في البيئات التي لا تكون فيها الاتصالات مشفرة بشكل جيد. مثال شائع هو شبكات الـ Wi-Fi العامة المفتوحة (مثل المتوفرة في المقاهي أو الأماكن العامة) والتي لا تستخدم بروتوكولات تشفير قوية. في مثل هذه الحالة، قد يقوم المهاجم بإنشاء نقطة اتصال لاسلكية وهمية أو استغلال ضعف إعدادات الشبكة للتنصت على حركة مرور البيانات. فعندما يتصل المستخدم الضحية بموقع ويب دون طبقة حماية (أي بدون استخدام **HTTPS** الآمن مثلاً)، يمكن للمهاجم التقاط المعلومات المرسلة - مثل كلمات المرور أو بيانات البطاقات البنكية - والتجسس عليها. الأسوأ من ذلك، يستطيع المهاجم أحيانًا تعديل البيانات أثناء انتقالها. فمثلاً، قد يغير محتوى رسالة أو يعيد توجيه الضحية إلى موقع مزيف دون أن يشعر المستخدم بشيء غير طبيعي. إن خطورة هجوم الوسيط تكمن في قدرته على تجاوز الحماية إذا كانت البيانات غير مشفرة، ولذلك يعد استخدام بروتوكولات التشفير و**الشبكات الافتراضية الخاصة (VPN)** من أفضل الممارسات لضمان سرية الاتصال وحمايته من أعين المتطفلين.

هجمات يوم الصفر (Zero-Day Attacks)

هجمات يوم الصفر هي هجمات تستغل ثغرات أمنية **جديدة وغير معروفة** لمطوري البرمجيات أو لخبراء الأمن عند وقوع الهجوم. يطلَق على الثغرة مصطلح "يوم الصفر" لأنها تُكتشف وتُستغل قبل أن يكون لدى المطور أي فرصة (صفر أيام) لإصلاحها أو إصدار ترقية لسدّها. في اللحظة التي يتم فيها الكشف عن الثغرة لأول مرة من قبل المهاجم (أو ربما باحث أمني)، يكون السباق قد بدأ بين المهاجمين الذين يسعون لاستغلالها بسرعة، وبين فرق التطوير التي تسارع لإعداد تصحيح (Patch) قبل انتشار الاستغلال على نطاق واسع.

تعتبر هجمات يوم الصفر من أخطر الهجمات نظرًا لعدم وجود دفاعات مسبقة تجاهها في أغلب الأحيان. بما أن الثغرة غير معروفة مسبقًا، فإن برامج مكافحة الفيروسات وأنظمة الحماية التقليدية قد لا تكتشف الهجوم في بدايته. يستغل المهاجم عنصر المفاجأة هذا لتحقيق اختراق سريع قبل انكشاف أمر الثغرة. أحيانًا يتم تداول الثغرات غير المعروفة في أسواق سوداء بين مجرمي الإنترنت لقيمتها العالية، حيث يمكن استخدامها في التجسس الإلكتروني أو مهاجمة أهداف استراتيجية. وعندما يتم الإعلان عن وجود ثغرة صفرية بعد استغلالها، يكون الضرر قد حدث بالفعل في كثير من الحالات. إن التصدي لهجمات يوم الصفر يمثل تحديًا كبيرًا؛ فهو يتطلب مزيجًا من تحديث مستمر للأنظمة بمجرد توفر ترقيعات أمان، واستخدام طبقات متعددة من الحماية (كالكشف عن السلوك الشاذ للبرامج) للتعرف على أي نشاط مريب، إضافة إلى الاستعانة بفرق مختصة لاختبار الاختراق واكتشاف الثغرات قبل أن يصل إليها المهاجمون.

هجمات سلسلة التوريد (Supply Chain Attacks)

في هجمات سلسلة التوريد، لا يستهدف المهاجم ضحيته بشكل مباشر منذ البداية، بل يقوم بدلًا من ذلك بضرب الحلقة الأضعف أو الأقل حذرًا في سلسلة التوريد الخاصة بالضحية. **سلسلة التوريد** في السياق التقني قد تشمل البرمجيات أو الأجهزة أو الخدمات التي تحصل عليها المؤسسة من موردين خارجيين. إذا تمكن المهاجم من اختراق أحد هؤلاء الموردين أو التلاعب بالمنتجات قبل وصولها إلى الضحية، فسيكون قد مهّد الطريق للوصول إلى الهدف الحقيقي بوسيلة غير مباشرة وخادعة.

تتخذ هجمات سلسلة التوريد أشكالًا متعددة. أحد السيناريوهات الخطيرة هو أن يقوم المهاجم بإضافة تعليمات برمجية ضارة إلى برنامج شائع الاستخدام أثناء عملية تطويره أو تحديثه لدى الشركة المزودة. عندما تقوم المؤسسات أو المستخدمون بتنزيل التحديث الجديد للبرنامج - ظنًا منهم أنه صادر من جهة موثوقة - تنتقل البرمجية الخبيثة إليهم دون أي شك. مثال آخر هو استهداف شركة تقدم خدمات تقنية

لجهات عديدة؛ فإذا نجح المهاجم باختراق أنظمة تلك الشركة، يمكنه استغلال الثقة والعلاقة بين المزود وعملائه لتنفيذ هجوم واسع على كل العملاء دفعة واحدة. تكمن خطورة هجمات سلسلة التوريد في أن مصدر الهجوم في الظاهر موثوق به (تحديث رسمي، أو برنامج معروف، أو شريك أعمال موثوق)، ما يصعّب الكشف المبكر عن الاختراق. لقد شهد العالم الإلكتروني حوادث بارزة من هذا النوع تسببت في أضرار جسيمة طالت آلاف الضحايا عبر العالم. من أجل مواجهة هذا الخطر، بات من الضروري للشركات مراقبة أمن موردّيها وفحص البرمجيات والأجهزة الواردة من مصادر خارجية للتأكد من سلامتها قبل استخدامها.

هجمات حقن SQL (SQL Injection)

هجمات حقن SQL هي نوع من هجمات تطبيقات الويب يستغل فيها المهاجم عدم قيام التطبيق بالتحقق بشكل صحيح من مدخلات المستخدم قبل استخدامها في استعلامات قاعدة البيانات. يقوم المهاجم في هذا النوع من الهجوم بإدخال أو "حقن" أوامر SQL خبيثة في حقول الإدخال المتاحة للمستخدم على الموقع، مثل حقول اسم المستخدم/كلمة المرور في نموذج تسجيل الدخول أو شريط البحث أو أي مدخل نصي آخر. إذا كان التطبيق مصابًا بثغرة حقن SQL، فسيعالج هذه الأوامر الضارة كجزء من الاستعلام الحقيقي، مما يتيح تنفيذها على قاعدة بيانات الموقع.

عندما تنجح هجمات حقن SQL، تكون العواقب وخيمة على أمن البيانات. قد يتمكن المهاجم من **استعراض معلومات حساسة** من قاعدة البيانات لم يكن من المفترض أن يطلع عليها - كالحصول على قائمة بأسماء المستخدمين وكلمات المرور (بشكل مشفّر أو حتى بنص واضح إذا كانت الحماية ضعيفة)، أو استخراج بيانات العملاء والأرقام المالية المخزنة. بالإضافة إلى سرقة البيانات، قد ينجح المهاجم أيضًا في **تعديل البيانات** المخزنة أو حذفها، مما يسبب تلفًا وأضرارًا لسلامة المعلومات. في بعض السيناريوهات، يمكن لهجوم حقن SQL أن يسمح بتخطي إجراءات المصادقة (مثلاً الدخول إلى حساب دون معرفة كلمة المرور عبر استغلال

الثغرة)، أو حتى السيطرة الكاملة على الخادم إذا تمكن المهاجم من تنفيذ أوامر نظام عبر قاعدة البيانات. لذا تعتبر هجمات حقن SQL من أخطر الثغرات في تطبيقات الويب، ويجب على المطورين التأكد من استخدام أساليب برمجية آمنة مثل *تعبئة المعلمات* (Parameterized Queries) والتحقق الصارم من صحة المدخلات لمنع إدخال أي أوامر غير متوقعة إلى قواعد البيانات.

هجمات التصيد المستهدف (Spear Phishing)

هجمات التصيد المستهدف (أو ما يعرف أيضًا بالتصيد الاحتيالي الموجّه) هي نسخة أكثر تطورًا وخصوصية من هجمات التصيد الاحتيالي التقليدية. على عكس التصيد العام الذي يُرسل إلى عدد كبير من الناس بشكل عشوائي، يستهدف التصيد الموجّه فردًا معينًا أو منظمة محددة بعينها. يقوم المهاجم في هذه الحالة بجمع معلومات مفصلة عن الضحية المحتملة من خلال البحث في المصادر المتاحة (مثل ملفات تعريف وسائل التواصل الاجتماعي أو مواقع الشركة أو حتى من خلال تسريبات بيانات سابقة). بعد ذلك، يستخدم المهاجم هذه المعلومات لصياغة رسالة بريد إلكتروني أو رسالة نصية تبدو شديدة المصداقية والخصوصية بالنسبة للضحية.

قد يتظاهر المهاجم في هجوم التصيد المستهدف بأنه زميل في العمل، أو مدير في الشركة، أو جهة تربطها علاقة بالضحية، ويستخدم تفاصيل حقيقية (كذكر اسم مشروع يعمل عليه الضحية، أو الإشارة إلى زملاء مشتركين) ليضفي شرعية على محتوى رسالته. وبسبب هذه **الدرجة العالية من التخصيص** في الهجوم، يكون من الصعب على الشخص المستهدف تمييز الرسالة الاحتيالية لأنها مصممة لتنسجم تمامًا مع سياقه. عادةً ما تحتوي رسالة التصيد الموجّه على طلب يقوم بدفع الضحية لأداء إجراء ما يخدم المهاجم - كالنقر على رابط يؤدي إلى موقع مزيف يشبه موقع الشركة الداخلي، أو فتح ملف مرفق يحتوي على برمجية خبيثة، أو إفشاء معلومات سرية ظنًا منه أنه يرسلها للشخص الصحيح. وغالبًا ما تُستخدم هجمات التصيد المستهدف كمرحلة أولى لاختراق الشركات والمؤسسات؛ فبمجرد خداع أحد

الموظفين وتسريب بيانات دخوله، يمكن للمهاجم التغلغل أكثر داخل شبكة المؤسسة. لذلك يعد التصيد المستهدف من أخطر التهديدات السيبرانية الحديثة، حيث يتطلب مواجهته تدريبًا واعيًا للمستخدمين على التحقق من هوية المرسلين وعدم الوثوق التام في رسائل البريد الإلكتروني، حتى لو بدت مخصصة وشخصية.

هجمات التزوير عبر البريد الإلكتروني (Email Spoofing)

هجمات التزوير عبر البريد الإلكتروني هي أسلوب خداعي يقوم فيه المهاجم بتزييف عنوان البريد الإلكتروني للمرسِل بحيث يبدو البريد الوارد للضحية وكأنه من جهة معروفة أو شخص موثوق، في حين أنه في الواقع قادم من المهاجم نفسه. هذا النوع من التزوير يستغل إحدى نقاط الضعف القديمة في نظام البريد الإلكتروني، حيث إن البروتوكولات الأساسية لإرسال البريد (مثل **SMTP**) لم تُصمَّم منذ البداية للتحقق الصارم من هوية المرسل. نتيجة لذلك، يستطيع المهاجم تعديل معلومات رأس الرسالة (Header) وتحديد اسم وعنوان مزيفين في خانة المرسِل.

يهدف المهاجم من خلال **انتحال البريد الإلكتروني** إلى خداع المستقبل ودفعه للتفاعل مع الرسالة كما لو كانت شرعية تمامًا. غالبًا ما تُستخدم هذه التقنية بالتزامن مع **هجمات التصيد الاحتيالي**. فعلى سبيل المثال، قد تصل الضحية رسالة تبدو أنها من مصرفها تطلب منها تحديث بيانات حسابها عبر رابط معين؛ وبما أن البريد الإلكتروني يبدو أنه صادر عن عنوان المصرف الرسمي، فإن احتمال انخداع الضحية يكون أكبر. مثال آخر هو رسائل تبدو من زميل عمل أو مدير، تطلب بشكل عاجل مشاركة معلومات سرية أو تحويل أموال لمكان ما، بينما الحقيقة أن المهاجم هو من أرسلها. تكمن خطورة هجمات التزوير عبر البريد الإلكتروني في قدرتها على تجاوز حذر المستخدم إذا كان يثق بالمصدر الذي يدّعي البريد الانتماء إليه. قد يفتح الضحية مرفقات خبيثة أو يضغط على روابط ضارة أو يسلم بيانات قيمة ظنًا منه أنه يتعامل مع جهة آمنة. من أجل مواجهة هذا النوع من الهجمات، يتم استخدام تقنيات تحقق

مثل **SPF** و**DKIM** و**DMARC** التي تساعد الخوادم على كشف الرسائل المزورة، لكن تظل يقظة المستخدم وفحصه لعناوين البريد بعناية عناصر أساسية للوقاية.

هجمات التشفير والتخمين (Brute Force & Dictionary Attacks)

هذا القسم يضم نوعين شائعين من أساليب اختراق كلمات المرور يعتمدان على التجربة والتخمين:

1. هجوم القوة الغاشمة (Brute Force): في هجوم القوة الغاشمة، يحاول المهاجم كسر كلمة مرور الحساب عن طريق تجربة كل تركيبة ممكنة من الأحرف والأرقام والرموز حتى يصل إلى الكلمة الصحيحة. يقوم برنامج مخصص أو سكريبت آلي بتوليد المحاولات بشكل سريع جدًا ويمكنه تجربة آلاف أو ملايين التخمينات في الدقيقة الواحدة، بحسب قوة المعالجة المتوفرة. إذا كانت كلمة المرور قصيرة أو بسيطة (مثل كلمة مكونة من أرقام قليلة أو كلمة شائعة)، فإن الهجوم بالقوة الغاشمة قد ينجح خلال وقت قصير نسبيًا. أما إذا كانت كلمة المرور طويلة ومعقدة، فإن عدد الاحتمالات سيكون هائلاً، ما يجعل نجاح الهجوم مسألة تتطلب وقتًا ربما يكون خارج نطاق المعقول (قد يستغرق سنوات طويلة جدًا). على الرغم من ذلك، مع تزايد قدرة الحوسبة وتوفر بطاقات رسومات ومعالجات قوية، تبقى كلمات المرور الضعيفة معرضة لخطر الكسر عبر القوة الغاشمة. غالبًا ما يستهدف المهاجمون الملفات أو الأنظمة المشفرة أيضًا بهذا الأسلوب، محاولين العثور على المفاتيح الصحيحة لفك التشفير بتجربة كل احتمال ممكن.

2. هجوم القاموس (Dictionary Attack): يعتبر هجوم القاموس تقنية أكثر ذكاءً من القوة الغاشمة التقليدية، حيث لا يحاول تجربة كل تركيبة عشوائية، بل يعتمد على قائمة معدّة مسبقًا من كلمات المرور الشائعة أو الكلمات الموجودة في القاموس وأي معلومات قد تكون مرتبطة بالهدف. تأتي تسمية "القاموس" من فكرة استخدام قائمة كلمات محتملة كما يجد المرء في قاموس اللغة. في الواقع، يستعين المهاجمون بملفات تحتوي على مئات الآلاف أو ملايين كلمات المرور التي تم تسريبها

سابقًا في حوادث اختراق، أو كلمات متداولة مثل "password123" وأسماء الأشخاص والأماكن المشهورة وتواريخ الميلاد وما شابه. إن افتراض الهجوم هنا هو أن الكثير من المستخدمين يعتمدون كلمات مرور يسهل تخمينها أو شائعة الاستعمال، وبالتالي احتمال النجاح مرتفع بتجربة تلك القائمة أولًا بدل إضاعة الوقت على تركيبات عشوائية بالكامل. هجوم القاموس يكون فعالًا بشكل خاص إذا كان بوسع المهاجم الحصول على **معلومات شخصية** عن الضحية تساعده في تضييق نطاق التخمين (كمعرفة اسم حيوان أليف أو تاريخ معين يستخدمه الشخص في كلمات مروره).

كلٌ من هجومي القوة الغاشمة والقاموس يستغلان نقطة ضعف أساسية هي **اختيار كلمات مرور ضعيفة أو متوقعة**. لتقليل فعالية هذه الهجمات، تستخدم العديد من أنظمة المواقع والخدمات تقنيات حماية إضافية، مثل وضع حد أعلى لعدد المحاولات الفاشلة قبل إقفال الحساب مؤقتًا، أو إضافة اختبار **CAPTCHA** لمنع التصريحات الآلية. ويبقى على المستخدمين أنفسهم دور مهم في الوقاية، وذلك عبر اختيار كلمات مرور قوية تتضمن مزيجًا من الأحرف الكبيرة والصغيرة والأرقام والرموز، وتجنب الكلمات الشائعة، بالإضافة إلى تفعيل المصادقة متعددة العوامل حيثما أمكن. كل هذه الإجراءات تجعل مهمة المهاجم أصعب بكثير في استخدام أساليب التخمين والكسر.

هجمات البرامج الإعلانية الضارة (Adware)

البرامج الإعلانية الضارة هي نوع من البرمجيات يندرج تحت فئة البرمجيات الخبيثة، هدفه الأساسي عرض الإعلانات للمستخدم بشكل مزعج وغير مرغوب فيه، وربما القيام بأنشطة خفية أخرى تضر بالجهاز أو الخصوصية. **البرمجيات الإعلانية (Adware)** عمومًا هي برامج تُدمج في تطبيقات أو مواقع لعرض إعلانات تلقائية بغرض تحقيق الربح عبر النقرات أو المشاهدات. بعضها قد يصنف نظريًا كغير ضار تمامًا (مجرد إعلانات مزعجة)، لكن عندما نصفها بأنها "ضارة" فإننا نشير إلى تلك التي

تتصرف بعدوانية وتُثبَّت على الجهاز من دون موافقة واضحة، وتقوم بتغييرات غير مرغوبة في النظام.

غالبًا ما تتسلل البرامج الإعلانية الضارة إلى الأجهزة عند قيام المستخدم بتثبيت برنامج مجاني مجهول المصدر أو من مصادر غير رسمية، حيث يكتشف لاحقًا أن ذلك البرنامج كان محملًا بحزمة إعلانية مزعجة. كذلك قد يجد المستخدم جهازه مصابًا ببرمجيات إعلانية بعد النقر على نافذة منبثقة خبيثة في موقع غير موثوق، تؤدي دون علمه إلى تنزيل تطبيق إعلاني. بمجرد الإصابة، تبدأ هذه البرامج بعرض الإعلانات المنبثقة في كل مكان على المتصفح أو حتى على سطح المكتب، مما يعوق تجربة الاستخدام الطبيعية. قد تعيد توجيه صفحات الويب تلقائيًا إلى مواقع إعلانية أو مواقع مشبوهة، وتغير صفحة البداية لمحرك البحث إلى صفحة مليئة بالإعلانات. بالإضافة إلى الإزعاج، تقوم بعض البرامج الإعلانية بجمع بيانات عن سلوك المستخدم على الإنترنت - مثل مواقع الويب التي يزورها أو مصطلحات البحث التي يستخدمها - وذلك بهدف استهدافه بإعلانات أكثر ملاءمة (مما يعد انتهاكًا للخصوصية). الأخطر من ذلك أن وجود برنامج إعلاني ضار قد يفتح **ثغرة خلفية** يمكن لبرمجيات خبيثة أخرى أشد خطورة الدخول منها، أو قد يقوم البرنامج ذاته بتنزيل برمجيات إضافية أكثر ضررًا دون علم المستخدم. بشكل عام، على الرغم من أن **البرامج الإعلانية الضارة** قد تبدو أقل تهديدًا مقارنة بالفيروسات أو برامج الفدية، فإنها لا تزال تشكل خطرًا حقيقيًا على أمن الجهاز وخصوصية البيانات. فهي تجعل النظام أبطأ وأقل استقرارًا، وتنتهك خصوصية المستخدم، وقد تكون خطوة أولى لإصابات أخطر. لذلك ينبغي التعامل معها على محمل الجد وإزالتها باستخدام أدوات مكافحة البرامج الضارة حال اكتشافها، وتوخي الحذر عند تثبيت أي برنامج مجاني بتجنب البرامج مجهولة المصدر أو عروض التثبيت غير الموثوقة.

الهندسة الاجتماعية

1. مقدمة عن الهندسة الاجتماعية

الهندسة الاجتماعية (Social Engineering) هي أسلوب احتيالي يستغل الثقة والعنصر البشري لاختراق الأنظمة والحصول على المعلومات الحساسة دون الحاجة إلى وسائل تقنية متقدمة. بدلاً من محاولة اختراق جدران الحماية أو الأنظمة المشفرة مباشرةً، يلجأ المهاجم إلى **اختراق عقول البشر** من خلال الخداع والإيهام. تعتبر الهندسة الاجتماعية من أخطر أنواع الهجمات السيبرانية لأن **العنصر البشري** غالبًا ما يكون الحلقة الأضعف في منظومة الأمن؛ فمهما بلغت قوة التدابير التقنية، يبقى من السهل استهداف الموظفين أو المستخدمين بخداع نفسي لإقناعهم بالكشف عن كلمات المرور أو المعلومات السرية أو القيام بإجراءات تضر بالأمن.

تعَد هجمات الهندسة الاجتماعية خطيرة بشكل خاص بسبب قدرتها على تجاوز العديد من الضوابط الأمنية التقنية. فبدلاً من استغلال ثغرة برمجية في نظام الكمبيوتر، يستغل المهاجم نقاط الضعف البشرية مثل الفضول، والثقة الزائدة، والرغبة في المساعدة، أو الخوف. ونظرًا لفاعلية هذه الأساليب، تشير العديد من التقارير إلى أن جزءًا كبيرًا من الاختراقات الأمنية الناجحة يعتمد بشكل أساسي على حيل الهندسة الاجتماعية. في هذا الفصل سنتعرف على مفهوم الهندسة الاجتماعية، وأنواعها، وكيفية تنفيذها، وأساليبها المختلفة، بالإضافة إلى أمثلة توضيحية وتدابير للحماية منها.

2. تعريف الهندسة الاجتماعية

يمكن تعريف الهندسة الاجتماعية ببساطة بأنها **فن الخداع والتلاعب بالناس** بهدف حملهم على إفشاء معلومات سرية أو أداء تصرفات تخدم مصلحة

المهاجم. يستخدم المهاجم مختلف الحيل النفسية لإقناع الضحية بأنه شخص موثوق أو ينتمي لجهة ذات سلطة أو حق، مما يدفع الضحية إلى الامتثال لطلباته دون إدراك النية الخبيثة وراءها. قد تتم الهجمات عبر وسائط مختلفة مثل الهاتف أو البريد الإلكتروني أو حتى وجهًا لوجه، وجميعها تشترك في أنها تستغل **الثقة الطبيعية أو قلة وعي الضحية** بالقواعد الأمنية.

على سبيل المثال، قد يدّعي المهاجم أنه موظف في قسم تقنية المعلومات بالشركة ويتصل بأحد الموظفين مدعيًا وجود مشكلة تقنية تتطلب منه الحصول على كلمة المرور لإصلاحها. إذا لم يكن الموظف مدربًا على الحذر، فقد يقدم له المعلومات معتقدًا أنه يساعد زميلًا له، وفي الحقيقة هو يكشف كلمة مروره لمحتال. مثال آخر شائع هو تلقي رسالة بريد إلكتروني تبدو وكأنها من بنك موثوق يطلب من المستخدم تحديث معلومات حسابه عبر رابط مزيف؛ عند الضغط عليه وإدخال المعلومات، يكون المستخدم قد وقع ضحية احتيال وسلم بياناته للمهاجم.

3. أنواع الهندسة الاجتماعية

هناك عدة أنواع وأساليب فرعية تندرج تحت مفهوم الهندسة الاجتماعية، يستخدمها المهاجمون بحسب السيناريو والموقف. من أبرز هذه الأنواع ما يلي:

- **التصيد الاحتيالي (Phishing):** يعد التصيد الاحتيالي من أشهر أساليب الهندسة الاجتماعية. يقوم المهاجم بإرسال رسائل مزيفة (عادة عبر البريد الإلكتروني، وأحيانًا عبر رسائل نصية أو وسائل التواصل الاجتماعي) تدّعي أنها من جهة موثوقة مثل بنك أو مؤسسة معروفة. تحتوي هذه الرسائل على روابط خبيثة أو مرفقات ضارة تهدف إلى خداع الضحية للنقر عليها. بمجرد تفاعل الضحية مع الرسالة (كالنقر على الرابط وتعبئة نموذج مزيف بمعلوماته السرية أو تنزيل ملف)، يحصل المهاجم على

تلك المعلومات أو يتمكن من زرع برمجيات خبيثة في جهاز الضحية.

- **انتحال الهوية:** في هذا الأسلوب ينتحل المهاجم شخصية شخص آخر للحصول على ثقة الضحية. قد يكون الانتحال بتقمص هوية موظف ذو صلاحيات، أو مدير في الشركة، أو زميل عمل، أو حتى شخصية معروفة للضحية. الهدف هو كسب ثقة المستهدف بسرعة ودفعه للكشف عن معلومات أو تنفيذ أوامر ظنًا منه أنه يتعامل مع شخص موثوق. على سبيل المثال، قد يتلقى الموظف اتصالاً أو رسالة من شخص يدّعي أنه المدير التنفيذي يطلب منه بشكل عاجل إرسال بيانات سرية أو تحويل أموال.

- **الهندسة الاجتماعية المقلوبة:** هذا النوع يُعرف بـ "الهندسة الاجتماعية العكسية" وفيه يعكس المهاجم الأسلوب التقليدي. بدلًا من أن يبادر بالاتصال بالمستهدف مباشرة، يقوم بصنع ظرف يدفع الضحية نفسه إلى الاتصال بالمهاجم وطلب المساعدة منه. قد يقوم المهاجم مثلاً بنشر مشكلة وهمية أو خلق حالة طارئة داخل المؤسسة (كإرسال رسالة لجميع الموظفين بأن هناك خللًا تقنيًا خطيرًا يجب حله)، ثم يقدم نفسه كخبير أو شخص قادر على حل المشكلة. عندما يتواصل الضحايا معه طلبًا للمساعدة، يستغل ثقتهم للحصول على المعلومات الحساسة. الفكرة هنا أن الضحية يشعر أنه *اختار* التواصل مع الشخص (المهاجم) مما يعزز مستوى الثقة ولا يشك أنه عملية احتيال.

- **أساليب أخرى:** تشمل الهندسة الاجتماعية أساليب إضافية متنوعة. من بينها **التذرّع (Pretexting)** حيث يختلق المهاجم قصة أو ذريعة مقنعة لخداع الضحية لتقديم المعلومات (مثل ادعاء المهاجم أنه مسؤول تحقيق أمني يحتاج بعض البيانات للتحقق من حادث ما). هناك أيضًا

الإغراء بالطُعم (Baiting) حيث يقدم المهاجم إغراءً للضحية مثل هدية مجانية أو مكافأة لجعله يقوم بفعل معين (كإعطاء بياناته أو تشغيل ملف خبيث؛ مثال على ذلك ترك ذاكرة USB مصابة بالفيروسات في مكان عام مع تسمية مغرية لتشجيع الأشخاص على التقاطها وتشغيلها).
بالإضافة إلى ذلك، يوجد **التصيد الصوتي (Vishing)** الذي يتم عبر مكالمات هاتفية احتيالية، و**التصيد عبر الرسائل النصية (Smishing)** الذي يتم عبر رسائل SMS خبيثة، وغيرها من الطرق التي تتطور باستمرار.

4. مراحل تنفيذ هجوم الهندسة الاجتماعية

عادةً ما يمر المهاجم الاجتماعي بسلسلة من **المراحل المنظمة** لتنفيذ هجومه بنجاح. فهم هذه المراحل يساعدنا على كشف الهجوم وإيقافه في أي خطوة قبل اكتماله. يمكن تلخيص مراحل تنفيذ هجوم الهندسة الاجتماعية فيما يلي:

1. **الوصول إلى الجهة المستهدفة:** في البداية يحدد المهاجم الهدف العام للهجوم، والذي قد يكون شركة أو مؤسسة أو مجموعة أشخاص ضمن جهة معينة. يعمل المهاجم على جمع المعلومات الأولية عن هذه الجهة المستهدفة بوسائل مختلفة مثل البحث عبر الإنترنت، وتتبع حسابات التواصل الاجتماعي، أو استغلال المعارف العامة. الهدف هو فهم هيكلية الهدف وتحديد الثغرات المحتملة في الجانب البشري (مثلاً معرفة من المسؤول عن ماذا، وما هي الخدمات التي تستخدمها الشركة، ومن الموظفون الجدد).

2. **اختيار الضحية المناسبة:** بعد فهم الجهة المستهدفة، ينتقل المهاجم لتحديد **فرد أو أفراد محددين** داخلها ليركز عليهم الهجوم. غالبًا ما يبحث المهاجم عن شخص لديه صلاحيات أو إمكانية وصول لمعلومات مهمة،

ويُفضل أن يكون هذا الشخص أقل خبرة أمنية أو أكثر قابلية للانخداع. على سبيل المثال، قد يختار المهاجم موظفًا جديدًا لا يعرف جميع إجراءات الأمن بعد، أو موظفًا في قسم يحتوي على معلومات حساسة (كقسم الموارد البشرية أو تكنولوجيا المعلومات) أو حتى شخصًا ودودًا يحب مساعدة الآخرين. هذه الخطوة تشمل أيضًا دراسة شخصية الضحية المحتملة وعاداتها واهتماماتها إن أمكن، لتخصيص أسلوب الخداع بما يلائمها.

3. **بناء علاقة وثقة:** في هذه المرحلة يبدأ المهاجم بالتواصل مع الضحية المستهدفة **لبناء جسور الثقة** وكسب المصداقية. قد يتم التواصل عبر مكالمة هاتفية، أو بريد إلكتروني، أو لقاء شخصي، أو عبر رسائل مواقع التواصل الاجتماعي، حسب السيناريو. المفتاح هنا هو أن يبدو المهاجم صادقًا وذا مصداقية عالية، وغالبًا ينتحل هوية مقبولة لدى الضحية (مثل زميل عمل، أو مسؤول تقني، أو صديق لصديق). مع مرور الوقت أو خلال المحادثة نفسها، يسعى المهاجم إلى تعزيز شعور الضحية بالأمان تجاهه، كأن يتبادل بعض المعلومات التي تبدو صحيحة لإثبات هويته الوهمية، أو يستخدم اللباقة والإطراء وادعاء الاهتمام لمراكمة الثقة. قد يطرح المهاجم أسئلة غير مباشرة لجمع معلومات إضافية من الضحية دون أن يثير شكوكها.

4. **استغلال العلاقة للحصول على المعلومات أو تنفيذ الأوامر:** بعد أن ينجح المهاجم في كسب ثقة الضحية، ينتقل إلى **مرحلة الاستغلال** الفعلي. يستفيد من العلاقة التي بناها ليطلب من الضحية ما يريده مباشرةً أو بشكل موارب. قد يكون ذلك الطلب الحصول على معلومات سرية (مثل كلمات مرور، بيانات عملاء، تفاصيل مشروع حساس)، أو دفع الضحية إلى القيام بفعل معين (مثل النقر على رابط، أو تحميل ملف

خبيث، أو منح صلاحية دخول). نظرًا لأن الضحية باتت تثق في المهاجم، غالبًا ما تكون استجابتها بالطاعة والامتثال، خاصة إذا تم الطلب بأسلوب يظهر أنه طبيعي أو ضمن سياق العمل. عند هذه المرحلة يكون الهجوم قد نجح فعليًا إذا لم يتنبه الضحية ويشك في الأمر. بمجرد حصول المهاجم على مبتغاه، سواء معلومات أو تنفيذ إجراء، يمكنه استخدامها لتحقيق أهدافه الخبيثة كسرقة بيانات أو اختراق أنظمة الشركة من الداخل.

5. أساليب استغلال الضحية

لا يقتصر المهاجمون الاجتماعيون على طريقة واحدة في تنفيذ هجماتهم، بل يستخدمون **عدة أساليب ووسائط للتواصل** مع الضحية واستغلالها. فيما يلي أبرز الأساليب التي يتم عبرها استهداف الضحايا وخداعهم:

- **عبر الهاتف (المكالمات الهاتفية):** الهاتف من أكثر الوسائل شيوعًا في هجمات الهندسة الاجتماعية. يتصل المهاجم بالضحية مدعيًا صفة معينة (كموظف في شركة معروفة أو جهة رسمية) وباستخدام نبرة صوت واثقة وبعض المعلومات الأولية، يبدأ في **استخراج المعلومات تدريجيًا**. على سبيل المثال، قد يقول: "مرحبًا، أنا أحمد من قسم الدعم التقني، ألاحظ وجود مشكلة في حسابك تحتاج تحديث كلمة المرور فورًا لإصلاح خلل أمني." هذا الأسلوب يسمى أحيانًا التصيد الصوتي **(Vishing)**. كثير من الناس يميلون للاستجابة للمكالمات الهاتفية خصوصًا عندما تكون لهجة المتصل احترافية وتحمل طابع الإلحاح.

- **عبر البريد الإلكتروني:** يعد البريد الإلكتروني ساحة رئيسية لهجمات التصيد الاحتيالي والهندسة الاجتماعية. يتلقى الضحية رسالة تبدو وكأنها

من مصدر موثوق (مدير في الشركة، بنك، منصة إلكترونية مشهورة). تتضمن الرسالة محتوى مصممًا بعناية لإقناع الضحية باتخاذ إجراء سريع، مثل: "يجب عليك تحديث بياناتك الآن" أو "تم تعليق حسابك - الرجاء الضغط على الرابط لإعادة تفعيله". غالبًا ما تحتوي الرسالة على **رابط خبيث** يقود إلى صفحة احتيالية تطلب بيانات تسجيل الدخول أو معلومات شخصية، أو قد تحوي **ملفًا مرفقًا ضارًا**. ولأن البريد الإلكتروني يُستخدم أيضًا في العمل والمراسلات الرسمية، قد يصعب أحيانًا على الموظف التمييز بين الرسالة الصحيحة والمزيفة إن لم يكن مدربًا على ذلك.

- **الهندسة العاطفية (استغلال المشاعر):** يعتمد هذا الأسلوب على **التلاعب بمشاعر الضحية** الإنسانية واستغلالها كمدخل للخداع. المهاجمون قد يثيرون مشاعر الخوف والقلق لإجبار الضحية على التصرف بسرعة دون تفكير (مثل رسائل تهديد: "إذا لم تفعل كذا فسيتم تجميد حسابك/معاقبتك فورًا")، أو يستغلون مشاعر الطمع والرغبة في الربح (مثل رسالة تعد بجائزة كبيرة مقابل إدخال بيانات بسيطة)، أو حتى يستغلون التعاطف وحب المساعدة (كأن يتظاهر المحتال بأنه شخص في مأزق ويطلب معونة عاجلة منك). عندما تنجح هذه **الهندسة العاطفية** في تحريك المشاعر، تقل قدرة الضحية على التفكير الناقد، وبالتالي قد يقدم المعلومات طوعًا أو ينفذ ما يُطلب منه تحت تأثير الشعور القوي الذي أثاره المهاجم.

- **سرقة الهوية:** تُعَد سرقة الهوية أسلوبًا قد يكون جزءًا من الهندسة الاجتماعية أو نتيجةً لها. في هذا السياق، قد يقوم المهاجم بالحصول على بيانات شخصية للضحية (مثل بطاقته التعريفية أو معلوماته البنكية) ومن ثم **انتحال شخصية الضحية نفسها** أمام جهات أخرى

لتحقيق مآربه. على سبيل المثال، إذا حصل المهاجم على بيانات موظف (كبياناته الشخصية ورقم هويته ووثائق ما) قد يستخدمها للتواصل مع قسم آخر في الشركة مدعيًا أنه الموظف نفسه للحصول على صلاحيات أو معلومات إضافية. أيضًا تشمل سرقة الهوية إنشاء حسابات أو مراسلات باسم الضحية الحقيقي واستخدامها دون علمه، مما قد يوقعه في مشاكل أمنية أو قانونية. المهاجم الاجتماعي قد لا يكتفي بسرقة المعلومات، بل يستغل هوية الضحية لمزيد من الاختراقات والخداع.

- **استغلال الشائعات:** تنتشر المعلومات والأخبار بسرعة كبيرة عبر وسائل التواصل الاجتماعي وبيئات العمل، ويمكن للمهاجم استغلال **قوة الإشاعة** لخداع الضحايا. قد يقوم بنشر خبر كاذب أو إشاعة داخل منظمة أو بين مجموعة من الناس، مثل إشاعة عن تغيير مهم في إجراءات الشركة أو إشعار أمني عاجل (كظهور فيروس خطير على الشبكة الداخلية). عندما تنتشر الإشاعة ويصبح الجميع قلقين أو متحمسين لمعرفة الحقيقة، يتدخل المهاجم مدعيًا امتلاكه **تفاصيل أو حلولًا** للمشكلة، ويرسل روابط أو تعليمات "لمعالجة الوضع" وهي في الواقع فخ احتيالي. استغلال الشائعات يُمكِّن المخترق من تغليف هجومه بغطاء يبدو موثوقًا بسبب انتشار الحديث عنه، مما يجعل الأشخاص أقل شكًا وأكثر قابلية للامتثال والتفاعل مع توجيهاته.

- **اصطياد بكلمات المرور:** أحد أهم أهداف المهندس الاجتماعي هو الحصول على **كلمات مرور الضحايا** لأنها المفتاح للولوج إلى الأنظمة والحسابات. يلجأ المخترق إلى عدة حيل للإيقاع بالضحية في فخ مشاركة كلمة مروره. من تلك الأساليب إنشاء **صفحات دخول مزيفة** تشبه مواقع معروفة (مثل صفحة وهمية لبريد إلكتروني أو لموقع بنك)

وإيهام الضحية بأنه يحتاج لتسجيل الدخول لسبب ما؛ وبمجرد أن يفعل تكون بياناته السرية قد سُرقت. أسلوب آخر هو ببساطة سؤال الضحية مباشرة عن كلمة المرور تحت ذريعة مقنعة، كما في مثال موظف الدعم التقني الذي يحتاج كلمة المرور "لحل مشكلة عاجلة". قد يستغل المهاجم أيضًا ميل البعض لاستخدام كلمات مرور سهلة أو متكررة، فيقوم **باصطياد الضحية** عبر تخمين كلمة المرور من معلومات متوفرة عنه (تواريخ ميلاد، أسماء أبنائه، فرق مفضلة، إلخ) أو إقناعه بكتابة كلمة المرور في استبيان أو نموذج مزيف. جميع هذه الأساليب تهدف في النهاية إلى كشف **الأسرار الائتمانية** التي يفترض أن تبقى آمنة.

6. أمثلة عملية

لفهم الهندسة الاجتماعية بشكل أوضح، نستعرض فيما يلي **سيناريوهين مبسّطين** يوضحان كيف يمكن لمهاجم أن يستغل سلوك الضحية وثقتها لتحقيق غاياته الخبيثة:

- **سيناريو 1 (موظف شركة يتعرض لخداع عبر الهاتف):** تصوّر أن *سعيد* يعمل موظفًا في قسم الموارد البشرية لشركة ما. يتلقى سعيد مكالمة هاتفية من شخص يقدم نفسه على أنه *محمود* من قسم تقنية المعلومات (الدعم الفني) بالشركة. يبلغ *محمود* (وهو في الحقيقة محتال) سعيد بأن هناك تحديثًا أمنيًا طارئًا يتطلب إعادة ضبط كلمات المرور لجميع موظفي الشركة فورًا، ويشرح الأمر له بنبرة رسمية مستعجلة. يبدي سعيد بعض التحفظ في البداية، لكن *محمود* يذكر له بعض المعلومات الداخلية (ربما حصل عليها مسبقًا من وسائل التواصل أو موقع الشركة، مثل أسماء بعض زملاء سعيد أو تفاصيل مشروع يعمل عليه) مما يعطي انطباعًا بأنه بالفعل موظف حقيقي في

الشركة. يقتنع سعيد بمصداقية المتصل. يطلب *محمود* من سعيد أن يخبره بكلمة مروره الحالية للتحقق من هويته قبل أن يقوم بتغييرها له عن بعد إلى كلمة جديدة مؤقتة. تحت ضغط الموقف ومع لهجة الاستعجال والثقة من طرف المحتال، يفشي سعيد كلمة مروره الحالية عبر الهاتف. بمجرد حصول المهاجم على كلمة المرور هذه، يشكره وينهي المكالمة. الآن أصبح للمهاجم إمكانية دخول الشبكة على أنه *سعيد* والوصول إلى بيانات الموظفين في قسم الموارد البشرية وربما معلومات حساسة أخرى، وكل ذلك تم بخدعة هاتفية بسيطة دون أي اختراق تقني مباشر.

- **سيناريو 2 (مستخدم يتعرض للتصيد عبر البريد الإلكتروني):** يتصفح *خالد* بريده الإلكتروني الشخصي فيجد رسالة جديدة بعنوان "تنبيه أمني: مشكلة في حسابك المصرفي تتطلب تدخلك الفوري". الرسالة تبدو كأنها واردة من بنك خالد الحقيقي، وتحمل شعار البنك ولغة احترافية تخبره بأنه لوحظت نشاطات غير اعتيادية في حسابه ويجب عليه تأكيد هويته فورًا عبر الرابط المرفق وإلا سيتم تجميد الحساب مؤقتًا. يشعر خالد بالقلق على أمواله ويضغط الرابط دون تمهل. يتم توجيهه إلى صفحة ويب تشبه تمامًا موقع البنك الإلكتروني، فيُدخل اسم المستخدم وكلمة المرور الخاصة به مطمئنًا. عند محاولة الضغط على "تسجيل الدخول"، لا يحدث شيء يذكر أو تظهر رسالة خطأ غير مفهومة. ينتابه بعض الشك ويتصل بخدمة عملاء البنك مباشرة، ليتبيّن أن حسابه سليم ولم ترسل أي إشعارات أمنية. هنا يُدرك خالد (ولكن بعد فوات الأوان) أنه وقع ضحية **هجوم تصيد احتيالي**، حيث قام المهاجم بإنشاء صفحة وهمية نسخت بيانات دخوله بمجرد أن أدخلها. في غضون دقائق ربما يستخدم المهاجم تلك المعلومات للدخول إلى حساب خالد الحقيقي وتحويل أموال أو سرقة بياناته المالية. هذا المثال يبيّن كيف يستغل

المخترق **خوف الضحية وقلقه** من خسارة حسابه ليجعله يتصرف بسرعة ويفصح عن معلوماته السرية دون تحقق كافٍ.

هذه السيناريوهات الواقعية (وإن كانت مبسطة) تظهر أن الهندسة الاجتماعية لا تعتمد على تعقيد فني بقدر ما تعتمد على **حسن استغلال المهاجم لثقة الضحية واندفاعها** تحت تأثير الانفعال أو السلطة الوهمية. الكثيرون قد يظنون أنهم لن ينخدعوا بسهولة، ولكن تحت ظروف وضغوط مناسبة يمكن حتى للأفراد الحذرين أن يقترفوا أخطاء جسيمة ما لم يكونوا واعين تمامًا لهذه التكتيكات.

7. تدابير الحماية

لحسن الحظ، يمكن **التصدي لهجمات الهندسة الاجتماعية** وتقليل مخاطرها بشكل كبير عبر اتباع مجموعة من إجراءات الوقاية والتوعية. فيما يلي أهم التدابير التي ينبغي للأفراد والمؤسسات اعتمادها للحماية من هذه الهجمات:

- **الوعي والتدريب:** يعتبر رفع مستوى الوعي لدى الموظفين والأفراد بشأن الهندسة الاجتماعية أفضل أسلحة الدفاع. يجب تقديم دورات تدريبية منتظمة في الأمن السيبراني تشرح أساليب الهندسة الاجتماعية الشائعة وكيفية التعرف عليها. كلما فهم المستخدم الحيل النفسية التي يلجأ إليها المخترقون (كالتصيد والإغراء والاستعجال غير المبرر)، زادت قدرته على الشك والتفكير قبل التجاوب مع أي طلب مريب. التدريب العملي على سيناريوهات خداعية (مثل إجراء اختبارات تصيد تجريبية داخل المؤسسة) مفيد جدًا لصقل مهارات الموظفين في التمييز بين ما هو مشروع وما هو احتيال.

- **عدم الإفصاح عن المعلومات الحساسة بسهولة:** ينبغي ترسيخ مبدأ "التشارك الحذر للمعلومات". أي معلومات شخصية أو بيانات عمل حساسة يجب التعامل معها كأصول ثمينة لا تُعطى إلا عند ضرورة قصوى ومع التأكد التام من هوية الطالب وسبب الطلب. على الفرد أن يتجنب الكشف عن كلمات المرور، أو معلومات الهوية، أو تفاصيل المشاريع الداخلية لأي شخص عبر الهاتف أو البريد الإلكتروني مهما كانت صفته، إلا بعد التحقق الصارم. حتى ضمن بيئة العمل، **مبدأ الأقل معرفة** ينبغي أن يطبق، بمعنى أن كل شخص لا يعرف إلا ما يحتاجه لعمله فقط ولا يشارك معلومات إلا في حدود ضيقة.

- **التحقق من الهوية قبل مشاركة البيانات:** من المهم دائمًا **التحقق المزدوج** عند التعامل مع أي طلب غير اعتيادي للمعلومات. إذا وصلك اتصال أو رسالة من شخص يدعي أنه مسؤول أو جهة معينة ويطلب شيئًا سريًا، فلا تكتفِ بما يقوله لإثبات هويته. قم بمحاولة تأكيد هويته عبر قناة تواصل مستقلة: اتصل بالرقم الرسمي المعروف لتلك الجهة أو الشخص، أو تواصل مع المؤسسة مباشرة للتثبت. في الشركات، يمكن وضع إجراءات داخلية مثل أن أي طلب عبر البريد لتغيير كلمة مرور أو الحصول على بيانات حساسة يجب أن يتم التأكد منه بالاتصال المباشر بالمرسل أو بمشرفه. هذه الطبقة الإضافية من التأكد قد تبدو مجهودًا إضافيًا لكنها غالبًا ما تفرق بين الوقوع في الفخ وبين إفشاله.

- **إعدادات الأمان الرقمية الأساسية:** اتباع **ممارسات الأمن الرقمي الجيدة** يضيف طبقات حماية تحدّ من أثر أي معلومة قد يحصل عليها المهاجم الاجتماعي. من هذه الممارسات استخدام **كلمات مرور قوية وفريدة** لكل حساب وتحديثها دوريًا، بحيث لو تسرّبت كلمة مرور لحساب ما لا يؤدي ذلك إلى اختراق جميع الحسابات الأخرى. أيضًا **تفعيل**

المصادقة الثنائية (2FA) على الحسابات الهامة، فحتى لو عرف المخترق كلمة المرور فلن يتمكن من الدخول بدون رمز تحقق إضافي يصل لصاحب الحساب الحقيقي. يُنصح كذلك بتحديث البرمجيات وأنظمة التشغيل باستمرار لسد الثغرات الأمنية، واستعمال برامج مكافحة الفيروسات وجدران الحماية لتقليل فرص نجاح الهجمات التقنية التي قد تتبع عمليات الهندسة الاجتماعية. وبشكل عام، فإن وجود سياسات واضحة لأمن المعلومات في المؤسسة والتزام الموظفين بها يوفر إطارًا صارمًا يجعل من الصعب على المهاجم استغلال الثغرات البشرية.

8. الخلاصة

- الهندسة الاجتماعية هي **هجوم على العنصر البشري** يستغل نقاط الضعف النفسية بدلاً من الثغرات التقنية، مما يجعلها خطرة جدًا وشائعة في الاختراقات السيبرانية الحديثة.

- تتخذ هجمات الهندسة الاجتماعية أشكالًا متعددة مثل التصيد الاحتيالي عبر البريد، والمكالمات الهاتفية الاحتيالية، وانتحال الهوية، والإغراء بالمكاسب الوهمية، وحتى **الهندسة الاجتماعية المقلوبة** حيث يخدع المهاجم الضحية ليتواصل معه بنفسه.

- عادةً ما يمر المهندس الاجتماعي بمراحل **جمع المعلومات عن الهدف ثم اختيار الضحية وبناء الثقة معها وأخيرًا استغلال تلك الثقة** للحصول على ما يريد. فهم هذه المراحل يساعد الأفراد والمؤسسات على رصد محاولات الخداع في وقت مبكر وإحباطها.

- **يقظة المستخدم ووعيه** هي خط الدفاع الأول ضد هذه الهجمات. حين يكون الموظفون والمستخدمون مدرَّبين على التحقق من الهوية وعدم الانجرار وراء العواطف والضغوط المفاجئة، فإن محاولات الخداع ستفشل مهما تنوعت أساليب المهاجمين.

- أخيرًا، إن مزيجًا من **التوعية المستمرة والإجراءات الأمنية التقنية** يشكل حصنًا قويًا ضد هجمات الهندسة الاجتماعية. تذكّر دائمًا: **لا تشارك معلوماتك الحساسة مع أحد إلا بعد التحقق التام، ولا تثق بأي طلب مريب مهما بدا مقنعًا**. ببساطة، التفكير بهدوء والتأكد مرّتين قبل التجاوب هو المفتاح لتفادي الوقوع في فخاخ الهندسة الاجتماعية.

البرمجيات الخبيثة

البرمجيات الخبيثة هي برامج أو تعليمات برمجية صُممت خصيصًا لإلحاق الضرر بالأجهزة الإلكترونية أو استغلالها دون علم المستخدم. وتشمل هذه البرمجيات أنواعًا عديدة مثل الفيروسات وأحصنة طروادة والديدان وغيرها، والتي تختلف في طريقة عملها ووسائل انتشارها. تعد البرمجيات الخبيثة من أخطر التهديدات في مجال الأمن السيبراني، نظرًا لقدرتها على سرقة المعلومات الحساسة وتعطيل الأنظمة والتسبب في خسائر مالية جسيمة. لذلك، فإن فهم أنواع البرمجيات الخبيثة وآلياتها يُعتبر خطوة أساسية لحماية الأجهزة والشبكات من هذه التهديدات.

الفيروسات (Computer Viruses)

الفيروسات هي أحد أقدم وأشهر أنواع البرمجيات الخبيثة. يتميز الفيروس بقدرته على نسخ نفسه عن طريق إصابة الملفات والبرامج السليمة وإدخال شفرته الضارة فيها. عند تشغيل ملف أو برنامج مصاب، يقوم الفيروس بالتنشيط أولًا ثم يبدأ بالانتشار إلى ملفات أخرى على نفس الجهاز، وقد ينتقل إلى أجهزة أخرى عند تبادل تلك الملفات بين المستخدمين.

تنتشر الفيروسات عادةً من خلال سلوك المستخدم نفسه، مثل فتح مرفقات بريد إلكتروني مشبوهة تحتوي على ملفات مصابة أو تنزيل برامج من مواقع غير موثوقة. كما يمكن أن تنتقل عبر وسائط التخزين المحمولة (مثل الأقراص وأجهزة USB) عند استخدامها بين أجهزة مختلفة. تختلف تأثيرات الفيروسات باختلاف نوعها؛ فقد تؤدي بعض الفيروسات إلى إبطاء أداء الجهاز وظهور رسائل مزعجة، في حين قد يتسبب البعض الآخر في تلف البيانات أو انهيار النظام بشكل كامل.

أحصنة طروادة (Trojans)

أحصنة طروادة هي برمجيات خبيثة تتنكر في هيئة برامج شرعية أو مفيدة لخداع المستخدمين. يستمد هذا النوع اسمه من قصة حصان طروادة الخشبي المشهورة، حيث قُدّم الحصان كهدية لكنه أخفى جنودًا بالداخل. بالمثل، يبدو حصان طروادة كبرنامج عادي، لكن عند تشغيله يقوم بتنفيذ أنشطة ضارة في الخفاء دون علم المستخدم. وعلى عكس الفيروسات والديدان، لا يمتلك حصان طروادة القدرة على نسخ نفسه أو إصابة ملفات أخرى تلقائيًا.

غالبًا يصل حصان طروادة إلى الأجهزة من خلال الخداع الاجتماعي، كأن يقوم المستخدم بتحميل برنامج من الإنترنت ظنًا أنه آمن أو فتح ملف مرفق برسالة بريد إلكتروني يبدو عاديًا. بعد التثبيت، قد يفتح حصان طروادة بابًا خلفيًا في النظام يسمح للمهاجم بالتحكم عن بُعد بالجهاز أو سرقة البيانات الحساسة. كما يمكن أن يُستخدم لتثبيت برمجيات خبيثة إضافية أو مراقبة نشاط المستخدم، وكل ذلك يجري دون أن يثير شكوكًا كبيرة في البداية.

الديدان (Worms)

الديدان هي نوع آخر من البرمجيات الخبيثة يتميز بقدرته على الانتشار الذاتي السريع عبر الشبكات دون حاجة إلى ملف مضيف. على عكس الفيروسات، لا تتطلب الدودة أن يقوم المستخدم بتشغيل ملف مصاب؛ فهي تستغل الثغرات الأمنية أو نقاط الضعف في الأنظمة لتتسلل من جهاز إلى آخر بشكل تلقائي. هذا يعني أن الديدان يمكنها الانتشار على نطاق واسع خلال زمن قصير جدًا إذا لم يتم اكتشافها واحتواؤها بسرعة.

تتسبب الديدان عادةً في استهلاك كبير لموارد الشبكة وأنظمة الحاسوب، مما قد يؤدي إلى بطء شديد في الأداء أو حتى تعطّل الخدمات في الشبكة المصابة. بعض الديدان قد يكون هدفها الوحيد هو الانتشار دون إحداث ضرر مباشر بالملفات، لكنها رغم ذلك تخلق فوضى عبر إرهاق الشبكات والمعالجات. وهناك ديدان أخرى تحمل

شحنات خبيثة إضافية، حيث تقوم بتثبيت أبواب خلفية أو حذف بيانات في الأجهزة التي تصيبها، مما يزيد من خطورتها وتأثيرها المدمر.

برامج التجسس (Spyware)

برامج التجسس هي برمجيات خبيثة مصممة لمراقبة المستخدمين خِفيةً وجمع المعلومات عنهم دون إذن أو علم منهم. تعمل هذه البرامج في الخلفية عادةً، فتقوم بتسجيل نشاطات المستخدم على الجهاز والإنترنت مثل مواقع الويب التي يزورها، وعمليات البحث التي يجريها، وحتى بيانات الإدخال مثل ضغطات لوحة المفاتيح. الهدف الأساسي لبرامج التجسس هو سرقة المعلومات الشخصية أو الحساسة ككلمات المرور وبيانات الحسابات البنكية أو بطاقات الائتمان، وإرسال هذه البيانات إلى جهة المهاجم للاستفادة منها بشكل غير مشروع.

غالبًا ما تتسلل برامج التجسس إلى الأجهزة مرافقةً لتثبيت برامج مجانية أو تطبيقات من مصادر غير موثوقة، أو من خلال فتح روابط ومرفقات ملوثة في رسائل البريد الإلكتروني. ما يجعلها خطرة هو أنها لا تتسبب عادةً في أضرار واضحة أو فورية بالنظام، مما يسمح لها بالبقاء لفترة طويلة قبل أن يلاحظ المستخدم وجودها. خلال هذه الفترة، قد تسبب انتهاكًا كبيرًا لخصوصية المستخدم، وقد تؤدي إلى عواقب جسيمة مثل سرقة الهوية أو التعرض للاحتيال المالي إذا حصل المهاجم على معلومات حساسة كبيانات الدخول إلى الحسابات المصرفية أو غيرها.

برامج الفدية (Ransomware)

برامج الفدية هي نوع خطير ومتزايد الانتشار من البرمجيات الخبيثة يقوم بتشفير ملفات الضحية أو حجب نظامه بالكامل، ثم يطلب فدية مالية مقابل استعادة القدرة على الوصول إلى تلك البيانات. بمجرد إصابة الجهاز، يبدأ برنامج الفدية في العمل بسرعة لتشفير كافة الملفات المهمة باستخدام مفاتيح تشفير معقدة، مما يجعل البيانات غير قابلة للقراءة أو الاستخدام. بعد ذلك، تظهر رسالة من المهاجم تخبر

الضحية بأن ملفاته قد تم احتجازها كرهينة، وتطالبه بدفع مبلغ من المال (عادةً بعملة رقمية مثل البتكوين) مقابل الحصول على مفتاح فك التشفير لاستعادة الملفات.

تنتشر برامج الفدية غالبًا عبر رسائل البريد الإلكتروني المخادعة التي تحتوي على مرفقات ضارة أو من خلال استغلال ثغرات أمنية في الأنظمة غير المحدثة. عند الإصابة، يجد الضحايا أنفسهم أمام معضلة صعبة: إما خسارة بياناتهم المهمة إلى الأبد أو دفع الفدية للمبتزين أملًا في استعادتها. تسببت هجمات برامج الفدية في أضرار جسيمة للعديد من المؤسسات والأفراد حول العالم، حيث أدت إلى تعطيل أعمال شركات ومستشفيات وإلحاق خسائر مالية كبيرة. ولهذا تعتبر برامج الفدية اليوم إحدى أبرز التهديدات في مشهد الأمن السيبراني الحديث، مما يستدعي اليقظة واتخاذ نسخ احتياطية منتظمة للبيانات كإجراء وقائي أساسي.

البرمجيات الإعلانية (Adware)

البرمجيات الإعلانية هي برامج خبيثة تعرض إعلانات مزعجة على جهاز المستخدم دون موافقته. غالبًا ما يتم تثبيت هذه البرامج على الجهاز خلسةً عند تنزيل تطبيقات مجانية أو برامج مقرصنة، حيث يجد المستخدم نفسه فجأة أمام وابل من الإعلانات المنبثقة أو الشعارات التسويقية أثناء استخدامه للجهاز أو تصفحه للإنترنت. على الرغم من أن البرمجيات الإعلانية لا تسبب ضررًا مباشرًا للملفات أو النظام في معظم الحالات، فإنها تتسبب في إزعاج كبير للمستخدم وتؤثر على تجربة الاستخدام بشكل سلبي.

قد تقوم بعض البرمجيات الإعلانية أيضًا بجمع بيانات عن سلوك المستخدم على الإنترنت، مثل المواقع التي يزورها أو الكلمات التي يبحث عنها، وذلك بهدف عرض إعلانات تتناسب مع اهتماماته أو بيع هذه المعلومات لجهات إعلانية. بالإضافة إلى الإزعاج وانتهاك الخصوصية، يمكن أن يؤدي وجود برمجيات إعلانية متعددة على الجهاز إلى إبطاء الأداء العام للنظام واستهلاك موارد المعالج والذاكرة بشكل ملحوظ. عادةً ما يلاحظ المستخدم إصابة جهازه بالبرمجيات الإعلانية من خلال التغيرات المفاجئة

في المتصفح (ظهور أشرطة أدوات غير مرغوبة أو تغيير الصفحة الرئيسية) أو التدفق المستمر للنوافذ الإعلانية دون توقف.

أدوات تسجيل لوحة المفاتيح (Keyloggers)

أدوات تسجيل لوحة المفاتيح هي نوع من برامج التجسس متخصص في تسجيل كل ضغطة مفتاح يكتبها المستخدم على لوحة المفاتيح. يكمن هدف هذه الأدوات في التقاط بيانات حساسة مثل كلمات المرور، وأرقام بطاقات الائتمان، والرسائل التي يكتبها المستخدم، بحيث يتمكن المهاجم من الاطلاع عليها لاحقًا واستخدامها بشكل غير مشروع. يعمل برنامج تسجيل لوحة المفاتيح عادةً بصمت تام في خلفية النظام، فلا يدري المستخدم أن كل ما يكتبه يتم تسجيله وإرساله إلى جهة خبيثة.

يمكن أن تصل أدوات تسجيل لوحة المفاتيح إلى جهاز الضحية بعدة طرق متنوعة. قد تُثبَّت كجزء من حصان طروادة أو ضمن حزمة برامج تجسس أخرى يقوم المستخدم بتحميلها دون علمه، أو قد يتمكن شخص لديه وصول فعلي إلى الحاسوب من تنصيبها يدويًا في دقائق معدودة. وبمجرد وجودها، يصبح أي نص يدخله المستخدم مكشوفًا للمهاجم، مما يشكل خطرًا بالغًا على خصوصية وأمان المعلومات الشخصية. على سبيل المثال، إذا تمكن المهاجم عبر هذه الطريقة من الحصول على كلمة مرور بريد إلكتروني أو حساب مصرفي، فقد يؤدي ذلك إلى سرقة حسابات الضحية أو أمواله دون أن يدرك مباشرةً كيف تم اختراقه.

الروتكيت (Rootkits)

الروتكيت هو نوع معقد وخطير من البرمجيات الخبيثة يهدف بشكل أساسي إلى إخفاء وجوده ووجود أي برمجيات خبيثة أخرى مرتبطة به داخل النظام المصاب. يشتق الاسم من مفهوم "Root" في أنظمة التشغيل، أي صلاحيات الجذر أو المدير، حيث يسعى الروتكيت للحصول على تلك الصلاحيات العليا ليتحكم بالنظام دون قيود وبشكل غير مرئي. بمجرد إصابة الجهاز وتنفيذ الروتكيت، يقوم بإخفاء نفسه بعمق داخل مكونات

النظام من خلال تعديل ملفات النظام أو اعتراض أوامر ونواتج النظام، مما يجعل اكتشافه صعبًا للغاية على برامج الحماية التقليدية.

غالبًا ما يستخدم المخترقون الروتكيت للحفاظ على وصول غير مصرح به طويل الأمد إلى أجهزة الضحايا دون أن يتم اكتشافهم. إذ يتيح الروتكيت للمهاجم التحكم الكامل في الجهاز عن بُعد، بما في ذلك إمكانية سرقة البيانات الحساسة أو تثبيت برمجيات ضارة إضافية أو حتى مراقبة نشاط المستخدم، وكل ذلك يحدث دون أن يظهر أي شيء غير طبيعي للمستخدم. بسبب طبيعة الروتكيت المخادعة وعمله في أعماق النظام، قد يبقى الجهاز مخترقًا لفترة طويلة قبل اكتشاف الأمر. وعندها يكون التخلص من الروتكيت معقدًا للغاية، وقد يتطلب استخدام أدوات أمنية متخصصة أو حتى إعادة تثبيت نظام التشغيل بالكامل في بعض الحالات للتأكد من إزالته تمامًا.

برامج التصيد الموجه (Spear Phishing)

برامج التصيد الموجه (أو ما يعرف بالتصيد الاحتيالي الموجّه) هي أسلوب هجوم إلكتروني يستهدف ضحية محددة بأساليب احتيال مصممة خصيصًا لها. في هذا النوع من الهجمات، يقوم المهاجم بدراسة الضحية بعناية، سواء كان فردًا أو منظمة، لجمع معلومات شخصية ومهنية عنه من مصادر مختلفة (كوسائل التواصل الاجتماعي أو المواقع الرسمية). بعد جمع هذه المعلومات، يجهّز المهاجم رسالة احتيالية تبدو شديدة المصداقية وكأنها صادرة من جهة موثوقة يعرفها الضحية – كأن تكون رسالة بريد إلكتروني من زميل عمل أو مسؤول في المؤسسة أو حتى من مؤسسة لها تعاملات مع الضحية.

تتضمن رسالة التصيد الموجه عادةً محتوى يسترعي انتباه الضحية ويحثه على القيام بإجراء ما على الفور، مثل النقر على رابط أو تنزيل ملف مرفق. هذا الرابط أو الملف يكون خبيثًا: فإما أن يوجه الضحية إلى موقع مزيف شبيه بموقع حقيقي لسرقة بيانات تسجيل الدخول أو المعلومات الحساسة، أو يقوم بتنزيل برمجيات ضارة (كحصان طروادة مثلًا) على جهاز الضحية. نظرًا للطبيعة المستهدفة والشخصية لهذه

الهجمات، فإنها غالبًا ما تنجح في خداع حتى المستخدمين الحذرين، وقد تؤدي إلى اختراق شبكات الشركات أو سرقة بيانات مهمة إذا وقع موظف رئيسي ضحية لها. لذلك يُعتبر التصيد الموجه من أخطر أساليب الاختراق القائمة على الهندسة الاجتماعية في الوقت الحالي.

برامج التخويف (Scareware)

برامج التخويف هي برمجيات ضارة تعتمد على إثارة الذعر والخوف لدى المستخدم كوسيلة للاحتيال عليه ودفعه للقيام بإجراءات تخدم المهاجم. تظهر هذه البرامج عادةً على شكل نوافذ منبثقة أو إشعارات مزيفة تدّعي اكتشاف فيروسات خطيرة أو مشاكل أمنية جسيمة في جهاز المستخدم. قد ينبثق على شاشة المستخدم تحذير عاجل يبدو وكأنه صادر عن نظام التشغيل أو برنامج مكافحة الفيروسات، ويبلغه بأن جهازه تعرض للاختراق أو أن هناك أعطال كارثية، ثم يقترح عليه تحميل برنامج معين أو شراء أداة "ضرورية" لحل المشكلة فورًا.

إذا انخدع المستخدم وامتثل لهذه التعليمات، فقد ينتهي به الأمر بتثبيت برنامج مزيف أو ضار بالفعل على جهازه. في كثير من الحالات، يكون "برنامج الحماية" الموصى به هو نفسه برمجية خبيثة، أو قد يُطلب من الضحية دفع مبلغ من المال لقاء برنامج أو خدمة عديمة الفائدة. بذلك ينجح المهاجم إما في تحقيق ربح مالي مباشر أو في زيادة انتشار البرامج الضارة على جهاز الضحية تحت ستار معالجة المشكلة الوهمية.
تتسبب برامج التخويف في حالة هلع للمستخدمين تدفعهم لاتخاذ قرارات متسرعة، وقد تؤدي إلى خسائر مالية أو إلى تعقيد أكبر للمشكلة الأمنية بدلاً من حلها. لذا ينصح دائمًا بالتروي وعدم الثقة بالرسائل المنبثقة المخيفة، بل الاعتماد على برامج أمنية معروفة والتحقق يدويًا من حالة الجهاز.

الروبوتات (Bots)

الروبوتات في سياق الأمن السيبراني هي برمجيات خبيثة تصيب الأجهزة وتحولها إلى "روبوتات" إلكترونية يمكن التحكم بها عن بُعد من قبل المهاجم. عندما يُصاب جهاز الحاسوب أو الهاتف ببرنامج ضار من هذا النوع، يصبح الجهاز بمثابة وحدة ضمن شبكة أكبر من الأجهزة المخترَقة تعرف باسم شبكة الروبوتات أو "بوت نت" (Botnet). يقوم المهاجم بإصدار أوامر عبر خادم التحكم والتحكم (C&C Server)، فتستجيب لها جميع الأجهزة المصابة في الشبكة وتنفذها بشكل جماعي دون علم أصحابها.

تُستخدم الروبوتات عادةً في تنفيذ هجمات وإجراءات خبيثة واسعة النطاق. على سبيل المثال، يستطيع المهاجم توجيه آلاف الأجهزة المخترقة simultan في الوقت نفسه لشن هجوم حجب خدمة موزع (DDoS) على موقع ويب معين بهدف إغراقه بالطلبات وإخراجه عن الخدمة. كما يمكن استغلال شبكات البوت نت لإرسال كميات هائلة من رسائل البريد العشوائي (Spam) أو لتنفيذ عمليات احتيال ونقرات وهمية على الإعلانات لتحقيق مكاسب مالية غير شرعية. غالبًا لا يلاحظ المستخدم العادي أن جهازه أصبح جزءًا من شبكة روبوتات، إلا من خلال بعض المؤشرات مثل بطء مفاجئ في الجهاز أو ارتفاع غير مبرر في استخدام الإنترنت. وفي تلك الأثناء، يكون جهازه مسخّرًا في الخفاء للمساهمة في أنشطة إجرامية رقمية كبرى دون علمه.

تعدين العملات الخفي (Cryptojacking)

تعدين العملات الخفي هو نوع حديث من التهديدات السيبرانية يهدف إلى استغلال موارد جهاز الضحية في تعدين العملات الرقمية بشكل غير شرعي ودون علمه. يقوم المهاجم في هذه الحالة بتشغيل برمجية تعدين خفية على حاسوب أو هاتف الضحية، مستغلًا قدرة المعالجة (وحدة المعالجة المركزية CPU أو بطاقة الرسومات GPU) لحل المعادلات الرياضية المعقدة المرتبطة بإنتاج العملات المشفرة مثل البتكوين أو مونيرو. ما يميز هذا النوع من الهجمات أنه لا يسعى إلى سرقة البيانات أو تخريب النظام بشكل مباشر، بل يستنزف طاقة الجهاز وقدرته الحاسوبية لتحقيق مكاسب مالية للمهاجم من خلال عملية التعدين المستمرة.

غالبًا ما يصل برنامج التعدين الخفي إلى الأجهزة عبر حيل الهندسة الاجتماعية أو باستغلال ثغرات البرامج. قد يتم إقناع المستخدم مثلًا بتنزيل تطبيق أو ملف يبدو حميدًا لكنه يحتوي على كود خبيث للتعدين، أو يتم حقن أكواد تعدين في بعض المواقع الإلكترونية الإخبارية أو الخدمية الشهيرة دون علمها بحيث تبدأ عملية التعدين فور زيارة المستخدم لتلك المواقع. في معظم الأحيان، لا يلاحظ المستخدم أن جهازه يتعرّض للاستغلال في التعدين إلا من خلال علامات غير مباشرة، مثل بطء مفاجئ في الأداء، وارتفاع حرارة الجهاز بشكل غير معتاد، ونفاد البطارية بسرعة (في حالة الأجهزة المحمولة)، أو سماع صوت المروحة يعمل باستمرار بسبب الجهد العالي على المعالج. وعلى الرغم من أن التعدين الخفي لا يشفّر ملفات المستخدم ولا يسرق بياناته، فإنه قد يسبب أضرارًا غير مباشرة مثل تقصير عمر المكونات الإلكترونية للجهاز نتيجة الضغط المستمر ورفع فاتورة استهلاك الكهرباء على الضحية دون فائدة تعود عليه.

البرمجيات الخبيثة الهجينة (Hybrid Malware)

البرمجيات الخبيثة الهجينة هي برمجيات تجمع بين خصائص أو وظائف عدة أنواع من البرمجيات الخبيثة في آن واحد لتحقيق أهدافها الخبيثة. بدلًا من الاعتماد على أسلوب واحد، قد يستخدم المهاجم برمجية هجينة تتصرف كفيروس ودودة وحصان طروادة معًا ضمن هجوم واحد. على سبيل المثال، قد يبدأ الهجوم عبر ملف يبدو كأنه موثوق (جزء طروادة) يسمح للبرمجية بدخول النظام، ثم تعمل تلك البرمجية كدودة فتنتشر تلقائيًا إلى أجهزة أخرى ضمن شبكة الشركة، وفي الوقت نفسه تحمل حمولة ضارة مثل برنامج فدية يقوم بتشفير البيانات على الأجهزة المصابة. هذا المزيج من الأساليب يجعل البرمجية الهجينة أكثر تعقيدًا وصعوبةً في الاكتشاف والمكافحة.

تهدف هذه الهجمات المركّبة إلى زيادة فرص نجاح الاختراق؛ فإذا فشل أحد الأساليب في تحقيق الهدف بسبب وجود إجراء دفاعي معين، قد ينجح أسلوب آخر تستخدمه البرمجية. كما أنها تستغل التنوع في نقاط الضعف، حيث يمكن لعنصر من عناصر

البرمجية الخبيثة الهجينة أن يمر دون أن ترصده أنظمة الحماية إذا كانت تلك الأنظمة تركز على نوع محدد من التهديدات. من أجل ذلك، تتطلب مواجهة هذا النوع من التهديدات نهجًا أمنيًا متعدد الطبقات، بحيث يتم استخدام مجموعة متكاملة من وسائل الحماية (مثل مكافحات الفيروسات وجدران الحماية وأنظمة كشف التسلل) لضمان كشف المكونات المختلفة للبرمجية الهجينة والتصدي لها قبل أن تُلحق الضرر بالنظام.

في الختام، تتنوع البرمجيات الخبيثة بأساليبها وأهدافها، وجميعها تشكل تهديدًا جديًا لأمن المعلومات والأجهزة. إن الوعي بهذه الأنواع المختلفة وفهم كيفية عملها يشكل خط الدفاع الأول للمستخدمين والمؤسسات في تأمين أنظمتهم ضد الهجمات. ومع استمرار تطور البرمجيات الخبيثة وابتكار أساليب جديدة للمهاجمين، تصبح اليقظة والتعلم المستمر حول مستجدات الأمن السيبراني ضرورة لا غنى عنها للحفاظ على السلامة الرقمية.

أنواع الجدران النارية (Firewalls)

مقدمة

الجدار الناري هو نظام أمني يراقب حركة مرور البيانات الشبكية ويقوم بتصفية الحزم (Packets) الواردة والصادرة وفقًا لقواعد محددة. يهدف الجدار الناري إلى تشكيل حاجز واقٍ بين الشبكة الداخلية الآمنة والعالم الخارجي غير الموثوق، بحيث يمنع محاولات الوصول غير المصرح بها ويحمي الأجهزة والبيانات من التهديدات الإلكترونية. تلعب الجدران النارية دورًا أساسيًا في مجال الأمن السيبراني؛ فهي خط الدفاع الأول في الشبكات الحديثة، وتُستخدَم على نطاق واسع في المنازل والشركات ومراكز البيانات لحماية الأنظمة من الهجمات والاختراقات.

في هذا الفصل، سنستعرض بشكل شامل أنواع الجدران النارية المختلفة وخصائص كل منها. سنبدأ بالتعريف بالجدار الناري التقليدي وأهم ميزاته وعيوبه، ثم ننتقل إلى جدار ناري الفحص ذو الحالة، ثم جدار ناري على مستوى التطبيق (الخادم الوكيل)، ثم جدار ناري من الجيل التالي المتقدم. بعد ذلك سنتناول تصنيف الجدران النارية حسب طريقة التنفيذ، بما في ذلك الجدران النارية البرمجية (المستندة إلى البرامج) والجدران النارية المادية (المستندة إلى الأجهزة) والجدران النارية السحابية (المستندة إلى السحابة). وأخيرًا، سنقدم مقارنة وصفية تبرز الفروق الأساسية بين هذه الأنواع من حيث الأداء ومستوى الحماية وسهولة الإدارة والتكلفة.

الجدار الناري التقليدي (Packet Filtering Firewall)

الجدار الناري التقليدي هو أقدم أنواع الجدران النارية وأبسطها. يعمل هذا الجدار كمرشِّح للحزم حيث يقوم بفحص كل حزمة بيانات تمر عبره بشكل مستقل استنادًا إلى معلومات رأس الحزمة، مثل عنوان بروتوكول الإنترنت (IP) للمصدر والوجهة، رقم المنفذ (Port)، ونوع البروتوكول المستخدم. يقارن الجدار الناري هذه المعلومات

بقواعد محددة مسبقًا (قوائم تحكم بالوصول ACLs) ليقرر ما إذا كان سيسمح بمرور الحزمة أو يحجبها. يتميز هذا النوع بأنه **عديم الحالة**؛ أي أنه لا يتابع سياق الاتصال أو حالة الجلسة بين المرسل والمستقبل، بل يتعامل مع كل حزمة على حدة بغض النظر عما قبلها أو بعدها. وبسبب بساطة عمله عند طبقة الشبكة، يكون أداؤه سريعًا جدًا مع تأخير طفيف للغاية في المرور عبره.

يمتاز **الجدار الناري التقليدي** بسرعته وكفاءته العالية نظرًا لبساطة آلية التصفية التي يستخدمها؛ فهو لا يستهلك موارد حوسبة كبيرة، مما يجعله خيارًا مناسبًا للشبكات الصغيرة أو البيئات محدودة الموارد. كما أنه عادة منخفض التكلفة وسهل الفهم من حيث المبدأ. ولكن بالمقابل، يعاني هذا النوع من بعض القيود والعيوب؛ فاعتماده على عناوين IP والمنافذ فقط يعني أنه يوفر مستوى حماية أساسي ومحدود، حيث لا يستطيع كشف محتوى البيانات أو التمييز بين الطلبات السليمة والخبيثة داخل الحمل (Payload). يمكن للمهاجمين التلاعب بالمعلومات الموجودة في رأس الحزمة (مثل تزوير عناوين IP) لتجاوز مرشحات الحزم البسيطة. كذلك قد تصبح إدارة قوائم القواعد معقدة كلما نمت الشبكة وكثرت الخدمات. لذلك غالبًا ما يُستخدم الجدار الناري التقليدي كخط دفاع أولي أو ضمن إستراتيجية دفاع متعددة الطبقات، ولحماية شبكات صغيرة أو كجزء من موجهات (Routers) توفر تصفية أساسية للحركة المرورية. أما في البيئات الكبيرة والمعرضة لتهديدات أعقد، فيُستعاض عنه أو يُدعم بأنواع أكثر ذكاءً من الجدران النارية.

الجدار الناري ذو الحالة (Stateful Inspection Firewall)

ظهر جدار الفحص ذو الحالة كجيل ثانٍ من الجدران النارية ليعالج قصور الجدار التقليدي. **الجدار الناري ذو الحالة** لا يكتفي بفحص الحزم فرديًا، بل يتابع تدفق حركة المرور ويراقب حالة الاتصالات الجارية بين الأجهزة. يحتفظ هذا الجدار بجدول حالة (State Table) يتعقب فيه معلومات حول الاتصالات المفتوحة حاليًا، مثل عناوين المصدر والوجهة والمنافذ المستخدمة وحالة بروتوكول النقل (كنشاط جلسة TCP

من فتح الاتصال إلى إغلاقه). عندما تصل حزمة بيانات، يتحقق الجدار ذو الحالة مما إذا كانت تنتمي إلى جلسة اتصال نشطة معروفة في جدول الحالة. فإذا كانت الحزمة جزءًا من اتصال قائم وشرعي، سيسمح بتمريرها تلقائيًا دون الحاجة لإعادة تطبيق كافة قواعد التصفية عليها. أما إذا كانت الحزمة محاولة اتصال جديدة، فسيطبق عليها سياسات الأمن المحددة لتحديد السماح أو الحجب. بهذه الطريقة يوفر الجدار ذو الحالة مستوى أعلى من الأمان بالمقارنة مع مرشح الحزم البسيط، لأنه يمنع المرور العشوائي للحزم غير المرتبطة بجلسات معروفة ويُسَهِّل مرور الردود المتوقعة ضمن الاتصالات الشرعية.

جدران الفحص ذات الحالة تمتاز بالقدرة على التمييز الديناميكي بين الحركة الشرعية وغير الشرعية بفضل تتبعها لحالة الاتصال. فهي أكثر أمانًا ومرونة من الجدران عديمة الحالة، حيث تستطيع تلقائيًا السماح لحزم الاستجابة من خدمات خارجيّة طالما أنها مطابقة لجلسة بدأتها أجهزة الشبكة الداخلية. يحقق ذلك توازنًا جيدًا بين الأمان وسهولة الاستخدام للمستخدمين (مثال: يسمح بعودة رد صفحة ويب طلبها المستخدم دون الحاجة لفتح عدد كبير من المنافذ يدويًا). كما توفر غالبًا قدرات إضافية مثل تسجيل الأحداث والإنذارات، مما يساعد المسؤولين على مراقبة الأنشطة المشبوهة. ومع ذلك، فإن هذه الجدران أعقد من حيث التصميم، وبالتالي قد تكون أبطأ قليلًا من المرشحات البسيطة لأنها تحتاج إلى معالجة إضافية لحفظ ومتابعة حالة الآلاف من الجلسات النشطة، مما يزيد الحمل على الذاكرة والمعالج. تكلفة جدار ذو الحالة تكون أعلى من الجدران التقليدية البسيطة، ولكنها ما زالت ضمن نطاق مقبول لمعظم الشركات نظرًا لفوائدها الأمنية. بشكل عام، تُستخدم **جدران الفحص ذات الحالة** على نطاق واسع في شبكات المؤسسات لأنها تقدم مستوى حماية كافيًا لمعظم الهجمات الشائعة، وهي اليوم الأساس لمعظم حلول الجدران النارية التجارية والمفتوحة المصدر. وغالبًا ما تكون هذه الخاصية مدمجة في العديد من أجهزة التوجيه والموجهات الحديثة أيضًا لتوفير طبقة حماية افتراضية في الشبكات.

الجدار الناري على مستوى التطبيق (Application-Level Gateway / Proxy Firewall)

الجدار الناري على مستوى التطبيق، المعروف أيضًا باسم **جدار وكيل (Proxy)**، يمثل الجيل الثالث من تقنيات الجدران النارية. تختلف آلية عمله عن السابقين بأنه يعمل كوسيط أو **خادم وكيل** بين الطرفين المتواصلين. عند استخدام جدار ناري وكيل، لا تتواصل الأجهزة الداخلية مباشرة مع الإنترنت، بل ترسل طلباتها إلى خادم الوكيل (وهو الجدار الناري)، الذي يقوم بدوره بإعادة إنشاء اتصال منفصل مع الوجهة النهائية الخارجية وتمرير الطلب. وبالمثل تستقبل الردود من الخارج ثم تُعيد توجيهها إلى الجهاز الداخلي الطالب بعد فحصها. خلال هذه العملية، يقوم الجدار الناري على مستوى التطبيق بفحص مفصل لمحتوى البيانات على مستوى طبقة التطبيق (Layer 7 من نموذج OSI). فهذا الجدار **"يفهم" البروتوكولات** والتطبيقات الشائعة مثل بروتوكول HTTP الخاص بتصفح الويب، وبروتوكول FTP لنقل الملفات، وبروتوكول SMTP للبريد الإلكتروني، وغيرها. يمكنه تحليل طلبات الويب مثل عناوين URL والأوامر المرسلة، أو أوامر بروتوكول FTP، والتأكد من أنها سليمة ومطابقة للسياسات قبل السماح بتمريرها. بذلك يستطيع منع الكثير من الهجمات التي تتخفى داخل حركة مرور تبدو عادية، مثل أكواد ضارة ضمن محتوى صفحة ويب أو أوامر غير شرعية في بروتوكول ما. بالإضافة إلى ذلك، يوفر عمل الوكيل طبقة إضافية من العزل؛ إذ تبقى عناوين الأجهزة الداخلية مخفية عن العالم الخارجي ولا تتواصل إلا عبر الجدار الوكيل، مما يعزز الخصوصية ويصعّب على المهاجمين استهداف الأجهزة الداخلية مباشرة.

يوفر **جدار مستوى التطبيق** أعلى درجة من التحكم الدقيق في حركة المرور والمحتوى. من أبرز مزاياه أنه يستطيع تطبيق سياسات أمنية دقيقة جدًا، كأن يسمح لمستخدم بتصفح موقع ويب معين لكن يمنعه من تنزيل ملفات منه، أو السماح ببروتوكول معين مع تقييد بعض أوامره الخطرة. كما أن تحليل المحتوى يُمكّنه من اكتشاف ومنع التهديدات المخفية التي لا يمكن لمرشحات الحزم أو حتى الفحص ذو الحالة كشفها (مثل هجمات على مستوى التطبيقات والبرمجيات الخبيثة المضمنة في

البيانات). ومع ذلك، تأتي هذه المزايا بثمن من ناحية الأداء والتعقيد: فجدار الوكيل عادة أبطأ من الجدران النارية الأخرى لأنه يفحص البيانات بشكل عميق ويتطلب إعادة إنشاء الاتصالات، مما يزيد من زمن الاستجابة للمستخدم النهائي. كذلك فإن إعداده وإدارته أكثر تعقيدًا، حيث قد يحتاج إلى إعداد خوادم وكيلة متعددة لكل نوع من الخدمات (وكيل للويب، آخر للبريد وهكذا)، وتحديث مستمر لقواعد الفحص مع تطور التطبيقات. التكلفة أيضًا تكون مرتفعة نسبيًا سواء في شراء حلول جاهزة أو من حيث الموارد الحاسوبية المطلوبة للتشغيل. بالإضافة إلى ذلك، قد لا يدعم هذا الجدار كل البروتوكولات أو التطبيقات بشكل سلس، فبعض التطبيقات المخصصة أو غير الشائعة قد لا يستطيع الوكيل التعامل معها مما يتطلب استثناءات خاصة. بشكل عام، يُستخدم **جدار ناري على مستوى التطبيق** في البيئات التي تتطلب أعلى مستويات الحماية التفصيلية، كالشركات التي ترغب في مراقبة صارمة لحركة تصفح الإنترنت من شبكة الموظفين، أو حماية خوادم تطبيقات حساسة من أي هجمات موجهة عبر بروتوكول تلك التطبيقات. وغالبًا ما يتم استخدامه جنبًا إلى جنب مع جدار تقليدي أو ذو حالة؛ حيث يتولى الجدار الوكيل فحص المحتوى للتطبيقات المهمة، بينما يستمر الجدار الآخر في تولي مهام التصفية العامة لباقي الحركة المرورية، تحقيقًا لتوازن بين الأمن والأداء.

الجدار الناري من الجيل التالي (Next-Generation Firewall)

الجدار الناري من الجيل التالي، ويُشار إليه اختصارًا بـ NGFW، هو تطور حديث وشامل لتقنية الجدران النارية يجمع بين مزايا الأنواع السابقة ويضيف قدرات متقدمة لمواجهة التهديدات المعاصرة. يعمل **جدار الجيل التالي** على عدة مستويات: فهو يقوم بتصفية الحزم التقليدية، ويفحص حالة الاتصالات مثل الجدار ذو الحالة، وكذلك يتعمق إلى مستوى التطبيق لفحص المحتوى (أي يمتلك قدرة **الفحص العميق للحزم DPI**). بالإضافة إلى ذلك، يدمج هذا الجدار وظائف أمنية أخرى كانت سابقًا منفصلة عن الجدار الناري، مثل أنظمة الكشف والتصدي للتسلل (IDS/IPS) التي ترصد أنماط الهجمات المعروفة وتمنعها، وميزات فلترة البرمجيات الخبيثة والفيروسات،

والتحكم في التطبيقات (لتحديد ومنع تطبيقات معينة من المرور عبر الشبكة بغض النظر عن المنفذ المستخدم)، وميزات مراقبة المستخدمين وفرض سياسات وفق هوية المستخدم أو الجهاز. باختصار، يتعرف الجدار الناري من الجيل التالي على **ماهية** حركة المرور وليس مجرد وجهتها أو مصدرها؛ فهو قادر على تمييز أنواع التطبيقات التي تولّد حركة البيانات (مثل التعرف على أن الحزمة تنتمي لتطبيق فيسبوك أو يوتيوب حتى لو استخدمت منفذًا غير قياسي)، وبالتالي يمكنه فرض سياسات أكثر ذكاءً ودقة.

تكمن قوة **جدار الجيل التالي** في شموليته وقدرته على توفير **حماية متعددة الطبقات** من خلال منصة واحدة. فمن ناحية مستوى الحماية، يعتبر هذا النوع الأكثر تقدمًا؛ إذ يستطيع إيقاف مجموعة واسعة جدًا من التهديدات الحديثة والمعقدة، مما يجعله ملائمًا للشركات والمؤسسات التي تعمل في بيئات عالية الخطورة أو تخضع لمعايير امتثال أمنية صارمة. كما أن قدرته على التعرف على التطبيقات والمستخدمين تسهّل إدارة السياسات الأمنية على المسؤولين (مثل: السماح لموظفي قسم معين باستخدام تطبيق معين أثناء حظره عن الآخرين). يوفّر أيضًا **الجدار من الجيل التالي** تحديثات تلقائية لقاعدة بيانات التهديدات والبرمجيات الخبيثة، مما يعني أن مستوى الحماية يتكيف باستمرار مع أحدث المخاطر. لكن في المقابل، فإن هذه الوظائف المتعددة تزيد من تعقيد الجهاز وتكوينه. يتطلب تشغيله بكفاءة خبرة فنية عالية، حيث يجب على المسؤول فهم العديد من الخصائص وضبطها بالشكل الصحيح لتجنب الثغرات أو الأداء المتدني. كما أن **جدران الجيل التالي** غالبًا ما تكون مرتفعة التكلفة مقارنة بغيرها، سواء من حيث سعر الأجهزة والبرمجيات أو تكاليف الاشتراك في خدمات التحديث والصيانة الدورية. الأداء أيضًا يمكن أن يكون تحديًا؛ فمع هذا الكم من الفحوصات (تصفية، تتبع حالة، فحص عميق، كشف اختراقات...) قد يزداد الحمل على موارد الجهاز. وللحفاظ على سرعة المعالجة، تعتمد هذه الأجهزة عادة على عتاد قوي جدًا وتقنيات تسريع مدمجة، ولكن رغم ذلك قد يؤدي تفعيل جميع الميزات إلى تقليل Throughput الشبكة مقارنة بجدار بسيط. تستخدم المؤسسات **الجدران النارية من الجيل التالي** كحل متكامل لحماية محيط الشبكة والقطاعات الحساسة داخلها، وهي شائعة في البيئات المؤسسية الكبيرة، والمراكز الحكومية والمالية.

وغيرها من القطاعات التي لا تتهاون في أمنها. ومع تزايد التهديدات الإلكترونية، أصبحت هذه الجدران خيارًا رائجًا حتى للشركات متوسطة الحجم التي تملك الموارد والخبرة الكافية لإدارتها، لضمان مستوى حماية عالي وشامل.

الجدار الناري المستند إلى البرامج (Software Firewall)

يقصد بالجدار الناري المستند إلى البرامج ذلك الذي يعمل كبرنامج على جهاز حاسوبي وليس كجهاز شبكي مستقل. يُسمى أيضًا **الجدار الناري البرمجي أو جدار الحماية الشخصي** عندما يكون مثبتًا على حاسوب مستخدم فرد أو خادم. يقوم هذا النوع من الجدران بوظائف التصفية والمراقبة لكنه يكون مدمجًا داخل نظام التشغيل للجهاز أو كتطبيق أمني منفصل. **طريقة عمل الجدار البرمجي** مشابهة من حيث المبدأ للأنواع الأخرى (فلترة عناوين ومنافذ وربما فحص حالة الاتصال والمحتوى على مستوى الجهاز)، ولكنه متخصص في حماية جهاز واحد فقط أو بيئة نظام تشغيل محددة. على سبيل المثال، يأتي نظام تشغيل كويندوز (Windows) مزودًا بجدار حماية برمجي مدمج يراقب الاتصالات الداخلة والخارجة من الحاسوب ويسمح للمستخدم أو المسؤول بضبط القواعد للسماح أو الحظر بناءً على التطبيق أو المنفذ. بالمثل، توفر أنظمة تشغيل أخرى مثل لينكس أو ماك أو.إس جدران حماية برمجية (مثل iptables في لينكس) تعمل على مستوى نواة النظام للتحكم بالاتصالات. هناك أيضًا برامج جدار حماية تجارية أو مفتوحة المصدر يمكن تثبيتها لتعزيز الحماية الشخصية. يقوم الجدار البرمجي عادة بحماية الجهاز من الاتصالات غير المرغوبة القادمة من الشبكة المحلية أو الإنترنت، ويمكنه أيضًا التحكم بالاتصالات الصادرة من الجهاز لمنع البرامج الضارة من الاتصال بخارج الجهاز بدون إذن.

الجدران النارية البرمجية لها مزايا مهمة أبرزها أنها توفر **حماية فردية مباشرة لكل جهاز**. فهي مفيدة بشكل خاص للأجهزة الطرفية (مثل حواسيب الموظفين المحمولة) التي قد تتصل بشبكات خارجية غير آمنة؛ فحتى لو كان الجهاز خارج نطاق شبكة الشركة المحمية بجدار مادي، فإن جداره الشخصي سيستمر في حمايته. كما

تمتاز بسهولة الحصول عليها؛ إذ غالبًا ما تكون مدمجة في أنظمة التشغيل أو متاحة عبر برامج مجانية أو مدفوعة يمكن تثبيتها فورًا دون حاجة لأجهزة إضافية. تكلفتها بالتالي منخفضة مقارنة بشراء عتاد مادي لكل جهاز. إضافة إلى ذلك، تمنح الجدران البرمجية تحكمًا دقيقًا على مستوى العملية أو التطبيق؛ فيستطيع المستخدم السماح أو منع اتصال برنامج محدد بالإنترنت، مما يوفر طبقة أمن إضافية ضد برمجيات خبيثة قد تُثبَّت على الجهاز. لكن يقابل هذه المزايا بعض القيود: فالجدار الناري البرمجي **يستهلك من موارد الجهاز المضيف** (المعالج، الذاكرة) مما قد يؤثر بشكل طفيف على أداء النظام خاصة في الأجهزة الضعيفة أو عند فحص عدد كبير من الاتصالات. كما أن **إدارة جدران عديدة** لكل جهاز على حدة قد تكون صعبة في شبكات الشركات؛ فبدلًا من نقطة تحكم مركزية واحدة، يجب ضمان إعداد وتحديث كل جدار على كل جهاز وهو ما يزيد العبء على فريق تقنية المعلومات. ولأن الجدار البرمجي يعمل على نفس الجهاز الذي يحميه، فإنه عرضة للتعطيل إذا تمكن برنامج خبيث من السيطرة على ذلك الجهاز أو تعطيل خدمة الجدار الناري في نظام التشغيل. أخيرًا، يغطي الجدار البرمجي نطاقًا محدودًا مقارنة بالجدار الشبكي؛ فهو يحمي جهازه فقط ولا يوفر رؤية شاملة لحركة المرور على مستوى الشبكة ككل. بناءً على ذلك، يستخدم **الجدار الناري المستند إلى البرامج** كحل حماية إضافي غالبًا - فيتم نشره على الأجهزة الفردية لدعم الجدار الناري الرئيسي للشبكة. كما أنه مثالي للاستخدام الشخصي والمنزلي؛ حيث يمكن للمستخدمين العاديين الاعتماد على جدار الحماية المدمج في أجهزتهم لحماية حواسيبهم أثناء اتصالها بالإنترنت مباشرة. وفي بيئات الشركات، قد تلجأ المؤسسات إلى إدارة مركزية لجدران الحماية البرمجية على جميع أجهزة الموظفين كجزء من إستراتيجية "الدفاع في العمق"، لضمان أنه حتى لو تجاوز تهديد ما الجدار الشبكي فإنه سيواجه دفاعًا آخر على مستوى الجهاز.

الجدار الناري المستند إلى الأجهزة (Hardware Firewall)

المقصود بالجدار الناري المستند إلى الأجهزة هو **جهاز مادي منفصل** مخصص ليعمل كجدار ناري للشبكة. هذا النوع غالبًا ما يكون عبارة عن علبة أو صندوق إلكتروني

يحتوي على معدات وشريحة حوسبة خاصة وبرمجيات مدمجة للقيام بوظائف الجدار الناري بشكل مستقل عن أجهزة الحاسوب العامة. يُوصل الجهاز عادة عند النقطة الفاصلة بين الشبكة الداخلية والإنترنت (أو بين أجزاء مختلفة من الشبكة)، ليعمل كبوابة عبور آمنة تمر عبرها جميع حركة البيانات بحيث يجري تصفيتها وفحصها قبل السماح لها بالدخول أو الخروج. **طريقة عمل الجدار الناري المادي** شبيهة بالمفاهيم التي ناقشناها (قد يطبق مرشح حزم، وفحص حالة، وحتى خصائص الجيل التالي بحسب فئة الجهاز)، ولكن المميز هنا أنه يعتمد على عتاد مُخصص. هذا العتاد غالبًا ما يكون مُجهَّزًا بمعالجات عالية الأداء وربما دوائر متخصصة (ASICs) لتسريع عمليات الفحص والتشفير، مما يمنحه قدرة على معالجة كم كبير من حركة المرور بكفاءة عالية دون تأخير يُذكر. كما أنه يعمل بشكل منفصل عن حواسيب الشبكة، فلا يستهلك مواردها ولا يعتمد عليها في أداء مهامه.

الجدار الناري المادي يتمتع بعدة مزايا تجعل منه خيارًا أساسيًا خاصة للشبكات المتوسطة والكبيرة. أولًا من ناحية **الأداء**، كونه جهازًا مستقلاً بموارد مخصصة، يتيح معالجة سريعة للحزم حتى في بيئات ضغط العمل العالي، وبعض الأجهزة تستطيع تحمل ملايين الحزم في الثانية مع تأخير طفيف جدًا، وهو أمر يصعب على حلول برمجية بحتة تحقيقه على نفس المستوى. ثانيًا، يوفر **نقطة تحكم مركزية** لكل الحركة العابرة بين أجزاء الشبكة؛ فبدلًا من توزيع سياسات الأمان على كل جهاز، يمكن للمسؤولين ضبط السياسات والقواعد في مكان واحد (على الجهاز المادي) لتُطبق على الجميع، مما يبسط الإدارة في كثير من الحالات. إضافة لذلك، غالبًا ما تأتي **الجدران النارية المادية** بوظائف أمان متقدمة مدمجة في الجهاز، وتشمل قدرات الجيل التالي أو إمكانيات إضافية (كـ VPN، وتصفية المحتوى، وغيرها) حسب الشركة المصنعة. ومن ميزاتها أيضًا أنها غير مرئية للمستخدمين النهائيين ولا يمكن التلاعب بها بسهولة من قبلهم، على عكس الجدار البرمجي الذي قد يقوم المستخدم بتعطيله أحيانًا لحل مشكلة ما. ومع ذلك، هناك بعض التحديات والعيوب: **تكلفة** الأجهزة المادية عالية نسبيًا، فشراء جهاز جدار ناري متخصص (بالإضافة لتكاليف الصيانة والدعم الفني له)

قد يشكل استثمارًا كبيرًا، خاصة للشركات الصغيرة. أيضًا يتطلب تشغيله **خبرات تقنية**: فهذه الأجهزة تأتي بواجهات إعداد وإدارة قد تكون معقدة، ويحتاج المسؤول إلى معرفة عميقة بالشبكات وطرق الحماية لضبطها بشكل صحيح. وإذا اعتمدت الشبكة بالكامل على جهاز جدار ناري واحد، فإن حدوث عطل فيه قد يؤدي إلى توقف أو ثغرة في حماية الشبكة بأكملها، لذا غالبًا ما تُنشأ أجهزة احتياطية أو حلول تجاوز فشل (failover) لتجنب نقطة الفشل الواحدة. أخيرًا، يكون **التحديث والترقية** للجدار المادي أقل مرونة من الحلول البرمجية؛ فترقية الأداء قد تتطلب شراء عتاد أحدث، بينما البرمجيات يمكن تحديثها على نفس الجهاز. بشكل عام، تُستخدم **الجدران النارية المادية** في البيئات الاحترافية لحماية الشبكات المحلية (LAN) بأكملها أو مناطق محددة منها. نجدها في مراكز البيانات، والشبكات المؤسسية، وحتى في بعض الاستخدامات المنزلية الراقية (كالموجهات المنزلية المتقدمة التي تحوي جدار حماية مدمج) لكنها في جوهرها مصممة لتأمين نطاق واسع من الأجهزة خلفها عبر بوابة موحَّدة قوية.

الجدار الناري المستند إلى السحابة (Cloud Firewall)

يشير مفهوم الجدار الناري السحابي إلى توفير وظائف الجدار الناري كخدمة سحابية عبر الإنترنت، بدلاً من جهاز أو برنامج يتم تشغيله محليًا في مقر الشركة. يُعرف أيضًا بمصطلح **Firewall as a Service (FWaaS)** أو **الجدار الناري المُستضاف**. تعتمد **طريقة عمل الجدار السحابي** على وجود منصة حماية لدى مزود الخدمة السحابية تقوم بمراقبة وفحص حركة البيانات الخاصة بالعميل (الشركة أو المستخدم) أثناء انتقالها عبر شبكة الإنترنت أو بين الشبكات السحابية. فعلى سبيل المثال، يمكن توجيه حركة الإنترنت الصادرة من فروع شركة ما عبر خدمة سحابية تقوم بتصفية تلك الحركة وفق سياسات أمان العميل قبل إيصالها إلى وجهتها النهائية، أو عند استضافة خوادم وتطبيقات في السحابة، يتولى الجدار السحابي حماية بيئة الشبكة الافتراضية المحيطة بتلك الخوادم. في كل الحالات، البنية الأساسية والتجهيزية للجدار

الناري تكون موجودة لدى طرف المزود، أما العميل فبوسعه إدارة السياسات والقواعد عبر واجهة ويب أو قد يترك المهمة كاملة لمزود الخدمة لإدارتها (وفق اتفاقيات مستوى خدمة محددة). هذا النموذج يشابه فكرة أن تكون هناك "بوابة أمنية في الإنترنت" تمر عبرها بيانات المؤسسة بدلاً من بوابة مادية داخل مقرها.

تمتاز **الجدران النارية السحابية** بالعديد من النقاط التي جعلتها تنتشر مؤخرًا خصوصًا مع التوجه نحو الحوسبة السحابية والتحول الرقمي. فهي أولًا توفر **مرونة عالية وقابلية للتوسع**؛ فلا حاجة لشراء أجهزة مادية إضافية عندما تزيد حركة الشبكة أو تتوسع الأعمال، بل يمكن تعديل خطة الاشتراك أو الموارد المخصصة للخدمة بسهولة لتستوعب الزيادة. كما أنها **أسهل في النشر الجغرافي**؛ فشركة لها فروع متعددة أو مستخدمون يعملون عن بعد يمكنهم جميعًا الاستفادة من نفس خدمة الحماية السحابية أينما كانوا، دون ضرورة تواجدهم عبر الشبكة الداخلية نفسها. من الناحية الإدارية، قد تخفف الجدران السحابية **عبء الإدارة والصيانة** عن قسم تقنية المعلومات في الشركة، فمزود الخدمة يتولى تحديث منصة الحماية وصيانتها الدورية وإدارة العتاد، بينما يركز فريق الشركة على ضبط السياسات المناسبة لأعمالهم. وعادةً ما توفر هذه الخدمات واجهات مركزية بسيطة لإدارة أمان الشبكة من أي مكان، مما يحسن قابلية الإدارة مقارنة بإدارة عدة أجهزة في مواقع مختلفة. على صعيد التكلفة، يمكن أن تكون **التكلفة أولية أقل** لأنه لا يلزم شراء أجهزة باهظة، وإنما يتم الدفع بنموذج اشتراك (شهري أو سنوي) يتناسب مع حجم الاستخدام؛ وهذا النموذج جذاب خصوصًا للشركات الصغيرة أو الناشئة التي لا تريد استثمار الكثير upfront في أجهزة أمنية. لكن بالمقابل، هناك تحديات وعيوب محتملة: **الاعتماد على طرف خارجي** في تأمين حركة البيانات قد يثير مخاوف تتعلق بالخصوصية والسيطرة على البيانات، فبعض المؤسسات الحساسة قد تتردد في إرسال بياناتها لتتم معالجتها عبر سحابة طرف ثالث. أيضًا **زمن الاستجابة** يمكن أن يتأثر؛ حيث أن توجيه البيانات إلى الخدمة السحابية للفحص ثم إعادة توجيهها قد يضيف زمنًا خاصة إذا كانت الخوادم السحابية بعيدة جغرافيًا عن المستخدمين أو الوجهات. ومع أن مزودي الخدمات عادة ينشرون

بنية تحتية عالمية لتقليل ذلك التأخير، لكنه يظل عاملًا ينبغي مراعاته. بالإضافة إلى ذلك، **انقطاع الاتصال بالإنترنت** يعني انقطاع الوصول للجدار الناري السحابي؛ فإذا واجهت خدمة المزود تعطلًا أو انقطع اتصال الفرع بالإنترنت، فقد تصبح الشبكة بدون حماية فعالة أو غير قادرة على الوصول للخدمات لحين حل المشكلة. وأخيرًا، من منظور التكلفة طويل الأجل، رسوم الاشتراك المستمرة قد تتجاوز ثمن شراء جهاز فعلي على المدى البعيد، رغم وفوراتها الآنية. إن **استخدام الجدار الناري السحابي** يتناسب خاصة مع المؤسسات التي تعتمد بشكل كبير على البنية السحابية (كتشغيل تطبيقاتها في سحابات عامة) أو تلك التي لديها توزيع جغرافي واسع وترغب في حل مركزي للحماية. أيضًا المؤسسات التي تفتقر إلى طاقم أمني خبير قد تفضل الاستعانة بخدمة مُدارة من قبل مختصين توفر لهم مستوى حماية جيد دون الحاجة لتفاصيل تقنية معقدة. في المقابل، قد تختار بعض الشركات الكبيرة نموذجًا **هجينًا** يجمع بين أجهزة جدران نارية مادية محلية وخدمات سحابية لتعزيز الحماية للمستخدمين عن بعد أو للخدمات السحابية، وبذلك تحصل على أفضل الميزات من الجانبين.

مقارنة بين الأنواع المختلفة

بعد استعراض الأنواع المختلفة للجدران النارية، فيما يلي مقارنة وصفية تُبرز الفروق الأساسية بينها من حيث **الأداء ومستوى الحماية وسهولة الإدارة والتكلفة**:

من حيث الأداء: يعتبر الجدار الناري التقليدي (مرشح الحزم) الأخف والأسرع أداءً لأنه يقوم بعمليات بسيطة نسبيًا ولا يتعمق كثيرًا في تحليل البيانات. يأتي بعده الجدار ذو الحالة الذي يضيف عبئًا طفيفًا لمتابعة حالة الاتصالات، ولكنه ما زال performant بدرجة جيدة في معظم البيئات المعتدلة الحجم. الجدران على مستوى التطبيق والوكلاء تكون عادة الأبطأ، إذ إنها تعيد توليد الاتصالات وتقرأ البيانات بشكل معمق، مما يؤدي إلى **خفض ملحوظ في سرعة النقل** وخاصة تحت أحمال ثقيلة. جدران الجيل التالي تتمتع بأداء متقدم بفضل العتاد القوي وتقنيات التحسين، ولكن تشغيل

ميزاتها العديدة (كالفحص العميق ومرشحات الـ IPS) قد يضع عبئًا كبيرًا على النظام؛ لذا تتفوق الأجهزة العالية المواصفات هنا، فيما قد يظهر بطء نسبي على الأجهزة الأضعف أو عند تفعيل كل الخصائص دفعةً واحدة. بالمقارنة بين **الحلول البرمجية والمادية والسحابية**: فالجدار المادي المتخصص غالبًا يوفر أفضل أداء إذا تم اختياره وتكوينه ليتناسب مع حجم المرور المطلوب، لأنه يستفيد من مكونات مُسرَّعة للأداء. الجدار البرمجي أداؤه محدود بقدرات الجهاز المضيف، فقد يكون كافيًا لحماية حاسوب شخصي أو خادم ذو حركة خفيفة، لكنه سيعاني إذا طُلب منه معالجة سيل ضخم من البيانات مقارنة بجهاز مخصص. الجدار السحابي من جهته يعتمد أداؤه على بُنية المزود؛ فيمكن أن يكون عالي الأداء نظرًا لاعتماده على مراكز بيانات ضخمة، ولكن عنصر الشبكة (سرعة الاتصال بالإنترنت وجودة الخط) يصبح عاملًا مؤثرًا على تجربة الأداء الكلية.

من حيث مستوى الحماية: يوفر مرشح الحزم التقليدي الحد الأدنى من الحماية؛ إذ يركز على عناصر بسيطة وقد يفوّت تهديدات معقدة تمر داخل حركة مشروعة ظاهريًا. جاء الجدار ذو الحالة ليُحسّن الحماية عبر منع التدفقات غير المتوقعة ومتابعة الجلسات، مما يغلق بعض الثغرات التي يمكن أن تتسلل منها الهجمات مستغلة عدم وعي الجدران التقليدية بسياق الاتصال. مع ذلك يظل كلاهما (التقليدي وذو الحالة) محدودًا عند مواجهة هجمات **طبقة التطبيق** أو البرمجيات الخبيثة المخفية في البيانات. هنا تبرز قوة الجدران **على مستوى التطبيق**؛ فهي قادرة على الكشف العميق ومنع محاولات الاختراق عبر التطبيقات (مثل اكتشاف أكواد ضارة في طلبات الويب أو منع تسريب بيانات عبر بروتوكول مسموح)، فتقدم **مستوى حماية أعلى بكثير** ضد تهديدات كان يمكن أن تعبر من الجدران الأبسط. أما **جدران الجيل التالي** فهي حاليًا الأكثر شمولا، إذ تمزج كل تلك القدرات (تصفية أساسية، تعقب حالة، فحص محتوى) وتضيف عليها ذكاء اصطناعي أحيانًا وقواعد معرفية عن الهجمات المعروفة وطرق التصدي لها. بالتالي هي توفر **أعلى مستوى من الحماية** ضمن الخيارات المطروحة، خاصة عند تفعيل كل المزايا من IDS/IPS إلى فلترة برمجيات خبيثة وغيرها. بالنسبة

للتصنيف حسب التنفيذ: **الجدار المادي** ليس بالضرورة أكثر أمانًا من البرمجي أو السحابي بحد ذاته، فهو مجرد وعاء تقني؛ مستوى الحماية يعتمد على التقنيات المطبقة فيه. ومع ذلك، تتميز الأجهزة المادية غالبًا بتضمين أحدث تقنيات الحماية (خاصة لو كانت من الفئة العليا NGFW) وبالتالي تمنح مستوى أمان مرتفع للشبكة المحمية بها. **الجدران البرمجية** المتاحة للأفراد عادة توفر ميزات حماية أساسية إلى متوسطة تركز على الجهاز نفسه، لكنها قد لا تضاهي تعقيد التقنيات في الأجهزة المؤسسية. ومع ذلك هناك جدران برمجية متقدمة (مثل حلول UTM مفتوحة المصدر أو تجارية) يمكن تشغيلها على خوادم وتحويلها إلى جدار متقدم، فالأمر يعود للبرنامج نفسه. **الجدران السحابية** بدورها غالبًا ما تكون من فئة الجيل التالي أو على الأقل متعددة الطبقات، لأن مزودي الخدمة يسعون لتقديم حماية قوية لعملائهم؛ كما أنهم قادرون على تحديث منظوماتهم بسرعة ضد التهديدات الجديدة. لذا يمكن اعتبار مستوى الحماية في الحلول السحابية عاليًا جدًا أيضًا، بشرط ثقة العميل في أن سياسات الأمن مطبقة كما ينبغي وأن بياناته تُعالج بشكل آمن لدى المزود.

من حيث سهولة الإدارة: يختلف الأمر تبعًا لنوع الجدار وبيئة الاستخدام. **الجدار التقليدي** بسيط من ناحية مبدأ العمل وعدد قليل من القواعد قد يكون سهل الإدارة، لكن مع زيادة عدد القواعد وتعقيد الشبكة تصبح إدارته تحديًا (إذ قد يحتاج المسؤول لتتبع قوائم طويلة من السماحات والمنع لكل خدمة وعنوان). **الجدار ذو الحالة** يُسهِّل الإدارة في بعض الجوانب لأنه تلقائيًا يسمح بردود الاتصالات الموثوقة، مما يقلل الحاجة لفتح منافذ ثابتة كثيرة يدويًا. لكن من جانب آخر، لا تزال عملية صياغة السياسات وإدارة الجدار مماثلة تقريبًا لإدارة جدار تقليدي وتتطلب فهمًا لبنية الشبكة والخدمات. **جدران مستوى التطبيق** هي الأكثر تحديًا في الإدارة؛ إعداد وكيل يتطلب معرفة عميقة بكل بروتوكول يتم فحصه، وضبط دقيق لضمان عدم تعطيل الخدمات المرغوبة أثناء منع الضار منها. كذلك تحليل السجلات وحل مشكلات الأداء التي قد يسببها الوكيل تضيف عبئًا إداريًا. أما **جدران الجيل التالي** فعلى الرغم من تعقيد ميزاتها، كثير منها يأتي مع واجهات إدارة متطورة وميزات أتمتة (مثل تحديث القواعد

تلقائيًا عبر السحابة أو التصنيف التلقائي للتطبيقات)، مما يساعد في الإدارة. لكن تبقى الحاجة **لمهارات متخصصة** أمرًا مشتركًا في إدارة الجيل التالي بسبب تشعب وظائفه. بالنظر للفئات الأخرى: **الجدار المادي** يوفر إدارة مركزية كما ذكرنا، وهذا يسهل التحكم بشكل عام مقارنة بتوزيع الإعدادات على أجهزة متعددة. غير أن تعلم واجهة إدارة جهاز شبكي قد يستغرق وقتًا وجهدًا، وتظهر صعوبة الإدارة عند الحاجة لتنسيق إعدادات عدة أجهزة معًا أو ربط الجدار المادي بمنظومة أمنية أشمل. **الجدار البرمجي** قد يكون بسيطًا جدًا للمستخدم العادي (مثل واجهة تشغيل أو إيقاف قواعد في نظام التشغيل)، مما يجعله سهل الإدارة على نطاق ضيق. لكن على نطاق واسع، إدارة برمجيات حماية على عشرات أو مئات الأجهزة تستدعي استخدام أدوات مركزية أو سياسات جماعية (Group Policy) لضمان توحيد الإعدادات، وإلا فسيكون الأمر مرهقًا ويتطلب المرور على كل جهاز لإعداده. **الجدار السحابي** من حيث الإدارة قد يكون الأسهل للشركات التي لا تريد الخوض في تفاصيل الأجهزة؛ فمزود الخدمة غالبًا يعطي **لوحة تحكم موحدة عبر الويب** تتيح ضبط السياسات ومشاهدة التقارير بسهولة، وأحيانًا يتوفر دعم managed بحيث يتولى المزود نفسه مهام الإدارة اليومية. هذا يقلل الحاجة للتعامل المباشر مع التحديثات والتكوينات المنخفضة المستوى، مما يُكسب المسؤولين وقتًا للتركيز على السياسات العامة بدلًا من التفاصيل التقنية. ومع ذلك، يجب تعلم منصة المزود نفسها ومصطلحاتها، والتنسيق المستمر معه للتأكد من أن الخدمة تلبي متطلبات الشبكة الفعلية للمؤسسة.

من حيث التكلفة: تختلف التكلفة باختلاف النوع والمستوى. **الجدار التقليدي** هو الأرخص عادة؛ فكثيرًا ما يكون مدمجًا في أجهزة توجيه موجودة أصلاً أو متاحًا عبر برامج مجانية، وبالتالي قد لا يتطلب إنفاقًا إضافيًا كبيرًا. **الجدران ذات الحالة** أصبحت هي الأخرى منتشرة وبتكلفة معقولة، إذ تتوفر في الكثير من منتجات الشبكات المتوسطة. الزيادة في التكلفة تأتي مع **جدران التطبيق والجيل التالي**؛ فهذه حلول تخصصية أو متقدمة غالبًا ما تكون بأسعار مرتفعة، وتشمل ليس فقط ثمن شراء الجهاز أو البرنامج بل أيضًا كُلف دعم وصيانة وربما اشتراكات لتحديث قواعد الحماية. لكن يجب

موازنة ذلك مقابل قيمة الحماية المحصَّلة، خاصة للشركات التي قد يوفر عليها منع اختراق واحد مبالغ طائلة. بالانتقال للتصنيفات الأخرى: **الجدار البرمجي** في كثير من الحالات مجاني أو مدرج ضمن نظام التشغيل (مثل Windows Defender Firewall) أو يأتي كجزء من حزمة حماية متكاملة. حتى الحلول المدفوعة منه أسعارها في متناول الأفراد والشركات الصغيرة عادة. تكلفته الخفية تكمن في الوقت والجهد لإدارته على نطاق واسع، لكن ماليًا لا يشكل عبئًا كبيرًا في العادة. **الجدار المادي** يستلزم **إنفاقًا رأسماليًا** ملحوظًا مقدمًا؛ شراء جهاز أو عدة أجهزة بمواصفات جيدة قد يكون مكلفًا، بالإضافة إلى كلفة التراخيص السنوية للتحديث والدعم الفني. كما أن له عمرًا افتراضيًا يستلزم بعده ترقية العتاد. مع ذلك، يوفر الجدار المادي حماية لمجموعة كبيرة من الأجهزة خلفه، فيمكن التفكير فيه كاستثمار لحماية شبكة كاملة بدل شراء برامج لكل جهاز على حدة. بالنسبة إلى **الجدار السحابي**، نموذج التكلفة فيه **تشغيلي مستمر** (OpEx) بدلًا من رأس مالي؛ حيث تدفع المؤسسة رسومًا دورية بحسب حجم البيانات أو عدد المستخدمين أو المواقع المحمية. قد تبدو هذه التكلفة أقل في البداية لعدم وجود شراء أجهزة، لكنها تتراكم مع الزمن. ميزة نموذج الاشتراك أنه قابل للتعديل حسب الميزانية شهريًا أو سنويًا، ويمكن إيقافه أو تبديله بسهولة لو لم يناسب، مما يعطي مرونة مالية. هناك حالات يكون فيها الجدار السحابي موفرًا للتكلفة، مثلاً: شركة صغيرة تحتاج حماية عالية لبضعة أشهر في السنة يمكنها الاشتراك خلال تلك الفترة بدل شراء جهاز غالٍ يُستخدم طوال السنة. في المقابل، شركة كبيرة ذات حركة بيانات ضخمة قد تجد أن الاستثمار في جهاز خاص بها أرخص خلال بضع سنوات من دفع رسوم حسب البيانات على الخدمة السحابية.

باختصار، عند المفاضلة بين أنواع الجدران النارية، يجب النظر إلى احتياجات المنظمة وإمكاناتها: فالشبكات الصغيرة جدًا قد تكتفي بجدار برمجي أو مرشح حزم بسيط منخفض الكلفة، بينما البيئات الكبيرة تحتاج غالبًا لمزيج من جدار مادي قوي وربما حلول سحابية مساندة لحماية الفروع البعيدة أو الخدمات السحابية. أما مستوى الحماية المطلوب فيحدده مدى حساسية البيانات وخطورة التهديدات المتوقعة؛ فإذا كانت المخاطر عالية فلا غنى عن تقنيات الجيل التالي المتقدمة، في حين قد تكفي حلول

أبسط في الحالات الأخرى. كذلك يمثل عامل **الإدارة والصيانة** عنصرًا حاسمًا؛ فالحل الأمثل هو ما يمكن للمؤسسة تشغيله بكفاءة - فلا جدوى من جهاز بالغ التعقيد دون توفر الخبرة لإدارته، ولا من خدمة سهلة لكنها لا تلبي متطلبات الأمان الخاصة بالمنظمة. وأخيرًا، تأتي **التكلفة** لتذكّرنا بأهمية تحقيق التوازن بين ميزانية الأمن المتاحة وبين قيمة الأصول المراد حمايتها، لضمان اختيار جدار ناري يمنح أفضل حماية ممكنة ضمن الحدود المالية والتنظيمية لكل حالة.

المصائد السيبرانية Honeypots

مقدمة

تُعرَّف مصائد المخترقين (Honeypots) بأنها أنظمة أو موارد رقمية خادعة تُنصب كطُعم لاستدراج المهاجمين الإلكترونيين. تبدو هذه الأنظمة للمهاجم كأنها هدف حقيقي ذو قيمة، مثل خادم حساس أو قاعدة بيانات ثرية بالمعلومات، ولكنها في الحقيقة معزولة وتحت المراقبة. عندما يحاول المهاجم اختراق المصيدة، يتم تسجيل نشاطه وتحليل أساليبه بعيدًا عن الأنظمة الحقيقية الحساسة. بهذا الأسلوب، تساهم أنظمة الـ Honeypot في تعزيز الأمن السيبراني عبر دورين رئيسيين: **الأول** هو كشف الهجمات والتعرف على أساليب المخترقين بصورة مبكرة، و**الثاني** هو تشتيت انتباه المهاجمين وإبعادهم عن الأهداف الحقيقية في الشبكة. تستخدم المؤسسات هذه المصائد كأدوات مراقبة استخبارية تتيح فهم أحدث التهديدات والثغرات التي يستغلها المخترقون، وبالتالي تحسين خطط الدفاع والحماية استنادًا إلى معلومات واقعية. فيما يلي نستعرض الأنواع المختلفة لمصائد المخترقين وتصنيفاتها الشائعة، مع شرح مبسط لكل نوع.

مصائد عالية التفاعل (High-Interaction Honeypots)

المصائد عالية التفاعل هي أنظمة خداعية توفر بيئة شبه كاملة للمهاجم للتفاعل معها كما لو كانت نظامًا حقيقيًا. فهي تقدم خدمات وأنظمة تشغيل حقيقية أو شبه حقيقية، مما يسمح للمهاجم بتنفيذ أنشطته الخبيثة بعمق داخل المصيدة. الهدف من هذا النوع هو إطالة مدة بقاء المخترق داخل المصيدة لأطول فترة ممكنة، مما يمنح فرق الأمن فرصة أكبر لمراقبة سلوكه وفهم أدواته وتقنياته. تتميز المصيدة عالية التفاعل بأنها **غنية بالمعلومات** - حيث يمكنها كشف نوايا المهاجم، والثغرات التي يحاول استغلالها، والمسارات التي يتنقل عبرها داخل النظام. لكن بالمقابل،

تكلفة تشغيلها مرتفعة وتعقيد إدارتها عالٍ؛ إذ تتطلب موارد كبيرة لمراقبتها وعزلها عن الأنظمة الحقيقية. كما ينبغي تأمين هذا النوع من المصائد بعناية (مثلاً عبر جدران نارية متقدمة) حتى لا يستغلها المهاجم كنقطة انطلاق لمهاجمة أنظمة أخرى خارج المصيدة. غالبًا ما تُستخدم المصائد عالية التفاعل في الأوساط البحثية أو البيئات الحساسة التي تحتاج إلى فهم متعمق لسلوك المهاجمين. هذه المصائد توفر أقصى درجة من الواقعية والإغراء للمهاجم، وبالتالي تعتبر أداة قوية لكشف الهجمات المعقدة والموجهة.

مصائد متوسطة التفاعل (Medium-Interaction Honeypots)

تمثل المصائد متوسطة التفاعل حلًّا وسطًا بين المصائد عالية ومنخفضة التفاعل. فهي لا توفر نظامًا كاملًا للمهاجم كما في المصائد عالية التفاعل، ولكنها أيضًا أكثر تفاعلية وواقعية من المصائد منخفضة التفاعل. عادةً ما تقوم المصيدة متوسطة التفاعل **بمحاكاة جزئية** لبعض الخدمات أو البروتوكولات بشكل متقدم. على سبيل المثال، قد تنفّذ هذه المصيدة بروتوكولًا معينًا (مثل HTTP أو FTP) بشكل شبه كامل للرد على المهاجم بطريقة واقعية، دون أن تكون نظام تشغيل حقيقي بكل خصائصه. الهدف هنا هو خداع المهاجم لفترة أطول وتوفير **معلومات أعمق** من تلك التي تقدمها مصيدة منخفضة التفاعل، ولكن مع تقليل المخاطرة والتعقيد مقارنة بالمصيدة عالية التفاعل. المصائد متوسطة التفاعل **أسهل إدارةً** من العالية و**أكثر قدرة على الخداع** من المنخفضة، لذا قد تستخدم في البيئات التي تتطلب توازناً بين جمع المعلومات وتقليل الموارد. ورغم أن هذا النوع ليس شائعًا بقدر النوعين الآخرين، إلا أنه مفيد في بعض السيناريوهات التي تتطلب محاكاة مقنعة دون تشغيل نظام كامل. بهذه الطريقة يمكن الحصول على بيانات حول أساليب الهجوم الرئيسية مع الحفاظ على درجة مقبولة من الأمان والتحكم.

مصائد منخفضة التفاعل (Low-Interaction Honeypots)

المصائد منخفضة التفاعل هي أبسط أنواع أنظمة الـ Honeypot وأقلها تعقيدًا. يقوم هذا النوع **بمحاكاة خدمات محدودة وبسيطة** تجذب المهاجمين دون تمكينهم من السيطرة الكاملة على نظام وهمي. عادةً ما تحاكي المصيدة منخفضة التفاعل بعض المنافذ أو البروتوكولات الشائعة - مثل بروتوكول HTTP أو SMTP - بقدرات محدودة جدًا. فعلى سبيل المثال، قد تستجيب لعمليات فحص المنافذ أو لبعض أوامر البروتوكول الأساسية دون أن تكون خادمًا حقيقيًا كاملاً. تتميز هذه المصائد بأنها **سهلة الإعداد وقليلة التكلفة** من حيث الموارد، إذ يمكن تشغيل العديد منها على جهاز فعلي واحد باستخدام المحاكاة الافتراضية. دورها الرئيسي هو **الاكتشاف المبكر** للأنشطة المشبوهة؛ فعندما يحاول مهاجم استطلاع الشبكة أو استغلال ثغرة معروفة، ستكشفه المصيدة عبر تسجيل محاولاته. رغم أنها توفر معلومات محدودة فقط (مثل عنوان المهاجم ونوع الهجوم الأساسي)، إلا أنها فعّالة في كشف الهجمات البسيطة والآلية بسرعة. تستخدم المصائد منخفضة التفاعل بشكل شائع في بيئات الإنتاج لدى الشركات كنظام إنذار مبكر: فهي **تنبه المسؤولين فورًا** عند حدوث أي محاولة تسلل، مما يسمح باتخاذ إجراءات سريعة. لكن نظراً لبساطة بيئتها، فإنها **لا تكشف تفاصيل معمقة** عن تقنيات المهاجم المتقدمة، إذ سيغادر المخترق بسرعة لعدم وجود ما يفعله كثيرًا داخل المصيدة.

مصائد نقية (Pure Honeypots)

المصيدة النقية هي نوع خاص من الـ Honeypot يمثل **نظامًا حقيقيًا وكاملًا** يتم استخدامه كطُعم. بخلاف المصائد الأخرى التي قد تعمل على برمجيات محاكاة أو أنظمة افتراضية، تكون المصيدة النقية عبارة عن **خادم فعلي أو نظام إنتاج حقيقي** يتم تكريسه ليكون فخًا للمهاجمين. هذا النظام يحتوي على بيانات فعلية (وإن كانت وهمية القيمة بالنسبة للمدافعين) وخدمات كاملة التشغيل بدون تعديل أو محاكاة، مما يجعله يبدو تمامًا كأي خادم آخر في الشبكة. يتم مراقبة المصيدة النقية عبر وسائل خارجية غير مرئية للمهاجم - مثل أجهزة مراقبة على الشبكة (Network Tap) أو

سجلات خاصة - دون تثبيت برامج كشف داخلية قد تنبه المخترق. تتميز هذه المصيدة بأنها **شديدة الواقعية وصعبة الاكتشاف** من قبل المهاجم، لأن كل ما فيها حقيقي من منظور المخترق. لكن هذه الميزة تأتي مع مخاطرة كبيرة: إذا نجح المهاجم في اختراق المصيدة النقية، فإنه يتعامل مع نظام كامل قد يستغله لمواصلة الهجوم أو إلحاق ضرر ما، إن لم يكن معزولًا بشكل صارم. لذلك يجب تأمين المصيدة النقية بحزم، مثل وضعها خلف شبكات حماية أو في بيئة منعزلة تمامًا. يُستخدم هذا النوع بشكل محدود نظرًا لمخاطره وتكاليفه، ولكن عند استخدامه فإنه **يوفر أوضح رؤية** لسلوك المهاجم في بيئة مطابقة للواقع، مما يساعد بشكل كبير في كشف الثغرات وتأمين الأنظمة الحقيقية المشابهة.

مصائد الإنتاج (Production Honeypots)

مصائد الإنتاج هي Honeypots يتم نشرها داخل البيئة التشغيلية الفعلية للمؤسسة (شبكة الإنتاج) بهدف **تعزيز أمن الشبكة الواقعية**. توضع هذه المصائد جنبًا إلى جنب مع الخوادم الحقيقية والخدمات التي تستخدمها المنظمة، لكنها تكون مخصّصة لرصد أي نشاط غير اعتيادي. تتميز مصائد الإنتاج بأنها **سهلة النشر نسبيًا** ولا تتطلب تعقيدًا كبيرًا، وغالبًا ما تكون من نوع منخفض التفاعل. تستخدمها الشركات كخط دفاع إضافي: فعندما يحاول مهاجم اختراق الشبكة الداخلية ويتفاعل مع المصيدة، يتم اكتشاف وجوده فورًا قبل أن يصل إلى الخوادم الحقيقية المهمة. المعلومات التي تجمعها مصائد الإنتاج عادةً ما تكون **محدودة النطاق** - مثل تسجيل محاولة الاتصال أو الأمر الذي أُرسل - لكنها **فعّالة في تنبيه الفريق الأمني** لأي اختراق. بعبارة أخرى، هذه المصائد أشبه بجهاز إنذار مبكر أكثر منها منصة دراسية لتحليل سلوك المهاجم. من فوائد مصائد الإنتاج أنها **تسد الفجوة** التي قد تتركها أنظمة الحماية التقليدية؛ فحتى لو تمكن مهاجم من تجاوز جدار الحماية أو نظام كشف التسلل، سيجد نفسه أمام خادم يبدو مهمًا لكنه في الحقيقة طُعم. وهكذا يتم رصده دون أن يعلم. استخدام مصائد الإنتاج يساعد المؤسسات على **تحسين الوضع**

الأمني العام لشبكتها بتكلفة منخفضة وجهد بسيط، نظرًا لإعدادها المباشر وقدرتها على العمل بشكل شبه ذاتي في خلفية الشبكة.

مصائد البحث (Research Honeypots)

مصائد البحث هي أنظمة Honeypot تُنشأ خصيصًا من قبل الباحثين الأمنيين والجهات الأكاديمية أو الحكومية بهدف **دراسة المهاجمين وفهم تهديداتهم** بشكل معمق. على عكس مصائد الإنتاج، لا تهدف المصائد البحثية إلى حماية شبكة محددة بقدر ما تهدف إلى **جمع معلومات استخبارية** عن الهجمات الإلكترونية وأساليب المخترقين على نطاق واسع. غالبًا ما تكون هذه المصائد **معقدة جدًا وعالية التفاعل**، لأن الباحثين يرغبون في منح المهاجم مساحة واسعة للقيام بنشاطه الخبيث ودراسته بالتفصيل. قد تُنشَر مصائد بحث متعددة ومتنوعة لاستدراج مختلف أنواع المهاجمين: مثل مصيدة مخصصة لاستهداف مجرمي البرامج الخبيثة، وأخرى لجذب مخترقي قواعد البيانات، وهكذا. تقوم هذه المصائد **بالتقاط كمية ضخمة من البيانات** حول كل خطوة يقوم بها المخترق، بما في ذلك أدوات الاختراق المستخدمة، والثغرات المستغلة، وأساليب التخفي والتملص. نظرًا لهذا الدور الشامل، فإن مصائد البحث **تتطلب خبرة تقنية عالية في إعدادها وصيانتها**، كما تتطلب موارد كبيرة لتحليل البيانات المستخلصة. لا توفر المصائد البحثية فائدة مباشرة لمؤسسة معينة (فقد تُهاجم من مجموعات إجرامية قد لا تستهدف تلك المؤسسة تحديدًا)، لكن الفائدة تأتي بشكل غير مباشر: فالنتائج المستخرجة منها تساعد في **معرفة التهديدات الناشئة** على الساحة، وتطوير استراتيجيات دفاعية وأدوات حماية جديدة تخدم الجميع. تستخدم المؤسسات البحثية والعسكرية والحكومية هذه المصائد كجزء من دراسات الأمن السيبراني الشاملة ولإثراء قاعدة المعرفة حول سلوك المهاجمين.

مصائد البرمجيات الخبيثة (Malware Honeypots)

مصيدة البرمجيات الخبيثة هي نظام خداعي مصمم خصيصًا **لاستدراج البرامج الضارة** مثل الفيروسات والديدان وأحصنة طروادة. تقوم هذه المصيدة بتمثيل هدف مغرٍ للبرمجيات الخبيثة عبر **إظهار ثغرات أو منافذ معروفة** تجذب البرمجيات الضارة التي تبحث عن أنظمة ضعيفة للإصابة بها. على سبيل المثال، قد تحاكي المصيدة خادمًا يحتوي على ثغرة أمنية معروفة، أو جهازًا غير مُحَصَّن يقوم بنشر خدمات قد تستهدفها الديدان الإلكترونية المنتشرة. عندما تهاجم البرمجية الخبيثة المصيدة، يتم احتواؤها وتسجيل سلوكها بدقة. يسمح ذلك لفِرَق الأمن بتحليل البرمجية الضارة **في بيئة آمنة** ومعرفة كيفية انتشارها ونوعية الضرر الذي يمكن أن تسببه. من خلال هذه المعلومات يمكن **تطوير مضادات فيروسات أو ترقيع الثغرات** في الأنظمة الحقيقية قبل أن يصيبها ذلك الهجوم. تعد مصائد البرمجيات الخبيثة أداة فعالة بشكل خاص ضد الهجمات واسعة الانتشار والآلية، مثل ديدان الشبكة التي تنتشر تلقائيًا. فبدلاً من أن تصيب الدودة أجهزة حقيقية، تنشغل بمهاجمة المصيدة التي تبدو لها كهدف سهل. وبمجرد وقوعها في الفخ، يستطيع الباحثون جمع عينات من البرمجية الخبيثة وفهم تقنياتها. من الأمثلة العملية لهذا النوع: مصائد مصممة خصيصًا لمحاكاة أجهزة إنترنت الأشياء الضعيفة التي تستهدفها برمجيات **إنترنت الأشياء الخبيثة** (كنوع من الديدان التي تُجنِّد أجهزة الراوتر والكاميرات في شبكات Botnet). هكذا تساهم مصائد البرمجيات الخبيثة في **رصد التهديدات الجديدة** وتحليلها قبل استفحالها وانتشارها على نطاق أوسع.

مصائد العميل (Client Honeypots)

على عكس معظم أنواع الـ Honeypot التي تعمل كخوادم تنتظر قدوم المهاجم، فإن مصائد العميل تقوم بالدور المعاكس: **هي التي تبحث عن المهاجم** بدلًا من انتظاره. يُطلق عليها أيضًا "مصائد الجانب العميل"، لأنها تحاكي أجهزة أو برامج العميل التي يستخدمها المستخدم النهائي (مثل متصفح الويب أو تطبيق بريد إلكتروني) وتضع نفسها في موقف من يتلقى الهجوم. تعمل مصيدة العميل عن طريق تجهيز نظام

يبدو وكأنه **عميل ضعيف أو غير محدث** يحتوي على ثغرات معروفة، ثم تقوم هذه المصيدة بالاتصال بخوادم أو مواقع خارجية مشبوهة بشكل استباقي. على سبيل المثال، قد يتصفح متصفح وهمي (تابع للمصيدة) مواقع ويب معروفة بنشر البرمجيات الخبيثة، أو يفتح ملفات ورسائل مشبوهة، وكأنه مستخدم عادي. إذا حاول خادم ضار استغلال الثغرة في هذا "العميل" الوهمي، يتم رصد المحاولة وتسجيل بيانات الهجوم. بهذا الأسلوب، تساعد مصائد العميل في **كشف الهجمات التي تستهدف المستخدمين** (الهجمات من جانب الخادم أو المواقع الخبيثة) مثل هجمات تصيد المتصفح أو استغلال الثغرات في البرمجيات العميلة. مصائد العميل عادةً ما تُدار من قبل فرق أمن متقدمة أو باحثين، وتوفر **نظرة تكاملية** للهجمات بحيث تغطي الجانب الذي قد لا تراه المصائد التقليدية (الخوادم). من خلال تحليل ما تتعرض له هذه "العملاء الوهمية"، يمكن تحسين أمن البرمجيات التي يستخدمها الجمهور العادي وسد الثغرات التي يستغلها المهاجمون ضد المستخدمين.

مصائد قواعد البيانات (Database Honeypots)

تركز مصائد قواعد البيانات على استدراج المهاجمين الذين يستهدفون **قواعد البيانات وأنظمة إدارة البيانات**. تُنشئ المنظمة في هذا النوع قاعدة بيانات خادعة تبدو للمهاجم غنية بالمعلومات الحساسة (مثل جداول تحتوي على بيانات مالية أو شخصية)، لكنها في الواقع مصيدة منفصلة عن قواعد البيانات الحقيقية. كثيرًا ما تترافق هذه المصيدة مع تطبيق ويب أو بوابة ظاهرية تعطي انطباعًا للمخترق بوجود ثغرات يمكن استغلالها في قاعدة البيانات. مثلًا، قد يتعمد المسؤولون ترك ثغرة SQL Injection (حقن لغة الاستعلام) ظاهرية تؤدي بالمهاجم إلى قاعدة بيانات المصيدة. عند محاولة الاختراق، **يتم توجيه الهجوم إلى قاعدة البيانات الوهمية** بدلًا من القاعدة الحقيقية، مما يسمح بتسجيل جميع استعلامات SQL الخبيثة التي يجربها المهاجم. توفر هذه الإستراتيجية فائدتين رئيسيتين: الأولى **حماية القواعد الفعلية** بمنح المهاجم هدفًا بديلاً سهلًا، والثانية **جمع معلومات مفصلة** حول تقنيات الهجوم

على قواعد البيانات (مثل أوامر SQL المستخدمة وأساليب رفع الامتيازات). بعض أنظمة جدران الحماية الخاصة بقواعد البيانات تتضمن بالفعل دعمًا لمصائد كهذه، حيث تكتشف الهجوم وتحوله تلقائيًا نحو قاعدة بيانات خادعة. ومن خلال تحليل نشاط المخترق في تلك القاعدة الوهمية، يمكن للخبراء **تقوية إعدادات الأمان** في قواعد البيانات الحقيقية وتصحيح نقاط الضعف المحتملة. تستخدم مصائد قواعد البيانات بشكل خاص في البيئات التي تكون فيها البيانات عنصراً جوهرياً يستهدفه المجرمون، مما يجعلها أداة قيّمة لرصد أي محاولة لسرقة البيانات أو تخريبها.

مصائد البريد الإلكتروني (Email Honeypots)

مصائد البريد الإلكتروني، التي تُعرف أيضًا بمصائد البريد العشوائي (Spam Honeypots)، هي آليات خادعة تُستخدم لمكافحة **رسائل البريد الإلكتروني الضارة أو المزعجة** والكشف عن مرسليها. تأخذ هذه المصائد عدة أشكال، أشهرها وضع **عناوين بريد إلكتروني وهمية** لا تُستخدم للتواصل الحقيقي، وإنما فقط كطُعم للمرسلين غير الشرعيين. فعلى سبيل المثال، قد يتم نشر عنوان بريد إلكتروني بشكل مخفي على صفحة ويب أو في مكان لا يصل إليه إلا جامعو العناوين التلقائيون (وهي البرمجيات التي يستخدمها مرسلو البريد العشوائي للبحث عن عناوين ضحايا جدد). عندما تبدأ الرسائل بالوصول إلى هذا العنوان الوهمي، يعرف المسؤولون أن كل تلك الرسائل هي حتمًا رسائل غير مرغوب فيها، لأن العنوان لم يُعطَ لأي جهة حقيقية. **يتم بذلك جمع رسائل spam وتحليلها** والتعرف على أساليب جديدة في الخداع أو محتويات التصيد. نوع آخر من مصائد البريد يتمثل في **محاكاة خوادم بريد مفتوحة** (مثل خادم SMTP يقبل الإرسال بدون قيود). هذا يجذب مرسلي البريد العشوائي الذين يبحثون عن مخدمات مفتوحة لإغراقها بالرسائل. وعند محاولة استخدام المصيدة كخادم إرسال، يتم تسجيل بيانات المرسل وأساليبه، بل ويمكن للمصيدة خداع المُرسِل بحيث يعتقد أن رسائله أُرسلت بنجاح بينما يتم إهمالها فعليًا وعدم تسليمها. هكذا تستطيع المؤسسات **بناء قواعد حظر وتحديث أنظمة الترشيح**

استنادًا إلى المعلومات المجموعة (مثل إضافة عناوين IP المشبوهة إلى القوائم السوداء). بشكل عام، تلعب مصائد البريد الإلكتروني دورًا مهمًا في تقليل **البريد الضار والمزعج** عبر تعقب مرسليه وأساليبهم، مما يحسن من فعالية مرشحات البريد الإلكتروني التقليدية ويحمي المستخدمين من الرسائل الخطرة.

شبكة المصائد (Honeynet)

يشير مصطلح "Honeynet" إلى شبكة كاملة مكونة من عدة مصائد Honeypot تعمل معًا بشكل منسق. بدلًا من مصيدة واحدة منفردة، يتم نشر **مجموعة من المصائد المتنوعة** على امتداد شبكة تبدو حقيقية وكاملة. قد تتضمن الـ Honeynet مصيدة عالية التفاعل إلى جانب أخرى منخفضة التفاعل، وعدة أنظمة وهمية مثل خوادم ويب، وقواعد بيانات، ومحطات عمل، بل وحتى أجهزة وهمية تمثل شبكات فرعية كاملة. الهدف من شبكة المصائد هو **تشكيل بيئة خداعية شاملة** تغطي مختلف مكونات الشبكة، بحيث يصعب على المهاجم تمييزها عن بيئة الإنتاج الحقيقية. عندما يخترق المهاجم الـ Honeynet، فإنه سيجد أمامه عدة أهداف وطبقات يمكنه التحرك عبرها، مما يمنح فرق الأمن **صورة أوسع للهجوم** تشمل أساليب التنقل الجانبي (Lateral Movement) وكيفية انتشار المهاجم بين الأنظمة المختلفة. تتم إدارة شبكات الـ Honeynet عادةً عبر **منصة مركزية** تراقب حركة المرور بالكامل داخل الشبكة الوهمية وفيما بينها، وتعمل على ضمان أن أي نشاط خبيث لا يخرج عن نطاق السيطرة أو ينتقل إلى شبكة المؤسسة الحقيقية. إحدى أشهر أدوات إدارة الـ Honeynet هي ما يُعرف بـ "الجدار العسل" (Honeywall) الذي يفصل الشبكة الخادعة عن العالم الخارجي ويراقب البيانات الداخلة والخارجة. تعتبر الـ Honeynets أقوى أسلوب خداعي متاح، لأنها **توفر كمًا هائلًا من المعلومات** وفي نفس الوقت **ترفع درجة الإيهام** للمهاجم إلى أقصى حد. بالمقابل، هي الأكثر تعقيدًا من ناحية الإعداد والصيانة، وغالبًا ما تُستخدم للأغراض البحثية أو لحماية المؤسسات الكبيرة التي تتعرض لهجمات معقدة ومستمرة.

قاعدة البيانات الخادعة (Decoy Database)

يقصد بقاعدة البيانات الخادعة إنشاء **قاعدة بيانات وهمية كطعم** للمهاجمين ضمن بيئة المؤسسة. يختلف هذا المفهوم قليلًا عن مصائد قواعد البيانات التقليدية في طريقة دمجه مع الأنظمة الموجودة: فقد تكون قاعدة البيانات الخادعة **منصوبة جنبًا إلى جنب مع قواعد البيانات الحقيقية** في الشبكة بحيث يبدو أنها جزء طبيعي من بنيتها. على سبيل المثال، قد يتم إدراج خادم قاعدة بيانات إضافي في الشبكة يحمل بيانات تبدو مهمة (مثل جدول عملاء أو سجلات مالية)، لكن **لا يستخدمه أحد فعليًا في العمل اليومي**. الهدف هو أنه إذا تمكن أحد المتسللين من الوصول إلى شبكة الشركة الداخلية وبدأ في استكشاف الخوادم، فسوف ينجذب إلى هذه القاعدة الوهمية معتقدًا أنها كنز من المعلومات. عندها، يتم **مراقبة تحركاته واستعلاماته** داخل القاعدة الخادعة لكشف نواياه. يمكن أيضًا أن يتم إعداد **بيانات زائفة ضمن قواعد البيانات الحقيقية** نفسها كنوع من "الطُعم"، بحيث لو جرت محاولة للوصول إلى بيانات معينة مع أنه لا يفترض بأحد استخدامها، يتم توليد تنبيه أمني (هذا يشابه مفهوم "وسم العسل" أو honeytoken داخل قواعد البيانات). لكن كوننا نتحدث عن أنظمة Honeypot، فإن قاعدة البيانات الخادعة عادةً ما تكون نظامًا مستقلًا بالكامل. تفيد هذه الإستراتيجية المؤسسات في **اكتشاف أي نشاط داخلي مشبوه** قد يقوم به عاملون أو مهاجمون نجحوا في التسلل عبر الدفاعات، حيث أن أي تفاعل مع القاعدة الخادعة يعتبر علامة تحذيرية فورية. بالإضافة إلى ذلك، يمكن أن تحتوي هذه القاعدة على **بيانات مضللة** تجعل المهاجم يظن أنه أحرز هدفًا، بينما يكون في الواقع يهدر وقته تحت المراقبة. بهذا الأسلوب، تساهم قواعد البيانات الخادعة في **حماية البيانات الحساسة الحقيقية** عبر تشتيت الهجوم وجمع أدلة رقمية حول أساليبه.

أنواع أخرى شائعة من المصائد

بالإضافة إلى ما سبق، هناك **مصائد متخصصة** تستخدم في مجالات محددة من الأمن السيبراني. على سبيل المثال، ظهرت **مصائد للأنظمة الصناعية الحرجة** لمحاكاة بيئات أنظمة التحكم الصناعي (Industrial Control Systems Honeypots). تستهدف هذه المصائد المهاجمين الذين يحاولون اختراق شبكات المصانع أو البنى التحتية (مثل أنظمة التحكم بالمحطات الكهربائية أو خطوط الإنتاج الآلي). تقوم المصيدة الصناعية بتقليد أجهزة التحكم ومنظومات الSCADA لجذب محاولات التخريب أو التجسس الصناعي، مما يمكّن الخبراء من دراسة تلك المحاولات وتأمين الأنظمة الصناعية الحقيقية وفقًا لذلك. كذلك توجد **مصائد لأجهزة إنترنت الأشياء (IoT)** نظرًا لانتشار الهجمات على الأجهزة الذكية ضعيفة الحماية (مثل الموجهات المنزلية والكاميرات الرقمية). هذه المصائد تتظاهر كأجهزة IoT قابلة للاختراق بحيث تغري برمجيات اختراق إنترنت الأشياء - التي عادةً ما تبحث عن أجهزة افتراضية لإضافتها إلى شبكات Botnet - بالهجوم عليها. ونتيجة لذلك، يتم حصر تلك البرمجيات الضارة ودراستها قبل أن تلحق الضرر بأجهزة حقيقية. تجدر الإشارة أيضًا إلى وجود **مصائد للعناكب الإلكترونية** مصممة لخداع برمجيات الزحف على الويب (Web Crawlers) الضارة عبر صفحات خاصة للإيقاع بها وحرمانها من المعلومات الحقيقية. بشكل عام، يظهر لنا أن مفهوم Honeypot قابل للتطبيق بمرونة وفق الحاجة: **أي نظام أو خدمة متصلة يمكن تحويلها إلى مصيدة** إذا ما صُممت لجذب المتسللين وتسجيل أفعالهم. ومع تطور التهديدات الرقمية، تستمر أساليب المصائد في الابتكار لتشمل منصات جديدة وقطاعات مختلفة، مما يجعلها جزءًا أساسيًا من منهجيات الدفاع السيبراني الشامل في عصرنا الحالي.

التحقيق الجنائي الرقمي

مقدمة عامة عن التحقيق الجنائي الرقمي

التحقيق الجنائي الرقمي هو مجال من مجالات العلوم الجنائية يركّز على اكتشاف وجمع وتحليل الأدلة المخزنة في الأجهزة الرقمية. يشمل ذلك أجهزة الحاسوب والهواتف الذكية والأجهزة اللوحية والشبكات وحتى البيانات المخزنة على الخدمات السحابية. يهدف هذا النوع من التحقيق إلى تتبُّع الأنشطة غير القانونية في الفضاء الرقمي والكشف عن الأدلة الإلكترونية المرتبطة بها لاستخدامها في الإجراءات القضائية.

تبرز أهمية هذا المجال في عصرنا الرقمي بسبب الانتشار الواسع للتكنولوجيا في كل جوانب الحياة اليومية. فالجرائم الحديثة غالبًا ما تترك وراءها أثرًا رقميًا كرسائل البريد الإلكتروني أو سجلات الأجهزة، مما يجعل تتبُّع تلك الآثار أمرًا ضروريًا لكشف الحقيقة. ومن خلال التحقيق الجنائي الرقمي تستطيع الجهات المختصة الوصول إلى معلومات مخفية داخل الأجهزة أو الشبكات، مما يساعد في حل الجرائم ودعم الأدلة أمام القضاء.

يختلف التحقيق الجنائي الرقمي عن التحقيقات التقليدية في أنه يتعامل مع بيانات إلكترونية غير ملموسة بدلًا من أدلة مادية محسوسة. ففي حين يبحث المحقق الجنائي التقليدي عن بصمات أصابع أو آثار مادية في مسرح الجريمة الواقعي، يتعمّق المحقق الرقمي في سجلات الحاسوب أو الهاتف لتحليل نشاط المستخدم والملفات الرقمية. يتطلب هذا المجال أيضًا مهارات تقنية متقدمة وأدوات برمجية خاصة لاستعادة المعلومات وتحليلها، بينما ترتكز بعض التحقيقات الأخرى على أدوات علمية مختلفة (كيميائية أو بيولوجية مثلاً). ورغم هذه الفروق، يشترك النوعان في ضرورة الحفاظ على سلامة الأدلة وتوثيقها لضمان مقبوليتها قانونيًا.

مراحل التحقيق الجنائي الرقمي

تمر عملية التحقيق الجنائي الرقمي بعدة مراحل أساسية منظمة لضمان التعامل الصحيح مع الأدلة الرقمية، وتشمل ما يلي:

1. **تحديد الحادثة (Identification):** تعني التعرف على الحادثة الرقمية أو الجريمة الإلكترونية التي وقعت وتحديد نطاق التحقيق. في هذه المرحلة يحدد المحقق ما الأنظمة أو الأجهزة المعنية بالحادث ويضع خطة أولية لجمع الأدلة المناسبة.

2. **جمع الأدلة (Collection):** يقوم المحقق في هذه المرحلة بجمع البيانات والأدلة الرقمية من الأجهزة أو المصادر الرقمية ذات الصلة بالحادث. يتم ذلك بأساليب تضمن عدم تغيير البيانات الأصلية، مثل استخدام أدوات متخصصة لنسخ محتوى الأقراص الصلبة بالكامل أو استخراج المعلومات من الهواتف والشبكات دون المساس بالأدلة.

3. **حفظ الأدلة (Preservation):** تركّز هذه المرحلة على حماية سلامة الأدلة الرقمية بعد جمعها. يتضمن ذلك تخزين النسخ المستخرجة من البيانات في مكان آمن، واستخدام وسائل مثل أجهزة منع الكتابة (Write Blockers) للحفاظ على الوسائط الأصلية دون تعديل. كما تشمل هذه المرحلة توثيق كل خطوة في التعامل مع الأدلة لضمان الحفاظ على سلسلة حفظ الأدلة القانونية من المصدر إلى المحكمة.

4. **تحليل البيانات (Analysis):** بعد حفظ الأدلة بأمان، يبدأ المحقق في فحص وتحليل المحتوى الرقمي المستخلص. يستخدم برامج وأدوات متخصصة لتفتيش الملفات وسجلات النظام ورسائل البريد الإلكتروني وغيرها، بحثًا عن أدلة ذات صلة بالقضية. قد يشمل التحليل إعادة بناء خط زمني للأحداث الرقمية، واستعادة الملفات المخفية أو المحذوفة، وفهم كيفية وقوع الحادثة

الرقمية وطريقة تنفيذها.

5. **إعداد التقرير وتقديمه (Reporting & Presentation):** في هذه المرحلة الختامية، يجمع المحقق نتائج تحليله في تقرير واضح ومنظم. يحتوي التقرير على شرح مبسّط للأدلة المكتشفة وكيف تم العثور عليها، مع توضيح أهميتها لمسار القضية. يُقدَّم هذا التقرير إلى الجهات المعنية مثل المحاكم أو مدراء المؤسسات، وقد يُطلَب من المحقق الإدلاء بشهادته كخبير لتوضيح النتائج بلغة يفهمها غير المتخصصين.

أنواع الأدلة الرقمية

تتنوع الأدلة الرقمية باختلاف مصدرها ونوع الجهاز أو الخدمة التي تُحفظ فيها. فيما يلي أبرز الأنواع الشائعة للأدلة الرقمية:

- **الأدلة من الحواسيب:** تشمل الملفات المخزنة على أجهزة الكمبيوتر، مثل المستندات والصور وقواعد البيانات، إضافةً إلى سجلات النظام (مثل سجلات الأحداث) التي قد تكشف عن نشاط المستخدم على الجهاز.

- **الأدلة من الأجهزة المحمولة:** تتضمن البيانات الموجودة في الهواتف الذكية والأجهزة اللوحية، مثل جهات الاتصال وسجل المكالمات والرسائل النصية ورسائل تطبيقات المحادثة، والصور ومقاطع الفيديو، بالإضافة إلى معلومات الموقع الجغرافي المخزنة في تلك الأجهزة.

- **الأدلة من الشبكات:** تشمل سجلات حركة المرور في الشبكة، مثل سجلات الخوادم وأجهزة التوجيه (الراوتر)، والتي تظهر الاتصالات والأنشطة التي تمت عبر الشبكة أو الإنترنت. على سبيل المثال، يمكن لتحليل سجل الخادم أو جدار

الحماية تحديد توقيت وتفاصيل حدوث اختراق إلكتروني وتتبّع مصدره عبر عنوان IP.

- **الأدلة من السحابة الإلكترونية:** تشمل البيانات المخزنة على خدمات الإنترنت (الحوسبة السحابية)، مثل رسائل البريد الإلكتروني المحفوظة على خوادم البريد، والملفات المخزنة على منصات التخزين السحابي، وبيانات حسابات التواصل الاجتماعي. علمًا بأن الحصول على هذه الأدلة يستوجب غالبًا التنسيق مع مزوّدي الخدمات واتباع الإجراءات القانونية المناسبة نظرًا لتواجدها خارج الأجهزة المادية للمشتبه بهم.

أدوات وتقنيات التحقيق الجنائي الرقمي

يعتمد المحقق الجنائي الرقمي على مجموعة من البرامج والتقنيات لمساعدته في استخراج الأدلة وفحصها. فيما يلي أمثلة على بعض الأدوات الشائعة في هذا المجال:

- **Autopsy:** أداة مفتوحة المصدر بواجهة رسومية تستخدم في تحليل الأدلة الرقمية. تساعد Autopsy المحقق في فحص نسخ مأخوذة من الأقراص الصلبة واكتشاف الملفات المخفية أو المحذوفة وتحليل نظام الملفات، وذلك دون التأثير على البيانات الأصلية.

- **FTK (Forensic Toolkit):** حزمة برمجية تجارية متكاملة تستخدم في مجالات التحقيق الرقمي. يتميز FTK بقدرته على معالجة كميات كبيرة من البيانات بسرعة من خلال فهرسة المحتوى لتسهيل البحث، كما يمكنه تحليل أنواع متعددة من الملفات (مثل الوثائق ورسائل البريد الإلكتروني وملفات الوسائط المتعددة).

- **Volatility:** أداة مفتوحة المصدر متخصصة في تحليل ذاكرة الوصول العشوائي (RAM) للحاسوب. تتيح هذه الأداة للمحقق استخراج معلومات مهمة من صورة الذاكرة، مثل العمليات التي كانت تعمل على الجهاز وقت الحادث وآثار البرمجيات الخبيثة التي قد لا تظهر في تحليل القرص الصلب.

بالطبع هناك العديد من الأدوات الأخرى المتوفرة في مجال التحقيق الرقمي، ويختار المحقق منها ما يناسب طبيعة كل قضية ونوع الأدلة التي يتعامل معها.

التحديات التي تواجه التحقيق الجنائي الرقمي

على الرغم من تطور تقنيات وأساليب التحقيق الرقمي، توجد العديد من التحديات التي تواجه المختصين في هذا المجال، من أبرزها:

- **التشفير:** يلجأ بعض المجرمين إلى استخدام تقنيات التشفير لحماية بياناتهم، مثل تشفير الأقراص الصلبة بالكامل أو وضع كلمات مرور معقدة على الملفات الحساسة. هذا يجعل الوصول إلى المحتوى الأصلي شديد الصعوبة من دون معرفة كلمة السر أو امتلاك مفاتيح التشفير. وبالتالي يُعد التشفير من أكبر العقبات أمام المحقق الجنائي الرقمي، حيث قد يستحيل تجاوز بعض خوارزميات التشفير الحديثة ما لم يتوفر المفتاح من قِبل المشتبه به أو يتم كسره بتصريح قانوني خاص.

- **إتلاف الأدلة:** قد يعمد مرتكبو الجرائم الرقمية إلى طمس آثارهم عبر حذف الملفات المهمة أو استخدام برامج تمسح البيانات بشكل نهائي، وأحيانًا يلجؤون إلى تخريب الأجهزة نفسها لإتلاف الأدلة. يواجه المحقق في هذه الحالات صعوبة في استعادة المعلومات المحذوفة. فعلى الرغم من توفر أدوات تستطيع استرجاع البيانات حتى بعد حذفها، يعتمد نجاح ذلك على عدم الكتابة فوق تلك البيانات في وسيط التخزين. وفي حال استخدام تقنيات مسح

متقدمة أو تعرُّض وسيط التخزين لتلف مادي متعمّد، فقد تصبح استعادة الأدلة الرقمية شبه مستحيلة.

- **تعدد الأنظمة والأجهزة:** يغطي التحقيق الرقمي طيفًا واسعًا من التقنيات والمنصات. على المحقق التعامل مع حواسيب بأنظمة تشغيل مختلفة (مثل ويندوز ولينكس وماك) ومع أجهزة محمولة متنوعة (أندرويد وiOS)، بالإضافة إلى الخوادم وأجهزة إنترنت الأشياء وغيرها. هذا التنوع يتطلب من المحقق مواكبة مستمرة للتطور التقني وتعلم استخدام أدوات مختلفة تناسب كل نظام أو جهاز، مما يزيد من تحديات المهمة وتعقيدها أحيانًا.

المهارات المطلوبة للمحقق الجنائي الرقمي

يحتاج المحقق الجنائي الرقمي إلى مزيج من المهارات التقنية والتحليلية والشخصية ليتمكن من أداء عمله بكفاءة. فيما يلي أهم المهارات التي ينبغي توفرها في المحقق الرقمي:

- **التفكير التحليلي:** القدرة على تحليل كم كبير من المعلومات الرقمية والربط بين الأدلة المختلفة لاستخلاص استنتاجات منطقية. يجب أن يمتلك المحقق عقلية نقدية تمكنه من ملاحظة التفاصيل الصغيرة واستقراء الأحداث المحتملة من الأدلة المتاحة.

- **الفهم التقني:** إلمام واسع بالتقنيات الرقمية، بما في ذلك أنظمة التشغيل المختلفة وهيكلية الملفات وشبكات الحاسوب ومكونات الأجهزة. هذه المعرفة التقنية تساعد المحقق على تحديد أين يمكن أن تتواجد الأدلة وكيفية استخراجها دون الإضرار بها؛ فمثلًا فهمه لأسلوب تخزين البيانات يمكنه من

معرفة الأماكن المحتملة للبحث عن الملفات المخفية أو المؤقتة.

- **الكتابة المهنية للتقارير:** مهارة صياغة التقارير بشكل واضح ومنظم ودقيق. على المحقق أن يشرح نتائجه بلغة يفهمها غير المتخصصين (مثل القضاة أو المدراء)، مع الحفاظ على دقة التفاصيل الفنية. يتضمن التقرير الجنائي الرقمي الجيد وصفًا للإجراءات المتبعة وشرحًا للأدلة المكتشفة وعلاقتها بالقضية بأسلوب موضوعي ومفهوم.

تطبيقات التحقيق الرقمي

يساهم التحقيق الجنائي الرقمي في كشف الحقائق وتحقيق العدالة في مجالات متعددة. فيما يلي بعض أبرز مجالات تطبيقه:

- **الجرائم الإلكترونية:** يشمل ذلك التحقيق في قضايا مثل اختراق الشبكات (القرصنة)، والاحتيال المالي عبر الإنترنت، وهجمات البرمجيات الخبيثة، وجرائم الابتزاز وانتهاك الخصوصية الرقمية. يعمل المحققون الرقميون مع جهات إنفاذ القانون لتتبّع أثر تلك الجرائم في الفضاء السيبراني؛ فعلى سبيل المثال، يمكنهم تتبّع عنوان IP لمخترق أو تحليل سجلات المحادثات لكشف عملية احتيال إلكتروني. تساعد هذه التحقيقات في جمع أدلة رقمية قوية تسهم في تقديم الجناة إلى العدالة.

- **الشركات والمنظمات:** تعتمد المؤسسات على التحقيق الرقمي عند وقوع حوادث أمنية أو انتهاكات داخلية. فإذا حدث مثلًا تسريب لبيانات سرية أو اشتُبه بقيام موظف بسرقة بيانات أو إساءة استخدام موارد الشركة، تستعين الإدارة بمحقق جنائي رقمي لفحص أجهزة الشركة وشبكتها. يتيح ذلك للإدارة تحديد كيفية وقوع الحادث ومن المسؤول عنه، مما يساعدها على اتخاذ قرارات مبنية

على أدلة موثوقة واستباق أي تهديدات مستقبلية.

- **النزاعات القانونية:** في الدعاوى المدنية والتجارية، كثيرًا ما يلجأ أطراف النزاع إلى الأدلة الرقمية لدعم موقفهم. على سبيل المثال، قد يستخدم أحد المحامين رسائل بريد إلكتروني أو محادثات نصية لإثبات دعوى أو نفيها. هنا يقوم المحقق الرقمي باستخراج تلك الأدلة والتأكد من موثوقيتها وتقديمها بشكل مناسب. كما أصبح التحقيق الرقمي جزءًا أساسيًا من عملية **الاكتشاف الإلكتروني (e-discovery)** في القضايا الحديثة، حيث يتم جمع وفرز كميات كبيرة من المستندات والوثائق الإلكترونية لتقديمها أمام المحكمة كأدلة داعمة.

أخلاقيات التحقيق الجنائي الرقمي

نظرًا لحساسية المعلومات التي يتعامل معها المحقق الجنائي الرقمي، فإن الالتزام بالمعايير الأخلاقية والمهنية أمر بالغ الأهمية. فيما يلي أبرز الجوانب الأخلاقية التي يجب مراعاتها أثناء ممارسة التحقيق الرقمي:

- **احترام الخصوصية:** يجب على المحقق احترام خصوصية الأفراد والجهات عند التعامل مع البيانات الرقمية. ينبغي عدم تفحّص المعلومات الخارجة عن نطاق القضية، وعدم إساءة استخدام الصلاحيات الممنوحة له إلا في حدود ما يتطلبه التحقيق. كما يتعين الحصول على الأذونات القانونية اللازمة (مثل أوامر التفتيش من السلطات المختصة) قبل فحص أي بيانات شخصية لضمان احترام الحقوق الفردية وخصوصية الآخرين.

- **النزاهة والحياد:** على المحقق أن يحافظ على موضوعيته وأمانته المهنية خلال جميع مراحل التحقيق. يجب عرض الحقائق كما هي دون تحريف أو انتقاء، وتجنب الانحياز لأي طرف. يلتزم المحقق أيضًا بعدم إخفاء أي دليل مهم، حتى لو كان في

غير صالح الجهة التي كلفته بالتحقيق، فدوره هو تقديم الحقيقة كاملة. كذلك عليه توظيف ما يمتلكه من معلومات ومهارات في إطار القانون فقط ودون تجاوز للسلطات المخوّلة له.

- **العمل ضمن الإطار القانوني:** يجب أن تُجرى عملية التحقيق الرقمي دائمًا ضمن حدود القانون والإجراءات المعتمدة. فالأدلة التي يتم الحصول عليها بطرق غير قانونية قد تفقد قيمتها أمام المحكمة أو تُستبعد تمامًا. لذلك يحرص المحقق الرقمي على اتباع منهجية قانونية صارمة تشمل توثيق كل خطوة يتم اتخاذها أثناء جمع وتحليل الأدلة (سلسلة حفظ الأدلة). يضمن هذا النهج سلامة التحقيق ومصداقية الأدلة، ويحول دون تعرض القضية للطعن بسبب إجراءات مخالفة للقانون.

بالالتزام بهذه المبادئ الأخلاقية والقانونية، يضمن المحقق الجنائي الرقمي أن تكون نتائج تحقيقاته موثوقة وعادلة. وهذا بدوره يعزز الثقة في مجال التحقيق الرقمي ويساعد على تحقيق العدالة في العصر الرقمي.

أهم وأشهر أدوات الأمن السيبراني

في عصرنا الرقمي الحالي، أصبحت أدوات الأمن السيبراني جزءًا أساسيًا من حماية الأنظمة والشبكات. تتنوع هذه الأدوات حسب مجالات الاستخدام، فبعضها مخصص لاختبار الاختراق، وبعضها لمراقبة الشبكات أو كشف التسلل، وغيرها لكسر كلمات المرور أو تحليل البرمجيات الخبيثة. فيما يلي **أهم وأشهر أدوات الأمن السيبراني** مرتبة حسب فئاتها الرئيسية، مع توضيح استخدامات كل أداة بإيجاز:

1. **Kali Linux** - *نظام تشغيل لاختبار الاختراق ومنصة أدوات*: توزيعة لينكس متخصصة تضم مئات من أدوات الأمن السيبراني (مثل Nmapg Metasploit وWireshark)، مما يوفر بيئة متكاملة وشاملة لاختبار الاختراق وتقييم أمان الأنظمة.

2. **Nmap** - *أداة فحص الشبكات واكتشاف الأجهزة*: أداة قوية لمسح الشبكات، ممتازة لاكتشاف الأجهزة المضيفة المتصلة بالشبكة وفحص المنافذ المفتوحة عليها، بالإضافة إلى تحديد الخدمات وتشغيلها على تلك المنافذ بغرض تقييم مستوى الأمان.

3. **Metasploit Framework** - *إطار اختبار الاختراق واستغلال الثغرات*: إطار عمل شهير يتيح تطوير وتشغيل ثغرات وبرامج استغلال (exploits) ضد الأنظمة المستهدفة. يوفر قاعدة بيانات واسعة لنقاط الضعف المعروفة ويسهّل على خبراء الأمن تجربة هجمات متنوعة بشكل ممنهج.

4. **Wireshark** - *محلل بروتوكولات الشبكة (Packet Sniffer)*: برنامج متخصص في التقاط حزم البيانات المارة عبر الشبكة وتحليلها في الوقت الحقيقي. مفيد جدًا لتشخيص مشاكل الشبكات، وفهم حركة المرور، ورصد أي أنشطة غير اعتيادية

أو مشبوهة قد تشير إلى تهديدات أمنية.

5. **Snort** - *نظام كشف ومنع التسلل (IDS/IPS)*: أداة مفتوحة المصدر لمراقبة حركة مرور الشبكة بشكل مستمر، تقوم بتحليل الحزم ورصد الأنماط المشبوهة. عند اكتشاف محاولة اختراق أو نشاط ضار مطابق لقواعد معرّفة مسبقًا، يقوم Snort بتنبيه المسؤولين أو اتخاذ إجراءات لمنع التهديد.

6. **Suricata** - *نظام كشف التسلل الحديث ومراقبة الشبكة*: نظام كشف اختراق ومنع حديث متعدد الخيوط (Multi-threaded)، يعتبر بديلًا متطورًا لـ Snort. يتميز Suricata بأداء عالٍ في البيئات كبيرة الحجم وقدرته على معالجة كميات كبيرة من حركة البيانات، مما يجعله مناسبًا للمؤسسات التي تتطلب مراقبة شبكية مكثفة.

7. **OSSEC** - *نظام كشف الاختراق المستند إلى المضيف*: نظام كشف اختراق مركزي مفتوح المصدر يركز على مستوى الأجهزة المضيفة (الخوادم والأجهزة الفردية). يقوم OSSEC بمراقبة سجلات الأنظمة، والتحقق من سلامة الملفات، وكشف الجذور الخفية (rootkits)، مما يساعد في رصد أي اختراق أو سلوك غير طبيعي على مستوى الجهاز نفسه.

8. **Burp Suite** - *أداة لاختبار أمان تطبيقات الويب*: حزمة أدوات متقدمة لفحص تطبيقات الويب بحثًا عن الثغرات. تتيح اعتراض وتعديل حركة مرور HTTP/S بين المتصفح والخادم، وفحص الأمن للتطبيقات عن طريق محاكاة هجمات مثل SQL Injection وXSS وغيرها، مما يساعد المختبرين في العثور على الثغرات الأمنية وتصحيحها.

9. **OWASP ZAP (Zed Attack Proxy)** - *ماسح أمني لتطبيقات الويب*: أداة مجانية ومفتوحة المصدر تُستخدم لاختبار أمان تطبيقات الويب، وتعتبر بديلًا لـ Burp Suite. تعمل كوكيل لاعتراض وتحليل حركة مرور الويب، وتحتوي على ماسح آلي لاكتشاف الثغرات الشائعة في تطبيقات الويب، مما يجعلها مناسبة للخبراء والمبتدئين على حد سواء.

10. **SQLMap** - *أداة لاكتشاف واستغلال ثغرات حقن قواعد البيانات*: برنامج آلي متخصص في الكشف عن ثغرات **حقن SQL** في تطبيقات الويب واستغلالها. يقوم SQLMap بإجراء اختبارات شاملة على معلمات الإدخال في صفحات الويب بهدف اكتشاف أي قابلية لحقن أوامر SQL ضارة، ويمكنه استخراج البيانات من قواعد البيانات وتشغيل أوامر خبيثة بشكل تلقائي عند العثور على ثغرة.

11. **John the Ripper** - *أداة كسر كلمات المرور وفحص قوتها*: برنامج مفتوح المصدر يستخدم لاختبار مدى قوة كلمات المرور عن طريق محاولة كسرها. يدعم John the Ripper أنماطًا متعددة من التجزئة (hashes) ويمكنه إجراء هجمات تخمين متنوعة **(Brute Force)** وهجمات بالقاموس لكشف كلمات المرور الضعيفة، مما يساعد المسؤولين على تعزيز سياسات كلمات المرور.

12. **Hashcat** - *أداة متقدمة لكسر كلمات المرور باستخدام المعالجة الموازيّة*: أحد أسرع أدوات كسر كلمات المرور المتاحة، تدعم استخدام وحدة معالجة الرسومات (GPU) لتسريع عملية فك تشفير التجزئات. تستطيع Hashcat تجربة مليارات من الاحتمالات في الثانية، مما يجعلها فعالة جدًا في استعادة كلمات المرور المفقودة أو اختبار قوة كلمات المرور المشفرة.

13. **Security Onion** - *منصة متكاملة لمراقبة الأمن وتحليل السجلات*: توزيعة لينكس مفتوحة المصدر مخصصة لإنشاء بيئة شاملة لمراقبة أمن الشبكات.

تضم Security Onion مجموعة من الأدوات القوية مثل Snort Suricatag Zeekg (Bro)) Elasticsearchg وغيرها، مما يمكّن فرق مركز العمليات الأمنية (SOC) من جمع وتحليل سجلات الأحداث والشبكات في الوقت الحقيقي لرصد التهديدات والاستجابة لها بسرعة.

14. **YARA** - *أداة لكشف البرمجيات الخبيثة عبر أنماط الملفات*: لغة وأداة مصممة للمساعدة في تحديد وتصنيف الملفات المشبوهة والبرمجيات الخبيثة من خلال وضع قواعد تعتمد على أنماط محددة. يُمكن لمحللي البرمجيات الضارة إنشاء قواعد YARA لكشف سلالات معينة من الفيروسات أو البرمجيات الخبيثة بناءً على توقيعاتها أو خصائصها الفريدة في الملفات.

15. **Maltego** - *أداة استخبارات المصادر المفتوحة ورسم الروابط*: منصة قوية للبحث في المعلومات المفتوحة (OSINT) وتحليل العلاقات بين الكيانات المختلفة. تساعد Maltego خبراء الأمن في جمع البيانات عن الأفراد أو المجالات أو عناوين IP وغيرها، ثم ترسم خرائط بيانية تُظهر العلاقات والاتصالات بين هذه الكيانات، مما يسهل عملية التحقيق السيبراني وتتبع الهويات الرقمية المرتبطة بالتهديدات.

16. **Splunk** - *منصة SIEM لتجميع وتحليل السجلات*: أحد أشهر أنظمة إدارة معلومات وأحداث الأمن (SIEM)، يقوم بتجميع سجلات النظام والشبكة من مصادر متعددة في مكان واحد. يتيح Splunk للمحللين البحث الفوري في كميات ضخمة من البيانات، وإجراء correlations بين الأحداث المختلفة، وإنشاء تنبيهات مخصصة عند تحقق أنماط مشبوهة، مما يساعد المؤسسات في اكتشاف الحوادث الأمنية والاستجابة لها بفعالية.

17. **حزمة ELK Stack** (Elasticsearch, Logstash, Kibana) - *إدارة سجلات وتحليلات مفتوحة المصدر*: مجموعة أدوات متكاملة مفتوحة المصدر تستخدم لإدارة سجلات الأنظمة وتحليلها. يقوم **Logstash** بتجميع ومعالجة البيانات، ويخزنها في **Elasticsearch** الذي يوفر محرك بحث قوي، ثم يقوم **Kibana** بعرض البيانات بشكل لوحات تحكم ورسوم بيانية تفاعلية. تُستخدم حزمة ELK بشكل واسع لبناء حلول مخصصة لمراقبة الأنظمة واكتشاف الأحداث الأمنية.

18. **OpenSCAP** - *أداة فحص الامتثال وإدارة الثغرات الأمنية*: عبارة عن مجموعة من الأدوات مفتوحة المصدر مبنية على معايير **SCAP** (Security Content Automation Protocol) لمراجعة الإعدادات الأمنية والامتثال للمعايير. يقوم OpenSCAP بإجراء تدقيق آلي لإعدادات الأنظمة ومقارنتها بقوالب معيارية للأمن (مثل سياسات الأمان الحكومية أو الصناعية)، مما يساعد المؤسسات في تحديد نقاط الضعف وعدم الامتثال وإصلاحها لضمان بيئة أكثر أمانًا.

19. **Bettercap** - *أداة هجوم الشبكات وتنفيذ هجمات الرجل في الوسط*: منصة مرنة لاختبارات الاختراق على الشبكة، تُستخدم في تنفيذ هجمات **الرجل في الوسط (MITM)**، وانتحال عناوين الشبكة، واعتراض حركة المرور وتعديلها. توفر Bettercap مجموعة واسعة من الميزات للاستطلاع الشبكي (مثل اكتشاف الأجهزة والخدمات)، ويمكنها تنفيذ هجمات على بروتوكولات Wi-Fi وBluetooth وEthernet، مما يجعلها أداة مفيدة لمختبري الاختراق في بيئات مختلفة.

20. **Cain & Abel** - *أداة قديمة لكشف كلمات المرور وتحليل الشبكة*: من الأدوات الكلاسيكية المعروفة في مجال الأمن السيبراني، تركز بشكل أساسي على أنظمة Windows. تشمل وظائفها اعتراض حركة مرور الشبكة لاستخراج كلمات المرور (مثل كلمات مرور الشبكة أو بروتوكول HTTP)، بالإضافة إلى

مجموعة من خوارزميات كسر كلمات المرور المشفرة. على الرغم من قِدمها، لا تزال Cain & Abel تُستخدم للتدريب ولمهام محددة في اختبارات الاختراق.

ختامًا: توفر هذه الأدوات مجموعة شاملة من الإمكانيات لأخصائيّي الأمن السيبراني لمواجهة التهديدات المتنوعة. اختيار الأداة المناسبة يعتمد على طبيعة المهمة المطلوبة؛ فقد يحتاج اختبار اختراق إلى أدوات مختلفة عن مراقبة الشبكة أو تحليل البرمجيات الخبيثة. من خلال فهم فئات هذه الأدوات واستخداماتها، يمكن للمتخصصين تعزيز دفاعاتهم الرقمية وحماية أصول مؤسساتهم بكفاءة وفعالية.

خارطة تعلّم الأمن السيبراني (من الصفر إلى الاحتراف)

المرحلة الأولى: الأساسيات التقنية (Fundamentals)

قبل الدخول في مجال الأمن السيبراني، من الضروري بناء قاعدة تقنية قوية. يعتمد الأمن السيبراني على فهم عميق لتقنيات الحاسوب والشبكات، لذا ابدأ بتعلم الأساسيات التالية:

- **أساسيات الحاسوب ونظم التشغيل:**

  - مكونات الحاسوب الرئيسية (وحدة المعالجة CPU، الذاكرة RAM، وحدة التخزين Disk، ونظام التشغيل OS).

- التعرّف على أساسيات نظامي التشغيل Windows وLinux واستخدامهما (هذا مهم جدًا).

- إتقان أوامر سطر الأوامر في كل من لينكس (Terminal) وويندوز (مثل أوامر CMD وPowerShell) للتعامل مع النظام بكفاءة.

- **الشبكات (Networking Basics):**

- فهم نموذج الشبكات OSI و بروتوكول TCP/IP وكيف يتم نقل البيانات عبر الطبقات المختلفة.

- معرفة عناوين IP وكيفية عملها، والتعرّف على البروتوكولات الشائعة (HTTP/HTTPS لخدمات الويب، DNS لترجمة الأسماء، FTP لنقل الملفات، SMTP للبريد الإلكتروني، SSH للتحكم عن بعد الآمن).

- فهم ما هو الجدار الناري (Firewall) وكيف يحمي الشبكات، ومعرفة دور الشبكة الافتراضية الخاصة VPN في تأمين الاتصال.

- تجربة أدوات الشبكة الأساسية مثل: `ping` لاختبار الاتصال، `traceroute` لتتبّع مسار حزم البيانات، `netstat` لمراقبة الاتصالات النشطة، و`nmap` لفحص المنافذ والأجهزة على الشبكة.

- **أساسيات البرمجة:**

- فهم المنطق البرمجي الأساسي (مثل استعمال عبارات **if** الشرطية، الحلقات التكرارية **loops**، المتغيرات).

- تعلّم لغة برمجة واحدة على الأقل - **يفضّل Python** للمبتدئين - نظرًا لبساطتها وقوتها. بايثون مفيدة لتحليل البيانات، وكتابة سكربتات أمنية، وأتمتة المهام المتكررة.

- تعلّم أساسيات البرمجة النصية (Scripting) للتعامل مع المهام على مستوى النظام بشكل مباشر.

- **أساسيات أمن نظم التشغيل:**

- فهم كيفية إدارة المستخدمين والصلاحيات في أنظمة التشغيل (مثل إنشاء حسابات وتعيين أذونات الملفات).

- التمييز بين ملفات النظام الحساسة والملفات التنفيذية العادية، ومعرفة مواقع الملفات الهامة في كل من Windows وLinux.

- التعرّف على إعدادات الأمان الأساسية في كل نظام تشغيل (مثل الجدار الناري لنظام التشغيل، وإعدادات التحديث التلقائي، والتحقق من سجلات النظام).

الهدف: في نهاية هذه المرحلة ستكون قد فهمت **كيف تعمل الأنظمة** - المعرفة التي ستساعدك لاحقًا على معرفة **كيف تُهاجَم الأنظمة وكيف تحميها**.

النقاط التلخيصية للمرحلة الأولى:

- تعرّف على مكونات الحاسوب وأنظمة التشغيل، وتعلّم أساسيات التعامل مع Windows وLinux خاصة عبر سطر الأوامر.

- فهم أساسيات الشبكات (النماذج، البروتوكولات، الأدوات) وأهمية الجدران النارية و الVPN في الحماية.

- إتقان مبادئ البرمجة الأساسية بلغة مثل بايثون، وفهم إدارة المستخدمين والصلاحيات وإعدادات الأمان في نظم التشغيل.

المرحلة الثانية: مفاهيم الأمن السيبراني الأساسية (Cybersecurity Fundamentals)

في هذه المرحلة، تركّز على استيعاب المفاهيم والمبادئ النظرية الأساسية في مجال الأمن السيبراني. فهمك لهذه الأساسيات سيبني الوعي الأمني الضروري قبل التعمّق في التفاصيل التقنية المتقدمة. **ما يجب فهمه:**

- **ما هو الأمن السيبراني وأنواعه؟**
  الأمن السيبراني هو ممارسة حماية الأنظمة والشبكات والبرمجيات والبيانات من الهجمات الرقمية. تعرّف على الفروع المختلفة للأمن السيبراني (مثل أمن المعلومات، أمن الشبكات، أمن التطبيقات... إلخ) وكيف يختلف كل نوع في نطاقه.

- **مبادئ مثلث الحماية CIA Triad:**
  هذه المبادئ الثلاثة تعتبر حجر الأساس في أمن المعلومات:

- **Confidentiality (السرية):** ضمان بقاء المعلومات متاحة فقط للأشخاص المخوّلين بالوصول إليها وعدم كشفها لغير المصرح لهم.

- **Integrity (السلامة):** الحفاظ على سلامة ودقة المعلومات وضمان عدم تعديلها أو إفسادها من قبل جهات غير مصرح لها.

- **Availability (الإتاحة):** التأكد من توفر المعلومات والأنظمة عند الحاجة إليها، وضمان استمرار الخدمات وعدم انقطاعها.

- **الفرق بين التهديدات والثغرات والمخاطر:**

  - التهديدات (Threats): هي الأحداث أو الجهات التي قد تستغل نقاط الضعف لإحداث ضرر (مثل قراصنة الإنترنت أو البرمجيات الخبيثة).

  - الثغرات (Vulnerabilities): هي نقاط الضعف أو الخلل في النظام التي قد تسمح بوقوع هجوم أو اختراق (سواء كانت برمجية أو بشرية أو غير ذلك).

  - المخاطر (Risks): هي احتمالية وقوع التهديد واستغلاله للثغرة والآثار المترتبة على ذلك. فهم كيفية تقييم المخاطر يجمع بين احتمال التهديد وشدة تأثيره.

- **أنواع الهجمات السيبرانية الشائعة:**
  تعرّف على أبرز الهجمات الإلكترونية التي ستواجهها في العالم الحقيقي:

- **التصيد الاحتيالي - Phishing:** محاولات خداع الضحية لإفشاء معلومات حساسة (مثل كلمات المرور) عن طريق الرسائل أو المواقع المزيفة.

- **البرمجيات الخبيثة - Malware:** برمجيات ضارة تشمل الفيروسات، وبرامج الفدية (Ransomware)، وأحصنة طروادة، وغيرها، تهدف إلى إلحاق الضرر أو سرقة البيانات.

- **هجمات حجب الخدمة - DDoS:** محاولة إغراق الخادم أو الشبكة بكمية هائلة من الطلبات غير الشرعية لتعطيلها ومنع المستخدمين الشرعيين من الوصول إليها.

- **سرقة الهوية الرقمية:** محاولة انتحال شخصية الضحية سرًا للوصول إلى مواردها الخاصة أو حساباتها.

- **الهندسة الاجتماعية:** استغلال العنصر البشري عبر خداع الأشخاص لحملهم على الإفصاح عن معلومات سرية أو تنفيذ إجراءات غير آمنة (كإيهام الموظف بأنه مسؤول تقني وطلب كلمة المرور منه).

- **التعرف على تصنيفات ومجالات الأمن السيبراني:**
  يشمل الأمن السيبراني مجالات متعددة، من المهم التعرف عليها لفهم الصورة الكاملة:

  - **أمن الشبكات - Network Security:** حماية الشبكات من الاختراقات وضمان تأمين نقل البيانات.

- **أمن التطبيقات - Application Security:** تأمين البرمجيات والتطبيقات من الثغرات البرمجية والاستغلال.

- **أمن السحابة - Cloud Security:** حماية البيانات والخدمات التي تعمل في البيئات السحابية (مثل AWS، Azure) وضمان إعدادها بشكل آمن.

- **الأمن التشغيلي - Operational Security:** حماية العمليات والإجراءات اليومية داخل المؤسسة، ويشمل التحكم في الوصول وإدارة الأصول والإجراءات الوقائية.

- **استمرارية الأعمال والتعافي من الكوارث:** التخطيط لضمان استمرار الخدمات أثناء الأزمات والأعطال الكبرى، ووضع خطط لاستعادة الأنظمة والبيانات بسرعة بعد وقوع الكوارث أو الهجمات.

الهدف: اكتساب وعي أمني نظري قوي وفهم مبادئ أمن المعلومات الأساسية. بعد هذه المرحلة ستكون لديك الأرضية المعرفية اللازمة لاستيعاب لماذا نقوم بتأمين الأنظمة وكيف نفكّر كمحترفي أمن معلومات.

النقاط التلخيصية للمرحلة الثانية:

- فهم **مفهوم الأمن السيبراني** وركائزه الأساسية، ومعرفة أهمية مبدأ **السرية والسلامة والإتاحة (CIA Triad)** في حماية المعلومات.

- التمييز بين **التهديدات والثغرات والمخاطر** وكيفية ترابطها، مما يساعد في تقييم المواقف الأمنية.

- الإلمام بالهجمات السيبرانية الشائعة (كالتصيد والبرمجيات الخبيثة وهجمات حجب الخدمة وغيرها) ومعرفة مجالات الأمن السيبراني المتعددة، مما يبني لديك صورة شاملة عن نطاق المجال.

المرحلة الثالثة: الأدوات والتطبيق العملي (Hands-on Tools)

بعد إتقان الأساسيات النظرية، حان وقت التطبيق العملي. في هذه المرحلة، ستبدأ بتجربة أدوات الأمن السيبراني الشهيرة بشكل عملي في بيئة افتراضية آمنة. الهدف هو فهم كيفية اكتشاف الثغرات وتحليل الأنظمة واكتساب مهارات تقنية فعّالة.
أدوات يجب تعلمها وتجربتها:

- **نظام Kali Linux:** توزيعة لينكس متخصصة تحتوي على مجموعة ضخمة من أدوات اختبار الاختراق والأمن. تعلّم كيفية استخدام Kali وتشغيل الأدوات من خلاله.

- **Nmap:** أداة مسح شبكات قوية تُستخدم لفحص الأجهزة والمنافذ المفتوحة والخدمات التي تعمل على الشبكة، وتساعد في رسم خريطة للأجهزة المتصلة.

- **Wireshark:** برنامج لتحليل حركة مرور الشبكة (Network Traffic Analysis). يسمح لك بالتجسس على حزم البيانات المارة عبر الشبكة وفهم البروتوكولات، وهو مفيد جدًا لتحرّي الأخطاء واكتشاف الأنشطة غير الطبيعية.

- **Metasploit Framework:** منصة لاختبار الثغرات واستغلالها (Exploitation Framework). تساعدك على تجربة استغلال نقاط الضعف المعروفة في بيئة محكومة لتتعلم كيفية يعمل المهاجمون وكيف يمكن صدّهم.

- **Burp Suite:** مجموعة من الأدوات لاختبار أمان تطبيقات الويب. تسمح لك باعتراض وتحليل الترافيك بين المتصفح والخادم، وتحتوي على أدوات لفحص الثغرات في تطبيقات الويب.

- **Hashcat و John the Ripper:** أدوات متقدمة لكسر كلمات المرور عبر تجربة توليفات متعددة بسرعة عالية. هذه الأدوات تستخدم في اختبار قوة كلمات المرور والتأكد من مدى تعقيدها.

- **Snort / Suricata:** أنظمة كشف التسلل (Intrusion Detection Systems). Snort و Suricata تساعدان في مراقبة حركة الشبكة بشكل لحظي لإشعارك حال رصد أي نشاط مشبوه أو هجوم معروف الأنماط.

- **منصات تحليل السجلات (Log Analysis):** مثل Splunk أو مكدس ELK (Elastic Stack). هذه الأدوات تستخدم لجمع سجلات الأنظمة والخدمات وتحليلها بحثًا عن أي علامات تدل على اختراق أو مشاكل أمنية.

بيئة التدريب: قم بإنشاء بيئة افتراضية معزولة للتدريب قبل استخدام هذه الأدوات على أي أنظمة حقيقية. يمكنك استخدام برامج المحاكاة مثل **VirtualBox أو VMware** لإنشاء أجهزة افتراضية. حمّل أنظمة وهمية مخصصة للتجربة مثل **Kali Linux** (كنظام مهاجم) و**Metasploitable** (كنظام ضحية مليء بالثغرات) لتطبيق ما تتعلمه بشكل عملي وآمن. تأكد دائمًا أن تجارب الاختبار لا تتم إلا ضمن نطاق قانوني أو في بيئة منزليّة خاصة بك.

الهدف: تطوير **المهارات العملية** في اكتشاف الثغرات وتحليل الأنظمة باستخدام أدوات احترافية، مع الالتزام ببيئة تجريبية آمنة. بنهاية هذه المرحلة ستتمكن من توظيف معرفتك النظرية في مواقف عملية حقيقية، وستكون قد لمست بشكل

عملي كيفية بحث المهاجمين عن الثغرات وكيف يمكن للمدافعين كشف الأنشطة غير الاعتيادية.

النقاط التلخيصية للمرحلة الثالثة:

- التعرّف على أهم أدوات اختبار الاختراق والتحليل الأمني مثل Kali و Nmap و Wireshark و Metasploit وغيرها، وتجربة استخدامها عمليًا.

- بناء معمل افتراضي آمن (باستخدام أدوات مثل VirtualBox) لتطبيق الاختبارات دون تعريض أنظمة حقيقة للخطر، واستخدام أنظمة وهمية ضعيفة لاكتساب خبرة في الاستغلال والكشف.

- ربط المعرفة النظرية بالتطبيق العملي من خلال تحليل الشبكة وكشف الثغرات واستغلالها بشكل قانوني، مما يعمّق فهمك لكيفية حدوث الهجمات وكيفية رصدها.

المرحلة الرابعة: التخصص في مجال محدد (Choose Your Path)

الأمن السيبراني مجال واسع جدًا ومتفرع. بعد تغطية الأساسيات التقنية والنظرية والتدرب على الأدوات، سيكون من الأفضل تحديد **مسار متخصص** تبني فيه خبرات أعمق. اختر المسار الأنسب لشغفك ولمهاراتك، ثم ركّز عليه في تعلّمك المستمر. فيما يلي **أهم المسارات المهنية** في الأمن السيبراني وبعض التفاصيل حول كل منها:

- **محلل أمني (Security Analyst / SOC):**

- **الدور الأساسي:** مراقبة الأنظمة بشكل مستمر، تحليل سجلات الأحداث (Logs) والتنبيهات، واكتشاف أي نشاط غير طبيعي أو محاولات اختراق في الوقت الفعلي. يعمل محلل الأمن عادة ضمن مركز عمليات الأمن (SOC) حيث يتابع لوحة تحكم الأمن ويتعامل مع التنبيهات الأمنية الأولية.

- **أدوات مستخدمة:** منصات **إدارة المعلومات الأمنية والأحداث (SIEM)** مثل Splunk، وأنظمة كشف التسلل مثل Security Onion، بالإضافة إلى أدوات تحليل الشبكة كـ Wireshark.

- **شهادات مفيدة:** CompTIA Security+ (شهادة الأمن الأساسية)، وشهادة **محلل الأمن السيبراني** CompTIA CySA (Cybersecurity+ Analyst) التي تركز على مهارات التحليل ومراقبة التهديدات.

- **مختبر اختراق (Penetration Tester / Ethical Hacker):**

- **الدور الأساسي:** القيام بعمليات محاكاة للهجمات بشكل قانوني وأخلاقي بهدف اكتشاف الثغرات الأمنية قبل أن يستغلها المهاجمون الحقيقيون. مختبر الاختراق (أو الهاكر الأخلاقي) يحاول اختراق أنظمة الشركة بإذنها ثم يقدم تقريرًا بالإصلاحات اللازمة.

- **أدوات مستخدمة:** منصات وأدوات الاختراق مثل Metasploit لاختبار الثغرات، وأداة Burp Suite لاختبار أمان تطبيقات الويب، وأدوات مسح الشبكات مثل Nmap، وأيضًا أدوات مشروع OWASP مثل OWASP ZAP لفحص تطبيقات الويب.

- **شهادات مفيدة: المخترق الأخلاقي المعتمد CEH (Certified Ethical Hacker)** للتحقق من فهمك لمبادئ الاختراق الأخلاقي، وشهادة **المختص باختبار الاختراق OSCP (Offensive Security Certified Professional)** التي تعتبر من أقوى الشهادات العملية في هذا المجال.

- **مستجيب للحوادث (Incident Responder / Digital Forensics):**

  - **الدور الأساسي:** التدخل عند وقوع حوادث أمنية أو اختراقات، والقيام بعملية **التحليل الجنائي الرقمي** لتتبع آثار المخترقين وجمع الأدلة الرقمية. هذا التخصص يتطلب التفكير بهدوء تحت الضغط، وتحليل الأجهزة المخترَقة لمعرفة ما حدث بالضبط، واتخاذ إجراءات لاحتواء الضرر واستعادة الأنظمة.

  - **أدوات مستخدمة:** برامج تحليل الأدلة الرقمية مثل Autopsy (منصة جنائية مفتوحة المصدر)، وإطار عمل Volatility لتحليل ذاكرة النظام واستخراج المعلومات منها، وأجنحة جنائية مثل FTK (Forensic Toolkit) لاستخراج وتحليل البيانات من الأقراص الصلبة والأجهزة المحمولة.

  - **شهادات مفيدة: المحقق الجنائي الرقمي المعتمد CHFI (Computer Hacking Forensic Investigator)** لتطوير مهارات التحقيق الجنائي في الحاسوب، وشهادات متقدمة مثل GCFA (GIAC Certified Forensic Analyst) للتركيز على التحليل الجنائي والاستجابة للحوادث.

- **أخصائي أمن سحابي (Cloud Security Specialist):**

- **الدور الأساسي:** تأمين البنية التحتية والخدمات السحابية لمنظمة ما عبر تطبيق أفضل الممارسات الأمنية ضمن منصات مثل AWS أو Azure أو Google Cloud. يتضمن ذلك ضبط إعدادات الوصول (IAM)، تشفير البيانات، ومراقبة البيئات السحابية ضد أي إعدادات خاطئة أو ثغرات قد تؤدي إلى اختراق.

- **مهارات أساسية:** فهم معماريات الحوسبة السحابية وكيفية تصميم بنية سحابية آمنة، إدارة الهويات والصلاحيات (IAM) في السحابة، إعداد الجدران النارية السحابية وقواعد الشبكة الافتراضية، وتطبيق سياسات **تشفير البيانات** في التخزين والانتقال.

- **شهادات مفيدة: أخصائي أمن سحابي معتمد CCSP (Certified Cloud Security Professional)** من (ISC)² والتي تغطي جوانب أمن السحابة بشكل شامل، أو شهادات أمنية خاصة بكل منصة مثل شهادة **AWS Certified Security - Specialty** لمنصة AWS.

- **مدير أمن المعلومات / متخصص الحوكمة (CISO / GRC Specialist):**

- **الدور الأساسي:** هذا المسار إداري/استراتيجي إلى حد كبير. مدير أمن المعلومات (أو متخصص الحوكمة والمخاطر والامتثال GRC) مسؤول عن وضع الاستراتيجية الأمنية الشاملة للمؤسسة. يشمل ذلك تطوير السياسات والإجراءات الأمنية، إجراء تقييمات المخاطر بشكل دوري، ضمان الامتثال للمعايير والقوانين (مثل معيار ISO 27001 أو اللوائح المحلية)، وإدارة فريق الأمن السيبراني والإشراف على جميع المبادرات الأمنية.

- **مهارات أساسية:** فهم عميق لكل جوانب الأمن السيبراني التقنية بالإضافة إلى مهارات إدارية وقيادية. القدرة على تقييم المخاطر على مستوى الأعمال، والتواصل مع الإدارة العليا بلغة الأعمال لشرح التهديدات والحاجة للاستثمار في الأمن، ووضع خطط لاستمرارية الأعمال والتعافي من الكوارث.

- **شهادات مفيدة: مدير أمن معلومات معتمد CISM (Certified Information Security Manager)** من ISACA والتي تركز على مهارات الإدارة الأمنية، وشهادة **محترف أمن معلومات معتمد CISSP (Certified Information Systems Security Professional)** من (ISC)² والتي تغطي نطاقًا واسعًا من مجالات الأمن على مستوى احترافي، بالإضافة إلى شهادات في الحوكمة مثل **شهادة ISO 27001 Lead Auditor/Implementer** إذا كان التركيز على الامتثال للمعايير.

الهدف: تحديد المجال الفرعي الذي يثير اهتمامك أكثر والتركيز عليه. بمجرد اختيار تخصصك، يمكنك بناء خطة تعلم تفصيلية ومركزة تناسب هذا التوجه، سواء عبر الدورات التدريبية المتقدمة أو الحصول على شهادات متخصصة أو اكتساب خبرة عملية مباشرة في هذا المسار.

النقاط التلخيصية للمرحلة الرابعة:

- الأمن السيبراني يشمل مسارات متعددة؛ **اختر التخصص** الذي يناسب ميولك: محلل أمني يركّز على المراقبة، أو مختبر اختراق يبحث عن الثغرات، أو مستجيب حوادث يحقق في الاختراقات، أو متخصص سحابة يؤمّن البنية السحابية، أو مدير أمن معلومات يضع الاستراتيجيات.

- لكل مسار **مهارات وأدوات** وشهادات خاصة به، احرص على فهم ما يتطلبه الدور الذي تريد متابعته واستثمر في تعلّم تلك المهارات (مثلاً البرمجة مهمة لمختبر الاختراق، والمعرفة السحابية عصب أخصائي السحابة، وهكذا).

- **بناء خطة تعلم متخصصة** بعد المرحلة الأساسية سيعطيك تقدّمًا أسرع واحترافية أعلى في المجال الذي اخترته ضمن الأمن السيبراني.

المرحلة الخامسة: الشهادات المعترف بها (Professional Certifications)

الشهادات المهنية المعترف بها دوليًا تعتبر طريقة ممتازة لإثبات معرفتك وتعزيز ثقتك أمام أصحاب العمل. الحصول على الشهادة المناسبة يمكن أن يفتح لك أبوابًا وظيفية جديدة ويؤكد التزامك وجديتك في هذا المجال. فيما يلي بعض الشهادات البارزة مرتبة حسب المستوى:

- **شهادات للمبتدئين:**

  - **CompTIA IT Fundamentals (ITF+):** شهادة مقدمة من كومبتيا تركز على أساسيات تكنولوجيا المعلومات بشكل عام، مناسبة لمن يريد إثبات فهمه للمفاهيم التقنية الأساسية.

  - **CompTIA Security+:** من أشهر الشهادات التأسيسية في الأمن السيبراني. تغطي أساسيات أمن المعلومات والتهديدات والشبكات وإدارة الهويات وغيرها، وتعد خطوة أولى ممتازة لمن يدخل المجال.

- **Certified Cybersecurity Entry-level Technician (CCET):** شهادة جديدة نسبيًا مقدمة من منظمة (ISC)² تستهدف المبتدئين. تركز على المبادئ الأساسية في الأمن السيبراني وتوفر أساسًا عمليًا أيضًا إلى جانب النظري.

- **شهادات متوسطة المستوى:**

  - **CEH (Certified Ethical Hacker):** شهادة الاختراق الأخلاقي المعتمد، تؤكد معرفتك بتقنيات اختبار الاختراق وأدواته بشكل أخلاقي وقانوني. تعتبر مفيدة لمختبري الاختراق وخبراء أمن التطبيقات.

  - **CompTIA CySA+ (Cybersecurity Analyst):** شهادة متخصصة في تحليل الأمن السيبراني. تركز على مهارات عمل محللي مركز العمليات الأمنية (SOC) مثل تحليل التهديدات ومراقبة الأنظمة والاستجابة للحوادث.

  - **CHFI (Computer Hacking Forensic Investigator):** شهادة المحقق الجنائي في حوادث الاختراق. مهمة لمن يرغب في التخصص بالتحليل الجنائي الرقمي وتتطلب فهمًا لكيفية جمع الأدلة من الأجهزة المخترَقة.

- **شهادات متقدمة:**

  - **CISM (Certified Information Security Manager):** شهادة مدير أمن معلومات معتمد من ISACA. موجّهة لمن يتطلعون لمناصب إدارية في أمن المعلومات، تغطي إدارة برامج الأمن وتقييم المخاطر وحوكمة أمن

المعلومات.

- **CISSP (Certified Information Systems Security Professional):** شهادة احترافية شاملة من (ISC)² تعتبر من أرقى الشهادات في المجال. تغطي ثمانية مجالات في الأمن السيبراني بمستوى متقدم، وتشترط خبرة عملية، وتثبت امتلاك حاملها لمستوى رفيع من المعرفة والمهارة.

- **OSCP (Offensive Security Certified Professional):** شهادة احترافية وعملية جدًا من شركة Offensive Security. يحصل عليها الشخص بعد اجتياز اختبار عملي مكثف في اختبار الاختراق. تعتبر **دليلًا قويًا على مهارات المختبر الأخلاقي** في استغلال الثغرات وحل التحديات تحت الضغط.

ملاحظات: اختيار الشهادة يعتمد على المسار الذي قررت اتباعه في المرحلة السابقة. ابدأ بشهادات المبتدئين لتعزيز سيرتك الذاتية بالأساسيات، ثم انتقل إلى شهادات المستوى المتوسط بمجرد حصولك على بعض الخبرة العملية، ثم لاحقًا فكّر في الشهادات المتقدمة التي تناسب دورك المستهدف. تذكّر أن الشهادات وحدها لا تكفي؛ **المهارة العملية ضرورية** بجانبها، لكن الشهادات تُظهر لأصحاب العمل أنك ملتزم بالتعلم والتطور المستمر.

النقاط التلخيصية للمرحلة الخامسة:

- الشهادات المهنية تعزّز فرصك وتثبت معرفتك. ابدأ بشهادات **تأسيسية (ITF+, Security+)** لبناء قاعدة معتمدة ثم تقدّم إلى شهادات **متخصصة** حسب مجال اهتمامك (مثل CEH لمختبر الاختراق أو CySA+ لمحلل الأمن).

- الشهادات **المتقدمة (CISM, CISSP, OSCP وغيرها)** تبرز خبرتك العميقة وقيادتك في المجال، لكنها تتطلب عادة خبرة سنوات وتحضير مكثف.

- اختر الشهادة المناسبة لمسارك المهني المستهدف، واعتبرها **هدفًا تعليميًا** يدفعك لدراسة المنهج المعتمد وممارسة المهارات المطلوبة لاجتيازها.

المرحلة السادسة: بناء مشروع عملي ومحفظة (Portfolio)

بعد تعلمك مجموعة واسعة من المهارات وحصولك على بعض الشهادات، حان الوقت لإثبات مهاراتك بشكل عملي من خلال مشاريع حقيقية. بناء **محفظة أعمال (Portfolio)** قوية سيساعدك على عرض خبراتك أمام أصحاب العمل المحتملين ويُظهر قدراتك بشكل ملموس. ابدأ بمشاريع بسيطة ثم تدرّج إلى الأصعب، وركز على **تطبيق ما تعلمته**:

- **محاكاة هجوم تصيّد (Phishing) بشكل قانوني:** صمم حملة تصيّد توعوية داخل بيئة افتراضية أو ضمن نطاق تجربة، قم بإعداد بريد إلكتروني وهمي وصفحة دخول مزيفة (دون استهداف أشخاص فعليين دون إذن) لمعرفة كيف يخدع المهاجمون الضحايا. وثّق الخطوات وكيفية الوقاية من هذه الهجمات.

- **إعداد شبكة افتراضية آمنة مع نظام كشف الاختراق:** قم ببناء شبكة محلية صغيرة باستخدام أجهزة وهمية، ثم ثبّت نظام كشف التسلل مثل Snort أو Suricata فيها. افتعل محاولات هجوم (مثل مسح منافذ باستخدام Nmap) ولاحظ كيف يتم تسجيلها في نظام كشف التسلل، واضبط الإعدادات لتحسين التنبيهات وتقليل الإنذارات الكاذبة.

- **تحليل حركة مرور شبكة باستخدام Wireshark:** التقط حزم بيانات من شبكة تجريبية (مثلاً تصفح موقع غير مشفّر باستخدام HTTP) ثم استخدم Wireshark لتحليل الحزم الملتقطة. حاول استخراج معلومات مفيدة أو كشف سلوك غير طبيعي، واكتب تقريرًا قصيرًا بالنتائج مع شرح ما قمت به.

- **كتابة تقرير أمني احترافي:** اختر ثغرة أمنية معروفة أو نتيجة فحص قمت به (مثل نتائج مشروع محاكاة الاختراق الذي قمت به في معملك الافتراضي)، ثم قم بإعداد تقرير أمني يشمل مقدمة عن الهدف، والمنهجية المتبعة، والنتائج المكتشفة، وتوصيات المعالجة. **التقرير المهني** مهارة مهمة لكل متخصص أمن سيبراني، فهو ما يصل إلى الإدارة ويشرح حالة الأمن بلغة واضحة.

بعد الانتهاء من المشاريع، **شارك أعمالك** بشكل احترافي:

- ارفع الأكواد أو التقارير أو بيئات الاختبار (إن أمكن) على منصة GitHub ليراها الآخرون، واحرص على تنظيمها وتوثيقها جيدًا.

- شارك تجربتك وملخصات ما أنجزته عبر صفحتك على LinkedIn أو المدونة الخاصة بك، وتحدث عن التحديات التي واجهتك وكيف تغلبت عليها وما تعلمته. هذا يظهر شغفك وتطورك المستمر للمجتمع المهني.

الهدف: بناء **محفظة مشاريع عملية** تبرز مهاراتك التقنية وقدرتك على تطبيق ما تعلمته في واقع عملي. هذه المحفظة ستكون دليلك العملي عند التقديم لوظيفة، حيث يستطيع صاحب العمل رؤية عيّنة من عملك الفعلي وليس مجرد شهادات نظرية. أيضًا، ستزيد ثقتك بنفسك وأنت ترى成果 جهودك ملموسة.

النقاط التلخيصية للمرحلة السادسة:

- طبّق ما تعلمته في **مشاريع عملية**: ابدأ بمشاريع صغيرة (حملة تصيّد وهمية، شبكة مختبرية مع IDS، تحليل حزمة بيانات، إلخ) لتقوية مهاراتك التقنية.

- قم **بتوثيق نتائجك** على شكل تقارير تقنية أو أكواد برمجية، وشاركها عبر GitHub أو LinkedIn لإثبات مهاراتك وبناء حضور احترافي.

- **المحفظة العملية** تعزز سيرتك الذاتية، فهي تعرض لأرباب العمل *كيف تحل المشكلات عمليًا* وليس فقط ماذا تعرف نظريًا.

المرحلة السابعة: التطوير المستمر (Continuous Learning)

الوصول إلى الاحتراف في الأمن السيبراني ليس له خط نهاية واضح، فالمجال **يتطور يوميًا** مع ظهور تهديدات جديدة وتقنيات حديثة. لذلك، جعل **التعلم المستمر** عادة لديك هو مفتاح البقاء في القمة. في هذه المرحلة الأخيرة والممتدة طوال حياتك المهنية، تأكد من القيام بالتالي باستمرار:

- **متابعة الأخبار الأمنية:** احرص على متابعة أحدث الأخبار والتقارير الأمنية عبر مواقع تقنية موثوقة ومدونات مختصة في الأمن السيبراني. تعرّف على الثغرات المكتشفة حديثًا (مثلاً إصدارات CVE الحرجة) وراقب كيفية حدوث الهجمات البارزة عالميًا. المعرفة المبكرة بالتهديدات تساعدك على اتخاذ إجراءات استباقية.

- **المشاركة في مسابقات وتحديات CTF:** تحديات "Capture The Flag" عبارة عن مسابقات في الأمن السيبراني تضعك أمام مسائل عملية لحلها (مثل فك تشفير رسالة، أو استغلال ثغرة في موقع وهمي، إلخ). المشاركة في الـCTF سواء عبر الإنترنت أو في الأحداث الواقعية تطوّر مهاراتك وتكشف لك جوانب

جديدة في التحليل والتفكير الإبداعي. كما أنها تجربة ممتعة وتتيح لك تقييم مستواك مقارنة بالآخرين.

- **الانخراط في المجتمعات المتخصصة:** انضم إلى منتديات ومجتمعات ناقشة الأمن السيبراني حيث يلتقي المهتمون والخبراء. على سبيل المثال، يمكنك متابعة المنتديات الفرعية على Reddit مثل r/cybersecurity و r/netsec، أو الانضمام إلى خوادم Discord المخصصة للأمن السيبراني حيث يتم تبادل الخبرات والنصائح. أيضًا جرّب المنصات التعليمية التفاعلية مثل **TryHackMe** و **HackTheBox** التي توفر بيئات تدريبية ومجتمعات تنافسية لتنمية مهاراتك بشكل مستمر.

- **التعلم من الموارد المتقدمة:** بعد فترة من العمل في المجال، يمكنك متابعة دورات متقدمة أو الحصول على شهادات أعلى للحفاظ على مستواك المعرفي. اقرأ الأبحاث الأمنية وأوراق العمل (Whitepapers) التي تنشرها الشركات والمؤتمرات، وتابع المؤتمرات العالمية افتراضيًا أو حضوريًا (مثل Black Hat و DEF CON وغيرها) لتبقى على اطلاع بآخر ما توصل إليه الخبراء.

الهدف: ترسيخ عقلية **التعلم المستمر** وعدم الاكتفاء بما تعلمته سابقًا. بالبقاء على اطلاع دائم بالتقنيات والتهديدات الجديدة، ستحافظ على **حدّة مهاراتك** وستكون قادرًا على تكييف استراتيجياتك الدفاعية أو الهجومية حسب المستجدات. التطور المستمر هو ما يميز المحترف الحقيقي في الأمن السيبراني.

النقاط التلخيصية للمرحلة السابعة:

- مواكبة **المستجدات الأمنية يوميًا** عبر قراءة الأخبار والتقارير، يضمن أنك على دراية بأحدث التهديدات والثغرات وأساليب الحماية.

- **الممارسة المستمرة** من خلال تحديات CTF والمسابقات والاختبارات الذاتية تصقل مهاراتك وتعرّفك على سيناريوهات جديدة، كما تبقي التعلم ممتعًا وتفاعليًا.

- الانضمام إلى **مجتمعات محترفي الأمن** والمشاركة في المؤتمرات والدورات المتقدمة يبقيك متصلًا مع مجتمع المجال ويتيح تبادل المعرفة، مما يضمن نموك المهني المستدام.

باتباع هذه **الخارطة الشاملة** خطوة بخطوة، ستنتقل من مرحلة المبتدئ الذي يستكشف أساسيات التقنية، إلى محترف أمن سيبراني جاهز للتعامل مع التهديدات المعقدة. تذكّر أن الرحلة طويلة لكنها ممتعة ومليئة بالتحديات المثيرة؛ تحلَّ بالصبر والمثابرة، وكن شغوفًا بالتعلم والتطور دائمًا. **الأمن السيبراني مجال يتطلب التفاني، ولكن ثماره مجزية** على الصعيدين المهني والشخصي. ابدأ اليوم، واستمتع برحلة التعلم نحو الاحتراف!

المسارات المهنية في الأمن السيبراني

المقدمة

الأمن السيبراني أصبح اليوم من أهم المجالات التقنية، ومع تزايد التهديدات الإلكترونية تحتاج المؤسسات إلى مختصين ذوي كفاءات عالية لحماية بياناتها وأنظمتها. وجود مسارات مهنية واضحة في هذا المجال يساعد المبتدئين على فهم الخيارات المتاحة وتحديد الاتجاه الأنسب لتطوير مهاراتهم. كما أن التخصص في أحد فروع الأمن السيبراني يعد مفتاحًا لبناء الكفاءات العميقة، حيث يتيح للفرد التركيز على مجال محدد واكتساب خبرة عملية قوية فيه. هذا التنوع في المسارات المهنية يعني أن كل مهتم بالأمن السيبراني يمكنه العثور على دور يناسب اهتماماته وقدراته.

فيما يلي نستعرض أبرز الأدوار الوظيفية في مجال الأمن السيبراني، مع توضيح مهام كل دور والمهارات المطلوبة ونوعية العمل، وذلك لمساعدة المبتدئين على تكوين صورة واضحة عن كل مسار وظيفي ممكن.

محلل أمني (Security Analyst)

يُعد محلل الأمن السيبراني أحد أول الأدوار التي يمكن البدء بها في هذا المجال. تتمثل مهمته الأساسية في مراقبة الأنظمة والشبكات بشكل مستمر لرصد أي نشاط غير اعتيادي قد يشير إلى تهديد أو هجوم إلكتروني. يقوم المحلل بفحص سجلات الأحداث والتنبيهات الأمنية وتحليلها بهدف اكتشاف محاولات الاختراق أو الثغرات، ويتولى الاستجابة الأولية للحوادث الأمنية أو تصعيدها إلى الفرق المختصة عند الضرورة. يساعد أيضًا في تطبيق إجراءات وقائية لمنع حدوث الهجمات من خلال تعزيز سياسات الأمان وتحديث أنظمة الحماية بانتظام.

يتطلب عمل محلل الأمان مهارات تقنية وتحليلية قوية. يجب أن يكون ملمًا بأساسيات الشبكات وأنظمة التشغيل المختلفة، ويمتلك القدرة على تحليل البيانات واستخلاص الاستنتاجات بسرعة. الانتباه للتفاصيل والدقة في مراقبة الأحداث عوامل حاسمة في نجاحه، حيث أن اكتشاف مشكلة أمنية في وقت مبكر يمكن أن يوفر على المؤسسة خسائر كبيرة. يعمل محلل الأمن السيبراني عادةً ضمن فريق مركز عمليات الأمن (SOC) وقد يعمل بنظام المناوبة لضمان المراقبة المستمرة على مدار الساعة.

مختبر اختراق (Penetration Tester)

يقوم مختبر الاختراق بدور القرصان الأخلاقي الذي يهاجم أنظمة المؤسسة بشكل مُصرَّح به بهدف اختبار قوة دفاعاتها. تعتمد طبيعة عمله على محاكاة الهجمات الإلكترونية الحقيقية للبحث عن الثغرات الأمنية في الشبكات والتطبيقات وأنظمة التشغيل قبل أن يستغلها المهاجمون الفعليون. بعد الانتهاء من الاختبار، يُعد تقارير مفصّلة تشرح نقاط الضعف المكتشفة ويوصي بالإجراءات التصحيحية اللازمة لتعزيز أمن النظام.

تتطلب وظيفة مختبر الاختراق مهارات تقنية متقدمة وروحًا إبداعية في حل المشكلات. ينبغي أن يكون ملمًا بأساليب الهجوم المختلفة وتقنيات الاختراق الحديثة، ولديه معرفة قوية ببروتوكولات الشبكات ونظم التشغيل وقواعد البيانات. غالبًا ما يستخدم أدوات متخصصة (مثل برامج فحص الثغرات وأطر الاختبار) ويحتاج إلى مهارات برمجية في بعض الحالات لتطوير سكربتات أو أدوات مخصصة. بالإضافة إلى ذلك، يجب أن يتحلى بالأمانة المهنية والالتزام بالمعايير الأخلاقية، نظرًا لحساسية العمل الذي يقوم به.

مستجيب للحوادث (Incident Responder)

دور مستجيب الحوادث يتركز على التعامل مع الهجمات السيبرانية بعد وقوعها للحد من الأضرار وإعادة الأمور إلى نصابها بسرعة. عندما يحدث اختراق أمني أو حادث

سيبراني، يقوم المستجيب باتخاذ إجراءات فورية لاحتواء الحادث، مثل عزل الأجهزة المخترقة عن الشبكة لمنع انتشار الهجوم إلى بقية الأنظمة. بعد ذلك يعمل على معالجة الخلل؛ فقد يقوم بإزالة البرمجيات الخبيثة، أو تصحيح الثغرة التي استغلها المخترق، واستعادة البيانات من النسخ الاحتياطية إذا لزم الأمر لإعادة تشغيل الخدمات المتأثرة.

تتطلب الاستجابة للحوادث هدوءًا تحت الضغط ومهارات تحليل جنائي رقمي لمعرفة كيفية حدوث الاختراق وتحديد نطاق الضرر. يجب أن يمتلك المستجيب معرفة واسعة بأنظمة الشبكات والتشغيل، بالإضافة إلى القدرة على اتباع خطط استجابة معدة مسبقًا (Incident Response Plans) وتحديثها حسب الدروس المستفادة. التواصل الفعال أيضًا جزء مهم من الدور، حيث ينبغي إعداد تقارير بعد الحوادث وشرحها للإدارة والفريق التقني لضمان اتخاذ خطوات تمنع تكرارها في المستقبل.

مهندس مركز عمليات الأمن (SOC Engineer)

يعمل مهندس مركز عمليات الأمن ضمن فريق متخصص لمراقبة حالة الأمن السيبراني في المؤسسة بشكل متواصل. مركز عمليات الأمن (Security Operations Center - SOC) هو المكان الذي تتم فيه إدارة ومتابعة الأحداث الأمنية على مدار الساعة، ودور المهندس هنا هو استخدام أنظمة المراقبة والتحليل (مثل منصات SIEM وأنظمة كشف الاختراق) لرصد أي تهديدات أو نشاط مريب في الشبكة أو الأنظمة. يقوم هذا المهندس بتحليل التنبيهات الواردة، والتفريق بين الإنذارات الكاذبة والتهديدات الحقيقية، واتخاذ إجراءات سريعة لمواجهة أي هجوم يتم اكتشافه أو تصعيده إلى فريق الاستجابة للحوادث عند الضرورة.

يتطلب دور مهندس مركز عمليات الأمن فهمًا عميقًا لبنية أنظمة تقنية المعلومات في المؤسسة ولمختلف أدوات الأمن السيبراني المستخدمة. يجب أن يمتلك مهارات عالية في تحليل البيانات ورصد الأنماط غير الطبيعية، بالإضافة إلى إلمام ببروتوكولات الشبكات وتقنيات الاختراق الشائعة ليتمكن من التعرف على الإشارات المبكرة

للهجمات. القدرة على العمل تحت الضغط والتعامل مع حجم كبير من التنبيهات يوميًا هي صفات أساسية، إلى جانب مهارات التواصل للعمل ضمن فريق والتنسيق مع الأقسام التقنية الأخرى. من خلال عمله، يساهم مهندس الـ SOC في تشكيل خط الدفاع الأول للمؤسسة ضد التهديدات الرقمية.

مستشار أمن سيبراني (Cybersecurity Consultant)

مستشار الأمن السيبراني هو الخبير الذي تستعين به المؤسسات لتقييم وضعها الأمني ووضع خطة لتحسينه. يقوم هذا المستشار بتحليل البنية التحتية الرقمية للمنظمة بحثًا عن نقاط الضعف المحتملة سواء في أنظمة الشبكات أو البرمجيات أو إجراءات العمل. بناءً على التقييم، يقدم توصيات واضحة وإجراءات عملية لتعزيز مستوى الحماية، مثل اعتماد سياسات أمنية جديدة، أو تحسين إعدادات أنظمة الحماية والجدران النارية، أو سد الثغرات المكتشفة عبر تحديث البرمجيات أو تعديل معمارية الأنظمة.

طبيعة عمل المستشار تتطلب رؤية شاملة ومواكبة لأحدث تهديدات وتقنيات الأمن. يجب أن يمتلك خلفية تقنية قوية تشمل الشبكات وأنظمة التشغيل والتشفير وإدارة الوصول، إلى جانب فهم لمعايير الامتثال والقوانين المتعلقة بحماية البيانات. مهارات التواصل ضرورية أيضًا، حيث يتعين عليه شرح المخاطر والحلول المقترحة بلغة يفهمها صناع القرار وفرق العمل غير المتخصصة. قد يشمل دوره كذلك تدريب الموظفين على ممارسات الأمن السيبراني السليمة ورفع مستوى الوعي الأمني داخل المؤسسة. يعمل المستشار إما بشكل مستقل أو ضمن شركة استشارية، ويتعامل مع عدة عملاء أحيانًا، مما يضيف تنوعًا وتحديًا إلى طبيعة عمله.

مدير أمن المعلومات (CISO)

مدير أمن المعلومات هو المسؤول التنفيذي الأعلى عن حماية أصول المعلومات في المؤسسة. يضع هذا المدير استراتيجية الأمن السيبراني الشاملة ويشرف على

تنفيذها عبر جميع الإدارات والفرق التقنية. يشمل دوره وضع السياسات والإجراءات الأمنية، والتأكد من امتثال الشركة للمعايير والقوانين المتعلقة بأمن المعلومات، وإدارة مخاطر الأمن السيبراني من خلال تحديد المخاطر المحتملة ووضع خطط للتعامل معها. كما يكون الـ CISO حلقة الوصل بين الإدارة العليا وفريق الأمن؛ إذ يقدم تقارير منتظمة للإدارة التنفيذية أو مجلس الإدارة حول مستوى الأمان والتهديدات المستجدة، ويقترح مبادرات لتحسين الوضع الأمني (كتبني تقنيات جديدة أو تعزيز برامج التوعية).

يتطلب منصب مدير أمن المعلومات خبرة طويلة وفهمًا عميقًا لمجال الأمن السيبراني وكذلك لمجال عمل المؤسسة نفسها. يجب أن يتمتع بمهارات قيادية لإدارة فرق الأمن وتنسيق جهودها، ومهارات اتصال عالية للتواصل مع بقية الإدارات وشرح المفاهيم التقنية بلغة الأعمال. القدرة على اتخاذ قرارات استراتيجية مهمة في ضوء التهديدات الأمنية والتطورات التقنية من السمات الأساسية لهذا الدور. غالبًا ما يحمل مدير أمن المعلومات شهادات مهنية متقدمة مثل CISSP أو CISM، بالإضافة إلى مؤهل أكاديمي عالٍ (ربما درجة ماجستير في إدارة الأعمال أو تقنية المعلومات)، مما يعكس مستوى المعرفة والتخصص المطلوب لهذه المسؤولية الكبيرة.

المهارات والشهادات المطلوبة

للانخراط الناجح في مسارات الأمن السيبراني، يحتاج الفرد إلى مزيج من المهارات التقنية والمهارات الشخصية (الناعمة). من الجانب التقني، لا بد من فهم قوي لأساسيات تكنولوجيا المعلومات، مثل الشبكات وبروتوكولاتها، وأنظمة التشغيل (ويندوز، لينكس وغيرها)، ومعرفة بآليات تأمين البيانات والتشفير وإدارة الثغرات. كما أن الإلمام بلغات البرمجة أو كتابة السكربتات الأساسية يفيد في العديد من الأدوار (خاصة للمختبرين والمحللين).

أما المهارات الشخصية فتشمل القدرة على حل المشكلات بطريقة منهجية، والتفكير التحليلي لتفسير البيانات والمؤشرات الأمنية، والانتباه الشديد للتفاصيل

للكشف عن أي شذوذ أو خطر محتمل. كذلك تُعد مهارات الاتصال والتعاون مهمة جدًا، لأن متخصص الأمن السيبراني يعمل عادةً ضمن فريق ويتواصل مع أقسام مختلفة لشرح المخاطر والإجراءات الوقائية. ولا ننسى أهمية الرغبة في التعلم المستمر، فالمجال يتطور بسرعة ويحتاج المحترف إلى متابعة كل جديد باستمرار.

إلى جانب المهارات، هناك العديد من الشهادات المهنية المعترف بها دوليًا التي تعزّز مصداقية الخبير في الأمن السيبراني وتثبت مدى إلمامه بالجوانب المختلفة للمجال. من أشهر هذه الشهادات: شهادة CompTIA Security+ التي تغطي أساسيات أمن المعلومات، وشهادة CEH (مخترق أخلاقي معتمد) المتخصصة في اختبار الاختراق، وشهادة CISM (مدير أمن المعلومات المعتمد) التي تركز على إدارة أمن المعلومات، وشهادة CISSP (محترف أمن نظم المعلومات معتمد) التي تعتبر من أعلى الشهادات قيمةً وتشمل مجالات متعددة في الأمن السيبراني. بالإضافة إلى ذلك، تتوفر شهادات أخرى متقدمة ومتخصصة مثل CompTIA CySA+ لأخصائي تحليل الأمن، وOSCP لمختبري الاختراق المتقدمين، وشهادات SANS/GIAC في مجالات مثل التحقيق الجنائي الرقمي وإدارة الحوادث. الحصول على بعض هذه الشهادات يفتح أبوابًا وظيفية أوسع ويعزز ثقة أصحاب العمل بقدرات المتقدم في هذا المجال.

مصادر تعلم الأمن السيبراني

يمثّل **مجال الأمن السيبراني** أحد أهم المجالات التقنية في عصرنا، ويتطلب التعلم المستمر عبر مصادر متنوعة. فيما يلي قائمة مُنظَّمة بحسب نوع المصادر لمساعدة المهتمين بتعلم الأمن السيبراني من الصفر وحتى مستويات متقدمة:

الدورات التدريبية (Courses)

تساعد **الدورات التدريبية** المنظمة على بناء أساس قوي في الأمن السيبراني بشكل منهجي. من أبرز الدورات المتاحة باللغة العربية ما يلي:

- **دورة الأمن السيبراني - CybersCourse:** دورة شاملة مصممة للمبتدئين تبدأ من الأساسيات وصولًا إلى مفاهيم متقدمة، مع تطبيقات عملية وشهادة دولية معتمدة عند الإنجاز.

- **دورة الأمن السيبراني المعتمدة - TheAI:** برنامج تدريبي متكامل يغطي حماية الأنظمة والشبكات والمعلومات من الصفر، مع اعتماد دولي يعترف به في الشرق الأوسط وعالميًا.

- **دورة الأمن السيبراني للمبتدئين - Dawraty:** دورة أساسية بالتعاون مع جامعة مرموقة، تقدم باللغة العربية للمبتدئين وتشمل محتوى نظري وتطبيقي وشهادة معتمدة عند الإكمال بنجاح.

- **دورة الأمن السيبراني - CyberSA.org:** منهج تدريبي شامل عبر الإنترنت يهدف إلى تعليم مبادئ الأمن السيبراني للمبتدئين، مع التركيز على فهم التهديدات الإلكترونية وسبل الحماية الأساسية.

- **دورة الهاكر الأخلاقي - CybersCourse:** دورة متخصصة في **الاختراق الأخلاقي** (Ethical Hacking) تركز على تعليم أساليب اختبار الاختراق بشكل قانوني وآمن، مما يساعد المتدربين على فهم طرق الهجوم الحديثة وكيفية التصدي لها عمليًا.

- **دورة الهاكر الأخلاقي المعتمدة - TheAI:** برنامج تدريبي احترافي يغطي أساسيات الاختراق الأخلاقي وأدواته المتقدمة، مع شهادة معترف بها تثبت كفاءة المتدرب في اختبار الاختراق وحماية الأنظمة بشكل أخلاقي.

الكتب والمراجع (Books & References)

تعد **الكتب** من المصادر الأساسية لتعميق الفهم النظري وتوفير مرجع دائم. يُنصَح بالاطلاع على كتب متخصصة في الأمن السيبراني باللغة العربية أو المترجمة، ومنها:

- *كتاب "الأمن السيبراني وأساسياته":* يقدم نظرة شاملة للمفاهيم الأساسية في حماية المعلومات والشبكات، مناسب للمبتدئين لفهم المصطلحات والتهديدات الشائعة.

- *كتاب "مقدمة في الأمن السيبراني":* يشرح مبادئ الأمن السيبراني بشكل مبسّط، بما في ذلك أنواع الهجمات الإلكترونية وطرق الوقاية، مما يساعد القارئ على بناء أساس قوي في المجال.

- *كتب متقدمة متخصصة:* بعد إتقان الأساسيات، يمكن التعمق عبر كتب متخصصة مثل تلك التي تغطي **اختبار الاختراق**، **الهندسة الاجتماعية**، أو **التحليل الجنائي الرقمي** لمزيد من التخصص والمعرفة العملية.

الفيديوهات التعليمية (Educational Videos)

توفر **الفيديوهات التعليمية** والمنصات الرقمية محتوى مرئي يسهل فهم المفاهيم المعقدة بطريقة تفاعلية. يمكن الاستفادة من مجموعة واسعة من الفيديوهات المجانية والمدفوعة على الإنترنت، مثل:

- **سلاسل يوتيوب تعليمية:** هناك قنوات يوتيوب عربية يديرها خبراء في الأمن السيبراني، تقدم شروحات من الصفر حول أساسيات أمن المعلومات وأساليب الحماية والهجوم بشكل مبسط. هذه السلاسل تغطي مواضيع مثل مبادئ التشفير، تأمين الشبكات، وفهم الثغرات الشائعة بطريقة عملية.

- **محاضرات جامعية ومُدوَّنات مرئية:** بعض الجامعات والمبادرات التعليمية توفر محاضرات مسجلة في الأمن السيبراني مترجمة للعربية أو مدبلجة، والتي تشمل مساقات معتمدة (مثل مساق مقدمة في الأمن السيبراني) لمساعدة المتعلم على فهم المفاهيم الأكاديمية بالتفصيل.

- **منصات التعليم المفتوح (MOOCs):** عبر منصات عالمية للتعليم المفتوح، تتوفر دورات أمن سيبراني باللغة الإنجليزية مع ترجمة عربية أحيانًا، تحتوي على فيديوهات تشرح المفاهيم خطوة بخطوة وتمارين تطبيقية يمكن للمتعلم متابعتها بالوتيرة التي تناسبه.

ورش العمل والمسابقات التطبيقية (Workshops & Practical Competitions)

ورش العمل والتدريبات التطبيقية تضيف جانبًا عمليًا أساسيًا لتعليم الأمن السيبراني، حيث تتيح للمشاركين تجربة ما تعلموه في بيئة تحاكي الواقع:

- **ورش العمل التدريبية:** تنظم جهات أكاديمية ومجتمعات تقنية محلية ورش عمل حضورية وافتراضية تغطي مواضيع محددة في الأمن السيبراني (مثل تحليل البرمجيات الخبيثة أو تأمين التطبيقات). هذه الورش غالبًا ما تكون قصيرة ومكثفة بإشراف خبراء، وتوفر فرصة للممارسة العملية المباشرة وطرح الأسئلة.

- **المعسكرات والهاكاثونات:** المعسكرات التقنية المتخصصة في الأمن السيبراني (Bootcamps) تقدم تدريبًا مكثفًا على مدى أسابيع، وتشمل مشاريع عملية بإشراف مدربين محترفين. كما تُقام هاكاثونات وتحديات أمنية تنافسية تضع المشاركين أمام مسائل حقيقية لحلها في مجال الأمن السيبراني ضمن فرق، مما ينمي مهارات التحليل والعمل الجماعي تحت الضغط.

- **مسابقات (Capture The Flag (CTF:** تعتبر مسابقات CTF من أشهر الأنشطة التطبيقية لرفع مستوى المهارات، حيث يتسابق المشاركون في حل تحديات أمنية متنوعة (اختراق مواقع افتراضية، فك تشفير، تحليل ثغرات) لكسب *"العلم"* الرقمي. المشاركة في هذه المسابقات توسّع المدارك العملية وتكشف الثغرات التي قد لا تظهر في التعلم النظري التقليدي.

المواقع الإلكترونية الرسمية (Official Websites)

تقدم الجهات الحكومية في الشرق الأوسط موارد موثوقة للتوعية والتعلم في مجال الأمن السيبراني. يُنصح بمتابعة المواقع الرسمية التالية للحصول على أحدث الإرشادات والأخبار والمبادرات:

- **الهيئة الوطنية للأمن السيبراني - السعودية:** الجهة الحكومية المسؤولة عن تنظيم وتعزيز الأمن السيبراني في المملكة العربية السعودية، تنشر

سياسات وأطر عمل وطنية، كما توفر مواد توعوية وتحديثات إستراتيجية للمختصين والعامة.

- **المركز الوطني للأمن السيبراني - الأردن:** مركز حكومي يهدف إلى حماية الفضاء السيبراني الأردني، ويقدم إرشادات وتعاميم لتعزيز أمن المعلومات على المستوى الوطني، إضافة إلى نشر محتوى توعوي للمستخدمين.

- **مجلس الأمن السيبراني - الإمارات:** مجلس رسمي ينسق جهود الأمن السيبراني على مستوى دولة الإمارات العربية المتحدة، ويطلق حملات توعية رقمية ومبادرات تهدف إلى رفع جاهزية المؤسسات والأفراد ضد التهديدات الإلكترونية.

- **الوكالة الوطنية للأمن السيبراني - قطر:** وكالة حكومية حديثة التأسيس تُعنى بوضع وتنفيذ إستراتيجيات الأمن السيبراني في قطر، وتوفير موارد تعليمية وإرشادية للمؤسسات والأفراد لحماية البنية التحتية الرقمية الوطنية.

- **المجلس الأعلى للأمن السيبراني - مصر:** مجلس حكومي تأسس لحماية البنية المعلوماتية الحرجة في مصر، يقوم بوضع سياسات وطنية للأمن السيبراني ويعمل على تنسيق جهود مختلف الجهات الحكومية في التصدي للهجمات السيبرانية، مع نشر تقارير ودراسات توعوية دورية.

خلاصة: إن تعلم الأمن السيبراني رحلة متعددة المسارات تجمع بين الدراسة النظرية والتدريب العملي. من المهم تنويع مصادر التعلم بين دورات تدريبية موثوقة، وكتب ومراجع معمّقة، ومحتوى مرئي تفاعلي، بالإضافة إلى المشاركة في تطبيقات عملية عبر ورش ومسابقات. وأخيرًا، تبقى متابعة التوجيهات الرسمية عبر المواقع الحكومية أمرًا ضروريًا للبقاء على اطلاع على أحدث التهديدات وأساليب الحماية وفقًا للمعايير

الوطنية والدولية. بهذه المقاربة الشاملة، يمكن للمتعلمين بناء مهارات قوية في مجال الأمن السيبراني خطوة بخطوة وبشكل منظم.

المعايير العالمية في الأمن السيبراني

في العصر الرقمي الحالي تتزايد التهديدات السيبرانية بشكل مطّرد، مما يجعل حماية البيانات والمعلومات الحساسة أمراً بالغ الأهمية لجميع المؤسسات. هنا تبرز **معايير الأمن السيبراني العالمية** كخط دفاع أساسي يضمن وضع ضوابط وإجراءات موحّدة لحماية البيانات. إن وجود معايير واضحة في مجال الأمن السيبراني يساعد المؤسسات على **حماية البيانات** من الاختراقات والضياع، ويضمن **الامتثال** للقوانين واللوائح التنظيمية، ويُسهم في **تقليل المخاطر** الأمنية عبر اتباع أفضل الممارسات. كما أن اتباع هذه المعايير يرسّخ الثقة بين العملاء والمؤسسات، حيث تطمئن الجهات المعنية إلى أن المنظمة تتبع أسسًا عالمية للحفاظ على سرية المعلومات وسلامتها. سنستعرض فيما يلي أبرز المعايير العالمية في الأمن السيبراني، مع توضيح تعريف كل معيار وهدفه، ونطاق تطبيقه، والجوانب التي يغطيها في مجال الأمن السيبراني، إضافة إلى أمثلة تطبيقية عامة على استخدامه.

معيار ISO/IEC 27001 (نظام إدارة أمن المعلومات)

تعريف المعيار والغرض منه: يعد معيار **ISO/IEC 27001** المعيار الدولي لنظم إدارة أمن المعلومات (ISMS). طورته المنظمة الدولية للمعايير (ISO) واللجنة الكهروتقنية الدولية (IEC) بهدف مساعدة المؤسسات على إنشاء وتشغيل وتحسين نظام متكامل لإدارة أمن المعلومات بشكل منهجي. يحدد المعيار متطلبات واضحة لوضع الضوابط والإجراءات الأمنية لحماية المعلومات الحساسة، ويهدف إلى **حماية سرية المعلومات وسلامتها وتوفرها** من خلال نهج إداري قائم على تقييم المخاطر ومعالجتها. كما يوفر ISO 27001 إطار عمل يضمن الاستمرارية في **تحسين مستوى الأمن** مع مرور الزمن.

نطاق التطبيق: يتميز ISO/IEC 27001 بأنه قابل للتطبيق على مختلف أنواع وأحجام المؤسسات في جميع القطاعات حول العالم. فهو مناسب للشركات التجارية والبنوك والجهات الحكومية والمؤسسات التعليمية وغيرها، سواء كانت كبيرة أو صغيرة. يمكن لأي منظمة تتعامل مع معلومات قيّمة اعتماد هذا المعيار لوضع نظام إدارة أمن معلومات فعال، كما يمكنها الحصول على شهادة ISO 27001 لإثبات امتثالها للمعيار. غالباً ما يشترط الشركاء أو العملاء حصول المؤسسة على هذه الشهادة كدليل على التزامها بأمن المعلومات.

الجوانب التي يغطيها: يغطي معيار ISO/IEC 27001 جميع جوانب الأمن السيبراني المتعلقة بإدارة وحماية المعلومات. فهو يشمل وضع **سياسات أمن المعلومات** وتحديد الأدوار والمسؤوليات، وإجراء **تحليل منهجي للمخاطر** لتحديد نقاط الضعف والتهديدات المحتملة ومعالجتها بإجراءات مناسبة. كما يتطرق إلى ضوابط أمنية تفصيلية تشمل **ضوابط تقنية** (مثل إدارة الوصول والتشفير وجدران الحماية)، و**ضوابط إجرائية** (مثل سياسات استخدام الأصول وإدارة الحوادث الأمنية)، و**ضوابط مادية** (لحماية مراكز البيانات والمرافق). باختصار، يضمن المعيار أن لدى المنظمة مجموعة متكاملة من الضوابط لحماية **سرية المعلومات وسلامتها وتوفرها** بشكل متواصل.

أمثلة أو تطبيقات عملية: من الأمثلة الشائعة لتطبيق ISO 27001 أن تقوم شركة تقنية أو مصرف بوضع نظام إدارة أمن معلومات وفق المعيار لحماية بيانات العملاء والموظفين. يشمل ذلك مثلاً إنشاء سياسة أمن معلومات داخلية، وتطبيق ضوابط للتحكم في صلاحيات الوصول إلى الأنظمة الحساسة، وتدريب الموظفين على الوعي الأمني، ووضع إجراءات للتعامل مع الحوادث السيبرانية. عند تطبيق المعيار بنجاح والحصول على شهادة ISO/IEC 27001، تستطيع المؤسسة طمأنة عملائها وشركائها بأنها تتبع أفضل الممارسات الدولية في حماية المعلومات، مما يقلل احتمال وقوع اختراقات كبيرة ويعزز سمعة المؤسسة في السوق.

إطار الأمن السيبراني NIST

تعريف المعيار والغرض منه: إطار عمل الأمن السيبراني NIST هو مجموعة من الإرشادات والممارسات التي طورها المعهد الوطني للمعايير والتكنولوجيا (NIST) في الولايات المتحدة بهدف مساعدة المؤسسات على إدارة مخاطر الأمن السيبراني بفعالية. تم إصدار النسخة الأولى من هذا الإطار في عام 2014 لحماية **البنية التحتية الحيوية**، ثم أصبح معتمدًا على نطاق أوسع كمرجع عام لأفضل ممارسات الأمن السيبراني. يقوم إطار NIST على **نهج قائم على المخاطر** (Risk-Based Approach) لتحديد أولويات الدفاع السيبراني، ويقدم **خمس وظائف أساسية** لإدارة الأمن السيبراني هي: *التعرف (Identify)*، *والحماية (Protect)*، *والكشف (Detect)*، *والاستجابة (Respond)*، *والاستعادة (Recover)*. الغرض الأساسي من هذا الإطار هو مساعدة المؤسسات على **فهم مخاطر الأمن السيبراني وتقليلها** عبر تبني إجراءات مرنة يمكن تكييفها مع طبيعة وظروف كل منظمة.

نطاق التطبيق: على الرغم من أن إطار NIST نشأ في سياق حماية البنية التحتية الأمريكية الحيوية، إلا أنه أصبح معيارًا مرجعيًا عالميًا يمكن لأي منظمة الاستفادة منه. فهو مناسب للشركات الخاصة والمؤسسات الحكومية على حد سواء، بغض النظر عن قطاعها أو حجمها. تستخدمه العديد من القطاعات مثل **القطاع المالي والرعاية الصحية والطاقة** لوضع برنامج أمن سيبراني متكامل. الإطار طوعي وليس إلزاميًا بقانون معين، لكن العديد من المؤسسات تتبناه طوعًا لرفع مستوى الحماية أو للامتثال لتوجيهات تنظيمية تستند إليه. ويتميز إطار NIST بمرونته، حيث يمكن تكييفه ليلائم الاحتياجات الخاصة لكل مؤسسة وفق مستوى النضج الأمني لديها وإمكانياتها.

الجوانب التي يغطيها: يغطي إطار عمل NIST مختلف جوانب برامج الأمن السيبراني من مرحلة **التعرف على الأصول والمخاطر** إلى مرحلة **استعادة العمليات بعد الحوادث**. في وظيفة "التعرف" يوجه الإطار المؤسسات لجرد الموجودات الرقمية

(أجهزة، أنظمة، بيانات) وفهم نقاط الضعف والتهديدات المحيطة بها. في وظيفة "الحماية" يشجع على تنفيذ ضوابط دفاعية مناسبة مثل تأمين الشبكات والتحكم بالوصول وتوعية المستخدمين. أما وظيفة "الكشف" فتتناول آليات **مراقبة الشبكات والأنظمة** للكشف المبكر عن أي نشاط غير اعتيادي أو محاولات اختراق. ثم تأتي وظيفة "الاستجابة" التي تحدد كيفية **التعامل الفوري مع الحوادث** عند وقوعها، عبر خطط استجابة فعالة لاحتواء الهجوم وتقليل أضراره. وأخيرًا وظيفة "الاستعادة" لضمان **استمرارية الأعمال** واسترجاع الخدمات وأنظمة المعلومات إلى وضعها الطبيعي بعد حدوث أي اضطراب سيبراني. هذا النهج الشمولي يضمن أن المؤسسة لديها خطة متوازنة تشمل الإجراءات الوقائية والاستعدادية وكذلك إجراءات الاستجابة والتعافي، مما يعزز قدرتها على الصمود أمام الهجمات.

أمثلة أو تطبيقات عملية: كمثال عملي، يمكن أن تعتمد مؤسسة مالية إطار NIST كأساس لمنظومة أمن المعلومات لديها. تبدأ المؤسسة بتحديد أهم الأصول مثل قواعد بيانات العملاء وأنظمة الدفع الإلكترونية وتحليل المخاطر التي تهددها (كالهجمات الإلكترونية أو تسريب البيانات). ثم تقوم المؤسسة بوضع ضوابط حماية مناسبة كاستخدام أنظمة تشفير لحماية البيانات المالية، وتطبيق سياسات لإدارة كلمات المرور والصلاحيات. بالإضافة إلى ذلك، تُنشئ آليات مراقبة مستمرة (مثل أنظمة كشف التسلل) لاكتشاف أي اختراق محتمل في وقت مبكر. وإذا تم رصد حادث أمني كاختراق أحد الخوادم، يكون لدى الفريق خطة **استجابة** واضحة لإغلاق الثغرة وإخطار الفرق المعنية واحتواء الضرر. وبعد احتواء الحادث، تتبع المنظمة خطة **استعادة** لإرجاع النظام للعمل بشكل كامل وإجراء مراجعة شاملة لما حدث لتفادي تكراره. عبر هذا التطبيق المتكامل، استطاعت المؤسسة استخدام إطار NIST لتحسين جاهزيتها الأمنية والتقليل من تأثير الحوادث السيبرانية على عملائها وعملياتها.

اللائحة العامة لحماية البيانات (GDPR)

تعريف المعيار والغرض منه: اللائحة العامة لحماية البيانات المعروفة اختصارًا بـ **GDPR** هي إطار قانوني صدر عن الاتحاد الأوروبي يضع معايير صارمة لحماية خصوصية البيانات الشخصية. بدأ تطبيق اللائحة في مايو 2018 بهدف إعطاء الأفراد سيطرة أكبر على بياناتهم الشخصية وضمان توحيد قوانين حماية البيانات عبر دول الاتحاد الأوروبي. يحدد GDPR **مبادئ أساسية لحماية البيانات** مثل الشفافية والحد من الغرض وتقليل جمع البيانات إلى الحد الأدنى الضروري، كما يقر حقوقًا للأفراد (صاحبي البيانات) مثل حق الوصول إلى بياناتهم وتصحيحها أو حذفها (حق النسيان). الغرض الرئيسي من GDPR هو **حماية خصوصية الأفراد** ومنع إساءة استخدام بياناتهم الشخصية، وذلك من خلال فرض التزامات أمنية وتنظيمية على الجهات التي تجمع أو تعالج تلك البيانات. كما تهدف اللائحة إلى تحسين مستوى الأمن السيبراني للبيانات الشخصية عبر اشتراط اتخاذ تدابير تقنية وتنظيمية مناسبة لمنع التسريبات والاختراقات، وفرض **عقوبات مالية قاسية** على المخالفين لضمان الامتثال.

نطاق التطبيق: يتميز GDPR بنطاق تطبيق عالمي واسع. فهو لا ينطبق فقط على المنظمات داخل دول الاتحاد الأوروبي، بل يشمل **أي منظمة في أي مكان في العالم** تقوم بمعالجة بيانات شخصية لأفراد موجودين في الاتحاد الأوروبي. يشمل ذلك الشركات التقنية الكبرى ومنصات التواصل الاجتماعي والبنوك ومقدمي الخدمات الصحية والمتاجر الإلكترونية وغيرها. سواء كانت الجهة **مراقب بيانات** (تحدد أغراض ووسائل معالجة البيانات) أو **معالج بيانات** (تعالج البيانات نيابة عن جهة أخرى)، يتوجب عليها الالتزام بمتطلبات GDPR إذا كانت تتعامل مع بيانات تخص أشخاصًا في أوروبا. هذا يعني أن شركة صغيرة في الشرق الأوسط أو آسيا تقدّم خدمات لمستخدمين أوروبيين يجب أن تلتزم أيضًا باللائحة. وقد أدى هذا النطاق الواسع إلى جعل GDPR بمثابة **معيار عالمي** لحماية البيانات الشخصية، ودفع العديد من الدول الأخرى إلى تحديث قوانينها المحلية لتتماشى مع مبادئه.

الجوانب التي يغطيها: تركز اللائحة العامة لحماية البيانات على **جوانب الخصوصية وحماية المعلومات الشخصية**، لكنها تتقاطع أيضًا مع الأمن السيبراني بشكل

مباشر. فهي تُلزم المؤسسات بتبنّي **إجراءات أمنية مناسبة** لحماية البيانات الشخصية من الوصول غير المصرح به أو التسريب أو التدمير. تتضمن هذه الإجراءات مثلاً **تشفير البيانات** الحساسة أو استخدام تقنيات إخفاء الهوية (Pseudonymization) عند تخزين المعلومات، بالإضافة إلى فرض سياسات للتحكم بالوصول إلى البيانات وتدريب الموظفين على التعامل الآمن معها. كما تفرض اللائحة على المؤسسات وضع **إجراءات للاستجابة لحوادث خرق البيانات**، بما في ذلك إشعار سلطات حماية البيانات الوطنية وأصحاب البيانات بأي خرق جسيم خلال مدة لا تتجاوز 72 ساعة من اكتشافه. وتشمل GDPR أيضًا تعيين **مسؤول حماية بيانات (DPO)** في بعض الحالات للإشراف على الامتثال والممارسات المتعلقة بالخصوصية. باختصار، تغطي اللائحة سلسلة واسعة من الضوابط تمتد من **مرحلة جمع البيانات وتخزينها** بشكل آمن، مرورًا بطريقة استخدامها ومشاركتها، وصولاً إلى التخلص منها بأمان أو إخفائها عندما تنتفي الحاجة إليها.

أمثلة أو تطبيقات عملية: عند دخول GDPR حيز التنفيذ، اضطرت معظم الشركات التي تتعامل مع بيانات أوروبية إلى **مراجعة سياساتها وإجراءاتها** بشكل شامل. على سبيل المثال، شركة تقدم خدمة عبر الإنترنت لمستخدمين في أوروبا كان عليها تحديث سياسة الخصوصية لتكون أكثر شفافية وبصياغة واضحة للمستخدم حول كيف سيتم استخدام بياناته. كما أصبحت مطالبة بالحصول على **موافقة صريحة** من المستخدمين قبل جمع أو معالجة بياناتهم الحساسة، مع توفير خيار سهل لسحب الموافقة. من الناحية التقنية، ربما قامت الشركة بتطبيق وسائل تشفير قوية لقواعد بيانات المستخدمين بحيث لو حدث اختراق لا يستطيع المهاجمون قراءة المعلومات الشخصية. أيضًا أعدّت الشركة خطة للتعامل مع حوادث خرق البيانات، بحيث إذا تسرّبت بيانات عدد من المستخدمين بسبب هجوم سيبراني فإنها تستطيع سريعًا إخطار الجهة الرقابية في الاتحاد الأوروبي وكذلك تنبيه المستخدمين المتأثرين لاتخاذ الاحتياطات. هذه الجهود مجتمعة مكّنت الشركة من الامتثال لمتطلبات GDPR، مما

يحميها من الغرامات الكبيرة (التي قد تصل إلى 4% من الإيرادات السنوية العالمية) ويحافظ على ثقة مستخدميها في أن خصوصيتهم مُصانة.

معيار أمن بيانات بطاقات الدفع (PCI DSS)

تعريف المعيار والغرض منه: معيار أمن بيانات بطاقات الدفع المعروف اختصارًا بـ **PCI DSS** هو معيار عالمي وضعه مجلس معايير أمن صناعة بطاقات الدفع (PCI Security Standards Council) لحماية بيانات حامل البطاقة ومنع الاحتيال في معاملات الدفع الإلكتروني. تم تطوير PCI DSS بالتعاون بين شبكات البطاقات العالمية الكبرى (مثل Visa وMastercard وAmerican Express وغيرها) لتوحيد متطلبات الأمان عند معالجة بطاقات الائتمان والخصم. يحدد المعيار **مجموعة شاملة من المتطلبات التقنية والتنظيمية** التي يجب على أي جهة تتعامل مع بيانات البطاقات اتباعها، بهدف ضمان **تأمين معلومات حامل البطاقة** (مثل رقم البطاقة وتاريخ الانتهاء ورمز الأمان) في جميع مراحل التخزين والمعالجة والنقل. الغرض الأساسي من PCI DSS هو **منع تسرب بيانات البطاقات** وتقليل حوادث الاختراق التي تؤدي إلى سرقة أرقام البطاقات، مما يحمي المستهلكين ويعزز ثقة الجمهور بوسائل الدفع الإلكتروني.

نطاق التطبيق: يمتد نطاق تطبيق PCI DSS ليشمل **جميع الكيانات** التي تخزن أو تعالج أو تنقل بيانات بطاقات الدفع. وهذا يشمل طيفًا واسعًا من المؤسسات: من المحلات التجارية التقليدية التي تقبل الدفع بالبطاقة، إلى مواقع التجارة الإلكترونية على الإنترنت، مرورًا بمعالجي المدفوعات (Payment Processors) والبنوك المزودة لخدمات البطاقات، وحتى مزودي الخدمات التقنية الذين يمكن أن تتضمن أعمالهم التعامل مع بيانات البطاقات بالنيابة عن عملائهم. وبعكس بعض المعايير الطوعية، يُعتبر الالتزام بـ PCI DSS **التزامًا تعاقديًا وإجباريًا** في صناعة الدفع؛ فعلى سبيل المثال تشترط البنوك على التجار الالتزام بالمعيار ضمن اتفاقيات خدمة الدفع، وقد يتعرض غير الممتثلين لغرامات أو لعقوبات مثل رفع رسوم المعاملات أو حتى إلغاء

حقهم في قبول بطاقات الدفع. لذا نجد أن مختلف الشركات - كبيرة أو صغيرة - التي تتعامل مع بطاقات الائتمان ملزمة بتطبيق PCI DSS لحماية بيانات عملائها وتفادي العواقب المالية والقانونية للتقصير الأمني.

الجوانب التي يغطيها: يغطي معيار PCI DSS **كافة جوانب أمن نظم الدفع الإلكتروني**، ويتألف من **12 متطلبًا رئيسيًا** grouped ضمن أهداف أمنية. من أبرز هذه الجوانب: **تأمين الشبكات والأنظمة** التي تعالج بيانات البطاقات عبر تركيب جدران حماية وضبط إعداداتها لمنع الوصول غير المصرح به، وكذلك **عدم استخدام كلمات مرور افتراضية** للأجهزة والأنظمة. يركز المعيار أيضًا على **حماية بيانات حامل البطاقة** نفسها من خلال تشفير بيانات البطاقات أثناء التخزين وفي أثناء انتقالها عبر الشبكات العامة. يتطلب PCI DSS أيضًا من المؤسسات **إدارة نقاط الضعف الأمنية بشكل مستمر**، فالمتطلبات تشمل استخدام برامج مضادة للبرمجيات الخبيثة وتحديثها باستمرار، وتطوير التطبيقات والنظم بشكل آمن لتجنب الثغرات المعروفة. من ناحية **التحكم في الوصول**، يفرض المعيار ضوابط صارمة مثل منح الصلاحيات على أساس الحاجة الوظيفية (أي أقل امتياز كافٍ لأداء العمل)، وتخصيص هوية فريدة لكل مستخدم ذو صلاحية، وتقييد **الوصول المادي** إلى أماكن تخزين بيانات البطاقات (مثل خوادم قواعد البيانات). كما يشدد على **مراقبة الشبكة وفحصها دوريًا**، عبر حفظ سجلات الدخول والوصول ومراجعتها للكشف عن أي أنشطة مريبة، وإجراء اختبارات أمنية منتظمة للشبكات والأنظمة للتأكد من سلامة الضوابط المطبقة. أخيرًا، يتطلب المعيار وجود **سياسة أمن معلومات شاملة** لدى المؤسسة تغطي جميع جوانب الأمن ذات الصلة بالبطاقات وتُلزم جميع الموظفين بإتباعها. هذه التغطية الشاملة تضمن أن كل مرحلة من دورة حياة بيانات البطاقة (من لحظة إدخالها في نظام نقطة البيع أو الموقع الإلكتروني، مرورًا بالتخزين والمعالجة، وحتى الإتلاف) تتمتع بالحماية الكافية ضد الاختراقات.

أمثلة أو تطبيقات عملية: مثال تطبيقي على PCI DSS يمكن رؤيته في متجر إلكتروني كبير يقبل مدفوعات ببطاقات الائتمان. على هذا المتجر الالتزام بإجراءات صارمة حتى

يُعدَّ ممتثلاً للمعيار: يقوم بتقسيم شبكته بحيث تكون الأنظمة التي تتعامل مع بيانات الدفع معزولة وآمنة، ويستخدم **تشفيرًا قويًا** (مثل بروتوكول TLS) عند إرسال بيانات البطاقة لإتمام المعاملة. لا يخزن المتجر أرقام البطاقات في قواعد بياناته إلا عند الضرورة القصوى، وحتى في حال التخزين يجب أن تكون الأرقام **مشّفرة أو مختصرة** (masked) بحيث لا يمكن للعاملين الاطلاع عليها كاملةً. إضافة لذلك، يُجري المتجر مسحًا دوريًا للثغرات الأمنية في خوادمه ويتعاقد مع شركات متخصصة لإجراء **اختبارات اختراق منتظمة** للتأكد من عدم وجود منفذ يمكن للمهاجمين استغلاله. على صعيد العمليات، كل موظف لديه صلاحية الوصول إلى نظام الدفع يحمل **هوية مستخدم فريدة وكلمة مرور قوية** ويتم تتبّع أنشطته، فلا يُسمح بمشاركة الحسابات بين الموظفين. أيضًا يدرّب المتجر موظفيه (خاصة فريق تقنية المعلومات وخدمة العملاء) على سياسات التعامل الآمن مع معلومات البطاقات، مثل عدم تدوين أرقام البطاقات في ملاحظات أو مشاركتها عبر البريد الإلكتروني. هذه الممارسات وغيرها كثير ضمن إطار PCI DSS تمكن المتجر الإلكتروني من تقليل احتمالات سرقة بيانات البطاقات، وتجنب خسائر مالية فادحة أو ضرر بسمعته في حال حدوث اختراق، كما أنها ضرورية لاستمرار السماح له بالتعامل مع أنظمة الدفع العالمية.

قانون HIPAA لحماية المعلومات الصحية

تعريف المعيار والغرض منه: قانون قابلية نقل التأمين الصحي والمساءلة لعام 1996 والمعروف اختصارًا بـ **HIPAA** هو تشريع اتحادي في الولايات المتحدة يضع معايير وطنية لحماية المعلومات الصحية الحساسة للمرضى. يهدف القانون إلى ضمان **خصوصية المعلومات الطبية** للأفراد بالإضافة إلى ضمان أمنها عند تخزينها أو تبادلها إلكترونيًا. في سياق الأمن السيبراني، يشتهر HIPAA تحديدًا بـ"قاعدة الأمان" (Security Rule) التي صدرت ضمن تعديلات القانون عام 2003، والتي تضع **ضوابط إلزامية** لحماية المعلومات الصحية المحمية إلكترونيًا (ePHI). الغرض الأساسي من

HIPAA هو تحقيق **التوازن بين حماية سرية وسلامة وتوفر المعلومات الصحية** من جهة، وبين تسهيل تدفق المعلومات اللازمة لتقديم رعاية صحية فعالة من جهة أخرى. وبعبارة أخرى، يسعى القانون لضمان أن المستشفيات والعيادات وشركات التأمين الصحي وباقي الجهات المشمولة تتخذ الخطوات الكافية فنيًا وإداريًا للحفاظ على **أمن بيانات المرضى**، وبنفس الوقت لا تعيق تبادل المعلومات بشكل يؤثر سلبًا على جودة الرعاية الصحية المقدمة.

نطاق التطبيق: ينطبق قانون HIPAA بشكل رئيسي على **الجهات الصحية المشمولة** (Covered Entities) في الولايات المتحدة. هذه الجهات تشمل مزوّدي الرعاية الصحية (مثل المستشفيات والعيادات والأطباء)، وخطط التأمين الصحي، إضافة إلى ما يُعرف بـ"مقايضات المعلومات الصحية" أو مراكز معالجة المعلومات الصحية إلكترونياً (Health Clearinghouses). كما يمتد نطاق الالتزام إلى **الشركاء التجاريين** (Business Associates) لتلك الجهات، وهم أي أشخاص أو جهات خارجية تقدم خدمات أو perform وظائف نيابةً عن جهة صحية مشمولة تتضمن التعامل مع معلومات صحية محمية. على سبيل المثال، شركة توفر خدمة استضافة سحابية لمستشفى وتتعامل مع سجلات المرضى الإلكترونية تعتبر شريكًا تجاريًا وعليها الالتزام بمتطلبات HIPAA الأمنية. وتجدر الإشارة إلى أن HIPAA هو قانون وطني أميركي، مما يعني أن الالتزام به **إلزامي ضمن الولايات المتحدة** لكل من يندرج تحت تعريف الجهات المشمولة أو شركائها الذين يتعاملون مع معلومات المرضى. وفي حال انتهاك متطلبات القانون، تواجه المؤسسة **عقوبات صارمة** تشمل غرامات مالية كبيرة بل وحتى مسؤولية جنائية في بعض الحالات، وذلك لضمان الجدية في تطبيق معايير الأمن والخصوصية المنصوص عليها.

الجوانب التي يغطيها: يغطي HIPAA عدة جوانب رئيسية لضمان أمن المعلومات الصحية، ويمكن تلخيصها في ثلاثة محاور ضمن "قاعدة الأمان": **الضمانات الإدارية، والضمانات المادية، والضمانات التقنية**. تشمل *الضمانات الإدارية* وضع سياسات وإجراءات داخلية تصف بالتفصيل كيفية امتثال المؤسسة لمتطلبات حماية

المعلومات الصحية. على سبيل المثال: إجراء **تقييم دوري للمخاطر** يحدد مواطن الضعف المحتملة في أنظمة المعلومات الصحية، ووضع خطة لمعالجة تلك المخاطر؛ وتعيين مسؤول أمن معلومات يتابع الامتثال ويحدث السياسات حسب الحاجة؛ وكذلك تدريب الموظفين بانتظام على ممارسات الخصوصية والأمن. أما *الضمانات المادية* فتتعلق بحماية البنية التحتية المادية التي تحتوي معلومات صحية. يتضمن ذلك تأمين المرافق مثل غرف الخوادم أو أرشيف السجلات الطبية ضد الوصول غير المصرح به، عبر أدوات كأقفال إلكترونية أو بطاقات دخول، والتحكم في استخدام الأجهزة المحمولة التي قد تحتوي بيانات مرضى (مثل وجوب تشفيرها وقفلها). أخيرًا تأتي *الضمانات التقنية* والتي تشمل الوسائل التقنية لحماية البيانات الصحية المحمية إلكترونيًا (ePHI). من أمثلة ذلك: **التحكم في الوصول الإلكتروني** بحيث يُمنح كل مستخدم حساب خاص مع صلاحيات محددة وفق دوره وعدم السماح بمشاركة الحسابات؛ واستخدام **التشفير** لحماية بيانات المرضى المخزنة في قواعد البيانات أو المرسلة عبر الشبكات (خاصة عند نقلها عبر الإنترنت) لضمان أنه حتى لو تم اعتراض البيانات لا يمكن قراءتها؛ إضافة إلى تطبيق آليات **التدقيق والتتبع** بحيث يجري تسجيل عمليات الوصول إلى سجلات المرضى إلكترونيًا ويمكن مراجعتها لاكتشاف أي تجاوزات. إلى جانب هذه الضمانات، يشمل HIPAA أيضًا *قاعدة إخطار الاختراقات* (Breach Notification Rule) التي تلزم الجهات بإبلاغ المرضى والجهات الحكومية بحالات اختراق بيانات كبيرة فور حدوثها، وكذلك *قاعدة الإنفاذ* التي تحدد آليات التحقيق والغرامات. بهذه المجموعة المتكاملة من الضوابط، يغطي HIPAA معظم النواحي لضمان سرية المعلومات الصحية وحمايتها من العبث أو التسريب، مع الحفاظ على توفرها للعاملين في الرعاية الصحية عند الحاجة.

أمثلة أو تطبيقات عملية: في قطاع الرعاية الصحية العملي، نجد تطبيقات واضحة لمتطلبات HIPAA. فمثلاً، مستشفى كبير يحتفظ بسجلات طبية إلكترونية للمرضى سيقوم بتنفيذ عدة إجراءات امتثالاً للقانون: سيستخدم نظام إدارة سجلات طبية يفرض تسجيل دخول فردي لكل طبيب أو ممرض مع **تحديد صلاحيات** دقيقة بحيث لا يرى كل موظف إلا ما يحتاجه لأداء عمله. كما سيضمن المستشفى أن أجهزة

الحاسوب في غرف الفحص **تُقفل تلقائيًا** بعد فترة قصيرة من عدم الاستخدام حتى لا يتمكن شخص غير مصرح له من الاطلاع على سجل مريض ترك مفتوحًا على الشاشة. أيضًا سيستخدم المستشفى تقنيات **تشفير** لقاعدة بيانات المرضى ولجميع الحواسيب المحمولة أو الأجهزة اللوحية التي يستخدمها الأطباء للمشاركة في رعاية المرضى، بحيث لو فُقد جهاز أو حدث اختراق فلن يستطيع المعتدي قراءة المعلومات الحساسة. وعلى الصعيد الإداري، يضع المستشفى **سياسة مكتوبة** توضح إجراءات التعامل مع معلومات المرضى، مثل كيفية مشاركة نتائج التحاليل مع طبيب خارجي بأمان، ومتى يسمح بإرسال معلومات عبر البريد الإلكتروني (عادة بشكل مشفر أو عبر بوابات آمنة فقط). كما يجري المستشفى **تدريبًا سنويًا** لجميع موظفيه لتذكيرهم بقواعد الخصوصية (مثل عدم التحدث عن حالات مرضى محددين خارج إطار العمل، وعدم فتح سجل مريض إلا لغرض يتعلق برعايته). وإذا حدث وتعرّض المستشفى لحادثة تسريب بيانات - كأن يتم اختراق نظامه الإلكتروني - فلديه خطة للاستجابة تشمل إبلاغ المرضى المتأثرين والجهات التنظيمية خلال المهلة المحددة، والتحقيق في سبب الاختراق لسد أي ثغرة أمنية. من خلال هذه الخطوات، يسعى المستشفى للوفاء بمتطلبات HIPAA، مما يحمي خصوصية مرضاه ويجنّبه العقوبات، والأهم أنه يعزز ثقة الجمهور بأن بياناتهم الصحية في أيدٍ أمينة.

إطار COBIT لحوكمة تقنية المعلومات

تعريف المعيار والغرض منه: إطار COBIT هو اختصار لـ *Control Objectives for Information and Related Technologies*، وهو إطار عالمي وضعته منظمة ISACA (جمعية تدقيق ومراقبة نظم المعلومات) لمساعدة المؤسسات على **حوكمة وإدارة تقنية المعلومات** بشكل فعّال ومتوافق مع أهداف العمل. يركز COBIT على إنشاء جسر بين المتطلبات التجارية للمؤسسة وبين خدمات تقنية المعلومات بما يشمل الأمن السيبراني وإدارة المخاطر. الغرض من COBIT هو ضمان أن **تقنية المعلومات تدعم أهداف العمل وتساهم في تحقيق القيمة للمؤسسة**، وفي نفس الوقت يتم

التحكم في مخاطر تقنية المعلومات (بما فيها مخاطر الأمن) عبر مجموعة من الضوابط والإجراءات المنظمة. بعبارة أخرى، يوفّر COBIT إطار عمل شامل يحدد *أفضل الممارسات* لإدارة كل جوانب أنظمة المعلومات داخل المنظمة، ابتداءً من التخطيط الإستراتيجي لتقنية المعلومات، مرورًا بتطوير الأنظمة وتشغيلها، ووصولاً إلى مراقبة الأداء وضمان استمرار التحسين. ونتيجة لذلك، تساعد معايير COBIT المؤسسات على تحقيق **التوازن بين تحقيق المنافع من التقنية وبين حماية الأصول المعلوماتية وتقليل المخاطر المرتبطة بها**.

نطاق التطبيق: يُعد إطار COBIT مناسبًا لأي منظمة تستخدم تقنية المعلومات في عملياتها وترغب في تعزيز حوكمتها. استخدمته العديد من **المؤسسات الكبيرة والشركات العالمية** كإطار مرجعي لضبط عمليات قسم تقنية المعلومات وضمان تلبيتها لمتطلبات العمل والتشريعات. كما أنه مفيد للمؤسسات المتوسطة والصغيرة التي تسعى لوضع هيكل حوكمة منظم لنظم المعلومات. غالبًا ما يُستخدم COBIT في البيئات الخاضعة للتدقيق والامتثال، مثل **القطاع المالي والمصرفي**، حيث تحتاج الشركات للالتزام بضوابط رقابية صارمة على أنظمة البيانات والماليات. أيضًا تعتمد شركات الاستشارات والتدقيق على COBIT كمعيار لتقييم **نضج حوكمة تقنية المعلومات** لدى عملائها. الإطار نفسه ليس إلزاميًا قانونيًا، لكنه اختياري وتتبناه المؤسسات طوعًا لتحسين الإدارة وضبط الجودة في مجال تقنية المعلومات. وقد تصدر إصدارات محدثة منه (مثل COBIT 2019 الأحدث حاليًا) لمواكبة تطور التقنية والمخاطر الجديدة، مما يجعل نطاق تطبيقه متجددًا ويتسع ليشمل مواضيع حديثة كالحوسبة السحابية وحوكمة أمن المعلومات بشكل أعمق.

الجوانب التي يغطيها: يغطي COBIT **عدداً واسعاً من عمليات وعمليات تقنية المعلومات**، مقسمة تقليديًا إلى مجالات رئيسية مثل: **التخطيط والتنظيم** (وضع استراتيجيات التقنية وملائمة هيكلية الإدارة)، **الاكتساب والتنفيذ** (تطوير أو شراء الأنظمة التقنية وتنفيذ المشاريع)، **التسليم والدعم** (تشغيل البنية التحتية التقنية ودعم المستخدمين وإدارة الأمن)، وأخيرًا **المراقبة والتقييم** (قياس أداء تقنية

المعلومات وضمان الامتثال والمتابعة المستمرة). ضمن هذه المجالات، يعرّف COBIT **أهداف تحكم** محددة (Control Objectives) ينبغي تحقيقها لضمان كفاءة وفعالية العمليات. فعلى سبيل المثال، في جانب **الأمن السيبراني**، يتضمن الإطار أهدافًا مثل: وجود **عملية لإدارة المخاطر الأمنية** تحدد وتقيس التهديدات ونقاط الضعف وتضع خططًا لمعالجتها؛ ووجود **سياسات أمن معلومات واضحة** يتم تحديثها دورياً وتطبيقها عملياً؛ وضمان **تكامل البيانات** في الأنظمة الهامة بحيث تكون مصونة من التلاعب غير المصرح به. كما يشمل COBIT ضوابط للتعافي من الكوارث واستمرارية الأعمال تضمن استعادة نظم المعلومات بعد أي انقطاع، وضوابط لإدارة التغيير في الأنظمة التقنية بشكل لا يؤثر سلبًا على الاستقرار والأمان. باختصار، COBIT إطار **إداري ورقابي شامل** يغطي التنظيم الهيكلي والعمليات اليومية والتدقيق والتقييم الدوري لكل ما يتعلق بتكنولوجيا المعلومات في المؤسسة، مع دمج مبدأ الأمن عبر جميع تلك المكونات كجزء أساسي من الحوكمة الرشيدة.

أمثلة أو تطبيقات عملية: تعتمد العديد من المؤسسات الكبيرة COBIT كدليل لضبط حوكمة تقنية المعلومات. فمثلاً، شركة خدمات مالية ترغب في ضمان أن أنظمة بيانات العملاء لديها تخضع لرقابة جيدة وستتوافق مع المتطلبات التنظيمية. ستبدأ الشركة بتطبيق COBIT عبر تقييم الوضع الحالي لحوكمة تقنية المعلومات: هل توجد **رؤية استراتيجية** واضحة لدور التقنية في دعم أهداف الشركة؟ هل توجد **سياسات وإجراءات مكتوبة** لإدارة أمن المعلومات وإدارة التغيير وإدارة المشاريع التقنية؟ بعد هذا التقييم، قد تكتشف الشركة نقصًا في بعض الجوانب، فمثلاً ربما لا توجد **عملية رسمية لتقييم مخاطر تقنية المعلومات** بشكل دوري. بناءً على توصيات COBIT، ستنشئ الشركة لجنة أو فريق لإدارة مخاطر التقنية يقوم بتحديد وتقييم المخاطر (مثل مخاطر الانقطاع أو الاختراق أو فشل نظام مالي) ووضع خطط Mitigation لها. كذلك، إذا وجدت أن **التوثيق** ضعيف، ستعمل على تدوين إجراءات تشغيل الأنظمة ودعم المستخدمين لضمان المعرفة المؤسسية وعدم الاعتماد على أفراد محددين فقط. ضمن مجال الأمن، سيحرص مسؤولو تقنية المعلومات على

أن سياسات الوصول للأنظمة المالية صارمة وفق مبدأ **الفصل بين المهام** (Separation of Duties) منعًا لتلاعب أحد الموظفين بالبيانات دون رقابة. كما ستنفذ الشركة ممارسات **النسخ الاحتياطي المنتظم** واختبار خطط التعافي من الكوارث للتأكد من قدرتها على استعادة الخوادم والبيانات في حال حصول مشكلة كبيرة. وباستخدام مؤشرات أداء ومراجعات منتظمة (كما يدعو COBIT في قسم المراقبة والتقييم)، تستطيع الإدارة العليا قياس مدى تحسن الوضع وضمان الالتزام المستمر. وبهذا الأسلوب، يصبح COBIT أداة فعالة لرفع مستوى **نضج حوكمة تقنية المعلومات** في الشركة، مما ينعكس إيجابًا على أمن المعلومات وجودة الخدمات التقنية المقدمة.

معيار SOC 2 لضوابط الخدمة

تعريف المعيار والغرض منه: SOC 2 هي اختصار لعبارة *Service Organization Control 2*، وهو ليس معيارًا تقنيًا بقدر ما هو **تقرير تدقيق** يصدر عن مدقق مستقل بهدف تقييم الضوابط الداخلية المتعلقة بالأمن والخصوصية لدى منظمات تقديم الخدمات التقنية. تم تطوير إطار SOC 2 بواسطة الجمعية الأمريكية للمحاسبين القانونيين المعتمدين (AICPA) ليكون وسيلة *إثبات* تُمكّن مقدمي الخدمات (خصوصًا في مجالات التقنية والحوسبة السحابية) من طمأنة عملائهم بأن لديهم الضوابط المناسبة لحماية بيانات العملاء. يركز SOC 2 على مجموعة من **مبادئ خدمة الثقة** (Trust Services Criteria) وهي: *الأمن*، *والتوافر*، *وسلامة المعالجة*، *والسرية*، *والخصوصية*. الغرض الرئيسي من SOC 2 هو **تقييم مدى التزام المنظمة بتطبيق ضوابط فعالة** في هذه المجالات الخمسة المتعلقة بأمان الخدمات، ومن ثم إصدار تقرير رسمي يمكن مشاركته مع العملاء المحتملين أو الجهات الطالبة للتدقيق. هذا التقرير يعتبر **شهادة ثقة** تؤكد أن المؤسسة تتبع ممارسات رصينة في حماية البيانات، مما يساعد على بناء الثقة في الخدمات السحابية أو التقنية التي تقدمها.

نطاق التطبيق: عادةً ما يكون SOC 2 موجهًا إلى **مؤسسات تقديم الخدمات التقنية**، خاصة تلك التي تحتفظ أو تعالج بيانات تخص عملاء آخرين. من أمثلة ذلك: شركات الحوسبة السحابية (مثل مزودي استضافة البيانات أو خدمات التخزين السحابي)، وشركات البرمجيات كخدمة (SaaS) التي تعتمد عليها المؤسسات لإدارة بياناتها (كخدمات إدارة علاقات العملاء أو الأنظمة المحاسبية السحابية)، ومراكز البيانات التي تستضيف خوادم لشركات أخرى. أي شركة يكون عملاؤها بحاجة للتأكد من ضوابطها الأمنية قد تسعى للحصول على تقرير SOC 2. الالتزام بـ SOC 2 **طوعي وليس إجباريًا** بموجب قانون، لكنه أصبح شبه متوقع في قطاع الخدمات السحابية والتقنية. فكثيرًا ما يطلب عملاء الشركات التقنية (خصوصًا العملاء من المؤسسات الكبيرة والقطاعات الحساسة) الاطلاع على تقرير تدقيق أمني قبل توقيع عقد الخدمة. لذا، أصبح الحصول على **تقرير SOC 2** نوعًا من *الميزة التنافسية* وضروريًا لكسب ثقة السوق، مما دفع العديد من الشركات الناشئة والتقليدية في مجال التقنية إلى الخضوع للتدقيق وفق هذا المعيار. التقارير تصدر بنوعين: **النوع الأول** (Type I) ويعني تدقيق تصميم الضوابط في نقطة زمنية محددة، و**النوع الثاني** (Type II) الذي يقيم فعالية تشغيل الضوابط على مدى فترة زمنية (عادة 6-12 شهر). النوع الثاني أكثر شمولاً ومصداقية لأنه يثبت أن الضوابط الأمنية تعمل باستمرار وليس مجرد وجودها نظريًا.

الجوانب التي يغطيها: يركز SOC 2 على الضوابط المتعلقة بمبادئ خدمة الثقة الخمسة المذكورة، وفي مقدمتها **الأمن** باعتباره العنصر المشترك الواجب توفره في كل تقرير SOC 2. تشمل ضوابط الأمن حماية الأنظمة والبيانات من الوصول غير المصرح به، مثل وجود **جدار حماية** فعال، وتطبيق التحكم بالوصول باستخدام آليات تعريف متعددة العوامل (MFA) إن أمكن، ومراقبة الأنظمة لكشف أي نشاط شاذ. بالنسبة لمبدأ **التوافر**، يتم تقييم إجراءات المنظمة لضمان استمرارية توفر الخدمة للعملاء، كتوفر بنية تحتية موثوقة مع خطط نسخ احتياطي واتصالات إنترنت زائدة عن الحاجة (Redundancy) وآليات **استعادة فورية** عند حدوث أعطال، بالإضافة إلى

اتفاقيات مستوى الخدمة (SLAs) التي تلتزم بها الشركة بشأن وقت التشغيل. مبدأ **سلامة المعالجة** يتحقق من أن نظم الشركة تعالج البيانات **بدقة وموثوقية** ووفق الهدف المحدد دون أخطاء أو تلاعب، وهذا يشمل ضوابط لمنع حدوث الأخطاء في العمليات (كآليات التحقق المزدوج للعمليات الحرجة) وضمان اكتمال المعالجة. أما **السرية** فيُعنى بها حماية البيانات الحساسة التي يحتفظ بها مزود الخدمة لصالح العملاء، ويشمل ذلك سياسات لتصنيف البيانات وتقييد الوصول للبيانات شديدة الحساسية، بالإضافة لتطبيق **التشفير** على البيانات المخزنة والمنقولة لضمان عدم كشفها حتى لو تم اعتراضها. أخيرًا **الخصوصية** يركّز على كيفية جمع شركة الخدمة للبيانات الشخصية واستخدامها ومشاركتها بما يتوافق مع إقرارات الخصوصية المقدمة للعملاء أو المستخدمين النهائيين. ويتطلب هذا المبدأ وجود **سياسة خصوصية** واضحة، وآليات تمكن الأفراد من طلب الوصول إلى بياناتهم أو حذفها، وضمان عدم استخدام البيانات إلا للأغراض المعلنة. خلاصة القول، يغطي SOC 2 **مزيجًا من الضوابط الإدارية والفنية** في مجالات الأمن والتشغيل وإدارة البيانات، للتأكد من أن مزود الخدمة يعمل بطريقة تحمي مصالح العملاء وبياناتهم في جميع الأوقات.

أمثلة أو تطبيقات عملية: شركة ناشئة تقدم نظامًا لإدارة الموارد البشرية بنموذج البرمجيات كخدمة (SaaS) قررت الحصول على تقرير SOC 2 لطمأنة عملائها (الذين قد يكونون شركات أخرى كبيرة). بدأت الشركة بتطبيق إجراءات داخلية استعدادًا للتدقيق: قامت بوضع **سياسات أمن معلومات داخلية** إذا لم تكن موجودة، مثل سياسة لاستخدام كلمات مرور قوية تُغير دوريًا، وسياسة لإدارة الحوادث الأمنية. ثم تأكدت من أن لديها ضوابط تقنية مثل **تشفير البيانات الحساسة** المخزنة في قواعد بياناتها (مثلاً تشفير بيانات رواتب الموظفين المرفوعة من قبل العملاء)، وأن الاتصال بين مستخدمي الخدمة وخوادمها يتم عبر بروتوكولات آمنة (HTTPS/TLS). لضمان *التوافر*، أنشأت الشركة بيئة استضافة سحابية مع خوادم احتياطية يمكنها تحمل تعطل أي مكوّن دون توقف الخدمة بالكامل، ووضعت نظام مراقبة يبلغ المهندسين فور

حصول أي انقطاع أو انخفاض في الأداء. فيما يتعلق *بسلامة المعالجة*، أضافت الشركة اختبارات آلية للتأكد من صحة أية بيانات يتم إدخالها أو تحديثها عبر النظام وتقارير لمراجعة العمليات المالية المهمة. بالنسبة *للسرية*، حدّدت الشركة أن فقط موظفي الدعم المصرح لهم يمكنهم الوصول إلى بيانات عملاء محددين عند الضرورة (مثلاً عند حل مشكلة ما)، وكل وصول منهم يتسجل للمراجعة، وبقية الموظفين ليس لديهم صلاحية الاطلاع على بيانات العملاء. وأعدّت الشركة صفحة لسياسة الخصوصية تشرح بالضبط ما تفعله ببيانات المستخدمين وكيف يمكن لمنظمة عميلة طلب حذف بياناتها إن أنهت الخدمة. بعد تطبيق هذه الضوابط لعدة أشهر، استعانت الشركة بمدقق مستقل أجرى مراجعة شاملة على مدى ستة أشهر (تدقيق من النوع الثاني) للتحقق من فعالية واستمرار هذه الضوابط. بنهاية التدقيق، حصلت الشركة على **تقرير SOC 2 Type II** إيجابي، تستطيع الآن مشاركته مع العملاء المحتملين. هذا التقرير أصبح أداة تسويقية أيضًا، فعند تفاوضها مع شركة كبرى لاستخدام منصتها، يكفي أن تبرز التزامها بمعايير SOC 2 ليشعر العميل بالثقة بأن بيانات موظفيه ستكون محمية وفق أرقى المعايير.

ضوابط CIS للأمن السيبراني

تعريف المعيار والغرض منه: ضوابط CIS هي قائمة من **الضوابط الأمنية السيبرانية الحرجة** (Critical Security Controls) التي طورها مركز أمن الإنترنت (Center for Internet Security - CIS)، وهي منظمة غير ربحية عالمية متخصصة في تعزيز أمن الفضاء السيبراني. تشتهر هذه الضوابط أيضًا باسم *CIS Critical Controls* وقد تطورت عبر الزمن (حاليًا الإصدار الثامن يضم 18 ضبطًا أساسيًا). الغرض من ضوابط CIS هو تقديم **دليل مُبسّط وعملي** لأهم الإجراءات الدفاعية التي ينبغي للمؤسسات اتخاذها لوقف أكثر الهجمات الإلكترونية شيوعًا. بعبارة أخرى، يمثل CIS قائمة **أولويات** في مجال الأمن؛ حيث يركّز على الإجراءات الأكثر تأثيرًا في **تقليل سطح الهجوم** والثغرات التي يستغلها القراصنة غالبًا، مما يساعد حتى المؤسسات ذات

الموارد المحدودة على البدء بخطوات فعالة تحقق أعلى قدر من الحماية السريعة. إن هذه الضوابط مستمدة من دراسات واقعية لأنماط الهجمات المتكررة، وبالتالي فهي تعالج المخاطر الأساسية بطريقة مباشرة وتوفر **خط دفاع أساسي** لأي منظمة.

نطاق التطبيق: إن جمال ضوابط CIS يكمن في أنها **ملائمة لأي منظمة** بغض النظر عن حجمها أو مجالها، فهي ليست مصممة لصناعة معينة أو مفروضة بقوة القانون، وإنما هي توصيات عامة مبنية على خبرات واسعة في مجتمع الأمن السيبراني. تناسب هذه الضوابط خصوصًا المؤسسات التي قد لا تملك نضجًا أمنياً كاملاً أو فرقًا متخصصة كبيرة، إذ تعطيهم خارطة طريق واضحة بأهم الخطوات الأولى. على سبيل المثال، كثير من الشركات الصغيرة والمتوسطة تتبنى ضوابط CIS كخارطة طريق لتحسين أمنها لأنها توفر نقطة انطلاق منهجية. كذلك تستخدمها أحيانًا جهات حكومية أو تعليمية كمعيار للتأكد من توفر الحدود الدنيا من ممارسات الأمن الجيد. بعض القطاعات الحساسة قد تستعين بضوابط CIS **إلى جانب معايير أخرى** لتعزيز دفاعاتها؛ فمثلاً قد يتبنى أحد البنوك متطلبات PCI DSS لكنه يستخدم أيضًا ضوابط CIS لضمان أنه لم يغفل أساسيات الأمن العام خارج نطاق حماية بيانات البطاقات فقط. وبما أن CIS Controls يتم تحديثها دورياً لمواكبة تطور التهديدات (مثل التحديث من الإصدار 7 إلى 8 لإضافة ضوابط حول أمن السحابة والعمل عن بعد)، فإن نطاق تطبيقها يظل حديثًا ومرنًا بحيث يمكن تخصيصها أيضًا حسب بيئة العمل (مثل توفر أدلة خاصة لتطبيق الضوابط في البيئات السحابية).

الجوانب التي يغطيها: تغطي ضوابط CIS **مجموعة واسعة من المجالات الأمنية التقنية والتنظيمية**، مرتبة بشكل هرمي من الأساسي إلى المتقدم. على رأس القائمة تأتي ضوابط **حصر الأصول**: حيث تشدد الضوابط الأولى على ضرورة أن تعرف المؤسسة جميع أجهزتها الموصولة بالشبكة وجميع البرمجيات المستخدمة. هذا يبدو بسيطًا لكنه حيوي؛ فلا يمكنك حماية ما لا تعلم بوجوده. ثم تنتقل الضوابط إلى ضمان **إعدادات آمنة** (Secure Configuration) للأجهزة والأنظمة، إذ غالبًا ما تستغل الهجمات الإعدادات الضعيفة أو الافتراضية. تشمل الضوابط أيضًا **إدارة الثغرات**

بتحديث الأنظمة والتطبيقات بانتظام وسد الثغرات المعروفة قبل أن تُستغل. هناك كذلك تركيز على **التحكم في صلاحيات الوصول**، مثل تطبيق مبدأ **الامتيازات الأقل** لكل مستخدم أو نظام، وإدارة الحسابات الإدارية بحذر. من الضوابط الهامة أيضًا ما يتعلق بـ**المراقبة المستمرة**، فالقائمة تتضمن ضبطًا لجمع سجلات الأحداث وتحليلها لرصد أي نشاط غير معتاد، وكذلك إجراء اختبارات دورية للاختراق وتقييم درجة المناعة. ولا تهمل ضوابط CIS الجانب البشري، حيث تتضمن أحد الضوابط الهامة **توعية وتدريب المستخدمين** على الأمن السيبراني لأن المستخدم غير المدرب قد يكون نقطة ضعف مهما كانت التقنيات قوية. أخيرًا تغطي الضوابط أيضًا جوانب الاستجابة للحوادث ووضع خطط لها كي تعرف المؤسسة كيف تتصرف عند وقوع اختراق أو مشكلة أمنية. تجدر الإشارة إلى أن الإصدار الحالي من الضوابط (الإصدار 8) يعيد ترتيب هذه المتطلبات إلى مجموعات أكثر تركيزًا، لكنه عموماً يغطي نفس المفاهيم: توفير **أساسيات الحماية** أولاً ثم التوسع نحو الضوابط الأكثر تقدمًا. هذه التغطية تجعل CIS أشبه بـ **منهجية تدريجية** ترفع مستوى الأمن خطوة بخطوة، حيث لا تنتقل المؤسسة للضوابط المعقدة إلا بعد تطبيق الأساسيات.

أمثلة أو تطبيقات عملية: شركة صغيرة في مجال التجارة الإلكترونية قررت اتباع ضوابط CIS لحماية نشاطها الرقمي. بدأت الشركة بتنفيذ الضوابط الأولى فحصرت جميع الحواسيب والخوادم التي تملكها وكل برامج وأنظمة التشغيل المثبتة عليها، وأنشأت قائمة مركزية لتلك الموجودات يتم تحديثها كلما أُضيف جهاز جديد أو برنامج جديد. بعد ذلك قامت بتطبيق **إعدادات معيارية آمنة**: استعانت بأدلة CIS المرافقة التي تعطي إعدادات مقترحة لأنظمة التشغيل الشهيرة وقامت بضبط إعدادات خوادمها وقواعد بياناتها وفق تلك التوصيات (مثلاً تعطيل الخدمات غير الضرورية، وتفعيل خيارات الحماية المدمجة في النظام). مضت الشركة قدمًا لتنفيذ **تحديثات دورية** للبرامج، فعيّنت مسؤولاً يتولى مراقبة نشرات الثغرات الجديدة والتأكد من تطبيق التحديثات الأمنية المهمة في أسرع وقت على مواقعها الإلكترونية وأنظمة إدارة المحتوى التي تستخدمها. أيضًا، أعادت الشركة **هيكلة نظام الحسابات**

والصلاحيات؛ فألغت الحسابات القديمة غير المستخدمة، وطبّقت استخدام حسابات شخصية لكل موظف بدلًا من حسابات مشتركة، وجعلت وصول المدراء لأنظمة حساسة يمر عبر موافقات متعددة. ومن الناحية التنظيمية، حرصت على تدريب فريقها الصغير على أساليب التصيّد الإلكتروني الشائعة وكيفية التعرف على الرسائل المشبوهة، وذلك ضمن التزامها بضابط التوعية الأمنية. وأخيرًا، وضعت الشركة خطة بسيطة **للاستجابة لحوادث الأمن** تحدد من سيتولى ماذا إذا ما وقع اختراق، وكيف يتم عزل الأنظمة المتأثرة وإبلاغ الإدارة والعملاء عند الضرورة. خلال أشهر قليلة، كانت هذه المؤسسة الصغيرة قد طبّقت معظم الضوابط الـ 18 الأساسية ورفعت بذلك مناعتها أمام التهديدات الشائعة مثل هجمات البرامج الخبيثة أو محاولات سرقة الحسابات. وفعلاً، حين حاول أحد المهاجمين اختراق خادم الويب مستغلاً ثغرة معروفة، وجد أن النظام قد تم تحديثه مسبقًا ولم تعد الثغرة موجودة، مما جنّب الشركة ضررًا محتملاً. هذا المثال يبيّن كيف تساعد **ضوابط CIS** حتى الفرق الصغيرة قليلة الخبرة على اتباع نهج واضح يحصنها ضد الأخطار الأكثر احتمالاً.

قانون FISMA (أمن المعلومات الفيدرالي)

تعريف المعيار والغرض منه: قانون إدارة أمن المعلومات الفيدرالي لعام 2002، المعروف اختصارًا بـ **FISMA**، هو قانون اتحادي أمريكي أقرّه الكونغرس بهدف تعزيز حماية الأنظمة والمعلومات الحكومية من التهديدات السيبرانية. يقر FISMA بأن **أمن المعلومات جزء لا يتجزأ من الأمن القومي والمصالح الاقتصادية** للولايات المتحدة، لذا فهو يفرض على الوكالات الفيدرالية **إنشاء وتنفيذ برنامج شامل لأمن المعلومات** يغطي جميع أنظمة المعلومات ضمن نطاق عملها. في عام 2014 تم تحديث القانون عبر "قانون تحديث أمن المعلومات الفيدرالي" (Federal Information Security Modernization Act) لتحديث بعض المتطلبات وتعزيز الأدوار. الغرض الرئيسي من FISMA هو **رفع مستوى الانتباه والالتزام بالأمن السيبراني داخل الهيئات الفيدرالية**، وذلك من خلال آليات منظمة مثل إلزام كل وكالة حكومية بوضع

خطة أمنية، واعتماد **نهج إدارة مخاطر** لتخصيص موارد الحماية بشكل فعال حسب حساسية المعلومات، وإجراء **مراجعات سنوية** للتأكد من فاعلية الضوابط الأمنية المطبقة. كما يهدف القانون إلى خلق **مساءلة دورية**، حيث تُرفع تقارير سنوية من الوكالات إلى مكتب الإدارة والميزانية (OMB) ثم إلى الكونغرس حول حالة الأمن السيبراني والامتثال، لضمان الشفافية والتحسين المستمر.

نطاق التطبيق: يغطي FISMA جميع **الوكالات الفيدرالية للولايات المتحدة** بلا استثناء، بما فيها الوزارات والهيئات المستقلة. وبالتبعية، يمتد تأثيره أيضًا إلى **المتعاقدين مع الجهات الحكومية** وأي جهات أخرى قد تتولى معالجة أو تخزين معلومات نيابةً عن وكالة فيدرالية. فعلى سبيل المثال، إذا تعاقدت وزارة ما مع شركة تقنية خاصة لإدارة أنظمتها أو بياناتها، يتعين على تلك الشركة الالتزام بمعايير الأمن الفيدرالية المنبثقة من FISMA، وغالبًا ما يكون ذلك منصوصًا عليه في عقدها مع الحكومة. وبالإضافة إلى ذلك، بعض الولايات الأمريكية التي تتعامل مع بيانات فدرالية أو برامج ممولة اتحاديًا تتبنى متطلبات FISMA لضمان الاتساق. من المهم ملاحظة أن FISMA يمثل **مظلة تشريعية**، أما التفاصيل الفنية لكيفية الامتثال فيتم تحديدها عبر إطار عمل أكثر تفصيلاً طوره المعهد الوطني للمعايير والتكنولوجيا (NIST) استجابة لمتطلبات FISMA. لذا نرى أن نطاق التطبيق يشمل فعليًا كل من يخضع للسلطات الفيدرالية أو يعمل معها في مجال نظم المعلومات. عدم الامتثال لـ FISMA قد يؤدي إلى عواقب مثل خفض التمويل المخصص لوكالة ما أو اتخاذ إجراءات رقابية، وبالتالي فهو قانون له **ثقل إداري وتنظيمي كبير** يدفع الجميع للالتزام.

الجوانب التي يغطيها: يغطي FISMA وعبر إرشادات NIST المرافقة مجموعة متكاملة من الأنشطة والضوابط لضمان أمن أنظمة المعلومات الحكومية. يتضمن ذلك **حصر وتصنيف أنظمة المعلومات والأصول** وفق مستوى حساسيتها أو تأثير الخطر عليها (على سبيل المثال: نظام يحتوي أسرارًا دفاعية يصنف عالي الخطورة، فيما قد يصنف نظام موقع معلومات عام منخفض الخطورة). بناءً على التصنيف، تطبق الوكالة مجموعة مناسبة من **ضوابط الأمن** مأخوذة من كتالوج معياري هو منشور

NIST الخاص 800-53، الذي يضم عشرات الضوابط في مجالات مثل التحكم بالوصول، والتشفير، والمراقبة المستمرة، وإدارة الهوية، وأمن الشبكات، وغيرها. قبل تشغيل أي نظام معلومات جديد، يتطلب FISMA إجراء **تقييم للمخاطر** ووضع خطة أمن للنظام (System Security Plan) توضح كيف سيتم تطبيق الضوابط، ثم الحصول على **تفويض وتشغيل** (Authorization) رسمي للنظام من مسؤول مخول، بعد التأكد عبر اختبار وتقييم أن الضوابط الأمنية كافية. كما يشدد FISMA على **المراقبة المستمرة**، أي أن الأمن ليس فحصًا لمرة واحدة، بل يجب على الوكالات مراقبة أنظمتها بشكل مستمر عبر أدوات فحص الثغرات وإدارة الأحداث وتحديث الضوابط مع تغير التهديدات. وتشمل متطلبات القانون أيضًا وجود **خطط لاستمرارية الأعمال والتعافي من الكوارث** تخص كل نظام حيوي، بحيث تضمن الوكالة استمرار الخدمات الحكومية حتى أثناء وقوع حوادث جسيمة. وإضافةً إلى ما سبق، يفرض FISMA أدوارًا تنظيمية داخل كل وكالة، مثل تعيين **كبير مسؤولي أمن معلومات (CISO)** يكون مسؤولاً أمام رئيس الوكالة عن تنفيذ البرنامج الأمني، وكذلك إشراك المفتشين العامين في التدقيق المستقل على فعالية برامج الأمن. ومن الجوانب المهمة أيضًا **التوعية والتدريب**، إذ يجب تدريب موظفي الوكالة والمتعاقدين على أسس أمن المعلومات ودورهم في حماية الأنظمة. بهذا يغطي FISMA كل حلقة من حلقات دورة حياة أمن المعلومات: من التخطيط ووضع السياسات، إلى تنفيذ الضوابط التقنية، إلى التقييم والتدقيق والتقارير، مما يجعله نموذجًا صارمًا تسترشد به حتى بعض المؤسسات خارج النطاق الحكومي لتحسين أمنها.

أمثلة أو تطبيقات عملية: في الممارسة العملية، يمكن تصور إحدى الوكالات الحكومية - ولنقل هيئة لإدارة الضمان الاجتماعي - وكيف تلتزم بمتطلبات FISMA. تبدأ الوكالة بعملية مسح شاملة لكل أنظمة المعلومات لديها: أنظمة قواعد بيانات المستفيدين، الخوادم، الشبكات الداخلية، تطبيقات الويب المقدمة للجمهور... ثم تقوم **بتصنيف تلك الأنظمة** وفق توجيهات NIST (منخفض، متوسط، عال) على صعيد تأثير اختراق السرية أو السلامة أو التعطيل، مستندة إلى معيار FIPS 199. مثلاً، قاعدة

بيانات تحتفظ بمعلومات شخصية حساسة لملايين المواطنين ستصنف كنظام عالي الحساسية. بناء على ذلك، تطبّق الوكالة **ضوابط أمن متقدمة** على هذا النظام حسب كتالوج 800-53: كاستخدام تشفير قوي للبيانات المخزنة، وتفعيل المصادقة متعددة العوامل لكل من يدخل إلى الخوادم، وتقنين حسابات المسؤولين بصلاحيات عالية، ونشر حلول كشف التسلل على الشبكة المحيطة به، وغيرها من الضوابط المناسبة لمستوى الخطورة العالي. قبل تشغيل النظام أو بعد تحديث رئيسي له، يتم إجراء **اختبار تقييم أمن** (Security Assessment) بواسطة فريق تقييم مستقل للتأكد من أن الضوابط تعمل كما هو مخطط. يرفع المُقيّم تقريرًا لإدارة الوكالة، ويقرر المسؤول المعني ما إذا كان يمنح **تفويض التشغيل (Authority to Operate (ATO** للنظام أو يحتاج تحسينات إضافية. على الصعيد المستمر، تستخدم الوكالة أدوات **مراقبة لوحات التحكم الأمنية** التي تعرض حالة الالتزام آنياً مثل عدد الأنظمة التي تحتاج تحديثات عاجلة، ومحاولات الاختراق التي تم صدّها حديثًا، ومستوى الامتثال عبر مقاييس محددة. ثم تقوم كل سنة بإعداد **تقرير FISMA** يضم نتائج التقييمات وأي حوادث أمنية وقعت وإجراءات التحسين المتخذة، وترسله إلى مكتب الإدارة والميزانية. هذه العملية المنظمة تضمن أنه لدى الوكالة **رؤية شاملة** عن أمنها وتطوراته، وتتيح للجهات العليا (OMB والكونغرس) مراقبة الحالة العامة واتخاذ قرارات داعمة مثل زيادة الموارد إذا لزم الأمر. وبهذا الأسلوب نجح FISMA في خلق ثقافة اهتمام أعلى بالأمن داخل المؤسسات الحكومية حيث باتت تعامله كجزء من الإدارة اليومية وليس مجرد أمر فني ثانوي.

قانون ساربينز-أوكسلي (SOX)

تعريف المعيار والغرض منه: قانون ساربينز-أوكسلي لعام 2002 (ويُعرف اختصارًا بـ SOX) هو تشريع فدرالي أمريكي صدر كرد فعل على سلسلة من فضائح المحاسبة الضخمة مثل شركتي Enron وWorldCom. يهدف القانون إلى **تعزيز مصداقية التقارير المالية وحماية المساهمين** والجمهور من أي تلاعب أو احتيال في البيانات

المالية للشركات العامة. بالرغم من أن SOX ليس معيارًا تقنيًا بحتًا في مجال الأمن السيبراني، إلا أنه يتضمن أحكامًا تجعل **الضوابط الداخلية في أنظمة المعلومات المالية** جزءًا أساسيًا من الامتثال. على سبيل المثال، تنص **المادة 404** الشهيرة من القانون على أن تقوم كل شركة عامة بتقييم فعالية **الضوابط الداخلية** لديها على التقارير المالية سنويًا، كما يجب على مراجعي الحسابات الخارجيين إصدار تقرير حول تلك الفعالية. الهدف من هذه المتطلبات هو التأكد من وجود **نظام محكم من الضوابط** يمنع الأخطاء والغش في عمليات إعداد البيانات المالية. وضمنيًا، تستلزم هذه الضوابط الكثير من **إجراءات أمن المعلومات**، حيث أن السجلات المالية باتت مخزنة ومعالجة إلكترونيًا. بالتالي يمكن اعتبار الهدف من SOX في جانب منه هو **ضمان سلامة وأمن أنظمة المعلومات المالية** حتى تكون المخرجات المالية صحيحة وموثوقة.

نطاق التطبيق: ينطبق قانون ساربينز-أوكسلي على **جميع الشركات المساهمة العامة** المسجلة في البورصات الأمريكية، بما في ذلك الشركات الأجنبية التي تتداول أسهمها في الأسواق المالية الأمريكية. كما يؤثر على شركات المحاسبة والتدقيق التي تقوم بتدقيق تلك الشركات، حيث يضع معايير لاستقلاليتها ومسؤولياتها (مثل إنشاء هيئة الرقابة المحاسبية PCAOB). ورغم أن SOX قانون أمريكي، إلا أن تأثيره صار عالميًا لأن الكثير من الشركات الدولية لديها إدراج في أسواق الولايات المتحدة أو تسعى للتماشي مع أفضل ممارسات الحوكمة المالية. لا يُطلب من الشركات الخاصة أو غير المدرجة الالتزام بـ SOX صراحةً، لكنها قد تختار تحسين ضوابطها الداخلية استنادًا إلى مبادئه طوعًا. أما من حيث الوظائف الداخلية، فإن نطاق الامتثال يمتد ليشمل **الإدارة التنفيذية العليا** (حيث تُلزم المادة 302 المدير التنفيذي والمدير المالي بالتوقيع شخصيًا على دقة التقارير المالية وفعالية الضوابط الداخلية)، وفرق المحاسبة والمالية، بالإضافة إلى **فرق تقنية المعلومات** المسؤولة عن الأنظمة المالية. إذ تقع على عاتق قسم تقنية المعلومات مسؤولية تنفيذ وصيانة كثير من **الضوابط التقنية** المطلوبة لضمان سلامة البيانات (مثل الفصل بين صلاحيات التطوير والتشغيل على

نظام المحاسبة، والتحكم في المستخدمين المسموح لهم بإدخال أو تعديل البيانات المالية). بالتالي يمكن القول إن نطاق SOX يشمل **الجوانب الإدارية والتقنية** للشركة لضمان تكامل الإبلاغ المالي.

الجوانب التي يغطيها: لا يحدد قانون SOX بشكل تفصيلي قائمة الضوابط الواجب اتباعها، بل يركز على النتائج المطلوب تحقيقها (أي الحصول على تقارير مالية موثوقة). لكن المنهجيات الشائعة للامتثال بـ SOX مثل إطار **COSO** للضوابط الداخلية وإطار **COBIT** لتقنية المعلومات تساعد في تحديد الجوانب المطلوبة. في سياق أمن المعلومات، من أبرز الجوانب المغطاة ضمن ضوابط SOX الداخلية: **ضمان سلامة بيانات المالية** (Integrity)، بمعنى منع التلاعب أو التعديل غير المشروع في سجلات المحاسبة. لتحقيق ذلك، تطبق الشركات ضوابط مثل *مبدأ الفصل الوظيفي*: فالموظف الذي يدخل فاتورة إلى النظام ليس هو نفسه الذي يوافق عليها نهائيًا، وذلك لمنع أي فرد من القدرة على إخفاء اختلاس أو تزوير. تقنيًا، يعني هذا إعداد **صلاحيات مستخدمين** دقيقة في نظام ERP أو المحاسبة بحيث تختلف الصلاحيات بين المحاسب والمراجع والمدير، ولا يستطيع شخص واحد القيام بدورة العملية كاملة بمفرده. جانب آخر هو **التتبع والتدقيق**: يجب أن يحتفظ النظام بسجل تدقيق (Audit Trail) يوثق أي تغييرات تتم على البيانات المالية ومن قام بها وفي أي وقت، بحيث يمكن مراجعتها لاحقًا. لذا تقوم أقسام تقنية المعلومات بتهيئة قواعد البيانات والتطبيقات لحفظ هذه السجلات وتأمينها من الحذف، كما توجب إجراء **مراجعات دورية** لها للتأكد من عدم وجود حركات غير اعتيادية. كذلك تغطي ضوابط SOX مسألة **ضمان توفر البيانات المالية** وعدم فقدانها، لذا يتم عمل نسخ احتياطية منتظمة لقواعد البيانات المالية وإجراءات لتعافيها في حال حدوث مشكلة تقنية، لأن ضياع جزء من السجلات قد يعني خرقًا لمتطلبات الإفصاح المالي الدقيق. وهناك تركيز أيضًا على **صحة عمل البرمجيات المالية**: أي ضمان أن البرمجيات التي تعالج البيانات (كأنظمة إعداد التقارير) خالية من الأخطاء التي قد تشوه الأرقام، ويتم ذلك عبر اختبارات قبول وتوثيق لأي تطوير أو تغيير برمجي قبل إدخاله في بيئة الإنتاج. أخيرًا، وبشكل غير مباشر،

يشجع SOX الشركات على **بناء ثقافة رقابة وامتثال** تشمل التدريب والتوعية للموظفين حول أخلاقيات العمل المالي والإبلاغ عن أي ممارسات غير سليمة، وهذا يتكامل مع الجانب الأمني بمنع تواطؤ داخلي أو استغلال غير مدركين للضوابط.

أمثلة أو تطبيقات عملية: في شركة صناعية كبيرة مدرجة في البورصة، يكون لقسم تقنية المعلومات دور أساسي في تلبية متطلبات SOX. على سبيل المثال، يمتلك **نظام إدارة الموارد المؤسسية (ERP)** الخاص بالشركة وحدة للمحاسبة والمخزون. لضمان امتثال هذا النظام لمتطلبات SOX: قام قسم تقنية المعلومات بالتعاون مع قسم المالية بتعريف **صلاحيات المستخدمين** داخل النظام بدقة، فموظف الحسابات الدائنة يستطيع إدخال فواتير الموردين لكنه لا يستطيع إصدار الدفعة، والمدير المالي يستطيع اعتماد الدفعات لكنه لا يستطيع إنشاء أو تعديل بيانات الموردين بدون مراجعة إضافية. هذا يحقق مبدأ الفصل ويمنع الاحتيال. أيضًا، كل عملية في النظام - كإنشاء فاتورة جديدة أو تعديل سجل مورد - يتم تسجيلها مع هوية المستخدم والوقت وتفاصيل التغيير، وهذه السجلات تُخزن في قاعدة بيانات منفصلة **مؤمنة ضد العبث** (ربما مع إمكانيات كشف التغييرات غير المصرح بها). يقوم قسم المراجعة الداخلية كل شهر أو ربع سنة **بتدقيق هذه السجلات** للتأكد من عدم وجود معاملات غير اعتيادية (مثلاً دفعة كبيرة تم تجزئتها بشكل مريب، أو إدخال ثم حذف متكرر لفاتورة). ومن ناحية أخرى، يحرص القسم التقني على **النسخ الاحتياطي اليومي** لقواعد البيانات المالية، وتمت تجربة استعادة النسخ احتياطيًا للتأكد من فعاليته ضمن خطة التعافي من الكوارث. وعند إجراء أي تحديث أو ترقية على نظام الERP، يتم ذلك عبر عملية مضبوطة: يُختبر التحديث في بيئة تجريبية، ثم يوافق فريق مختص على نقله، بحيث لا يستطيع المبرمج منفردًا إجراء تغيير مباشر على النظام المالي بدون توثيق وفحص. بالإضافة إلى ذلك، ربما تستخدم الشركة **نظامًا لكشف الاختراقات** أو تحاليل سلوك المستخدمين لمراقبة أي محاولة دخول غير عادية للحسابات الهامة في النظام المالي كطبقة حماية إضافية ضد التلاعب الخارجي. عبر هذه الجهود، عندما يأتي المدقق الخارجي السنوي، يمكن للشركة أن

تُظهر براهين على أن لديها **بيئة رقابة قوية**: سياسات مكتوبة، وضوابط تقنية فعالة، ومراجعات مستمرة، مما يؤدي في النهاية إلى تقرير إيجابي حول فعالية الضوابط الداخلية وفق متطلبات SOX ويعزز ثقة المستثمرين في البيانات المالية المنشورة.

خاتمة

في الختام، يتضح أن **معايير الأمن السيبراني العالمية** والقوانين التنظيمية المتعلقة بها تشكّل إطارًا ضروريًا لبناء دفاعات رقمية قوية في وجه التهديدات المتنامية. ورغم تنوع تلك المعايير من حيث أهدافها ونطاقاتها - فمنها ما يركز على حماية بيانات مالية أو صحية، ومنها ما يضع أسسًا لإدارة أمن المعلومات بشكل منهجي - إلا أنها جميعًا تشترك في هدف جوهري واحد هو **رفع مستوى الأمان والثقة في البيئة الرقمية**. إن التزام المؤسسات بتطبيق هذه المعايير لا يحمي بياناتها فحسب، بل يرسّخ أيضًا ثقافة ووعيًا أمنيًا لدى العاملين والإدارة، مما يساهم في الحدّ من الحوادث وتقليل خسائرها. ومع استمرار تطور التقنيات والتهديدات، تظل هذه المعايير في تحديث مستمر لتلبية المتطلبات الجديدة، الأمر الذي يحتم على المؤسسات مواكبتها وتبنّي مبدأ **التحسين المستمر للأمن السيبراني**. باعتماد المعايير المناسبة لطبيعة كل منظمة والالتزام بها، يمكن للشركات والجهات الحكومية تحقيق توازن فعّال بين الاستفادة القصوى من التطور الرقمي وبين حماية الأصول المعلوماتية وصون خصوصية الأفراد، وهو ما يعود بالنفع على الجميع ويضمن ازدهاراً رقمياً آمناً ومستداماً.

شهادات الأمن السيبراني: دليل شامل حسب المستوى

مقدمة تمهيدية حول أهمية الشهادات في الأمن السيبراني

في العصر الرقمي الحالي تتزايد الحاجة إلى محترفي **الأمن السيبراني** لحماية البيانات والأنظمة من الهجمات المتطورة. تعد **شهادات الأمن السيبراني** دليلًا رسميًا على امتلاك حاملها للمعرفة والمهارات المطلوبة في هذا المجال، مما يعزز المصداقية والاعتراف المهني لدى أصحاب العمل والعملاء. الحصول على الشهادة المناسبة قد يفتح لصاحبها أبواب وظائف أوسع وفرصًا وظيفية برواتب أعلى، نظرًا للطلب الكبير على الخبرات المؤهلة. علاوة على ذلك، فإن التحضير لنيل هذه الشهادات يساهم في تطوير المهارات التقنية باستمرار ومواكبة أحدث التوجهات والتهديدات في مجال الأمن السيبراني. العديد من المؤسسات - وخاصةً الهيئات الحكومية والشركات الكبرى - تشترط أو تُفضِّل وجود موظفين يحملون شهادات معتمدة لضمان الالتزام بالمعايير الأمنية وحماية الأصول الرقمية.

توجد مجموعة متنوعة من الشهادات الاحترافية في الأمن السيبراني تلائم مستويات خبرة مختلفة. فبعضها مخصص **للمبتدئين** الذين يخطون خطواتهم الأولى في المجال، وأخرى **لذوي المستوى المتوسط** ممن يمتلكون أساسيات قوية ويرغبون في التخصص أكثر، بالإضافة إلى شهادات **للمحترفين والمتقدمين** من ذوي الخبرة العميقة. فيما يلي تصنيف لأهم الشهادات في المجال حسب المستوى، مع شرح مفصل لكل شهادة يشمل الجهة المانحة والفئة المستهدفة والمهارات المغطاة والمتطلبات وطبيعة الاختبار.

شهادات للمبتدئين

هذا المستوى يشمل شهادات مناسبة للأفراد الذين يبدأون مسيرتهم في مجال الأمن السيبراني أو تقنية المعلومات. تتميز هذه الشهادات بتغطية **الأساسيات والمفاهيم التمهيدية**، ولا تتطلب عادةً خبرة عملية كبيرة مسبقة، مما يجعلها نقطة انطلاق ممتازة لبناء المعرفة والمهارات الأمنية. فيما يلي أبرز شهادات المبتدئين:

شهادة CompTIA Security+

- **الجهة المانحة للشهادة:** منظمة CompTIA (اختصار لـ Computing Technology Industry Association)، وهي مؤسسة غير ربحية معروفة عالميًا بشهاداتها في مجال تقنية المعلومات.

- **الفئة المناسبة لها:** تعتبر Security+ شهادة أساسية للمبتدئين في مجال الأمن السيبراني. فهي مناسبة لأي شخص يرغب في دخول المجال بدون خبرة سابقة، كما يستفيد منها مسؤولو نظم وشبكات يريدون تعزيز معرفتهم بأساسيات أمن المعلومات.

- **المهارات والمجالات التي تغطيها:** توفر هذه الشهادة فهمًا شاملاً للمفاهيم **الأساسية في أمن المعلومات**. تشمل المواضيع المغطاة أنواع التهديدات والهجمات الشائعة ونقاط الضعف، أساسيات تأمين الشبكات (مثل الجدران النارية وأنظمة كشف التسلل)، إدارة الهوية والتحكم بالوصول، مفاهيم التشفير الأساسية واستخدامها لحماية البيانات، بالإضافة إلى مبادئ إدارة المخاطر والاستجابة الأولية للحوادث الأمنية.

- **المتطلبات المسبقة:** لا توجد متطلبات إلزامية رسميًا للتقدم للامتحان، إذ صُممت الشهادة للمبتدئين. لكن **يُفضل** أن يمتلك المرشح بعض المعرفة التقنية الأساسية؛ على سبيل المثال يُنصح بفهم مبادئ الشبكات (حاصلًا على شهادة Network+ أو خبرة مكافئة) لتسهيل استيعاب المحتوى. هذه المعرفة

المسبقة ليست شرطًا، لكنها تساعد في التحضير.

- **طبيعة الاختبار ومحتواه:** يتألف امتحان Security+ من أسئلة **اختيار من متعدد** مع بعض الأسئلة العملية (أداء المهام في محاكاة). عادةً يتضمن حوالي 90 سؤالًا ينبغي إنجازها خلال مدة زمنية محددة (حوالي 90 دقيقة). يغطي الاختبار خمسة مجالات أساسية تشمل: مفاهيم التهديدات والهجمات ونقاط الضعف، **هندسة وتصميم الأمن** (لحماية الشبكات والأنظمة)، تطبيق وإدارة الحلول الأمنية (مثل إدارة الوصول والتشفير)، العمليات والإجراءات الأمنية (المراقبة والاستجابة للحوادث)، وأخيرًا **الحوكمة والامتثال** في مجال الأمن. يحتاج الممتحن لتحقيق درجة نجاح لا تقل عن نحو 750 من 900 نقطة (أي حوالي 83% بشكل تقريبي).

شهادة (ISC)² المعتمدة في الأمن السيبراني (CC)

- **الجهة المانحة للشهادة:** منظمة (ISC)² الدولية (اختصار لـ International Information Systems Security Certification Consortium)، وهي الجهة المقدمة أيضًا لشهادات متقدمة مثل CISSP.

- **الفئة المناسبة لها:** تستهدف شهادة **(Certified in Cybersecurity (CC** الأفراد المبتدئين تمامًا في المجال، بما في ذلك الخريجين الجدد أو الراغبين في التحول المهني إلى الأمن السيبراني دون أن تكون لديهم خبرة سابقة. هذه الشهادة مصممة كبوابة دخول لمن يريد إثبات الإلمام بالمبادئ الأساسية للأمن.

- **المهارات والمجالات التي تغطيها:** تغطي CC مفاهيم أساسية جدًا في الأمن السيبراني. تشمل **مبادئ الأمن** العامة مثل سرية المعلومات وسلامتها

وتوفرها، أساسيات حوكمة أمن المعلومات وإدارة المخاطر بصورة مبسطة، مفاهيم **الأمن الشبكي** الأساسية (كالبروتوكولات الآمنة والجدران النارية)، مبادئ التحكم بالوصول وإدارة الهويات، إضافة إلى أساسيات في **عمليات الأمن** (مثل المراقبة المستمرة للحوادث وتنبيهها) والوعي الأمني. الهدف هو تأكيد فهم المرشح **للأساسيات** التي تشكل قاعدة لأي تخصص لاحق في المجال.

- **المتطلبات المسبقة:** لا تتطلب هذه الشهادة أي خبرة عمل سابقة في المجال، مما يجعلها مثالية لمن يخطط لبدء مسيرته المهنية في الأمن السيبراني. يكفي الإلمام العام بالمفاهيم التقنية الأساسية وقدرات التفكير المنطقي.

- **طبيعة الاختبار ومحتواه:** الامتحان مكوَّن من **أسئلة اختيار من متعدد** (حوالي 100 سؤال) تُغطي **خمسة مجالات** رئيسية. هذه المجالات هي: (1) المفاهيم الأمنية والمخاطر والحوكمة بشكل عام، (2) مبادئ حماية الأجهزة والبيانات (بما فيها أساسيات التشفير وأمن الشبكات)، (3) أمن الأنظمة والتطبيقات والبيانات، (4) إدارة الوصول والهوية، و(5) الكشف عن الحوادث والاستجابة لها بشكل مبدئي. مدة الامتحان حوالي ساعتين، ويتطلب النجاح تحقيق درجة تبلغ حوالي 700 من 1000. تعد طبيعة الأسئلة مباشرة نسبيًا وتقيس الفهم النظري للمفاهيم أكثر من التطبيق العملي المتعمق، نظرًا لكون الشهادة موجهة للمبتدئين.

شهادة SSCP (Systems Security Certified Practitioner)

- **الجهة المانحة للشهادة:** منظمة (ISC)² أيضًا. تأتي شهادة SSCP كخيار من (ISC)² للأفراد الذين يرغبون في اعتماد مهاراتهم العملية الأساسية في أمن

المعلومات قبل الوصول لمستويات متقدمة كـ CISSP.

- **الفئة المناسبة لها:** تستهدف SSCP العاملين في مجال تقنية المعلومات ممن لديهم معرفة **أساسية في أمن الأنظمة** ويرغبون في إثبات كفاءتهم بشكل احترافي. مثلًا، **مسؤولو النظم أو مسؤولو الشبكات** الذين يقومون بمهام أمنية في عملهم اليومي هم الفئة المثلى لهذه الشهادة. يمكن اعتبارها ملائمة للمبتدئين أو أصحاب الخبرة القليلة (نحو سنة خبرة) الذين يودون تعزيز مهاراتهم التشغيلية في الأمن.

- **المهارات والمجالات التي تغطيها:** تركّز الشهادة على **الجوانب العملية والتشغيلية لأمن المعلومات**. من المجالات التي تشملها: إدارة التحكم بالوصول وصلاحيات المستخدمين على الأنظمة، **عمليات الأمن** وإدارة الأجهزة والخوادم بشكل آمن (بما في ذلك إجراءات النسخ الاحتياطي وتطبيق التحديثات الأمنية وإدارة البرمجيات الخبيثة)، مراقبة الشبكات والأنظمة واكتشاف الحوادث الأمنية، أساسيات **التشفير** واستخداماته لحماية البيانات، أمن الشبكات والاتصالات (مثل تأمين البروتوكولات وخطوط الاتصال)، إضافة إلى أمن التطبيقات والبيانات. تهدف SSCP إلى التحقق من أن حاملها يستطيع تنفيذ مهام الأمن اليومي بفعالية وفق أفضل الممارسات.

- **المتطلبات المسبقة:** يُشترط رسميًا **سنة واحدة من الخبرة العملية** في واحد أو أكثر من مجالات أمن المعلومات السبع التي تغطيها الشهادة. يمكن أن تكون هذه الخبرة في وظائف مثل إدارة الشبكات أو دعم النظم بشرط تضمّنها لمهام أمنية. إذا لم تتوفر الخبرة، تسمح (ISC)² بالتقدم للامتحان على أن يحصل المرشح - في حال نجاحه - على لقب **Associate of (ISC)²** إلى حين إكمال سنة الخبرة المطلوبة ثم يحصل على الاعتماد الكامل.

- **طبيعة الاختبار ومحتواه:** يتكون اختبار SSCP من **125 سؤالًا اختيار من متعدد** ينبغي إنجازها خلال ثلاث ساعات. يغطي الامتحان **سبعة نطاقات معرفية** هي باختصار: (1) التحكم بالوصول (إدارة حسابات المستخدمين وقيود الوصول للموارد)، (2) عمليات وإدارة الأمن (سياسات وإجراءات الأمن اليومية وإدارة الموجودات والصلاحيات)، (3) تقييم المخاطر والاستجابة للحوادث (بما في ذلك أساليب التعافي من الكوارث واستمرارية الأعمال بشكل مبدئي)، (4) التشفير (مبادئ وأساليب التعمية وحماية البيانات)، (5) أمن الشبكات والاتصالات (تأمين نقل البيانات والشبكات السلكية واللاسلكية)، (6) أمن الأنظمة والتطبيقات (تأمين أنظمة التشغيل وقواعد البيانات والتطبيقات من الثغرات)، و(7) أمن المعلومات والخصوصية. أسئلة الامتحان متوسطة الصعوبة وتركز على قدرة المرشح على تطبيق المفاهيم عمليًا. نسبة النجاح عادة في حدود 70% صحيحة تقريبًا. بشكل عام، نيل شهادة SSCP يثبت أن الشخص قادر على تنفيذ مهام **أخصائي أمن معلومات** على المستوى التشغيلي اليومي بكفاءة.

شهادات للمستوى المتوسط

تتوجه هذه الشهادات إلى المتخصصين الذين قطعوا شوطًا معقولًا في مجال الأمن السيبراني وأصبح لديهم أساس قوي من المعرفة التقنية. غالبًا ما يمتلك المرشحون لهذه الشهادات بعض الخبرة العملية (عدة سنوات) أو شهادات مبتدئة ويرغبون في **التعمق أكثر أو التخصص** في مجالات محددة ضمن الأمن السيبراني. تتميز اختبارات المستوى المتوسط بأنها تغطي موضوعات أكثر تقدمًا من الأساسيات وتختبر قدرة المرشح على التحليل والتطبيق العملي للمفاهيم الأمنية. فيما يلي أهم الشهادات المتوسطة:

شهادة المخترق الأخلاقي المعتمد (CEH)

- **الجهة المانحة للشهادة:** منظمة EC-Council (المجلس الدولي لمستشاري التجارة الإلكترونية)، وهي جهة معروفة تقدم شهادات في مجال الأمن الهجومي والتحقيق الجنائي الرقمي.

- **الفئة المناسبة لها:** تستهدف **Certified Ethical Hacker** المهنيين في مجال أمن المعلومات الراغبين في التخصص في **اختبار الاختراق والقرصنة الأخلاقية**. المرشح المثالي هو من لديه إلمام بأساسيات الشبكات ونظم التشغيل وربما خبرة سنة أو أكثر في دعم أمن الأنظمة، ويريد تعلم أساليب الاختراق بشكل منهجي وقانوني. عادةً ما يحصل عليها مسؤولو الأمن أو محللو النظم أو مهندسو الشبكات الذين يريدون التحول إلى دور **مختبِر اختراق** (Penetration Tester) أو **محلل نقاط ضعف**.

- **المهارات والمجالات التي تغطيها:** تزود شهادة CEH حاملها بالمعرفة والأدوات المستخدمة من قبل **المخترقين (الهاكرز) الأخلاقيين** لاختبار أمن الأنظمة. تغطي الشهادة **منهجية الاختراق** بكافة مراحلها، بدءًا من مرحلة الاستطلاع وجمع المعلومات (Reconnaissance) عن الهدف، مرورًا بمرحلة المسح والفحص (Scanning) لتحديد المنافذ المفتوحة والخدمات والثغرات، ثم مرحلة **الاستخراق** أو استغلال الثغرات (Exploitation) للحصول على وصول غير مصرح به إلى الأنظمة، تليها مراحل الحفاظ على الوصول (Maintaining Access) وتتبع الآثار وطمسها (Covering Tracks). تشمل المجالات أيضًا مواضيع **الهندسة الاجتماعية** وتقنيات خداع المستخدمين، اختبار اختراق الشبكات السلكية واللاسلكية، أمن تطبيقات الويب وقواعد البيانات وكيفية استغلال نقاط ضعفها، وفهم أدوات الاختراق الشائعة مثل ماسحات الثغرات (على سبيل المثال Nmap وNessus) وأطر العمل الهجومية (مثل Metasploit). الهدف هو تمكين المتخصص من التفكير كـ "هاكر" لاكتشاف الثغرات الأمنية

ومعالجتها قبل أن يستغلها المهاجمون الحقيقيون.

- **المتطلبات المسبقة:** رسميًا، تشترط منظمة EC-Council إما حضور دورة تدريبية معتمدة في اختبار الاختراق أو امتلاك ما لا يقل عن **سنتين من الخبرة** العملية في مجال أمن المعلومات (مع تقديم إثبات) قبل السماح بالتقدم للامتحان. لذا يُفضل أن يكون المرشح قد عمل سابقًا في دور تقني ذي صلة أو على الأقل قام بدراسة مكثفة لمجال الشبكات وأنظمة التشغيل. كثير من المرشحين يحصلون أولًا على شهادة مثل Security+ أو خبرة معملية في أساسيات الاختراق قبل محاولة اختبار CEH.

- **طبيعة الاختبار ومحتواه:** يتكون امتحان CEH من **125 سؤال اختيار من متعدد** يُجاب عنها في مدة أقصاها 4 ساعات. الاختبار متوفر بالإنجليزية وعادةً نسخته الحالية تحمل رقم إصدار (مثل CEH v12). تغطي الأسئلة نطاقًا واسعًا من المواضيع المذكورة في المنهج، مع التركيز على أدوات القرصنة وطرائق الهجوم والدفاع. الأسئلة تختبر المعرفة النظرية بالأدوات (مثلاً: أي أداة تستخدم لفحص المنافذ؟ ما التقنية المستخدمة لكسر كلمات المرور؟) وكذلك فهم مراحل الاختراق وأفضل الممارسات الأخلاقية. درجة النجاح تتطلب الحصول على نسبة حوالي 70%. بالإضافة إلى الامتحان النظري، تقدم EC-Council اختبارًا عمليًا منفصلًا (CEH Practical) يستطيع الحاصل على CEH اجتيازه للحصول على لقب **CEH Master**، حيث يثبت من خلاله مهاراته في تحديات اختراق حقيقية في مختبر افتراضي. على كل حال، شهادة CEH الأساسية (النظرية) هي خطوة مهمة لإثبات المعرفة في القرصنة الأخلاقية.

شهادة CySA+ (CompTIA Cybersecurity Analyst)

- **الجهة المانحة للشهادة:** منظمة CompTIA.

- **الفئة المناسبة لها:** تستهدف شهادة **CySA+** فئة **محللي الأمن السيبراني** العاملين في مراكز عمليات الأمن (SOC) أو فرق الاستجابة للحوادث، وكذلك **مسؤولي حماية الأنظمة** الذين يركزون على الجانب الدفاعي. المرشح المثالي هو من لديه معرفة بأساسيات الأمن (ربما حاصل على Security+ أو خبرة مكافئة) ويريد التخصص أكثر في **تحليل التهديدات والمراقبة الأمنية** واستجابة الحوادث. غالبًا ما يكون لدى المتقدم خبرة عملية من 3-4 سنوات في مجال تقنية المعلومات أو الشبكات مع انخراط في بعض المهام الأمنية.

- **المهارات والمجالات التي تغطيها:** تركز CySA+ على الجانب الدفاعي وإجراءات **الكشف عن التهديدات وتحليلها والتعامل معها**. تغطي الشهادة عدة مجالات أساسية منها: **إدارة التهديدات ونقاط الضعف** (Threat & Vulnerability Management) والتي تشمل إجراء المسوح الأمنية المنتظمة وتقييم الثغرات في الشبكات والأنظمة، **مراقبة الشبكة والأجهزة** (Security Operations & Monitoring) عبر استخدام أنظمة كشف التسلل (IDS) وأنظمة المعلومات الأمنية وإدارة الأحداث (SIEM) لتحليل سجلات الأحداث واكتشاف السلوك المشبوه، التحقيق في الحوادث الأمنية وفهم خطوات الاستجابة incident response (مثل احتواء الحادث واستئصال التهديد والتعافي)، بالإضافة إلى **معالجة التقارير الأمنية** والامتثال (بمعنى فهم تقارير التحليل الأمني والتوصية بتحسينات وتلبية معايير الأمن مثل PCI-DSS أو GDPR عند الحاجة). يكتسب الحاصل على الشهادة مهارات في تحليل البرمجيات الخبيثة بشكل مبدئي، واستخدام أدوات مثل Wireshark لتحليل حركة الشبكة، كما يتعرف على منهجيات مثل **تحليل سلوك المستخدمين** (UEBA) في كشف التهديدات.

- **المتطلبات المسبقة:** لا يشترط وجود شهادة محددة قبل +CySA، لكن CompTIA توصي بشدة أن يكون المرشح حاصلاً على شهادة +Security أو ما يعادلها من معرفة، إلى جانب **خبرة عملية حوالي 3-4 سنوات** في مجال أمن المعلومات أو تحليل البيانات/الشبكات. هذه الخبرة تساعد بشكل كبير في فهم سيناريوهات التحليل المطروحة في الاختبار. بدون تلك الخلفية، قد يصعب على المبتدئ الإلمام بكل المفاهيم المتقدمة في هذه الشهادة.

- **طبيعة الاختبار ومحتواه:** امتحان +CySA عبارة عن **مزيج من أسئلة اختيار من متعدد وأسئلة أداء عملية (محاكاة)**، بعدد إجمالي يقارب 85 سؤالًا، وزمن إجابة قدره 165 دقيقة (ساعتان و45 دقيقة تقريبًا). يغطي الاختبار أربعة مجالات رئيسية تتوافق مع محتوى الشهادة: (1) إدارة التهديدات والثغرات (يشمل مفاهيم التهديدات الشائعة، وتقارير الثغرات CVEs، وآليات تقييم نقاط الضعف وإدارتها)، (2) التحليل والإدارة الأمنية (ويشمل رصد الشبكات والأنظمة عبر سجلات الأحداث وتحليلها ومتابعة مؤشرات الاختراق)، (3) الاستجابة للحوادث وإدارة الطوارئ (بما فيها خطط الاستجابة، والتحقيق الجنائي الرقمي الأساسي، وأساليب احتواء الحوادث واستعادة الخدمات)، و(4) الامتثال وتنفيذ التقارير (مع التركيز على فهم سياسات الأمن والالتزام بالمعايير وإعداد التقارير الفنية للإدارة). درجة النجاح تكون حوالي 750 من 900. عمومًا، يعد امتحان +CySA عميقًا نسبيًا ويختبر قدرة المحلل على تفسير المعطيات الأمنية واتخاذ القرارات المناسبة لحماية المؤسسة.

شهادة CompTIA PenTest+

- **الجهة المانحة للشهادة:** منظمة CompTIA.

- **الفئة المناسبة لها:** صُممت **PenTest+** للمتخصصين الراغبين في أداء **اختبارات الاختراق العملية** وتقييم الثغرات الأمنية في الشبكات والأنظمة. فهي مناسبة **لمختبري الاختراق المبتدئين إلى المتوسطين** الذين ربما حصلوا على CEH أو لديهم خلفية جيدة في الشبكات ويريدون شهادة تُثبت مهاراتهم التطبيقية في هذا المجال. أيضًا تعتبر ملائمة لمحللي نقاط الضعف أو مهندسي الأمن الذين تكون مهامهم تتضمن محاكاة هجمات على منظومات مؤسساتهم بهدف تقوية دفاعاتها. عادةً يمتلك المرشح خبرة 2-3 سنوات في تقنية المعلومات مع فهم قوي لنظم التشغيل والشبكات، وقد يكون حاصلًا على Security+ أو خبرة معادلة.

- **المهارات والمجالات التي تغطيها:** تغطي شهادة PenTest+ جميع مراحل **عملية اختبار الاختراق** بصورة شاملة. يشمل ذلك: **التخطيط والهندسة الاجتماعية** (Planning & Scoping) حيث يتعلم المرشح كيف يحدد نطاق الاختبار وأهدافه ويتعامل مع الجوانب القانونية والأخلاقية قبل بدء أي اختبار اختراق، **جمع المعلومات والاستطلاع** (Information Gathering & Reconnaissance) عبر أساليب البحث المفتوح (OSINT) والمسح الشبكي لتحديد الأهداف المحتملة، **تحديد الثغرات وتحليلها** (Vulnerability Identification) بما في ذلك استخدام أدوات المسح الآلي وتحليل نتائجها لتحديد الثغرات الحرجة، **استغلال الثغرات** (Exploitation) على مستوى الشبكة والأنظمة وتطبيقات الويب - أي تنفيذ هجمات عملية لكشف مدى إمكانية الدخول غير المصرح به أو رفع الصلاحيات في النظام - مع فهم أدوات مثل ميتاسبلويت وأطر العمل الأخرى، ثم **عمليات ما بعد الاختراق** (Post-Exploitation) التي تشمل الحفاظ على الوصول وجمع الأدلة وإجراءات تغطية الأثر عند الحاجة، وأخيرًا **كتابة التقارير والتواصل** (Reporting & Communication) حيث يتوجب على مختبر الاختراق توثيق نتائج الاختبار وتقديم تقرير احترافي يوضح الثغرات المكتشفة وتصنيف خطورتها والتوصيات لسدها

بلغة يفهمها كل من التقنيين والإدارة.

- **المتطلبات المسبقة:** توصي CompTIA بأن يكون المتقدم قد حصل على شهادة Security+ أو يمتلك معرفة مماثلة، إلى جانب خبرة تقنية عملية (شبكات أو دعم نظم) لمدة سنتين على الأقل، ويفضل أن يكون جزء منها في مجال الأمن أو إدارة الأنظمة. هذه الخلفية تضمن أن المرشح ملم بأساسيات التعامل مع الأنظمة والشبكات وبالمفاهيم الأمنية الأساسية قبل الغوص في تفاصيل الاختراق. على الرغم من أنها توصيات غير إلزامية، إلا أن المرشح دون هذه الخبرة قد يواجه صعوبة في الجوانب التقنية العميقة للاختبار.

- **طبيعة الاختبار ومحتواه:** يتكون اختبار PenTest+ من حوالي **85 سؤالًا** يجمع بين **الأسئلة متعددة الاختيارات والأسئلة العملية** (Performance-Based Questions) في مختبرات افتراضية مصغرة. المدة المخصصة للامتحان 165 دقيقة. يرتكز محتوى الامتحان على خمسة مجالات أساسية: (1) التخطيط والنطاق (التعامل مع سيناريوهات لتحديد نطاق اختبار اختراق ضمن قيود واعتبارات معينة)، (2) جمع المعلومات وتحديد الثغرات (أسئلة حول أدوات المسح الشبكي وتحليل المخرجات واختيار أدوات الاستطلاع المناسبة لكل موقف)، (3) الهجوم والاستغلال (يقدم للمرشح بيئات افتراضية عليه فيها تنفيذ خطوات اختراق فعلية أو تحديد أي ثغرة يمكن استغلالها وكيف)، (4) عمليات ما بعد الاستغلال (أسئلة حول الإجراءات التي يمكن اتخاذها بعد النجاح في الاختراق مثل توسيع الاختراق أو الحفاظ على الوصول)، و(5) تحليل التقارير (فهم نتائج الاختبار وترجمتها إلى توصيات أمنية). يميل الاختبار إلى تقييم **المهارة العملية** بقدر تقييم المعرفة النظرية، لذا يعتبر اجتيازه مؤشرًا على امتلاك الحاصل على الشهادة قدرة واقعية على تنفيذ اختبارات اختراق وكتابة تقاريرها. درجة النجاح عادة حوالي 750 من 900.

شهادة GSEC (GIAC Security Essentials)

- **الجهة المانحة للشهادة:** معهد GIAC (اختصار لـ Global Information Assurance Certification)، وهو تابع لمؤسسة SANS التعليمية المشهورة بتقديم تدريب متقدم في الأمن السيبراني.

- **الفئة المناسبة لها:** شهادة GSEC موجَّهة للمختصين في أمن المعلومات الذين يرغبون في إثبات كفاءتهم في **طيف واسع من أساسيات الأمن** بمستوى متقدم نسبيًا عن شهادة المبتدئين. كثيرًا ما يتقدم لها من أكمل **دورة تدريب SANS Security Essentials (SEC401)** أو ما يعادلها، أو محترفو تقنية المعلومات الذين لديهم خبرة جيدة (ربما 1-2 سنة) في المجال الأمني أو الإداري التقني ويريدون شهادة معترف بها عالميًا تثبت مهاراتهم. هي مناسبة لمن تجاوز مستوى المبتدئ ويريد شمولية أكبر في المعرفة دون الوصول بعد إلى التخصصات الدقيقة جدًا.

- **المهارات والمجالات التي تغطيها:** تعتبر GSEC شهادة **شاملة** تغطي نطاقًا عريضًا من مواضيع أمن المعلومات، مما يؤكد امتلاك حاملها فهمًا قويًا للتقنيات والممارسات الأمنية الأساسية. تشمل المجالات التي يغطيها المنهج: **مفاهيم التشفير** العملية (مثل خوارزميات التشفير المتماثل وغير المتماثل وكيفية تطبيقها لحماية البيانات)، **أمن الشبكات** بمختلف جوانبه (بروتوكولات الشبكة الآمنة، تصميم الشبكات الآمنة، كشف التسلل، تأمين نقاط الاتصال اللاسلكية)، **أمن أنظمة التشغيل والخوادم** لكل من بيئة ويندوز ويونكس/لينكس (مثل إعدادات التأمين على مستوى نظام التشغيل، آليات التحكم بالوصول، إدارة التحديثات والرقع الأمنية)، **إدارة الهويات والحسابات**، **تحليل البرمجيات الخبيثة والمخاطر** على مستوى أساسي، **مفاهيم الاستجابة للحوادث** وبداية التحقيق الجنائي الرقمي، **أمن التطبيقات**

والويب (مفاهيم عامة حول ثغرات التطبيقات مثل SQL injection و XSS ولكن ليس بتعمق شديد كالشهادات المخصصة للتطبيقات). كما يتضمن المنهج نواحي تتعلق **بإدارة وسياسات الأمن** لضمان أن المتخصص يفهم الإطار العام لأمن المعلومات في بيئة العمل. بشكل عام، تغطي GSEC ما يزيد عن 30 مجالًا فرعيًا ضمن موضوعات الأمن، ولهذا تعتبر شهادة واسعة النطاق.

- **المتطلبات المسبقة:** لا توجد متطلبات خبرة محددة لامتحان GSEC، إذ يمكن لأي شخص التسجيل للامتحان. لكن نظراً لعمق واتساع المحتوى، يُنصح بشدة بحضور دورة تدريبية معتمدة من SANS أو امتلاك خلفية معرفية جيدة في مواضيع الأمن الأساسي قبل التقدم. كثير من المتقدمين يحملون شهادات كمبتيا (Security+/Network+) أو لديهم ممارسة عملية مما يساعدهم في الإعداد. الطبيعة **المفتوحة** للامتحان (انظر أدناه) تجعل من الضروري التحضير الجيد وجمع المذكرات والمراجع للإفادة منها أثناء الاختبار.

- **طبيعة الاختبار ومحتواه:** امتحان GSEC فريد من نوعه مقارنة بالشهادات الأخرى لأنه **اختبار كتاب مفتوح** - يُسمح للممتحن بجلب مواد مطبوعة ككتب أو ملاحظات شخصية أثناء الاختبار. ورغم ذلك، الامتحان ليس سهلًا، فهو يتكون من **106 أسئلة** اختيار من متعدد على مدار 4 ساعات. نظرًا لشمولية المادة، تغطي الأسئلة نطاقًا واسعًا من التفاصيل التقنية، مما يتطلب من المرشح القدرة على **البحث السريع** في مواده المرجعية أثناء الامتحان والعثور على المعلومات الصحيحة. معدل الإجابة الصحيحة المطلوب للنجاح هو حوالي **73%** (قد تختلف النسبة قليلًا حسب إصدارات الامتحان). الأسئلة غالبًا تكون سيناريوهات أو تفصيلات حول إعدادات أمنية صحيحة أو أدوات معينة أو خطوات ينبغي اتخاذها في موقف أمني محدد، مما يختبر مدى الفهم العميق والخبرة العملية للممتحن. إجمالاً، نجاح المرشح في GSEC دليل على أنه يمتلك أساسًا قويًا جدًا ومتعدد الجوانب في أمن المعلومات، ويستطيع تطبيق مبادئ

الحماية عبر مختلف الأنظمة والتقنيات.

شهادات للمحترفين والمتقدمين

تضم هذه الفئة الشهادات المخصصة لأصحاب الخبرة العريضة في مجال الأمن السيبراني. عادةً ما تتطلب هذه الشهادات **سنوات من الخبرة العملية** وتتعمق في مجالات استراتيجية أو تقنية متقدمة، مما يؤهل الحاصلين عليها لتولي مناصب قيادية أو اختصاصية عليا. الحصول على إحدى هذه الشهادات المرموقة يبرهن أن المحترف يمتلك فهمًا شموليًا ومهارات راسخة تمكنه من **وضع السياسات الأمنية وإدارة البرامج الأمنية أو تنفيذ عمليات معقدة** على مستوى عالٍ. فيما يلي أبرز شهادات الخبراء:

شهادة محترف أمن نظم المعلومات المعتمد (CISSP)

- **الجهة المانحة للشهادة:** منظمة (ISC)² العالمية.

- **الفئة المناسبة لها:** تعتبر **CISSP** على نطاق واسع **"المعيار الذهبي لشهادات أمن المعلومات"**، وهي موجهة للخبراء الذين يطمحون لتولي أدوار عليا في أمن المعلومات. المرشح المثالي هو شخص ذو **خبرة لا تقل عن خمس سنوات** في أمن المعلومات (في جوانب متعددة)، يعمل ربما كمدير أمن معلومات أو مستشار أمني أو مهندس أمن رئيسي، ويريد توثيق معرفته الواسعة والمعمقة. الشهادة تناسب كل من **المديرين والفنيين** الكبار على حد سواء، لأنها تغطي نطاقًا متكاملاً من الجوانب الإدارية والتقنية. غالبًا ما يُنظر إلى CISSP كمتطلب للتقدم لمناصب كمدير أمن معلومات (CISO) أو خبير أمن معلومات معتمد لدى المؤسسات الكبرى.

- **المهارات والمجالات التي تغطيها:** يتميز منهج CISSP بأنه **شامل** ويغطي **ثمانية مجالات (Domains)** تمثل معًا كل جوانب أمن المعلومات. هذه المجالات الثمانية هي بإيجاز:

1. **إدارة الأمن والمخاطر:** ويتضمن حوكمة أمن المعلومات، وضع سياسات الأمن وإجراءات الامتثال، إدارة المخاطر وتحليلها، مفهوم استمرارية الأعمال والتعافي من الكوارث، وأخلاقيات المهنة.

2. **أمن الأصول:** ويشمل تصنيف وإدارة أصول المعلومات، وإجراءات حماية البيانات في مختلف دورات حياتها (تخزين، نقل، إتلاف)، إلى جانب مفاهيم الخصوصية.

3. **هندسة الأمن:** وهو مجال يغطي تصميم وبناء بنى أمنية قوية للأنظمة، مبادئ **التشفير المتقدم** وتطبيقاته العملية، أمن المعدات المادية (كأقفال الأجهزة وأنظمة المراقبة) وكذلك **أمن البيئات السحابية** والتقنيات الناشئة.

4. **أمن الاتصالات والشبكات:** يتناول تأمين شبكات البيانات بمختلف أنواعها (سلكية ولاسلكية)، تصاميم شبكية آمنة، بروتوكولات الاتصال الآمن، تقنيات VPN، حماية البنية التحتية الحرجة للإنترنت، كشف التسلل وأنظمة الوقاية، والجوانب المرتبطة بهندسة الشبكات.

5. **إدارة الهوية والتحكم بالوصول:** يشمل أنظمة إدارة حسابات المستخدمين والصلاحيات، نماذج التحكم بالوصول (مثل DAC وMAC وRBAC)، خدمات الدليل (كـ Active Directory)، إدارة الهويات الرقمية والتحقق الثنائي (2FA)، ودورة حياة إدارة وصول المستخدم من التسجيل

حتى الإلغاء.

6. **تقييم الأمن والاختبار:** يركز على منهجيات تقييم الثغرات (مثل الفحص الأمني الدوري)، اختبار الاختراق وأدواته على نطاق أساسي إلى متوسط، إجراءات التدقيق الأمني، التقييم التقني للضوابط الأمنية، بالإضافة إلى **التحقيق الجنائي الرقمي** ومفاهيم جمع الأدلة وتحليلها عند وقوع الحوادث.

7. **عمليات الأمن:** وهو مجال كبير يتناول إدارة العمليات الأمنية اليومية داخل المؤسسة. يتضمن مراقبة الأحداث الأمنية، الاستجابة للحوادث (خطط التعامل مع الاختراقات ودروس مستفادة)، إدارة **مراكز العمليات الأمنية (SOC)**، إدارة التغييرات والإصدارات في الأنظمة بشكل آمن، التحكم في البرمجيات الخبيثة (الفيروسات والبرمجيات الضارة) وآليات مكافحتها، إدارة النُظم وبُنى الشبكات الحرجة، أمن العمليات التشغيلية (مثل الفصل بين المهام، وإجراءات النسخ الاحتياطي، والتعامل مع الأدلة عند الجرائم السيبرانية)، إضافة إلى موضوعات مثل التحقيق في الحوادث بعد وقوعها والطب الشرعي الرقمي بشكل أوّلي.

8. **أمن تطوير البرمجيات:** يغطي مبادئ **التطوير الآمن للبرمجيات** عبر دورة حياة تطوير الأنظمة (SDLC)، اكتشاف ومعالجة ثغرات التطبيقات (مثل البرمجة الدفاعية ضد SQL Injection و XSS وغيرها)، نماذج النضج الأمني للتطوير (SAMM مثلاً)، اختبار البرمجيات بحثًا عن الثغرات، وضمان تضمين الضوابط الأمنية أثناء تصميم الأنظمة وقواعد البيانات.

هذه المجالات تُظهر مدى الاتساع في محتوى CISSP، حيث تمزج بين الإدارة الاستراتيجية والتقنية المتخصصة. نجاح المرشح يعني امتلاكه فهمًا متينًا في كل هذه الجوانب وقدرة على دمجها ضمن إطار أمني متكامل.

- **المتطلبات المسبقة:** يُشترط للتقدم للحصول على شهادة CISSP وجود **5 سنوات على الأقل من الخبرة العملية الموثوقة** بدوام كامل في ميدان أمن المعلومات، على أن تشمل الخبرة مجالين اثنين أو أكثر من المجالات الثمانية المذكورة أعلاه. يمكن تخفيض المطلوب إلى 4 سنوات من الخبرة إذا كان المرشح حاصلًا على شهادة جامعية (بكالوريوس أو ما يعادلها في تخصص ذو صلة) أو على إحدى الشهادات المعتمدة التي تمنح إعفاءً (مثل Security+ أو CEH وغيرها بحسب قائمة (ISC)²). في حال اجتياز الامتحان من قبل مرشح لا يملك الخبرة الكاملة بعد، فسيُمنح لقب **Associate of (ISC)²** ويكون أمامه فترة تصل إلى 6 سنوات لاستكمال خبرة الخمس سنوات المطلوبة؛ بعد توثيق الخبرة يحصل رسميًا على اعتماد CISSP. بالإضافة لذلك، يتعين على المرشح المقبول توقيع **مدونة أخلاقيات المهنة** الخاصة بـ (ISC)² والإفصاح عن أي سوابق جنائية أو مخالفات تتعلق بأمانة الدور المهني. كما يجب الحصول على توقيع أحد الحاصلين على CISSP حاليًا كشاهد على صحة خبرات المرشح وسيرته المهنية (عملية توثيق).

- **طبيعة الاختبار ومحتواه:** اختبار CISSP من الاختبارات الصعبة التي تتطلب تحضيرًا مكثفًا نظرًا لتشعب مواضيعه. يتوفر الامتحان بعدة لغات، لكن باللغة الإنجليزية يُقدَّم بنظام **الاختبار المتكيف المحوسب (CAT)**. يتراوح عدد الأسئلة من 100 إلى 150 سؤالًا (قد يصل أحيانًا إلى 150 حسب أداء الممتحن)، ويُمنح الممتحن ثلاث ساعات كحد أقصى لإكماله. الأسئلة مزيج من **اختيار من متعدد** وأسئلة "تقدم/تأخر" أو سحب وإفلات وغيرها (لكنها ليست عملية محضة كتشغيل أدوات، بل تفاعلية ضمن منصة الامتحان). يركز الامتحان بشكل كبير

على أسئلة **سيناريوهات** تتطلب تحليل موقف واختيار الإجراء الأنسب من منظور أمني، ما يعني أن مجرد حفظ المعلومات لا يكفي، بل يجب فهم كيفية التطبيق العملي للمفاهيم في الواقع. يتم تحديد درجة النجاح على شكل **نسبة مئوية معيارية (Scaled Score)** بحد أدنى 700 من 1000 (أي نحو 70% - تختلف طريقة الحساب الداخلي). في حالة تقديم الامتحان بلغات أخرى غير الإنجليزية يكون بطريقة ورقية أو مركزية بعدد ثابت ~250 سؤالًا في 6 ساعات. بعد الحصول على الشهادة، يلتزم المحترف بإتمام **التعليم المهني المستمر (CPE)** بما لا يقل عن 40 ساعة سنويًا (120 ساعة كل 3 سنوات) للحفاظ على اعتماده وتحديث معارفه وفق تطور المجال. عمومًا، يعد اجتياز CISSP دليلًا على مستوى رفيع من الخبرة والإلمام بمعايير أمن المعلومات العالمية.

شهادة مدير أمن المعلومات المعتمد (CISM)

- **الجهة المانحة للشهادة:** منظمة ISACA (جمعية تدقيق وضبط نظم المعلومات).

- **الفئة المناسبة لها:** تستهدف **CISM** العاملين في إدارة أمن المعلومات والذين يطمحون إلى **مناصب قيادية** في المجال الأمني. فهي مصممة خصيصًا **لمديري أمن المعلومات** أو من في حكمهم (كالمدراء التنفيذيين لأمن المعلومات CISO أو مدراء المخاطر التقنية)، وكذلك **استشاريي أمن المعلومات** ذوي الخبرة الذين يضعون السياسات والاستراتيجيات الأمنية للمؤسسات. المرشح المثالي يجب أن يمتلك فهمًا للجانب الإداري والتنظيمي للأمن، بالإضافة للخبرة التقنية العامة، بحيث يستطيع الربط بين أهداف العمل ومتطلبات الأمن. غالبًا ما يكون لديه خمس سنوات أو أكثر من الخبرة، منها بضع سنوات في دور إداري إشرافي.

- **المهارات والمجالات التي تغطيها:** يركز منهج CISM على **إدارة أمن المعلومات من منظور مؤسسي**، ويغطي **أربع مناطق/مجالات رئيسية** تعكس دورة حياة برنامج الأمن في المؤسسة:

1. **حوكمة أمن المعلومات:** ويتضمن كيفية مواءمة استراتيجية الأمن مع استراتيجية العمل العامة، تطوير سياسات أمن المعلومات والإشراف على تطبيقها، وضع هيكل الحوكمة وتحديد الأدوار والمسؤوليات، وضمان الامتثال للقوانين واللوائح المنظمة (مثل معايير حماية البيانات).

2. **إدارة المخاطر في أمن المعلومات:** يدور حول عملية **تقييم المخاطر** التي تهدد أصول المعلومات (تحديد الأصول وتقييم أهميتها، تحديد التهديدات ونقاط الضعف، تحليل تأثير حدوث المخاطر واحتمالية وقوعها)، ثم **تطوير استراتيجيات المعالجة** (كمعالجة المخاطر بالتخفيف عبر الضوابط، أو نقلها عبر التأمين، أو تجنبها، أو قبولها ضمن حدود معينة) ورصد المخاطر بشكل مستمر.

3. **تطوير وإدارة برامج أمن المعلومات:** وهو جزء جوهري حيث يتناول كيفية **تصميم برنامج أمن معلومات متكامل** للمؤسسة. يشمل ذلك تحديد المتطلبات الأمنية، اختيار و**تنفيذ الضوابط الأمنية** المناسبة (تقنية وإجرائية)، إدارة فرق الأمن وتحديد مهامهم، التخطيط لمشاريع أمنية وتنفيذها (مثل نشر أنظمة جديدة أو آليات توعوية)، وقياس فعالية البرنامج الأمني عبر **مؤشرات أداء** ولوحات متابعة، وتحديث البرنامج دوريًا لمواكبة التغييرات.

4. **إدارة حوادث أمن المعلومات:** يغطي كيفية إنشاء **خطة استجابة للحوادث** (CSIRP) داخل المنظمة، وتأسيس فريق الاستجابة للحوادث (CIRT) وتحديد أدواره، الإجراءات الواجب اتباعها عند وقوع حادث أمني من أول الاكتشاف مرورًا بالاحتواء والتحقيق الفني والتعافي واستئناف العمليات، بالإضافة إلى **التعلم من الحوادث** عبر تحليلها وضمان عدم تكرارها (على سبيل المثال: تنفيذ تحسينات بعد حادث اختراق). كما يشمل هذا المجال أيضًا التخطيط للطوارئ واستمرارية الأعمال من منظور أمني.

بشكل عام، تمثل المجالات الأربعة أعلاه مهارات مدير أمن المعلومات الذي لا ينخرط فقط في التفاصيل التقنية الدقيقة، بل يدير الصورة الشاملة للأمن السيبراني في المنظمة ويربطها بالأعمال والأهداف المؤسسية.

- **المتطلبات المسبقة:** تشترط ISACA أن يمتلك المرشح خبرة عملية لا تقل عن **5 سنوات** في مجال أمن المعلومات، منها **3 سنوات على الأقل في إدارة أمن المعلومات** (أي في مهام إشرافية أو قيادية تتعلق بالمجالات المذكورة أعلاه). يمكن تقليل المتطلب الإجمالي للخبرة بحد أقصى سنتين في حالات محددة؛ على سبيل المثال: يمكن احتساب شهادة جامعية متعلقة بتقنية المعلومات أو شهادات معتمدة معينة (مثل CISSP أو CISA وغيرهما) كبديل لسنة أو سنتين من الخبرة. لكن على أية حال، يجب أن يكون لدى المرشح 3 سنوات خبرة إدارية أمنية فعلية مهما كانت الإعفاءات. أيضًا، يشترط التقدم لنيل الشهادة خلال فترة لا تزيد عن 5 سنوات بعد النجاح في الاختبار وإلا تعتبر النتيجة لاغية.

- **طبيعة الاختبار ومحتواه:** امتحان CISM يكون **ورقيًا أو إلكترونيًا** ويتضمن **150 سؤال اختيار من متعدد** يجب حلها خلال مدة أقصاها 4 ساعات. الأسئلة

موزعة بنسبة متقاربة على المجالات الأربعة، وتتميز بأنها **سيناريوهات إدارية** تتطلب من الممتحن اختيار الإجراء الأنسب كمدير أمن معلومات مسؤول. على سبيل المثال: قد يُعطى سيناريو عن اكتشاف ثغرة حرجة في نظام ما، ويُسأل "ما أول ما يجب على مدير أمن المعلومات فعله؟" مع خيارات مثل (إبلاغ الإدارة العليا، أو فصل النظام عن الشبكة، أو إجراء تحليل مخاطر لتقييم التأثير، ...إلخ). هذه الطبيعة تعكس التركيز على **القرار الإداري الصحيح** أكثر من التفاصيل التقنية. درجة النجاح تمثل الحصول على **450 نقطة من 800** (وفق نظام ISACA للدرجات المعيارية). لا توجد علامة رسوب/نجاح كنسبة مئوية معلنة، لكن تقريبًا تعادل هذه الدرجة الصافية حوالي 70%. بعد الحصول على الشهادة، يتعين على حاملها الالتزام بممارسة مهنة أمن المعلومات وفق **الميثاق الأخلاقي لـ ISACA**، كما يجب تجديدها سنويًا عبر كسب **ساعات التعليم المستمر (CPE)** المطلوبة ودفع رسوم الصيانة السنوية، حيث يلزم 120 ساعة على مدار 3 سنوات للحفاظ على الشهادة. شهادة CISM تحظى بتقدير عالمي، وإثباتها يعني أن حاملها قادر على **قيادة البرنامج الأمني** داخل المؤسسة بكفاءة ورؤية إستراتيجية.

شهادة مدقق نظم المعلومات المعتمد (CISA)

- **الجهة المانحة للشهادة:** منظمة ISACA أيضًا.

- **الفئة المناسبة لها:** تستهدف **CISA** المتخصصين في مجال **تدقيق ومراجعة نظم المعلومات** والرقابة عليها، بما يشمل تدقيق جوانب أمن المعلومات. تُعد شهادة أساسية لمن يعمل كـ **مدقق نظم معلومات** (IT Auditor) سواءً في شركات تدقيق خارجية أو ضمن قسم التدقيق الداخلي للمؤسسات، وكذلك **استشاري التدقيق وتقنية المعلومات** الذين يقومون بمراجعات دورية على ضوابط تقنية المعلومات وأمنها. أيضًا يمكن أن يستفيد منها **مسؤولو**

الامتثال والمراقبة الداخلية في المؤسسات لفهم معايير الرقابة المطلوبة على أنظمة المعلومات. عادة المرشح لديه خلفية في تقنية المعلومات أو المحاسبة ونظم الرقابة مع خبرة عدة سنوات، ويريد توثيق معرفته بممارسات التدقيق المعتمدة دوليًا.

- **المهارات والمجالات التي تغطيها:** يغطي منهج CISA **خمسة مجالات رئيسية** تمثل دورة عملية التدقيق والفحص في بيئة تقنية المعلومات:

1. **عملية تدقيق نظم المعلومات:** يركز هذا الجزء على منهجية التدقيق نفسها. يتضمن تخطيط مهام التدقيق ووضع الأهداف والنطاق، تنفيذ إجراءات التدقيق (جمع الأدلة باستخدام أساليب مثل المقابلات والاستبيانات وأدوات المراجعة التقنية)، تقييم عناصر الرقابة وتحديد نقاط الضعف، توثيق النتائج، وإعداد تقارير التدقيق مع التوصيات. كما يشمل ضمان الجودة لعملية التدقيق والالتزام **بالمعايير المهنية** (مثل معايير ISACA للتدقيق).

2. **حوكمة تقنية المعلومات وإدارة الموارد التقنية:** يغطي هذا الجزء كيفية **إدارة المؤسسة لموارد تقنية المعلومات** وأمنها. يشمل تقييم هيكل الحوكمة في قسم تقنية المعلومات، مواءمة استراتيجية تقنية المعلومات مع استراتيجية الشركة، سياسات وإجراءات التقنية، **إدارة المخاطر التقنية** وكيفية مراقبتها، هيكلة قسم تقنية المعلومات وصلاحياته، إضافة إلى **إدارة المشاريع التقنية** واستثمارات تقنية المعلومات من منظور الحوكمة. هنا يركز المدقق على ما إذا كانت هناك ضوابط تنظيمية مناسبة لضمان تحقيق أهداف تقنية المعلومات ودعم أهداف العمل.

3. **اكتساب وتطوير وتنفيذ الأنظمة:** يركز هذا المجال على **دورة حياة تطوير الأنظمة (SDLC)** وكيفية التدقيق عليها. يشمل تقييم ضوابط **مشاريع تطوير البرمجيات** أو شراء الأنظمة الجاهزة، مراجعة مراحل التحليل والتصميم والاختبار والتطبيق لضمان تضمين الضوابط الأمنية والرقابية في كل مرحلة، تقييم **ضوابط التغيير** عند تعديل الأنظمة، وفحص ضمان الجودة في عمليات تسليم المشاريع التقنية. أيضًا يتضمن تدقيق **إدارة التغييرات والترقيات** للأنظمة القائمة للتأكد من اتباع منهجيات سليمة وتوثيق كافٍ وبيئات اختبار منفصلة. الهدف هو ضمان أن عملية بناء أو شراء الأنظمة الجديدة تتم وفق ضوابط تحمي من ظهور ثغرات أو مشاكل تشغيلية مستقبلًا.

4. **عمليات وخدمات تقنية المعلومات** (تشمل الدعم والصيانة): يغطي هذا الجزء تقييم الضوابط المطبقة في **تشغيل البنية التحتية التقنية** يوميًا. يشمل ذلك تدقيق **إدارة العمليات** (مثل إجراءات التشغيل القياسية، وحدات الدعم الفني، وإدارة حوادث تقنية المعلومات والأعطال)، **إدارة الوصول** للمستخدمين (حسابات الدخول والصلاحيات وآليات الموافقة والمراجعة الدورية للحسابات)، **إدارة الأصول** التقنية (كالسيرفرات وأجهزة الشبكة وقواعد البيانات) وصيانتها، **إدارة قواعد البيانات** وعمليات النسخ الاحتياطي واستعادة البيانات، **أمن الشبكات والاتصالات** والتأكد من فعالية الضوابط (جدران نارية، أنظمة كشف التسلل، ...إلخ)، بالإضافة إلى تقييم جاهزية **خطط استمرارية الأعمال والتعافي من الكوارث** من المنظور التقني (هل توجد خطة، هل تم اختبارها؟). التركيز هنا على أن عمليات تقنية المعلومات اليوميّة تتم وفق سياسات وضوابط تضمن استمرارية الأعمال وحماية الخدمات من الفشل أو الاختراق.

5. **حماية أصول المعلومات:** يغطي هذا المجال **الجوانب الأمنية البحتة** ضمن نطاق التدقيق. يتضمن تقييم فعالية الضوابط الأمنية لحماية **موجودات المعلومات** المهمة لدى المؤسسة. يشمل ذلك سياسات أمن المعلومات ومدى اتباعها، إجراءات **تحديد وتصنيف الأصول** الحساسة (بيانات أو أنظمة)، ضوابط الوصول المنطقي (مثل كلمات المرور وتعدد العوامل والتشفير) ومدى كفايتها، ضوابط الأمن المادي (حماية مراكز البيانات ومواقع الأجهزة)، إجراءات **رصد الحوادث الأمنية والاستجابة** لها، تدريب الموظفين على الوعي الأمني، والامتثال لمعايير أمنية أو متطلبات قانونية محددة (مثل حماية البيانات الشخصية). المدقق هنا يتحقق من أن البيئة التقنية للمؤسسة محمية بشكل ملائم ضد التهديدات الشائعة وأن أي قصور في الضوابط يتم تحديده ومعالجته.

هذه المجالات الخمسة تعطي صورة كاملة لمهام مدقق نظم المعلومات ودوره في ضمان أن الضوابط التقنية تعمل كما ينبغي لحماية أصول الشركة وتدعيم أهدافها.

- **المتطلبات المسبقة:** يُطلب للحصول على اعتماد CISA وجود خبرة عملية لمدة **5 سنوات** في مجال **تدقيق نظم المعلومات أو الرقابة عليها أو أمن المعلومات**. يمكن تخفيض حتى 3 سنوات من هذا المتطلب وفق قواعد ISACA لحالات تعليمية أو شهادات محددة: فمثلًا درجة جامعية أربع سنوات قد تُعادل سنة من الخبرة، وشهادة مثل CISA أو CISSP أو الماجستير في أمن المعلومات قد تعادل سنة أخرى، وهكذا (لكن بحد أقصى 3 سنوات مجتمعة). ومع ذلك، ينبغي أن تكون معظم الخبرة في مجال **التدقيق التقني** مباشرة، حيث يجب أن يقضي المرشح سنة على الأقل من الخبرة في عملية تدقيق نظم المعلومات نفسها (لا يُعفى عنها). كحال CISM، يجب التقدم بطلب نيل

الشهادة خلال 5 سنوات من اجتياز الامتحان وإلا يحتاج لإعادته.

- **طبيعة الاختبار ومحتواه:** يشابه امتحان CISA بقية امتحانات ISACA من حيث الصيغة؛ فهو عبارة عن **150 سؤال اختيار من متعدد** تُجاب في غضون 4 ساعات. الأسئلة مصممة لاختبار **الفهم التطبيقي** لمعايير التدقيق والرقابة. كثير منها في شكل سيناريو: على سبيل المثال قد يُسأل "إذا وجد المدقق أن سياسة النسخ الاحتياطي للبيانات غير موجودة في المؤسسة، ما مدى خطورة ذلك وما التوصية الأنسب؟". الخيارات ستكون كلها تبدو صحيحة لكن واحدة منها تعكس **أفضل ممارسة** حسب معايير ISACA. لذلك يستلزم الامتحان فهمًا للمبادئ الإرشادية في مجال التدقيق أكثر من مجرد الحقائق التقنية. نظام النجاح أيضًا على مقياس 800، وبحد أدنى 450 (أي ما يقارب 70% كما هو معتاد). بعد نيل الشهادة، يتعين الالتزام بمتطلبات التجديد (120 ساعة تعليم مستمر كل 3 سنوات، والالتزام بأخلاقيات المهنة ومعايير التدقيق المهني). تعتبر CISA شهادة معترف بها عالميًا وتضفي على صاحبها **موثوقية عالية في مجال التدقيق وضبط نظم المعلومات**، وهي كثيرًا ما تكون متطلبًا وظيفيًا للمناصب المتقدمة في التدقيق الداخلي أو الخارجي لتقنية المعلومات.

شهادة OSCP (Offensive Security Certified Professional)

- **الجهة المانحة للشهادة:** شركة Offensive Security (وهي الجهة التي تطور توزيعة Kali Linux الشهيرة وأطر اختبار الاختراق المتقدمة).

- **الفئة المناسبة لها:** تختلف **OSCP** عن باقي الشهادات المذكورة إذ تركز بشكل صارم على **المهارات العملية في اختبار الاختراق**. هي موجَّهة للخبراء التقنيين الذين يعملون في مجال **الأمن الهجومي**، أي مختبري الاختراق المحترفين الذين لديهم خبرة تقنية قوية ويرغبون في إثبات قدراتهم عبر أحد أصعب الاختبارات

العملية. المرشح المناسب هو شخص يمتلك خلفية صلبة في إدارة النظم (خاصة Linux) والشبكات والبرمجة/البرمجة النصية، وقام فعليًا بتنفيذ اختبارات اختراق على بيئات مختبرية أو حقيقية. غالبًا يكون قد اجتاز شهادات أساسية مثل CEH أو PenTest+، أو على الأقل تدرب عبر منصات اختراق مثل HackTheBox و TryHackMe، أو حضر دورة **PWK (Penetration Testing with Kali)** من Offensive Security نفسها. الشهادة تناسب من يسعى للعمل كـ **مختبر اختراق بدوام كامل** أو **استشاري أمن هجومي**، وهي مطلوبة في بعض الوظائف المتقدمة في الشركات الأمنية.

- **المهارات والمجالات التي تغطيها:** يركز منهج OSCP (الذي يغطيه تدريب PEN-200 من OffSec) على منهجية اختبار اختراق شاملة مع تأكيد على **الإبداع والقدرة على حل المشاكل**. على الحاصل على OSCP أن يكون قادرًا على: جمع المعلومات عن الهدف واستغلال نقاط الضعف المعروفة وغير المعروفة للوصول إلى الأنظمة، **استغلال الثغرات اليدوية** دون الاعتماد على أدوات تلقائية فقط (بما في ذلك القدرة على قراءة كود الاستغلالات وتعديلها لملاءمة بيئة معينة أو ربما كتابة استغلالات بسيطة بنفسه)، فهم **ثغرات التطبيقات وخدمات الشبكات** الشائعة (مثل ثغرات الBuffer Overflow، وثغرات الWeb مثل SQLi وXSS وFile Inclusiong وغيرها) وكيفية استغلالها للحصول على دخول إلى النظام، إجراء **تصعيد امتيازات** (Privilege Escalation) على كل من أنظمة Windows وLinux للوصول إلى صلاحيات أعلى بعد الدخول الأولي، **التحرك بشكل أفقي ورأسي** داخل الشبكة (Pivoting) لاختراق أنظمة أخرى اعتمادًا على foothold تم الحصول عليه، وكل ذلك ضمن **بيئة معملية مغلقة** تحاكي شبكة شركة تحتوي على مجموعة متنوعة من الأنظمة والخدمات. أيضًا من المهارات الجوهرية التي تثبتها OSCP هي **كتابة تقرير اختبار اختراق احترافي**، حيث يجب على المرشح توثيق كل خطوة قام بها والأدوات المستخدمة ونتائجها، وشرح الثغرات وطريقة استغلالها وتقديم

توصيات سد الثغرات بصورة منهجية. هذا يعني أن الحاصل على OSCP لا يمتلك فقط مهارة الاختراق، بل **مهارة التواصل الكتابي التقني** أيضًا.

- **المتطلبات المسبقة:** لا توجد اشتراطات رسمية محددة للتقدم لامتحان OSCP؛ إذ يستطيع أي شخص شراء قسيمة الامتحان بعد الاشتراك في تدريب PEN-200 (أو إثبات حصوله على التدريب). لكن فعليًا، نظرًا لصعوبة التحدي، ينبغي للمرشح أن يكون متمكنًا مسبقًا من مفاهيم الاختراق الأساسية. يُفضل أن يمتلك خبرة لا تقل عن **سنة إلى سنتين** في إدارة أنظمة Linux/Windows أو دعم الشبكات مع اشتغاله في أوقات الفراغ على تجربة الاختراق في المختبرات. المهارات البرمجية البسيطة في **بايثون أو Bash** مهمة لفهم/تعديل السكربتات. كما أن الإلمام بثغرات التطبيقات وطرق استغلالها (مثلاً عبر منصات تعليمية أو CTFs) يعتبر ضروريًا. العديد ممن يتقدمون لـ OSCP يكونون حاصلين على CEH أو ما يماثلها ويقررون رفع مستواهم العملي من خلالها. باختصار، لا يُنصح بها كأول شهادة أمن سيبراني لشخص حديث العهد بالمجال.

- **طبيعة الاختبار ومحتواه:** يُعد امتحان OSCP من أكثر الامتحانات تميّزًا في مجاله لاعتماده الكامل على الأداء العملي بدل الأسئلة النظرية. يمتد الاختبار عبر **يومين (48 ساعة)** مقسمة إلى جزئين: **24 ساعة** مخصصة لعمليات الاختراق في بيئة افتراضية خاصة بالمرشح، تليها **24 ساعة** أخرى لإعداد **تقرير مفصل** يشرح ما تم إنجازه. في جزء الاختراق، يحصل المرشح على اتصال بشبكة افتراضية تحوي عادةً حوالي 5 أهداف (أجهزة) ذات أنظمة تشغيل وخدمات مختلفة بعضها مخفي خلف الأخرى. لكل هدف قيمة نقاط معينة وفقًا لصعوبة اختراقه. يجب على المرشح اختراق أكبر عدد ممكن من الأجهزة وجمع "أعلام" رقمية (ملفات دليل) لإثبات وصوله الإداري إليها. غالبًا، يتضمن التحدي جهازًا واحدًا على الأقل يتطلب **استغلال ثغرة يوم-صفر مصغرة**

(ثغرة غير مباشرة) أو **ثغرة من تطوير الممتحن نفسه** كجزء من المهارات المطلوبة (خاصة في الاصدارات الأحدث من الامتحان)، إضافة لأجهزة تتطلب إتقان خطوات تصعيد الامتيازات المعقدة أو الربط بين معلومات من عدة أجهزة. أما **جزء التقرير**، فهو لا يقل أهمية؛ إذ يجب أن يشمل توثيقًا لكل خطوة نفذها المرشح: أوامر الطرفية المستخدمة، الشفرة البرمجية التي كُتبت أو عُدلت، لقطات للشاشة كأدلة، شرحًا لنوع الثغرة في كل جهاز وكيفية استغلالها، وتوصيات لإصلاحها. يتم تقييم المرشح على كفاءة الاختراق (عدد النقاط المحصّلة من الأهداف) **وعلى جودة التقرير** معًا. عادةً يتطلب النجاح الحصول على **70 نقطة من أصل 100** مقسمة على الأهداف (كل هدف لديه نقاط، وبعض النقاط مرتبطة بتقديم شرح وافٍ في التقرير). **لا توجد أسئلة نظرية** أو اختيار من متعدد على الإطلاق. إذا لم ينجح المرشح في المحاولة الأولى، بإمكانه إعادة الاختبار بعد تجهيز أفضل. وعند النجاح، يحصل مباشرة على شهادة OSCP التي لا تحتاج لتجديد دوري حاليًا (شهادة مدى الحياة)، مما يعني أن حاملها قد أثبت في تلك اللحظة مهارات اختراق عملية ملموسة. عمومًا، يحمل الحصول على OSCP وزنًا كبيرًا في مجتمع الأمن السيبراني، حيث يُعد **دليلًا على الجدارة الفنية العالية** في مجال الاختراق الأخلاقي.

ختامًا، يمثل هذا الاستعراض الشامل دليلًا مرجعيًا للراغبين في دخول مجال الأمن السيبراني أو التطور فيه عبر **الشهادات الاحترافية**. من المهم اختيار الشهادة المناسبة استنادًا إلى مستوى خبرتك الحالي واهتماماتك المهنية المستقبلية؛ فالشهادات للمبتدئين تساعدك على تأسيس معرفي قوي، والشهادات المتوسطة تصقل مهاراتك التخصصية، أما شهادات المحترفين فتبوّئك مكانة الخبير المتمرس. إن الاستثمار في نيل إحدى هذه الشهادات **يتطلب جهدًا ودراسة** ولكنه يعود بفوائد

جمّة على المستوى المهني، حيث يعزز من فرصك الوظيفية ويثبت لأرباب العمل أنك ملتزم بتطوير نفسك ومواكب لأحدث معايير المجال. الأمن السيبراني ميدان سريع التغير، والشهادات تساعد على **الاستمرار في التعلم المنهجي** والتواصل مع مجتمع المحترفين. لذلك، ضع خطة لمسارك التعليمي والعملي، واختر الشهادة الأنسب لأهدافك، وتذكر أن **رحلة التعلم في الأمن السيبراني مستمرة لا تنتهي** نظرًا لتطور التهديدات والتقنيات باستمرار. بالتوفيق في مسعاك نحو الاحتراف في حماية المعلومات والأنظمة!

اختبارات الأمن السيبراني

مقدمة

في عصر تزداد فيه التهديدات السيبرانية تعقيدًا وانتشارًا، أصبحت اختبارات الأمن السيبراني عنصرًا أساسيًا لحماية الأنظمة والمعلومات. تهدف هذه الاختبارات إلى تقييم مستوى الأمان في الشبكات والأنظمة والتطبيقات من خلال محاكاة هجمات إلكترونية واكتشاف الثغرات ونقاط الضعف. ومن خلال تحديد تلك الثغرات قبل أن يستغلها المهاجمون، يمكن للمؤسسات تعزيز دفاعاتها ورفع جاهزيتها ضد الهجمات الحقيقية. بالإضافة إلى ذلك، تسهم اختبارات الأمن السيبراني في ضمان الامتثال للمعايير التنظيمية وتجنب الخسائر الناجمة عن الاختراقات الأمنية، مما يجعلها جزءًا حيويًا من استراتيجية الأمن لأي مؤسسة.

أنواع اختبارات الأمن السيبراني

تتنوع اختبارات الأمن السيبراني من حيث الأسلوب والنطاق والأهداف. فيما يلي أبرز الأنواع الشائعة لهذه الاختبارات:

- **اختبار الاختراق (Penetration Testing):** محاكاة هجوم إلكتروني فعلي على نظام أو شبكة بهدف تحديد الثغرات الأمنية ومحاولة استغلالها كما يفعل المهاجم الحقيقي. يساعد هذا النوع من الاختبارات على قياس مدى قوة الدفاعات الحالية وفهم التأثير المحتمل لأي اختراق ناجح، مما يمكّن فريق الأمن من معالجة نقاط الضعف قبل وقوع هجوم حقيقي.

- **اختبارات الصندوق الأسود/الأبيض/الرمادي:** تشير هذه المصطلحات إلى مستوى المعرفة والمعلومات المتاحة لمختبِر الاختراق قبل بدء الاختبار. في اختبار **الصندوق الأسود** لا يتم تزويد المُختبِر بأي معلومات مسبقة عن النظام

قيد الاختبار، ما يحاكي هجومًا خارجيًا من قبل مهاجم لا يملك معرفة داخلية. أما **الصندوق الأبيض** فيتلقى فيه المُختبِر معرفة كاملة عن هيكلية النظام وكود المصدر وبيانات الاعتماد، مما يسمح بفحص شامل ودقيق لكل المكوّنات (أشبه باختبار من الداخل). ويأتي **الصندوق الرمادي** كحل وسط، حيث يحصل المُختبِر على معلومات محدودة أو صلاحيات معيّنة فقط، وبالتالي يجمع بين مزايا الاختبارين السابقين ليقدّم رؤية واقعية عن مستوى الأمان من منظور يمتلك بعض المعلومات الداخلية.

- **تقييم الثغرات الأمنية (Vulnerability Assessment):** عملية فحص منهجية تهدف إلى تحديد مواطن الضعف الأمنية في الأنظمة والتطبيقات دون محاولة استغلالها بشكل نشط. يقوم هذا التقييم عادةً باستخدام أدوات آلية (مثل ماسحات الثغرات) لكشف الثغرات المعروفة وتقديم قائمة بها مع تصنيف لدرجة خطورتها. يتميّز تقييم الثغرات بالسرعة والشمول في تغطية نطاق واسع من الأهداف، لكنه لا يتعمّق في إثبات مدى إمكانية استغلال كل ثغرة كما يحدث في اختبار الاختراق.

- **اختبارات التطبيقات والشبكات:** تستهدف هذه الاختبارات جوانب محددة من البنية التحتية التقنية. **اختبار أمن التطبيقات** يركّز على فحص الثغرات في تطبيقات البرمجيات (مثل تطبيقات الويب أو الهاتف المحمول)، بما في ذلك مشاكل شائعة مثل حقن أوامر قواعد البيانات SQL، والبرمجة عبر المواقع (XSS)، وغيرها، وذلك لضمان أن التطبيق مُحصَّن ضد الهجمات المعروفة. أما **اختبار أمن الشبكات** فيُعنى بتحليل الشبكة والبنية التحتية (مثل الخوادم وأجهزة التوجيه والجدران النارية) لكشف نقاط الضعف مثل المنافذ المفتوحة، والإعدادات الخاطئة، وبروتوكولات الاتصال غير الآمنة. يعتبر كلا النوعين مُكمّلًا للآخر لتحقيق نظرة شاملة على أمن المؤسسة، حيث يغطي أحدهما جانب

البرمجيات والآخر جانب المعدات والهيكلة الشبكية.

- **اختبارات الهندسة الاجتماعية:** تركّز هذه الاختبارات على العنصر البشري كجزء من منظومة أمن المعلومات. يقوم المختبِرون في هذا النوع بمحاولة خداع الأفراد أو استغلال الثقة للحصول على معلومات سرية أو وصول غير مصرح به، دون الاعتماد على الاختراق التقني المباشر. تشمل أساليب الهندسة الاجتماعية اختبارات التصيّد الاحتيالي (Phishing) عبر البريد الإلكتروني لاختبار وعي الموظفين، ومحاولات انتحال الهوية للحصول على معلومات حساسة عبر الهاتف (مثل الادعاء بمكالمة دعم تقني)، وحتى محاولات الوصول المادي غير المصرّح به للمكاتب أو الأجهزة. الهدف هو تقييم مدى جاهزية العاملين والإجراءات التنظيمية لمثل هذه الهجمات، ثم تعزيز الوعي والتدريب الأمني بناءً على النتائج لسد الثغرات البشرية في الدفاعات.

- **الاختبارات الدورية مقابل الاختبارات حسب الطلب:** يشير هذا التصنيف إلى توقيت وجدولة إجراء اختبارات الأمن السيبراني. **الاختبارات الدورية** هي اختبارات تُنفَّذ بشكل منتظم (مثلًا بصورة ربع سنوية أو سنوية) كجزء ثابت من برنامج الأمن في المؤسسة، بهدف المراقبة المستمرة وتحسين المستوى الأمني مع مرور الوقت. أما **الاختبارات حسب الطلب** فتتم عند الحاجة أو في ظروف محددة، مثل إطلاق نظام جديد، أو بعد حدوث حادثة أمنية، أو عند الاشتباه في تهديد معين؛ حيث يتم إجراء اختبار أمني مركَّز في تلك اللحظة. كلا النهجين ضروري؛ فالاختبارات الدورية تضمن كشفًا مستمرًا لأي ثغرات قد تظهر بمرور الزمن، بينما الاختبارات حسب الطلب توفر مرونة لفحص الأمن في الأوقات الحرجة أو غير الاعتيادية حسب مقتضيات الموقف.

خطوات تنفيذ اختبارات الأمن السيبراني

يتم تنفيذ اختبارات الأمن السيبراني وفق خطوات منهجية تضمن تغطية جميع الجوانب من مرحلة التخطيط الأولى وحتى تقديم النتائج والتوصيات النهائية. فيما يلي المراحل الأساسية لعملية الاختبار الأمني:

1. **جمع المعلومات (Reconnaissance):** في هذه المرحلة الأولية، يتم جمع أكبر قدر ممكن من المعلومات حول الهدف المراد اختباره (سواء كان نظامًا أم شبكة أم تطبيقًا). يشمل ذلك جمع البيانات المتاحة للعامة عن المؤسسة وأصولها (مثل نطاقات الإنترنت وعناوين IP المرتبطة بها، والمعلومات المنشورة عن الشركة أو الموظفين)، بالإضافة إلى استخدام أدوات المسح التقني (Scanning) لتحديد الأجهزة المضيفة النشطة، والمنافذ المفتوحة، والخدمات قيد التشغيل، وإصدار البرمجيات المستخدمة. يساعد جمع المعلومات على رسم خريطة أولية لـ "سطح الهجوم" المتاح وفهم البيئة المستهدفة قبل الشروع في المراحل التالية.

2. **التحليل والتخطيط:** بعد جمع المعلومات، يقوم فريق الاختبار بتحليل البيانات لتحديد نقاط الضعف المحتملة ووضع خطة منهجية للهجوم. تتضمن هذه الخطوة دراسة الثغرات المكتشفة أو المتوقع وجودها وتقييم مستوى خطورتها، ثم اختيار أساليب وأدوات الاختبار الملائمة لمحاولة استغلال تلك الثغرات بشكل آمن ومراقَب. في هذه المرحلة أيضًا يتم تحديد نطاق الاختبار بدقة والتأكد من وجود اتفاق واضح مع الجهة المالكة للنظام حول ما سيتم اختباره وكيفية ذلك (بما في ذلك حدود الاختبار الزمنية والجغرافية والأدوات المسموح استخدامها). يضمن هذا التخطيط المسبق أن تكون عملية الاختبار مُتحكَّمًا بها ولن تسبب أضرارًا غير مقصودة للبنية التحتية أو البيانات.

3. **التنفيذ (Execution):** في هذه المرحلة يبدأ التنفيذ الفعلي للاختبار بناءً على الخطة الموضوعة. يقوم مختبرو الاختراق بمحاولة استغلال الثغرات المكتشفة للوصول غير المصرح به إلى الأنظمة أو البيانات، تمامًا كما قد يفعل

المهاجم الحقيقي. يشمل ذلك إطلاق هجمات تقنية متنوعة، مثل استغلال ثغرات البرامج (على سبيل المثال: استغلال ثغرة في نظام تشغيل أو خادم ويب)، وحقن التعليمات البرمجية الخبيثة (مثل SQL Injection في قاعدة بيانات)، وتصعيد الامتيازات بعد الحصول على وصول أولي محدود، والتحرك أفقيًا عبر الشبكة إذا كان ذلك ضمن النطاق. قد تتضمن مرحلة التنفيذ أيضًا اختبارات الهندسة الاجتماعية (كإرسال رسائل تصيّد مستهدفة) إذا كانت مشمولة في نطاق الاختبار المتفق عليه. تتم عملية التنفيذ بحذرٍ شديد لضمان عدم التسبب في تعطيل الخدمات أو فقدان البيانات؛ فالاختبار يتم في بيئة مراقَبة، ويتم إيقاف الهجمات على الفور إذا تبيّن أنها قد تؤدي إلى ضرر فعلي خارج عن حدود المقبول. الهدف المحوري من هذه الخطوة هو إثبات إمكانية الاختراق وتقييم مدى تأثير أي استغلال ناجح على أمن المنظمة.

4. **التقرير والتوصيات (Reporting):** المرحلة الأخيرة هي توثيق نتائج الاختبار وتقديم التوصيات للتحسين. يُعِد فريق الاختبار تقريرًا تفصيليًا يتضمن جميع الثغرات ونقاط الضعف التي تم اكتشافها، مع وصف فني لكل منها وكيفية استغلالها (إن تم الاستغلال) أو كيفية إمكانية استغلالها نظريًا، بالإضافة إلى تقييم لخطورة كل ثغرة من حيث تأثيرها على الأعمال واحتمالية استغلالها. يشمل التقرير أيضًا تفاصيل الأدوات والطرق التي استُخدمت خلال الاختبار والخطوات المتبعة في التنفيذ لإعطاء صورة واضحة للجهة المستهدفة عمّا تم القيام به. الأهم من ذلك، يحتوي التقرير على **توصيات عملية** لمعالجة كل ثغرة وتقوية الوضع الأمني، مثل: تطبيق ترقيعات (Patches) لبرمجيات معيّنة، أو تعديل إعدادات ضعيفة التكوين، أو تحسين سياسات الوصول، أو تدريب الموظفين لرفع الوعي الأمني. بعد تقديم التقرير، يُعقد عادةً اجتماع ختامي (جلسة نقاش أو عرض تقديمي) مع أصحاب القرار والفريق التقني في المؤسسة لمراجعة النتائج وشرح المخاطر بلغتهم، والإجابة على الأسئلة، ووضع خطة إجراءات تصحيحية بجدول زمني لمعالجة جوانب الضعف

المكتشفة.

المعايير والمنهجيات المستخدمة

تعتمد اختبارات الأمن السيبراني على عدد من المعايير العالمية والمنهجيات المُعتمدة لضمان التغطية الشاملة واتباع أفضل الممارسات أثناء الاختبار. من أبرز هذه المنهجيات والمعايير:

- **OWASP (مشروع أمان تطبيقات الويب المفتوح):** هي منظمة غير ربحية توفر إرشادات وأدوات لتحسين أمن تطبيقات الويب. يشتهر مشروع OWASP بنشر قائمة **"أفضل 10 ثغرات في تطبيقات الويب"** (OWASP Top 10) والتي تُحدَّث دوريًا لتسليط الضوء على أخطر الثغرات الشائعة، كما يصدر **دليل اختبار أمان تطبيقات الويب** الذي يقدّم منهجية شاملة لاختبار مختلف جوانب أمن التطبيقات (مثل المصادقة، وإدارة الجلسات، وإدخال البيانات وغيرها). الاعتماد على موارد OWASP يساعد مختبري الاختراق على التركيز على أشهر مواطن الضعف وضمان عدم إغفال الثغرات المعروفة أثناء إجراء الاختبارات.

- **معايير NIST (المعهد الوطني للمعايير والتقنية):** يوفر NIST الأمريكي مجموعة من الإرشادات والمعايير المتعلقة بالأمن السيبراني، من ضمنها أدلة خاصة باختبارات الاختراق وتقييم الثغرات. على سبيل المثال، يقدم المنشور **NIST SP 800-115** إطارًا منهجيًا لكيفية إجراء اختبارات الأمن وتقنيات التقييم بشكل آمن وفعّال. تعتمد الكثير من الجهات الحكومية والخاصة على معايير NIST كمرجع أساسي لوضع سياسات الاختبار الأمني، حيث يحدد NIST خطوات واضحة مثل التخطيط المسبق، وأساليب جمع المعلومات، وإجراءات الاختبار الفني، وتوثيق النتائج. الامتثال لهذه المعايير يضمن أن الاختبارات تُنفَّذ وفقًا

لأفضل الممارسات المعترف بها حكوميًا ودوليًا.

- **منهجية OSSTMM (دليل اختبار أمان مفتوح المصدر):** هو منهج مفتوح المصدر لاختبار أمن المعلومات طُوِّر من قبل خبراء عالميين تحت إشراف معهد ISECOM. يوفر دليل OSSTMM إطار عمل علمي ومنظّم لتقييم الأمن واختبار الاختراق عبر خمسة مجالات رئيسية (المعلومات، والتحكم، والإجراءات، والقنوات، والبشر). تتميز هذه المنهجية بتحديد مقاييس كمية لقياس مستوى الثغرات ودرجة الثقة الأمنية بعد الاختبار، مما يساعد في تقديم نتائج قابلة للقياس والمقارنة. على سبيل المثال، يعرّف OSSTMM مفهوم "معدل السطح الموثوق" ليوضّح نسبة الأصول الآمنة مقابل المعرضة للخطر بعد الاختبار. استخدام OSSTMM يساعد المختبرين على اتباع منهجية دقيقة وشاملة وعدم الاقتصار على الفحص العشوائي، بل اتباع خطوات مدروسة وتوثيق منهجي للنتائج.

- **معيار تنفيذ اختبار الاختراق (PTES):** هو معيار صناعي وُضع بواسطة مجتمع مختصي الأمن بهدف توحيد خطوات عملية اختبار الاختراق وتفاصيلها. يقسم **PTES** عملية الاختبار إلى مراحل واضحة ومترابطة، بدءًا من **مرحلة ما قبل الاختبار (Pre-engagement)** التي يتم فيها الاتفاق على النطاق والأهداف والقواعد، مرورًا بمرحلة **جمع المعلومات** و**النمذجة والتحليل** لتقييم التهديدات والثغرات المحتملة، ثم **مرحلة الاستغلال (Exploitation)** حيث تُنفَّذ محاولات الاختراق الفعلية، تليها **مرحلة ما بعد الاستغلال (Post-Exploitation)** التي تركز على الحفاظ على الوصول وتقييم الأصول التي تم اختراقها، وأخيرًا مرحلة **إعداد التقرير**. يوفّر PTES قائمة تفصيلية بالمهام والتقنيات المقترحة في كل مرحلة، مما يساعد المختبرين على التأكد من تغطية جميع جوانب الاختبار وعدم إغفال أي خطوة مهمة. اعتماد هذا المعيار يعزّز من

اتساق جودة الاختبارات عبر مختلف الفرق والمشاريع.

(فضلًا عن ما سبق، هناك أيضًا معايير أخرى يعتمد عليها بعض المختبرين كمعيار ***ISSAF*** *القديم - إطار تقييم أمان نظم المعلومات - ومعايير* ***ISO*** *ذات الصلة بإدارة أمن المعلومات التي تشمل جوانب الاختبار الأمني، لكن OWASP وNIST وOSSTMM وPTES تظل من أكثر الأطر استخدامًا وانتشارًا في مجال اختبار الأمن السيبراني.)*

الاعتبارات الأخلاقية والقانونية

عند إجراء اختبارات الأمن السيبراني، هناك مجموعة من الاعتبارات الأخلاقية والقانونية التي يجب مراعاتها لضمان أن عملية الاختبار تتم بشكل مشروع وآمن وتحترم حقوق جميع الأطراف. من أهم هذه الاعتبارات:

- **الحصول على إذن خطي وصريح:** يجب عدم الشروع في أي اختبار اختراق أو تقييم أمني دون موافقة رسمية واضحة من مالكي النظام أو البيانات المستهدفة. يتضمن ذلك عادةً توقيع عقد أو اتفاقية خطية تُحدّد نطاق الاختبار وشروطه، مثل **اتفاقية عدم الإفصاح (NDA)** لحماية سرية المعلومات، و**اتفاقية قواعد الاختبار (Rules of Engagement)** التي تبيّن ما هو مسموح ومحظور أثناء الاختبار. وجود هذه الموافقات الخطية يحمي كلًا من المُختبِر والجهة المالكة قانونيًا، ويضمن أن الاختبار يجري برضا الطرفين.

- **تحديد النطاق والالتزام به:** من الضروري جدًا رسم حدود واضحة لما سيشمله الاختبار الأمني قبل البدء. يشمل ذلك تحديد الأنظمة والتطبيقات والعناوين الشبكية الداخلة ضمن الاختبار، بالإضافة إلى تحديد الفترة الزمنية المسموح إجراء الاختبار خلالها وأوقات التنفيذ (لتفادي التأثير على أوقات الذروة مثلًا). يجب على المُختبِرين الالتزام الصارم بهذا النطاق وعدم تجاوزه إلى أي أنظمة أو بيانات خارج التفويض. إن أي خروج عن النطاق المتفق عليه قد يعتبر

اختراقًا غير مشروع ويتعرّض فيه المُختبِر للمساءلة القانونية، فضلًا عن إمكانية تسبّبه في أضرار لأطراف أخرى غير مشمولة بالاتفاق.

- **الامتثال للقوانين والتنظيمات:** على مختبر الأمن السيبراني الإلمام بالقوانين المحلية والدولية ذات الصلة. ممارسة **القرصنة الأخلاقية** تختلف عن القرصنة غير المشروعة في وجود الإذن، لكن بالرغم من ذلك قد تكون هناك أدوات أو تقنيات ممنوعة قانونيًا حتى ضمن إطار الاختبار (مثل استخدام أساليب اعتراض الاتصالات في بعض الدول). يجب التأكد من أن جميع خطوات الاختبار تقع ضمن إطار القانون (مثل قوانين حماية البيانات والخصوصية، وقوانين جرائم تقنية المعلومات) وألا تنتهك أي تشريعات. كذلك، ينبغي احترام سياسات الشركة الداخلية والمعايير المنظمة للصناعة التي قد تكون معنية (مثل معايير PCI-DSS في حالة اختبار أنظمة بطاقات الدفع).

- **عدم إلحاق ضرر فعلي بالأنظمة:** الهدف من الاختبار هو **التقييم** وليس التخريب، لذلك ينبغي اتخاذ الحيطة لتجنّب التسبّب في أضرار أثناء الاختبار. على سبيل المثال، ينبغي توخي الحذر عند تنفيذ هجمات قد تكون ذات تأثير خطير كاختبارات حجب الخدمة (DoS) أو تحميل الأنظمة ببيانات ضخمة، وألا يتم اللجوء إلى مثل هذه الأساليب إلا بوجود ضرورة قصوى وضمن نطاق متفق عليه مسبقًا. يُفضل دائمًا بدء الاختبارات بشكل تدريجي وتصعيد الشدة بحذر، ومراقبة استجابة الأنظمة أولًا بأول. في حال لوحظ أي تأثير غير متوقع (مثل تباطؤ شديد أو تعطل خدمة) يجب إيقاف الاختبار فورًا والتنسيق مع الفريق المسؤول. كذلك، من الجيد إجراء الاختبارات الحساسة خارج أوقات العمل أو على بيئات تجريبية إن أمكن لتفادي أي انقطاع في الخدمات الإنتاجية.

- **الحفاظ على السرية وخصوصية البيانات:** أثناء الاختبار قد يصل المختبر إلى معلومات حساسة (كبيانات عملاء، أو بيانات مالية، أو أسرار تجارية). من

الضروري التعامل مع أي بيانات يتم الوصول إليها بسرية تامة. هذا يعني عدم نسخ البيانات أو الاحتفاظ بها خارج بيئة الاختبار، وعدم مشاركتها مع أي جهة غير مخول لها الاطلاع. بعد انتهاء الاختبار، يجب تسليم أو إتلاف أي بيانات سرية تم الحصول عليها، وفقًا لشروط الاتفاق مع الجهة المالكة. التزام المُختبِر بأخلاقيات المهنة يقضي بألا يُفشي أي معلومة اكتُشفت خلال الاختبار لأي طرف ثالث، وألا يستخدمها لمصلحته الخاصة. اتفاقيات عدم الإفصاح (NDAs) التي يوقعها المختبرون تجعل هذا الالتزام رسميًا وقانونيًا.

- **السلوك الأخلاقي والمهني:** يُتوقع من مختبري الاختراق الالتزام **بمدونة سلوك** أخلاقية عالية. العديد من المنظمات المهنية (مثل (ISC)² وEC-Council وغيرهما) لديها مواثيق أخلاقية يجب على الأعضاء والشهادات المُعتمَدة اتباعها. من أهم معايير السلوك المهني: تحرّي المصلحة الفضلى للعميل (أي أن يكون هدف المختبِر دائمًا مساعدة الشركة على تعزيز أمنها)، وتجنّب أي تعارض مصالح أثناء العمل (مثلاً ألا يقوم المختبِر باختبار نظام لجهة هو مرتبط بها بطريقة ما بدون تصريح مناسب)، والتحلّي بالنزاهة والصدق في جميع مراحل الاختبار (كأن يبلغ عن جميع الثغرات بموضوعية تامة دون مبالغة أو تهوين)، والحفاظ على المهنية عند تقديم النتائج (فلا يستخف بقدرات فريق الشركة ولا يبالغ في قدراته الذاتية). السلوك الأخلاقي يشمل أيضًا عدم استغلال المعرفة أو الوصول المكتسب خلال الاختبار بأي شكل يضر بمصلحة الجهة المفحوصة أو المستخدمين.

المهارات المطلوبة لأداء هذه الاختبارات بشكل احترافي

يتطلّب التنفيذ الاحترافي لاختبارات الأمن السيبراني توفر مجموعة متنوعة من المهارات التقنية والعملية في المختصين القائمين على هذه المهام. فيما يلي أبرز المهارات التي ينبغي توافرها في محترفي اختبار الأمن السيبراني:

- **فهم عميق لبنية الشبكات وأنظمة التشغيل:** ينبغي أن يمتلك مختبر الأمن فهمًا قويًا لكيفية عمل الشبكات (بما في ذلك البروتوكولات الشائعة مثل TCP/IP وHTTP، وطريقة عمل أجهزة الشبكة كالموجّهات والجدران النارية وأنظمة كشف التسلل) وكذلك إلمام بأنظمة التشغيل المختلفة (مثل Windows، Linux، Unix، وأنظمة تشغيل الأجهزة المحمولة). تتوزع الثغرات الأمنية في كثير من الأحيان على مستويات عدة (شبكة، نظام تشغيل، تطبيق)، لذلك فإن المعرفة التفصيلية ببنية الشبكات وآلية عمل أنظمة التشغيل تساعد المختبر على تحديد نقاط الضعف المحتملة ضمن كل طبقة وفهم كيفية استغلالها أو تأمينها.

- **إتقان لغات البرمجة والبرمجة النصية:** القدرة على قراءة وكتابة الشيفرات البرمجية تُعد ميزة كبيرة لمختبري الاختراق. يساعد ذلك في فهم الثغرات البرمجية المعقّدة عند مراجعة الشيفرة المصدرية للتطبيقات (في اختبارات الصندوق الأبيض مثلًا)، كما يمكّن المختبر من تطوير أدوات أو سكربتات مخصصة لأتمتة بعض أجزاء الاختبار أو استغلال ثغرات معينة. من المفيد إتقان لغات برمجية متعددة: فعلى سبيل المثال **لغة بايثون (Python)** تُستخدم على نطاق واسع في كتابة أدوات الاختبار السريع، و**لغة جافا سكريبت** مهمة لفهم واستغلال ثغرات تطبيقات الويب، و**لغة SQL** لفهم استعلامات قواعد البيانات واختبار حقن SQL. كما أن الإلمام بلغات برمجية منخفضة المستوى (مثل C أو معرفة بالبرمجة بلغة التجميع) يصبح ضروريًا عند محاولة فهم أو تطوير استغلالات للثغرات على مستوى النظام أو الذاكرة.

- **معرفة واسعة بثغرات الأمن السيبراني وأنواع الهجمات:** يجب على المختبر الإلمام بمختلف أنواع الثغرات الأمنية الشائعة وكيفية عملها. يشمل ذلك الثغرات في تطبيقات الويب (مثل ثغرات حقن تعليمات SQL، وثغرات البرمجة عبر المواقع XSS، ورفع ملفات خبيثة عبر واجهات التحميل)، ونقاط الضعف

على مستوى الشبكة (مثل استخدام بروتوكولات أو إعدادات غير آمنة، أو منافذ مفتوحة بدون حماية، أو هجمات على بروتوكول DNS وARP)، وكذلك الثغرات في أنظمة التشغيل والبرامج (مثل ثغرات تجاوز سعة الذاكرة Buffer Overflow، وسوء إعدادات الصلاحيات، والتخزين غير الآمن لكلمات المرور). بالإضافة إلى فهم الثغرات، ينبغي للمختبر معرفة تقنيات الهجوم والاستغلال المرتبطة بها، مثل هجمات **القوة الغاشمة** لكسر كلمات المرور، ونشر **البرمجيات الخبيثة (Malware)**، وتقنيات **الهندسة الاجتماعية** لخداع المستخدمين. هذه المعرفة الموسوعية تمكّن المختبر من البحث الاستباقي عن الثغرات في كل مكوّن، وتخيّل سيناريوهات الهجوم المحتملة التي قد يلجأ إليها المهاجمون الحقيقيون.

- **الخبرة في استخدام أدوات الاختبار الأمني:** يعتمد مختبرو الاختراق على ترسانة من الأدوات البرمجية المتخصصة التي تساعدهم في الكشف عن الثغرات وتحليلها. إتقان استخدام هذه الأدوات يساهم في تسريع عملية الاختبار وزيادة دقتها. على سبيل المثال، ينبغي للمختبر أن يتقن استخدام **ماسحات الثغرات** Vulnerability Scanners (مثل: Nessus، OpenVAS) لفحص الأنظمة بحثًا عن الثغرات المعروفة تلقائيًا، واستخدام **أدوات تحليل الشبكات** (مثل: Nmap لفحص المنافذ وتحديد الخدمات، Wireshark لتحليل حركة المرور الشبكية) لفهم بنية الشبكة والتقاط أي بيانات ضرورية. كذلك، **أطر العمل الاختراقية** مثل Metasploit Framework تُعد أساسية لمختبري الاختراق حيث توفر منصة جاهزة لاستغلال الثغرات المعروفة وتشغيل شفرات الاستغلال (Exploits) ضد الأهداف. أيضًا، أدوات اختبار تطبيقات الويب مثل **Burp Suite** مهمة لاعتراض وفحص وتعديل حركة مرور HTTP واكتشاف ثغرات الويب يدويًا أو نصف أوتوماتيكي. المختبر المحترف يكون قادرًا على اختيار الأداة المناسبة لكل مهمة، وفهم مخرجاتها بدقة، وتخصيص إعداداتها حسب الحاجة، بل

وأحيانًا برمجة أدواته الخاصة إن لزم الأمر.

- **مهارات التحليل وحل المشكلات:** يعد التفكير التحليلي والمنطقي، إلى جانب القدرة على حل المشكلات بطريقة إبداعية، من أهم السمات التي تميز مختبِر الاختراق المحترف. في البيئات الحقيقية، قد لا تكون الثغرات واضحة أو مباشرة الاستغلال، وقد يضطر المختبر إلى التجريب عدة مرات وبطرق غير تقليدية لكي يصل إلى هدفه. مثلًا، قد يجمع المختبر معلومات متفرقة من عدة مصادر (خوادم مختلفة أو حسابات متعددة الصلاحيات) ثم يربط بينها لاستنتاج وجود ثغرة معقدة. القدرة على تحليل مخرجات الأدوات (التي قد تكون كبيرة الحجم ومعقدة) واستخلاص النتائج المفيدة منها تتطلب صبرًا وانتباها للتفاصيل. على المختبر أيضًا أن يكون مرن التفكير؛ فإذا فشلت طريقة ما عليه تجربة أسلوب آخر، وإذا واجه نظامًا مجهولًا أو تقنية جديدة، يستطيع بسرعة دراستها وفهمها بحثًا عن نقاط ضعف. باختصار، مهارة حل المشكلات بشكل ابتكاري تساعد المختبر على تجاوز العقبات غير المتوقعة التي تظهر أثناء الاختبار.

- **مهارات التواصل وإعداد التقارير:** العثور على الثغرات لا يحقق فائدة تُذكر ما لم يتم توثيقه وشرحه بوضوح لمن يهمهم الأمر. لذلك فإن مهارة **صياغة التقارير الفنية** وشرح النتائج بطريقة مفهومة تُعد ضرورية. يجب أن يكون مختبر الأمن قادرًا على كتابة تقرير احترافي يُبرز المكتشفات بلغة تناسب القارئ المستهدف؛ فقد يُقدم التقرير إلى فرق تقنية تحتاج تفاصيل دقيقة وإرشادات إصلاح تقنية، وفي نفس الوقت قد يطلع عليه مديرون تنفيذيون يهمهم فهم مستوى الخطر بشكل مبسّط وتأثيره على الأعمال. تقرير الاختبار الجيد يتضمن مقدمة عن نطاق وأساليب الاختبار، ثم قائمة بالثغرات مصنفة حسب الخطورة، لكل منها وصف غير تقني موجز يبيّن المشكلة (لغير المختصين) ووصف تقني مفصّل لكيفية الاستغلال والآثار (للمختصين)، ثم توصيات العلاج. إلى جانب التقارير المكتوبة، غالبًا ما يُطلب من المختبر تقديم عرض شفهي أو اجتماع

لشرح النتائج، وهنا تبرز أهمية **مهارات العرض والتواصل الشفهي**: ينبغي أن يستطيع المختبر إيصال الأفكار والنتائج بوضوح وثقة، وأن يجيب على أسئلة الحضور (سواء كانوا تقنيين أو إداريين) بلغة يفهمونها، ويوازن بين عدم التهويل وإيصال خطورة الثغرات بشكل صحيح. هذه المهارات الناعمة تجعل عمل المختبر أكثر احترافية وتضمن تنفيذ توصياته وإجراءات الإصلاح بناءً على قدرته على الإقناع والتوضيح.

- **التعلم المستمر والبقاء على اطلاع:** مجال الأمن السيبراني سريع التغير والتطور؛ تظهر ثغرات جديدة باستمرار وتُكتشف طرق هجومية أكثر تطورًا مع مرور الوقت. لذلك يجب على المختص أن يحرص على **تحديث معرفته بشكل دوري**. يتم ذلك بعدة طرق، مثل: متابعة التقارير الأمنية وقواعد بيانات الثغرات الشهيرة (على سبيل المثال قواعد بيانات CVE و CWE)، وقراءة الأبحاث وأوراق العمل الجديدة في مجال الهجوم والدفاع، وحضور مؤتمرات أمن المعلومات وورش العمل، بالإضافة إلى الحصول على شهادات احترافية متقدمة للحفاظ على مستوى معرفته (حيث تتطلب معظم الشهادات تجديدًا أو تعليمًا مستمرًا). كما يفيد جدًا أن يكون جزءًا من **مجتمع الأمن السيبراني** عبر الإنترنت أو بشكل محلي، للمشاركة في منصات ومنتديات تناقش أحدث التهديدات والتقنيات، والاستفادة من خبرات الآخرين. القدرة على **التعلم الذاتي** والتكيف السريع مع التقنيات الحديثة تعتبر مهارة جوهرية؛ فالمختبر الذي يتمتع بالفضول العلمي والاستعداد الدائم لتعلّم أشياء جديدة سيكون أكثر قدرة على مواكبة أساليب المهاجمين الجدد وابتكار حلول دفاعية أو هجومية مناسبة لكل عصر.

أشهر اختبارات الأمن السيبراني

هناك العديد من الاختبارات والشهادات الاحترافية المعروفة عالميًا في مجال الأمن السيبراني، والتي تهدف إلى قياس واعتماد مهارات الأفراد العاملين في هذا المجال. تكمن أهمية هذه الاختبارات في أنها توفر **معيارًا موحّدًا** لتقييم المعرفة والخبرة، كما أنها تعزّز ثقة أصحاب العمل والعملاء في قدرات الحاصلين عليها. فيما يلي قائمة بأشهر اختبارات وشهادات الأمن السيبراني، مُصنّفة حسب مستوى الخبرة (مبتدئ، متوسط، متقدم)، مع نبذة مختصرة عن كل منها تشمل الهدف والمحتوى العام:

مستوى مبتدئ:

- **شهادة الهاكر الأخلاقي المعتمد (CEH - Certified Ethical Hacker):** تعتبر هذه الشهادة من الشهادات التأسيسية في مجال اختبار الاختراق والأمن السيبراني الهجومي. تهدف CEH إلى تعليم المتخصصين أساليب التفكير كالهاكر ولكن بشكل أخلاقي وقانوني، بحيث يتمكن الحاصل عليها من فهم **أدوات وتقنيات الاختراق** التي يستخدمها المخترقون غير الشرعيين، واستخدامها لكشف الثغرات في أنظمة وشبكات مؤسسته بهدف إصلاحها. يشمل محتوى التدريب والامتحان مواضيع متعددة مثل: أساليب **جمع المعلومات** عن الهدف، وفحص الأنظمة والشبكات عن الثغرات (Scanning & Enumeration)، واستغلال الثغرات المعروفة في الأنظمة والتطبيقات، واستخدام أدوات اختبار الاختراق الشائعة (كأدوات تحليل الشبكة واستكشاف المنافذ ونقاط الضعف)، بالإضافة لمقدمة حول أساليب **التشفير** والبرمجيات الخبيثة والفيروسات. شهادة CEH مقدمة من منظمة EC-Council، وعادةً ما تغطي أساسيات واسعة دون التعمق في مجال محدد، لذا فهي مناسبة للمبتدئين نسبيًا في مجال الاختراق الأخلاقي أو لمن لديه خلفية عامة في تكنولوجيا المعلومات ويرغب في دخول مجال الأمن السيبراني الهجومي. الحصول على هذه الشهادة يثبت إلمام الشخص بالمبادئ والأساليب الأساسية للاختراق الأخلاقي، ويكون بمثابة نقطة انطلاق نحو شهادات أكثر

تقدمًا.

- **شهادة Security+ (CompTIA Security+):** تُعد Security+ شهادة عالمية معترف بها كمعيار لمعارف الأمن السيبراني الأساسية. على الرغم من أنها ليست متخصصة حصريًا في اختبار الاختراق، إلا أنها تغطي **مفاهيم الأمن العامة** التي تشكل قاعدة ضرورية لأي متخصص أمن معلومات. تهدف الشهادة إلى التأكد من أن الحاصل عليها يفهم أساسيات حماية الشبكات والأنظمة، وإدارة التحكم بالوصول والصلاحيات، والتشفير، وتأمين البيانات، بالإضافة إلى فهم أنواع التهديدات والثغرات الشائعة. يشمل منهج Security+ موضوعات مثل: أساسيات **أنظمة التشغيل والشبكات** من منظور أمني، إدارة الثغرات والتحديثات الأمنية، مبادئ الجدار الناري ونظم كشف الاختراق، أمن التطبيقات والبيانات، والمهام المرتبطة بإدارة الهوية الرقمية وحماية الوصول. تعتبر Security+ غالبًا **أول شهادة** يسعى إليها المبتدئون في مجال الأمن السيبراني بشكل عام، لأنها تثبت امتلاكهم المعرفة الضرورية لبدء مشوارهم المهني في هذا المجال. حصول الشخص على Security+ يمنحه فهمًا واسعًا للأمن يمكن البناء عليه بالتخصص لاحقًا في مجالات أدق (مثل اختبار الاختراق أو التحليل الجنائي الرقمي أو الإدارة الأمنية).

مستوى متوسط:

- **شهادة محترف الأمن الهجومي المعتمد (OSCP - Offensive Security Certified Professional):** تُعتبر OSCP واحدة من أبرز الشهادات التقنية العملية في مجال اختبار الاختراق. ما يميز هذه الشهادة هو تركيزها الشديد على **المهارات العملية** بدلاً من الأسئلة النظرية التقليدية. يقدمها معهد Offensive Security، ويتطلب الامتحان من المتقدم خوض تجربة اختراق فعلية في بيئة معملية. يُمنح المتقدم للاختبار مدة 24 ساعة لاختراق عدد من الأجهزة

المتنوعة معدّة خصيصًا للاختبار بدرجات متفاوتة من الصعوبة، حيث يجب عليه استخدام مهاراته وأدواته للحصول على صلاحيات إدارية (Root أو Admin) على تلك الأنظمة. يتضمن منهج OSCP مجموعة واسعة من تقنيات الاختراق، تشمل: أساليب **الاستطلاع وجمع المعلومات** المتقدمة، استغلال الثغرات في الخدمات والشبكات (مثل ثغرات تجاوز الذاكرة في البرامج أو ثغرات خدمات الويب)، **تصعيد الصلاحيات** بعد الوصول الأولي إلى الأنظمة، والتحرك أفقيًا داخل الشبكة للوصول إلى أهداف أخرى. يعتمد المتدرب في OSCP بشكل كبير على توزيعة **كالي لينكس (Kali Linux)** وأدواتها في الاختبار، مع تشجيع على كتابة السكربتات أو تعديل استغلالات جاهزة لتتلاءم مع الموقف (مما يختبر قدرته على **البرمجة والتحليل** أيضًا). تعتبر OSCP شهادة **مُرهِقة ومُجزية في آن واحد** - فهي تتطلب جهدًا وتفكيرًا إبداعيًا عاليًا أثناء الامتحان، لكن النجاح فيها يُعد دليلًا قويًا على امتلاك صاحبها مهارات متقدمة في اختبار الاختراق العملي وقدرة على حل المشكلات تحت الضغط. غالبًا ما ينظر أصحاب العمل إلى شهادة OSCP باحترام لأنها تشير إلى مستوى احترافي ملموس في مجال القرصنة الأخلاقية.

- **شهادة مُختبِر الاختراق المُعتمد GPEN (GIAC Penetration Tester):** تقدم هذه الشهادة من قبل منظمة SANS العالمية ضمن شهادات GIAC، وهي موجّهة للمختصين الذين يرغبون في إثبات معرفتهم النظرية والعملية بمنهجيات اختبار الاختراق وأفضل الممارسات المتبعة فيه. يغطي امتحان **GPEN** نطاقًا واسعًا من المواضيع المتعلقة باختبار الاختراق، مركّزًا على التأكد من فهم المرشح **لدورة حياة الاختبار الكامل**. يشمل ذلك مراحل مثل: **تخطيط واستطلاع الاختبار** (Planning & Reconnaissance)، **تحليل الثغرات وتقييمها**، استراتيجيات مختلفة لعمليات **الاستغلال** (Exploitation) الآمن، بالإضافة إلى مواضيع في **اختبار الشبكات والتطبيقات** وأساسيات **الهندسة الاجتماعية** من منظور المختبر. على عكس OSCP، يكون امتحان GPEN عادةً

على شكل أسئلة (خيار متعدد وتحليلي) تقيس مدى استيعاب المفاهيم وتطبيقها، دون اختبار عملي مباشر أثناء الامتحان. لكن الكثيرين يحضرون لدخول GPEN عبر **دورات SANS التدريبية** المميزة (مثل دورة SEC560: Network Penetration Testing and Ethical Hacking) والتي تتضمن مختبرات وتمارين عملية مكثفة تجعل الحاصل على GPEN ذا خبرة تطبيقية جيدة أيضًا. تُعتبر GPEN شهادة **متوسطة إلى متقدمة المستوى** - فهي تتطلب فهمًا راسخًا لمفاهيم الاختراق الأخلاقي وكيفية إدارة وتنفيذ اختبار اختراق ناجح من الألف إلى الياء. حصول الشخص على GPEN يدل على أنه ملمّ بمنهجيات الاختبار الاحترافي وقادر على إجراء اختبار اختراق وتقييم أمني متكامل وفق معايير عالمية.

مستوى متقدم:

- **شهادة محترف أمن نظم المعلومات المعتمد (CISSP - Certified Information Systems Security Professional):** شهادة CISSP تُعد على نطاق واسع **المعيار الذهبي** لشهادات الأمن السيبراني الشاملة ومتعددة المجالات. على الرغم من أن CISSP ليست مركزة على اختبار الاختراق فقط، إلا أنها تغطي **ثمانية مجالات** أساسية في أمن المعلومات (تعرف باسم CBK - Common Body of Knowledge) تتضمن جوانب على مستوى عالٍ من الأهمية لأي برنامج أمن سيبراني ناجح. هذه المجالات تشمل: **إدارة أمن المعلومات والحوكمة** (بما في ذلك مفاهيم إدارة المخاطر واستمرارية الأعمال والامتثال)، **أمن الأصول** (حماية الأصول المادية والبيانات وتصنيفها والتعامل معها)، **هندسة الأمن والعمارة** (تصميم البنية الأمنية للأنظمة والتشفير وأمن الحوسبة السحابية وغيرها)، **أمن الشبكات والاتصالات**، **إدارة الهوية والصلاحيات**، **تقييم واختبار الأمن** (وهنا تغطي مفاهيم تتعلق بعمليات التدقيق الأمني والفحص الدوري والتي تشمل أنشطة مثل الاختراق المصرّح به)، **العمليات**

الأمنية (إدارة الحوادث والاستجابة للطوارئ والطب الشرعي الرقمي)، وأخيرًا **أمن تطوير البرمجيات**. الحصول على CISSP يتطلب خبرة عملية لا تقل عن 5 سنوات في مجالات أمن المعلومات (أو 4 سنوات مع درجة علمية ذات صلة)، مما يجعلها شهادة **متقدمة** موجهة لأصحاب الخبرة. تُمنح الشهادة من قبل منظمة (ISC)² بعد اجتياز امتحان طويل وشامل. حامل شهادة CISSP يُنظر إليه كخبير يمتلك رؤية شمولية لأمن المعلومات ويمكنه **تصميم وإدارة برنامج أمني مؤسسي** بالكامل، بما يشمل الجوانب التقنية والإجرائية معًا. غالبًا ما يشغل الحاصلون على CISSP مناصب قيادية أو استشارية عليا (مثل مدير أمن المعلومات CISO أو مستشار أمني رفيع) نظرًا لما تعكسه الشهادة من مستوى متقدم في الفهم والاحترافية.

- **شهادة خبير الاختراق المتقدم (OSCE - Offensive Security Certified Expert):** تعتبر شهادة OSCE من الشهادات التقنية المتقدمة جدًا في المسار الهجومي للاختراق الأخلاقي. قدّمتها شركة Offensive Security كخطوة تالية بعد OSCP، حيث تركز على مهارات الاختراق **المتقدمة والمتخصصة** التي تتجاوز الأساسيات. يتطلب التقدم لـ OSCE فهمًا عميقًا لهندسة النظم والبرمجيات، إذ تشمل مجالات الاختبار تطوير واستغلال الثغرات بطريقة مخصصة (على سبيل المثال: تحليل الثغرات ذات مستوى **استغلال معقّد** وكتابة شفرات استغلال من الصفر لتخطي آليات الحماية مثل ASLR و DEP في التطبيقات)، والهندسة العكسية للبرمجيات، واستهداف بيئات أكثر تعقيدًا قد تحوي **آليات دفاع متقدمة**. الامتحان العملي لشهادة OSCE كان يتطلب من المتقدم اختراق مجموعة من الأنظمة المصممة لتحتوي تحديات غير تقليدية ضمن زمن محدد، وإثبات قدرته على التفكير خارج الصندوق لحل تحديات أمنية صعبة للغاية. اجتياز هذا الامتحان بنجاح يُعد إنجازًا مرموقًا، إذ يدل على أن المختبر لديه **مهارات نخبوية** في القرصنة الأخلاقية، بما فيها البرمجة والأتمتة والتحليل الثاقب. يجدر بالذكر أن Offensive Security تقوم بتحديث مسارات شهاداتها بشكل دوري -

فمثلًا تم تحديث مسمى وهيكل OSCE إلى شهادات أحدث ضمن مسار "مستشار الاختراق المتقدم" - لكن تبقى القيمة الجوهرية لها ثابتة: التأكيد على امتلاك مستوى خبير في مهارات الاختراق والتقييم الأمني المتقدم. إن الحصول على شهادة متقدمة مثل OSCE (أو ما يعادلها من شهادات متطورة حديثة) يضع صاحبه ضمن نخبة مختصي الاختراق الأخلاقي القادرين على التعامل مع أصعب التحديات التقنية في ميدان الأمن السيبراني.